



CMMC 2.0

Companion Guide for VMware Cloud Foundation 9.1

June 2026

Table of Contents

Disclaimer.....7

Version..... 8

Introduction 8

Third Party Identifiers and Mappings 8

Coverage Levels 8

Controls..... 9

 Control AC.L1-b.1.i 9

 Control AC.L1-b.1.ii 14

 Control AC.L1-b.1.iii 19

 Control AC.L1-b.1.iv 21

 Control AC.L2-3.1.1 26

 Control AC.L2-3.1.2 31

 Control AC.L2-3.1.3 36

 Control AC.L2-3.1.4 40

 Control AC.L2-3.1.5 44

 Control AC.L2-3.1.6 50

 Control AC.L2-3.1.7 51

 Control AC.L2-3.1.8 55

 Control AC.L2-3.1.9 57

 Control AC.L2-3.1.10 59

 Control AC.L2-3.1.11 61

 Control AC.L2-3.1.12 64

 Control AC.L2-3.1.13 67

 Control AC.L2-3.1.14 70

 Control AC.L2-3.1.15 72

 Control AC.L2-3.1.16 76

 Control AC.L2-3.1.17 77

 Control AC.L2-3.1.18 78

 Control AC.L2-3.1.19 79

 Control AC.L2-3.1.20 80

 Control AC.L2-3.1.21 82

 Control AC.L2-3.1.22 83

 Control AC.L3-3.1.2e 88

Control AC.L3-3.1.3e	93
Control AT.L2-3.2.1	97
Control AT.L2-3.2.2	98
Control AT.L2-3.2.3	99
Control AT.L3-3.2.1e	100
Control AT.L3-3.2.2e	101
Control AU.L2-3.3.1	102
Control AU.L2-3.3.2	106
Control AU.L2-3.3.3	112
Control AU.L2-3.3.4	118
Control AU.L2-3.3.5	121
Control AU.L2-3.3.6	125
Control AU.L2-3.3.7	130
Control AU.L2-3.3.8	134
Control AU.L2-3.3.9	139
Control CA.L2-3.12.1	144
Control CA.L2-3.12.2	145
Control CA.L2-3.12.3	146
Control CA.L2-3.12.4	148
Control CA.L3-3.12.1e	149
Control CM.L2-3.4.1	150
Control CM.L2-3.4.2	154
Control CM.L2-3.4.3	160
Control CM.L2-3.4.4	164
Control CM.L2-3.4.5	165
Control CM.L2-3.4.6	170
Control CM.L2-3.4.7	174
Control CM.L2-3.4.8	179
Control CM.L2-3.4.9	183
Control CM.L3-3.4.1e	186
Control CM.L3-3.4.2e	189
Control CM.L3-3.4.3e	192
Control IA.L1-b.1.v	195
Control IA.L1-b.1.vi	200

Control IA.L2-3.5.1	205
Control IA.L2-3.5.2	210
Control IA.L2-3.5.3	215
Control IA.L2-3.5.4	217
Control IA.L2-3.5.5	220
Control IA.L2-3.5.6	221
Control IA.L2-3.5.7	223
Control IA.L2-3.5.8	226
Control IA.L2-3.5.9	231
Control IA.L2-3.5.10	236
Control IA.L2-3.5.11	240
Control IA.L3-3.5.1e	243
Control IA.L3-3.5.3e	246
Control IR.L2-3.6.1	249
Control IR.L2-3.6.2	253
Control IR.L2-3.6.3	257
Control IR.L3-3.6.1e	258
Control IR.L3-3.6.2e	259
Control MA.L2-3.7.1	260
Control MA.L2-3.7.2	264
Control MA.L2-3.7.3	266
Control MA.L2-3.7.4	268
Control MA.L2-3.7.5	269
Control MA.L2-3.7.6	273
Control MP.L1-b.1.vii	276
Control MP.L2-3.8.1	280
Control MP.L2-3.8.2	286
Control MP.L2-3.8.3	290
Control MP.L2-3.8.4	294
Control MP.L2-3.8.5	295
Control MP.L2-3.8.6	297
Control MP.L2-3.8.7	301
Control MP.L2-3.8.8	303
Control MP.L2-3.8.9	304

Control PE.L1-b.1.ix	310
Control PE.L1-b.1.viii	311
Control PE.L2-3.10.1	312
Control PE.L2-3.10.2	313
Control PE.L2-3.10.3	314
Control PE.L2-3.10.4	315
Control PE.L2-3.10.5	316
Control PE.L2-3.10.6	317
Control PS.L2-3.9.1	318
Control PS.L2-3.9.2	319
Control PS.L3-3.9.2e	321
Control RA.L2-3.11.1	323
Control RA.L2-3.11.2	324
Control RA.L2-3.11.3	327
Control RA.L3-3.11.1e	331
Control RA.L3-3.11.2e	333
Control RA.L3-3.11.3e	336
Control RA.L3-3.11.4e	337
Control RA.L3-3.11.5e	338
Control RA.L3-3.11.6e	339
Control RA.L3-3.11.7e	340
Control SC.L1-b.1.x	341
Control SC.L1-b.1.xi	345
Control SC.L2-3.13.1	349
Control SC.L2-3.13.2	353
Control SC.L2-3.13.3	358
Control SC.L2-3.13.4	362
Control SC.L2-3.13.5	366
Control SC.L2-3.13.6	370
Control SC.L2-3.13.7	374
Control SC.L2-3.13.8	375
Control SC.L2-3.13.9	380
Control SC.L2-3.13.10	383
Control SC.L2-3.13.11	388

Control SC.L2-3.13.12	395
Control SC.L2-3.13.13	396
Control SC.L2-3.13.14	397
Control SC.L2-3.13.15	398
Control SC.L2-3.13.16	403
Control SC.L3-3.13.4e	407
Control SI.L1-b.1.xii	412
Control SI.L1-b.1.xiii	416
Control SI.L1-b.1.xiv	420
Control SI.L1-b.1.xv	421
Control SI.L2-3.14.1	425
Control SI.L2-3.14.2	429
Control SI.L2-3.14.3	433
Control SI.L2-3.14.4	438
Control SI.L2-3.14.5	439
Control SI.L2-3.14.6	441
Control SI.L2-3.14.7	447
Control SI.L3-3.14.1e	450
Control SI.L3-3.14.3e	454
Control SI.L3-3.14.6e	458

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260612-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward Cybersecurity Maturity Model Certification (CMMC) 2.0. The CMMC 2.0 program, administered by the US Department of Defense, requires defense contractors to implement safeguarding requirements at three levels: Level 1 (the basic safeguarding requirements of FAR 52.204-21), Level 2 (the security requirements of NIST SP 800-171 Revision 2), and Level 3 (selected enhanced requirements from NIST SP 800-172). This guide covers the practices at all three levels. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for achieving and maintaining certification remains with the contractor.

<https://dodcio.defense.gov/CMMC/>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control AC.L1-b.1.i

> Limit information system access to authorized users, processes acting on behalf of authorized users, or devices (including other information systems)

SCF Controls: IAC-01, IAC-02, IAC-08, IAC-15.1, IAC-20, TPM-01, TPM-05, TPM-05.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID

Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is

automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces logical access control through a privilege-based authorization model. A privilege in PNR is the right to perform a specific action, such as creating a recovery plan or modifying a protection group. PNR restricts login access to VMware vCenter administrators by default, and other users must be explicitly granted access by an administrator before they can perform any protection or recovery operations. PNR augments vCenter roles and permissions with additional privileges that allow detailed control over PNR-specific tasks and operations.

PNR roles follow least privilege through granular role assignment. The vSphere Replication predefined roles can be cloned and customized by adding or removing individual privileges, allowing administrators to create custom roles that grant only the minimum permissions needed for a specific function. The Propagate to Children option can be deselected to create permission hierarchies that override inherited permissions at specific nodes without affecting child object permissions. vSphere Replication enforces permission denial with an error message when users without appropriate privileges attempt restricted operations. PNR roles do not include vSphere Replication privileges, so a user who is not a vCenter administrator but requires both PNR and vSphere Replication operations should be added to two separate user groups rather than granted full vCenter administrator privilege.

For cross-site operations, PNR enforces dual-site authorization. PNR requires permissions on both vCenter objects and on PNR objects to function properly, and PNR verifies permissions on the remote vCenter instance as part of its access control validation. Removing a user's permission on a protected site stops that user from continuing operations on resources at that site. In shared recovery site configurations, the vCenter administrator must manage permissions so that each user has

sufficient privileges to configure and use PNR while no user has access to resources belonging to other organizations. PNR restricts users in shared recovery site configurations from renaming, moving, or deleting data centers or hosts.

For automatic protection of virtual machines, administrators can assign the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group rather than granting global vCenter administrator privilege. The PNR clean room Orchestrator restricts connections to only IP addresses or IP address ranges that have been added to a configured management access list, providing network-layer access enforcement on top of the role-based model. For PNR deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users. Provider Administrators select which replication classes each Organization can use, and Organization Administrators manage the pairing of namespaces and assignment of replication classes within their Organization.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal dsm_mgmt management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory

groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control AC.L1-b.1.ii

> Limit information system access to the types of transactions and functions that authorized users are permitted to execute

SCF Controls: IAC-08, IAC-15

Aggregate Coverage: Meets

VCF (Meets)

VCF provides account management capabilities for the infrastructure platform's own user, group, system, and service accounts. The broader organizational governance of account management across all enterprise systems is outside VCF's scope.

VCF SSO is the centralized identity service for the platform. Administrators manage individual and group accounts through VMware vCenter, and can integrate external identity sources (Active Directory, LDAP, OIDC) so that account lifecycle management follows existing enterprise directory services. vCenter also supports System for Cross-domain Identity Management (SCIM), enabling automated provisioning and deprovisioning of user and group accounts when synchronized with a supported external identity provider. VCF Automation also supports LDAP, OIDC, and SAML-compliant identity providers for user authentication, allowing consistent identity federation across the stack.

VCF Operations provides a consolidated view of accounts across the VCF stack through its password management dashboard, including account statuses and remediation needs. This centralized visibility helps administrators track account states and identify accounts requiring attention. The password management interface, accessible to users with the Administrator role, supports password rotation and remediation for service account passwords across integrated components. Administrators should plan maintenance windows when rotating passwords for multiple accounts to avoid service interruptions.

At the compute layer, VMware ESX hosts support local account management through the HostLocalAccountManager interface, which allows administrators to create and manage user accounts on individual hosts. In a properly configured VCF environment, access to ESX is brokered through vCenter rather than managed directly on each host. The vSphere Web Services API documentation recommends that user accounts be given the minimal number of privileges required for their roles, consistent with least-privilege principles. For guest virtual machines, vCenter allows administrators to configure VCF SSO user mappings to guest operating system accounts, enabling centralized control over which VCF SSO users can access accounts within guest VMs.

VCF Operations offers account management capabilities including the ability to add, edit, remove, and import user accounts, manage roles, define object-level access for users assigned to specific roles, and manage user group membership. Each user must have a unique account with one or more roles assigned. User accounts can be associated with specific objects in the VCF Operations cluster to control the scope of access. VCF Operations supports importing user accounts from external sources such as LDAP databases or single sign-on servers, allowing organizations to integrate their existing directory services with VCF Operations access control.

VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

NSX Manager supports management of local user accounts through both its user interface and CLI. Through the UI, administrators can configure password expiration, deactivate users, and reset passwords. Through the CLI, the admin user can manage local user account passwords, change user names, and add, delete, or deactivate user accounts. NSX Manager has one active local account out of the box (admin), which cannot be deleted or deactivated, and best practice is to keep all other local user accounts deactivated.

VCF Automation allows system administrators to create other system administrator and user accounts within the provider organization. Service accounts are created by administrators who hold the View Service Accounts and Manage Service Accounts privileges, providing controlled delegation of service account creation. These service accounts authenticate using API access tokens that rotate after each use. Organization owners can add and manage other users within their scope.

The VCF Consumption layer (VMware Kubernetes Service (VKS) and vSphere namespaces) introduces a structured model for service and application account management governed through the Kubernetes API. Kubernetes ServiceAccount resources are namespace-scoped objects that provide distinct, non-human identities for application pods, in-cluster services, and other entities that need to authenticate to the Kubernetes API server. Service accounts are created automatically when namespaces are provisioned or on demand through API calls, and each is bound to roles through RoleBinding or ClusterRoleBinding resources, enabling RBAC-governed access at either namespace or cluster scope. The Kubernetes documentation advises against granting cluster-wide roles to all service accounts; per-namespace permission management is the recommended practice to maintain proper access control boundaries. Service account tokens should be scoped to minimize their usage to only the application that requires them, and the Kubernetes RBAC model specifies that user account creation must block reuse of deleted usernames so that newly created accounts with identical names do not inherit the permissions of prior accounts. Service account definitions should be included in configuration bundles for complex containerized workloads to support portability of system component identities.

Kubernetes provides lifecycle controls for service account credentials. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that have not been used within a specified time period, with a default retention period of one year, supporting governance of stale credentials. Infrastructure credentials, including certificates used by service accounts and cluster components, should be configured with short lifetimes and automated rotation to support ongoing account lifecycle management. Separating ServiceAccount creation from human user onboarding enables distinct audit strategies for each account type, and production VKS clusters should be configured with multiple accounts holding differentiated levels of access to different namespaces rather than relying on a single administrative account. IAM role trust policies for VKS workloads should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level.

For Windows workloads running in VKS clusters, Supervisor supports Group Managed Service Accounts (gMSAs). When Windows node pools are joined to an Active Directory domain, gMSAs provide automatic password management, simplified service principal name (SPN) management, and delegated administration across multiple servers. Access to gMSA credentials is controlled through Active Directory security groups, and the VKS cluster configuration specifies the relevant security group through the gmSAControlSecurityGroupDN setting. Configuring gMSA support for Windows node pools also requires an Active Directory service account with service principal names following Kerberos naming rules, and the VKS Security Group must be granted delegation rights to that account. HostProcess containers running as local user accounts use ephemeral local user accounts that are created and joined to a specified user group at container initialization, eliminating the need to manage passwords for those local accounts.

The Argo CD Supervisor Service supports local account creation through the spec.localAccounts field, allowing named accounts to be defined for GitOps workflows. Argo CD RBAC policy rules and group mappings control account permissions and role assignments, including the ability to grant administrative roles to specific local accounts. Both local accounts and OIDC-authenticated users can be governed through the same RBAC policy framework. Argo CD cluster registration creates a service account with cluster-level privileges to manage the target cluster, so administrators should review and scope those privileges to what is operationally required.

Avi Load Balancer uses a combination of roles and tenants to determine user account authorization, supporting multi-tenant access control for load balancing services.

Role-based access control is available across all VCF components, supporting the principle of least privilege through granular role definitions. User accounts should be given the minimal set of privileges required for their responsibilities.

While VCF provides these technical account management mechanisms across its components, proactive account governance requires organizational policies and procedures that define account lifecycle management, periodic access reviews, temporary and guest account provisioning standards, and account termination processes. These governance activities fall outside the scope of what VCF provides as a platform.

VMware vDefend (Contributes)

Within its own management plane, VMware vDefend (vDefend) Security Services Platform (SSP) maintains two built-in local user accounts: an admin user with the Enterprise Admin role providing full management access, and an audit user with the Auditor role providing access to APIs and services for system auditing. In vDefend, SSP defines five roles at the platform level: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, enabling separation of duties across administration, auditing, security engineering, security operations, and diagnostic support functions.

SSP enforces password policies for local accounts; passwords must meet defined complexity requirements and can be changed or reset through the Platform and Instance Management interfaces. Remote users and remote user groups are managed through the System > User Management interface, where administrators assign and modify roles. SSP supports directory-managed accounts through external identity providers such as Active Directory over LDAP and OpenLDAP, extending account management to enterprise identity sources; local accounts remain available even when external identity providers are disconnected.

This coverage is limited to vDefend's own management-plane accounts. Organization-wide account management for individual, group, system, service, application, guest, and temporary accounts across all technology assets is outside vDefend's scope and must be addressed through dedicated identity and access management platforms.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides account management mechanisms for the accounts it directly governs: the DSM administrator account, DSM user accounts (local and LDAPS-federated), database owner accounts, and the internal service account DSM uses to authenticate to VMware vCenter.

DSM supports two identity sources for user accounts. Local users are created directly within DSM using an email address as the login username and a password. LDAPS users are federated from a configured directory server, allowing organizations to manage DSM access through their existing identity infrastructure. Administrators can configure one or both identity sources depending on organizational requirements. For LDAP-federated accounts, DSM supports group-based access control by assigning roles to Directory Service Groups, so that group membership in the directory server determines DSM access. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager.

DSM implements role-based access control with two role types. The DSM Administrator role has full visibility and maintenance capabilities across all data services and is responsible for managing DSM settings including LDAPS and SMTP configuration, database backups, and high availability settings. The DSM Administrator also manages namespaces and permissions for database ownership. The DSM User role allows individuals to provision and manage their own databases and perform database lifecycle operations while having no visibility into other users' data services. DSM User roles support namespace-level access controls that can be configured at the time a user account is created, scoping access to specific Supervisor namespaces. This separation restricts administrative capabilities to designated personnel and scopes each user to the resources they own.

DSM user accounts maintain `failed_login_count`, `last_failed_login_time`, `locked_state_start_time`, and `force_password_change` attributes to enforce account lockout and password management policies. These fields track authentication failures, record when an account entered a locked state, and flag accounts that must change their password at the next login. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager > Create Directory Service Groups Using the Data Services Manager UI.

The initial DSM administrator account is created during deployment of the DSM Provider Appliance and is mandatory; it cannot be deleted. When access needs to be suspended without disrupting running databases, administrators can reset a local user's password and delegate management of the user's databases to a different user rather than deleting the account.

For database-level accounts, DSM allows database owners to set or change the database administrator password at any time while the database is online. DSM also supports LDAPS user creation for PostgreSQL database authentication and access control, enabling directory-managed credentials for database access rather than locally maintained passwords.

DSM introduces SQL Server as a managed database engine, with specific account management controls for SQL Server instances. DSM deactivates the default `sa` account and uses a reserved internal account, `dsm_mgmt`, with `sysadmin` privileges for management operations. The `dsm_mgmt` account restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context. DSM uses contained database users for SQL Server database access, so users authenticate directly against the database rather than through a server-level login. For SQL Server clusters in Active Directory environments, DSM requires a service account that is a standard Active Directory user and a member of the Domain Users group. DSM can also be configured with a privileged Active Directory account to automate the management of service principal names (SPNs) and DNS records for SQL Server clusters. The `dbo` user is mapped to administrator-controlled identities for SQL Server database access.

DSM maintains an internal service account for authentication to vCenter. This account is required for DSM to provision and manage infrastructure resources. DSM maintains service account rotation logs that administrators can review to diagnose vCenter authentication failures. Administrators should monitor for alerts indicating that the service account has expired, as an expired service account causes ongoing DSM operations to fail.

DSM's account management capabilities address the technical layer of this control within its scope. Broader account governance (including formal provisioning and deprovisioning procedures, periodic access reviews, approval workflows for account creation and role changes, and lifecycle management for temporary or guest accounts) requires organizational processes that operate outside DSM. Organizations should establish procedures for reviewing DSM account assignments, managing LDAPS group membership to reflect current job roles, and deprovisioning access when personnel change responsibilities.

VMware Avi Load Balancer (Meets)

Avi Load Balancer maintains its own account management plane on the Avi Controller, distinct from the underlying VCF infrastructure. User accounts are organized into two categories: local users, whose credentials are stored on the Controller, and remote users, who authenticate through an external authentication, authorization, and accounting (AAA) server such as LDAP or Active Directory. The admin account is a special system account used for initial setup that remains locally authenticated even when the system is configured for remote authentication. Local accounts remain available even if external identity providers such as LDAP or OpenLDAP become disconnected, providing a resilient fallback path for administrative access.

Account management operations are gated by role-based access control: configuring or managing user accounts requires write access to the Accounts section, as defined by the role assigned to the managing account. Avi provides predefined roles that can be customized or extended by administrators with appropriate access. Each account can be scoped to specific tenants and assigned different roles within each tenant through Tenant and Role assignment, supporting both centralized administration and delegated management across multi-tenant deployments. When a user has access to multiple tenants, the system places them into a default tenant after login. If no additional tenants have been created, all new user accounts are automatically added to the admin tenant. In the VCF for Avi integration, a Provider or Load Balancer Administrator manages resource assignments to enforce quotas and resource boundaries within organization-managed mode.

User Account Profiles govern account attributes and access controls. All users are attached to the Default-User-Account-Profile by default, which enforces standard lockout thresholds and password policies. Administrators can assign the No-Lockout-User-Account-Profile for accounts that require uninterrupted access, and can create custom UserAccountProfile objects to tailor security policies for different user populations. In the VCF for Avi integration, the system manages two specific accounts for password updates: admin and vcfops-admin, providing a defined account scope for VCF-integrated deployments.

Account lifecycle operations available through the Controller include account creation, deletion, deactivation, and reactivation. Deletion removes an account from the system entirely. Deactivation suspends access without deleting the account record, and reactivation restores access for a previously deactivated account. These operations are available only to users with write access to the Accounts section, scoping account management authority to authorized administrators. The Avi SaaS Controller supports service account configuration for programmatic and automated access, extending account lifecycle management to service identities within the Avi-managed plane.

Control AC.L1-b.1.iii

> Verify and control/limit connections to and use of external information systems

SCF Controls: DCH-13, DCH-13.1, DCH-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered set of authorization, access control, and tenant isolation mechanisms that help organizations restrict how external parties interact with data within the environment. While VCF does not itself manage processing agreements or perform external security assessments, its technical controls enforce the boundaries that such governance processes define.

VCF's authorization model is built on the principle that every principal must be authenticated and authorized before accessing any object or performing any operation. VCF SSO provides centralized, token-based authentication for all management interfaces. Identity federation through OIDC-compliant external identity providers (such as Okta or AD FS) allows organizations to extend their existing authentication policies to VCF access. The Authorization Code grant type is supported and is compatible with multi-factor authentication, while the Password grant type is flagged as something to avoid for third-party application authentication. The VCF Identity Broker provides a centralized authentication source for VCF components, and VCF Operations supports VCF SSO integration for centralized management of federated access through unified identity configuration. At the per-host level, the VMware Host Client supports a configurable login banner that can display an access restriction warning and require explicit user acceptance of terms of use before authentication is permitted, providing a mechanism for communicating authorized use boundaries to anyone accessing VMware ESX hosts directly.

The VMware vCenter AuthorizationManager controls access to server objects based on the permissions associated with each object, allowing administrators to grant, modify, and revoke permissions by associating privileges with specific users or groups. Authenticated users can only view objects or invoke operations on the server that match the permissions assigned to their account. The vCenter authorization model provides consistent security control regardless of operational context, meaning that whether access originates from an internal or external party, the same permission checks apply.

Role-based access control (RBAC) is enforced across VCF components including vCenter, NSX, ESX, and VCF Operations. In VCF Operations, each user must have a unique account with one or more roles assigned, and users can only perform actions that their permissions allow. In VCF Automation, organization-level access controls restrict which users and organizations can interact with specific entity types, and organization users can use only those rights from their roles that are published to their organizations. VCF Automation defined entity access control supports granular permissions through View (read-only), Edit (create and modify), and Full Control (create, view, modify, and delete) rights that can be assigned to user roles. The Avi Load Balancer similarly determines user authorization based on the combination of roles and tenants assigned to the account. User criteria can be configured to prevent specific users from accessing particular projects or catalog items.

For multi-tenant environments, VCF Automation organizations provide infrastructure isolation, quotas, and chargeback capabilities. NSX multi-tenancy enables project-level isolation of networking configurations, restricting each tenant's visibility to only their own objects. These controls allow administrators to technically restrict external parties from storing, processing, or transmitting data within VCF until access has been explicitly granted.

For third-party integrations, VCF enforces credential and role requirements at the point of access. A user adding third-party data sources in VCF Operations for Networks must provide appropriate device credentials and hold a specific role such as Network Operator. VCF Operations Orchestrator allows organization administrators to manage authorizations for users interacting with orchestrator capabilities, and the orchestrator can import TLS certificates from external systems to establish secure connections. Organization administrators can manage and revoke API tokens issued to tenant users, providing direct control over programmatic access granted to external parties.

Data isolation is enforced at multiple levels. The ESX Agent Manager restricts solutions so they can only access data about ESX agencies they themselves create, preventing one solution from accessing another solution's data on the same host. Encryption privilege separation further restricts sensitive operations: only administrators with explicit encryption privileges can

perform encryption and decryption tasks on vSAN data-at-rest encryption, limiting who can handle protected data regardless of their other administrative roles.

Verifying that external parties have implemented required security controls (part 1 of this control) and retaining processing agreements (part 2) are organizational governance activities outside VCF's scope. Organizations must establish their own verification procedures and agreement management processes, using VCF's technical controls to enforce the access decisions those processes produce.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides several mechanisms that contribute to governing how external parties and technology assets, applications, and services (TAAS) are used to store, process, and transmit data.

The vDefend distributed firewall (DFW) and Gateway Firewall (GFW) enforce network-level policies governing which external parties and external services are permitted to communicate with internal systems, restricting unauthorized data flows to and from external TAAS and third-party services.

Security Services Platform (SSP) maintains a centralized inventory of current organizational IT assets, including servers, software, and network devices along with their configurations. SSP classifies assets into infrastructure assets, regions, zones, environments, and applications, and identifies whether application assets are critical or regular. This classification gives administrators the context needed to define appropriate network-level controls on external data flows. Platform Inventory monitors asset operational state, collects VM tags with their scopes for asset tracking, and organizes assets by region and zone.

SSP manages certificate infrastructure for external connectivity. Web proxy certificates identify the proxy servers used to connect securely to external services. CA bundles establish trust for communicating with external services, including the Malware Prevention Service when enabled. SSP rejects certificates or configurations using deprecated cryptographic algorithms or weak key lengths for external connections. License Hub also supports importing CA bundles to establish trust for communicating with external services.

The Security Segmentation workflow in SSP identifies risky application protocols that transmit data in cleartext and recommends restricting or blocking them as part of segmentation policy. Administrators can review segmentation analysis, classify application assets as critical or regular, and publish environment rules, inventory assets, and policies to enforce controls on external data flows.

vDefend TLS Inspection supports External TLS Decryption for traffic destined to external services the enterprise does not own, making decrypted traffic available for IDS/IPS, Malware Prevention, and URL Filtering inspection.

vDefend does not directly govern contractual or legal obligations with external parties, but it enforces the network-layer technical controls that reflect those obligations.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L1-b.1.iv

> Control information posted or processed on publicly accessible information systems

SCF Controls: CLD-01, CLD-02, CLD-06, CLD-10, DCH-15, HRS-01, HRS-05, HRS-05.1, HRS-05.2, WEB-01, WEB-02, WEB-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cloud management controls that address security, compliance, and operational governance for cloud instances across private and hybrid cloud environments.

VCF Automation delivers policy-based governance for provisioning and scaling a multi-tenant private cloud. Administrators define infrastructure-as-a-service offerings while maintaining control through policies that govern what resources can be deployed, where they can be deployed, and under what conditions. Cloud accounts in VCF Automation are the configured permissions that the platform uses to collect data from regions or data centers and to deploy cloud templates to those regions, establishing a permissions-based model for all cloud operations. Approval policies provide governance control over deployment and day 2 action requests, requiring designated approvers before deployments are provisioned from specific cloud templates. Approval policies can be scoped to the organization level. Resource quota policies cap resource consumption at the project level by specifying scope-level limits for each resource, and cloud zone limits reject deployments that would exceed configured thresholds. When provisioning machines, sensitive parts of the cloud configuration support encryption using a secret versioning scheme, restricting exposure of credentials and other sensitive data during deployment. Passwords in cloud config scripts can be marked as sensitive and encrypted, and input properties in cloud templates can include an encrypted flag to keep passwords encrypted in deployment request details. VCF Automation Kubernetes Management extends this governance to containerized workloads by supporting security policies that can be assigned to clusters and enforced across the organization.

The VMware Cloud services platform manages common requirements for all cloud services, including authentication and user roles. This centralized identity and access management layer applies consistent security policies across cloud service consumption. Role-based access control is available across VCF components. NSX implements RBAC to restrict management access by assigning roles with specific permissions across networking, inventory, and system management domains, and supports custom role creation. VCF Operations provides its own RBAC model with configurable roles and permissions for monitoring and management functions. Cloud administrators can assign tags to existing security groups and incorporate those groups into cloud templates, enabling standardized network security controls across deployments. For NSX-based environments, administrators can add existing security groups or define new ones directly within cloud template design, embedding network security into the provisioning workflow. On-demand security groups are supported for NSX when used with the NSX policy manager.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these cloud management controls to containerized workloads. VKS provisions workload clusters that are secure by default, drawing on vSphere security features built into VMware vCenter and VMware ESX to establish a security baseline before application workloads are deployed. Kubernetes RBAC uses Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to scope permissions within and across namespaces, providing fine-grained access control at the Kubernetes API level. Namespace isolation provides boundary enforcement between tenants, with resource quotas and limit ranges constraining what each namespace can consume. Pod security is governed through Kubernetes Pod Security Admission, which supports Baseline, Restricted, and Privileged profiles configurable with audit, warn, and enforce modes, allowing organizations to block known attack vectors at the platform level while auditing and warning on more restrictive policies. VCF provides unified management of VMs, Kubernetes clusters, and other resources through a single, consistent API, supporting centralized governance and configuration of cloud instances across the environment.

VCF Operations includes a security and compliance capability that measures infrastructure configurations against built-in benchmarks, including the VCF Security Baseline and the DISA STIG. Compliance scanning detects violations, highlights risk areas, and provides remediation recommendations. Organizations can also create and import custom benchmarks to evaluate

configurations against their own security standards. The VCF Operations security dashboard surfaces security posture information in a single view.

VCF Operations monitors the health, performance, and capacity risks of connected cloud environments through integration with VCF Automation, giving administrators visibility into the operational posture of deployed cloud instances. VCF Operations includes integrations with multiple cloud providers by default, enabling consistent monitoring and management across hybrid environments. Configuration change tracking identifies settings that have changed from their baseline through drift detection, and each change is traced to the authenticated user who initiated it with a timestamp. Audit events capture platform interactions including user logins, capability checks, and configuration modifications across vSphere, vSAN, and NSX resources. Kubernetes audit logging within VKS, with configurable audit policy and webhook or log backends, captures Kubernetes API server activity to support accountability and review of cluster operations. VKS supports integration with Wiz, which provides cloud security posture management and cloud workload protection capabilities for continuous security monitoring of deployed Kubernetes workloads, including identification of security risks and compliance deviations.

All VCF components support syslog forwarding to external SIEM systems for centralized security monitoring and log retention. VCF Operations supports syslog configuration including enabling, disabling, adding, editing, and deleting syslog servers, with the ability to map syslog servers to platforms, alerts, or collectors. VCF Log Management includes pre-built content packs with dashboards and alerts for VCF components. ESX hosts generate audit logs capturing authentication attempts, configuration changes, and administrative actions at the hypervisor level.

VCF Operations provides a unified, non-disruptive TLS certificate management system for centralized control of certificates across all components in the VCF private cloud. Certificate lifecycle management and rotation are handled through the same interface, which exposes REST APIs for managing trusted certificates. VCF Encryption Management allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks in the VCF environment, giving organizations control over the encryption of their cloud workloads.

VCF Automation's All Apps organizations offer application teams a set of built-in cloud services to provision VMs, Kubernetes, networking, volumes, Secret Store, databases, container registries, external DNS, certificates, and AI workloads. These services can be consumed on a self-service basis through a curated catalog, with governance policies enforcing security and compliance requirements on every provisioned resource. Organizations in VCF Automation support policy-based governance on usage of resources. The Secret Store service enforces role-based access control for administrators, DevOps engineers, and application tenants when managing and distributing sensitive data across the platform. The Argo CD Supervisor Service manages application secrets securely outside of Git and enforces access controls across all CI/CD pipeline components. The vSphere Supervisor VM Service enables virtual machines to securely access secrets through a disk-based sidecar injection mechanism that keeps credentials out of the VM image. Kubernetes Secrets within VKS clusters are protected by etcd encryption at rest.

A PowerShell CloudServices module provides cmdlets for programmatic VMware Cloud Services management, supporting automation of cloud governance tasks. VCF PowerCLI version 12.4.0 and later also provides low-level cmdlets for all available VCF API services through the vSphere Automation SDK for PowerShell.

For organizations using ServiceNow, VCF Operations integrates through a management pack that creates ServiceNow incidents, alerts, or events and associates them with their Configuration Item in the CMDB. VCF Automation also provides a ServiceNow ITSM plug-in supporting approval workflows, support ticket creation, and deployment tracking within ServiceNow.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides network security controls that contribute to securing cloud instances in line with industry practices. While cloud management spans compute governance, identity management, compliance scanning, and operational monitoring, vDefend addresses the network security dimension through multiple integrated capabilities.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level across all workloads running on VCF. Security policies follow workloads regardless of network location, enabling zero-trust segmentation that limits lateral movement between cloud instances. Administrators define firewall rules using security groups, tags, and dynamic

membership criteria, allowing policy to adapt automatically as workloads are provisioned or relocated. Privileged Labels provide a tamper-proof mechanism that anchors firewall rules to immutable labels, preventing virtual machines from leaking out of their assigned security groups. Identity Firewall can be enabled on compute clusters to extend policy enforcement to Active Directory user and group identity, enabling security rules that follow users across workloads. The Gateway Firewall extends protection to north-south traffic at Virtual Private Cloud (VPC) boundaries, and Pre-defined Security Strategies allow administrators to define a baseline security posture for VPCs to establish consistent protection policies.

vDefend integrates with VCF Automation to allow organizations to define and enforce security postures for workloads within self-service private cloud environments. Groups in vDefend map cloud constructs from VCF Automation into the underlying vDefend infrastructure, enabling policy recognition and enforcement on VPCs, Groups, and virtual machines within namespaces. This integration maintains consistent security postures as workloads are provisioned through automation workflows.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention for cloud workloads. Organizations can import custom signatures or integrate with third-party threat feeds, including industry-specific Information Sharing and Analysis Centers (ISACs). Virtual patching capabilities allow deployment of protective signatures before vendor patches are available, reducing the exposure window for cloud instances. In federated deployments, a Global Manager provides centralized management for blocking malicious traffic across all connected Local Manager sites, maintaining and propagating untrustworthy IP address lists based on historical behavior patterns.

Malware Prevention through Advanced Threat Prevention (ATP) inspects files traversing east-west and north-south network paths. Malware Prevention profiles can be configured to send files to the VMware vDefend ATP Cloud Service for cloud-based analysis, or to process files locally without cloud analysis, without requiring agents on individual instances. Security policies can be defined, propagated, and enforced across Bare Metal servers through Security Services Platform, extending consistent enforcement across physical infrastructure.

Security Services Platform (SSP) is a modern microservices platform that hosts features that collect, ingest, and correlate network traffic data. SSP includes Security Intelligence, which allows administrators to accept or modify inferred classifications of compute entities as network infrastructure or non-infrastructure services, supporting accurate security policy planning. SSP maintains a centralized repository of current organizational IT assets, including servers, software, and network devices with their configurations, providing an authoritative inventory for policy planning purposes. Network Detection and Response (NDR) provides behavioral analysis and anomaly detection across east-west traffic flows, identifying threats that signature-based detection may miss. NDR data sharing to the vDefend ATP Cloud Service is activated by default and can be configured through System > Privacy, allowing organizations to control whether data is shared to the cloud where data residency requirements apply. SSP has high availability capabilities by default and supports scaling out individual services, including Analytics, Data Storage, Messaging, and Metrics, through System > Platform & Features > Core Services.

Together, these capabilities address the network security requirements within a broader cloud management control framework, providing workload-level enforcement, threat detection, and traffic visibility for cloud instances.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides access segmentation mechanisms for multi-tenant disaster recovery environments, particularly in shared recovery site configurations where multiple organizations or business units recover workloads to a common site.

In 9.1, the PNR service controller is designed to translate user intent into orchestrated calls across protection components while managing multi-tenant isolation as an explicit architectural function.

In a shared recovery site deployment, the VMware vCenter administrator manages permissions so that each user has sufficient privileges to configure and operate PNR for their own protected site while restricting access to resources belonging to other users. PNR includes a Multi-Tenancy Considerations and Configuration section documenting how administrators should scope permissions across deployments. Each user is assigned a separate virtual machine folder in the vCenter inventory on the shared recovery site, with permissions configured to prevent any other user from placing virtual machines in it. Dedicated resource pools, datastores, and networks are assigned to each user, and permissions are configured consistently with those

on folders. Permission propagation on the root folder, data centers, and hosts is restricted to prevent unintended access across different organizations' resources.

For environments with multiple PNR deployments on a single vCenter, administrators must configure different automatic protection accounts per PNR instance and assign permissions that split the vCenter inventory to simulate a multi-tenant environment. This approach segments the automated operations performed by each deployment instance. When multiple PNR deployments share the same underlying storage array, the best practice is to create separate user accounts on the storage arrays for each PNR deployment and use different LUNs per server to maintain logical separation.

The vSphere Replication component of PNR provides an additional RBAC layer with granular roles. The VRM Virtual Machine Replication User role can be assigned with propagation to enable users to configure replication between specific sites and access designated datastores on target sites. The VRM Replication Viewer role allows viewing of replication configuration without modification rights. These roles require separate user accounts on each participating site before assignment.

The Cyber Recovery capability within PNR supports physical isolation of recovery environments. The clean room should be configured with dedicated compute resources and isolated networks. PNR supports directing the same protected virtual machine to two different sites, enabling physical separation between a disaster recovery site and a clean room.

Administrators should be aware that the shared recovery site model assumes trust between the vSphere sites, and users cannot be completely isolated from each other even when their individual resources are isolated. If the deployment requires complete separation between all users, a shared recovery site configuration is not suitable and separate PNR deployments with dedicated infrastructure should be used instead.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that contribute to the implementation of cloud management controls for database-as-a-service workloads deployed on VCF.

Data service policies are a central control mechanism in DSM. Administrators define and configure these policies to govern how database clusters are provisioned, what infrastructure resources they may consume, and which organizational standards apply. When integrated with VCF Automation, data service policies can be applied across multiple tenants or organizations, with each tenant or organization required to adhere to its prescribed configurations. Administrators can tailor policies to specific requirements and assign them to one or more organizations, supporting consistent governance across a multi-tenant environment. The DSM UI provides a dedicated interface for configuring policies for each supported database type, including SQL Server in addition to PostgreSQL and MySQL. This policy enforcement model gives platform administrators a mechanism for translating organizational cloud management standards into operational constraints that apply at provisioning time.

Infrastructure policies in DSM control the placement of database VMs within storage and determine which VM classes and datastores are used when database clusters are created. Cloud Administrators configure which infrastructure policies are available within each consumption namespace, restricting database provisioning to resources and configurations that meet organizational standards. This limits how Cloud Users can consume database capacity without requiring explicit administrative approval for each individual deployment.

DSM manages instance certificates for database clusters and establishes TLS connections to both the DSM Provider VM and individual database instances. Administrators can add trusted certificate authorities to the OS trust store to verify connections, and a Cloud Administrator must obtain and save a TLS certificate for secure communication between the Consumption Operator and the DSM provider before enabling self-service consumption. DSM also establishes secure connections to VMware vCenter using certificate validation, providing certificate-based authentication across the management plane.

Database provisioning in DSM is self-service within the bounds set by the Cloud Administrator. Cloud Users deploy database clusters through Kubernetes-native resources in namespaces configured and controlled by the Cloud Administrator. This model delegates provisioning authority to end users while preserving administrative control over the infrastructure and policies available to them. The Consumption Operator, installed and managed by the Cloud Administrator, is the mechanism through which this bounded self-service access is enabled.

Meeting this control fully requires the organization to establish and maintain a cloud management program that defines security standards, monitors compliance posture, and updates policies as requirements evolve. DSM's policy enforcement capabilities support that program for database workloads, but the broader governance activities, including risk assessments, vendor management reviews, and cross-service compliance monitoring, remain organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides enforcement mechanisms at the virtual service level that organizations can use to control access to publicly facing application endpoints. Network security policies applied directly to virtual service VIPs establish the front-end security boundary for any Avi virtual service exposed to the internet, allowing administrators to define which source addresses, protocols, and connection types are permitted through the Service Engine before requests reach backend workloads.

At the HTTP application layer, Avi's HTTP security policies provide rule-based request control. Rules can match on request attributes and enforce blocking actions, such as returning an HTTP 403 response with a custom response body, configured via the `http_security_action_send_response` setting. This allows Avi to block specific classes of traffic at the load-balancer boundary before requests reach application servers. Content rewrite profiles, associated with HTTP(S) virtual services through the `content-rewrite-profile` setting, enable modification of HTML content within request and response bodies, providing an additional mechanism to manage application-layer content delivery.

For globally distributed deployments using Avi's Global Server Load Balancing (GSLB), Avi includes settings to explicitly distinguish public from private service exposure. GSLB Client Groups, configured under Infrastructure > GSLB > Sites, classify clients as public or private to drive routing and access decisions. Client classification is determined solely by these Client Groups. In NAT-aware public-private GSLB configurations, the `private-list` setting designates known private client addresses so that all unlisted addresses are treated as public by default. A separate `publish_vip_to_public_zone` flag in the cloud configuration controls whether a virtual service VIP with a private IP is published into a public DNS zone, providing a discrete toggle for controlling internet-facing DNS exposure of Avi services.

Organizations must define which content or services should be publicly accessible, classify data accordingly, and configure Avi policies to enforce those decisions. Avi provides the technical enforcement layer; content governance policies and configuration management remain organizational responsibilities.

Control AC.L2-3.1.1

> Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems).

SCF Controls: IAC-01, IAC-02, IAC-08, IAC-15.1, IAC-20, TPM-01, TPM-05, TPM-05.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory.

Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim name carries group membership when the OIDC provider uses a non-default name. The oidc-extra-audiences setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces logical access control through a privilege-based authorization model. A privilege in PNR is the right to perform a specific action, such as creating a recovery plan or modifying a protection group. PNR restricts login access to VMware vCenter administrators by default, and other users must be explicitly granted access by an administrator before they can perform any protection or recovery operations. PNR augments vCenter roles and permissions with additional privileges that allow detailed control over PNR-specific tasks and operations.

PNR roles follow least privilege through granular role assignment. The vSphere Replication predefined roles can be cloned and customized by adding or removing individual privileges, allowing administrators to create custom roles that grant only the minimum permissions needed for a specific function. The Propagate to Children option can be deselected to create permission hierarchies that override inherited permissions at specific nodes without affecting child object permissions. vSphere Replication enforces permission denial with an error message when users without appropriate privileges attempt restricted operations. PNR roles do not include vSphere Replication privileges, so a user who is not a vCenter administrator but requires both PNR and vSphere Replication operations should be added to two separate user groups rather than granted full vCenter administrator privilege.

For cross-site operations, PNR enforces dual-site authorization. PNR requires permissions on both vCenter objects and on PNR objects to function properly, and PNR verifies permissions on the remote vCenter instance as part of its access control validation. Removing a user's permission on a protected site stops that user from continuing operations on resources at that site. In shared recovery site configurations, the vCenter administrator must manage permissions so that each user has sufficient privileges to configure and use PNR while no user has access to resources belonging to other organizations. PNR restricts users in shared recovery site configurations from renaming, moving, or deleting data centers or hosts.

For automatic protection of virtual machines, administrators can assign the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group rather than granting global vCenter administrator privilege. The PNR clean room Orchestrator restricts connections to only IP addresses or IP address ranges that have been added to a configured management access list, providing network-layer access enforcement on top of the role-based model. For PNR deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users. Provider Administrators select which replication classes each Organization can use, and Organization Administrators manage the pairing of namespaces and assignment of replication classes within their Organization.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control AC.L2-3.1.2

> Limit system access to the types of transactions and functions that authorized users are permitted to execute.

SCF Controls: IAC-08, IAC-15

Aggregate Coverage: Meets

VCF (Meets)

VCF provides account management capabilities for the infrastructure platform's own user, group, system, and service accounts. The broader organizational governance of account management across all enterprise systems is outside VCF's scope.

VCF SSO is the centralized identity service for the platform. Administrators manage individual and group accounts through VMware vCenter, and can integrate external identity sources (Active Directory, LDAP, OIDC) so that account lifecycle management follows existing enterprise directory services. vCenter also supports System for Cross-domain Identity Management (SCIM), enabling automated provisioning and deprovisioning of user and group accounts when synchronized with a supported external identity provider. VCF Automation also supports LDAP, OIDC, and SAML-compliant identity providers for user authentication, allowing consistent identity federation across the stack.

VCF Operations provides a consolidated view of accounts across the VCF stack through its password management dashboard, including account statuses and remediation needs. This centralized visibility helps administrators track account states and identify accounts requiring attention. The password management interface, accessible to users with the Administrator role, supports password rotation and remediation for service account passwords across integrated components. Administrators should plan maintenance windows when rotating passwords for multiple accounts to avoid service interruptions.

At the compute layer, VMware ESX hosts support local account management through the HostLocalAccountManager interface, which allows administrators to create and manage user accounts on individual hosts. In a properly configured VCF environment, access to ESX is brokered through vCenter rather than managed directly on each host. The vSphere Web Services API documentation recommends that user accounts be given the minimal number of privileges required for their roles, consistent with least-privilege principles. For guest virtual machines, vCenter allows administrators to configure VCF SSO user mappings to guest operating system accounts, enabling centralized control over which VCF SSO users can access accounts within guest VMs.

VCF Operations offers account management capabilities including the ability to add, edit, remove, and import user accounts, manage roles, define object-level access for users assigned to specific roles, and manage user group membership. Each user must have a unique account with one or more roles assigned. User accounts can be associated with specific objects in the VCF Operations cluster to control the scope of access. VCF Operations supports importing user accounts from external sources such as LDAP databases or single sign-on servers, allowing organizations to integrate their existing directory services with VCF Operations access control.

VCF Operations for Networks supports local user management with role-based access control, where users are assigned roles during account creation.

NSX Manager supports management of local user accounts through both its user interface and CLI. Through the UI, administrators can configure password expiration, deactivate users, and reset passwords. Through the CLI, the admin user can manage local user account passwords, change user names, and add, delete, or deactivate user accounts. NSX Manager has one active local account out of the box (admin), which cannot be deleted or deactivated, and best practice is to keep all other local user accounts deactivated.

VCF Automation allows system administrators to create other system administrator and user accounts within the provider organization. Service accounts are created by administrators who hold the View Service Accounts and Manage Service Accounts privileges, providing controlled delegation of service account creation. These service accounts authenticate using API access tokens that rotate after each use. Organization owners can add and manage other users within their scope.

The VCF Consumption layer (VMware Kubernetes Service (VKS) and vSphere namespaces) introduces a structured model for service and application account management governed through the Kubernetes API. Kubernetes ServiceAccount resources are namespace-scoped objects that provide distinct, non-human identities for application pods, in-cluster services, and other entities that need to authenticate to the Kubernetes API server. Service accounts are created automatically when namespaces are provisioned or on demand through API calls, and each is bound to roles through RoleBinding or ClusterRoleBinding resources, enabling RBAC-governed access at either namespace or cluster scope. The Kubernetes documentation advises against granting cluster-wide roles to all service accounts; per-namespace permission management is the recommended practice to maintain proper access control boundaries. Service account tokens should be scoped to minimize their usage to only the application that requires them, and the Kubernetes RBAC model specifies that user account creation must block reuse of deleted usernames so that newly created accounts with identical names do not inherit the permissions of prior accounts. Service account definitions should be included in configuration bundles for complex containerized workloads to support portability of system component identities.

Kubernetes provides lifecycle controls for service account credentials. The LegacyServiceAccountTokenCleanup feature gate enables automatic cleanup of Secret-based service account tokens that have not been used within a specified time period, with a default retention period of one year, supporting governance of stale credentials. Infrastructure credentials, including certificates used by service accounts and cluster components, should be configured with short lifetimes and automated rotation to support ongoing account lifecycle management. Separating ServiceAccount creation from human user onboarding enables distinct audit strategies for each account type, and production VKS clusters should be configured with multiple accounts holding differentiated levels of access to different namespaces rather than relying on a single administrative account. IAM role trust policies for VKS workloads should be scoped to specific service accounts and namespaces to enforce least privilege at the workload level.

For Windows workloads running in VKS clusters, Supervisor supports Group Managed Service Accounts (gMSAs). When Windows node pools are joined to an Active Directory domain, gMSAs provide automatic password management, simplified service principal name (SPN) management, and delegated administration across multiple servers. Access to gMSA credentials is controlled through Active Directory security groups, and the VKS cluster configuration specifies the relevant security group through the gmSAControlSecurityGroupDN setting. Configuring gMSA support for Windows node pools also requires an Active Directory service account with service principal names following Kerberos naming rules, and the VKS Security Group must be granted delegation rights to that account. HostProcess containers running as local user accounts use ephemeral local user accounts that are created and joined to a specified user group at container initialization, eliminating the need to manage passwords for those local accounts.

The Argo CD Supervisor Service supports local account creation through the spec.localAccounts field, allowing named accounts to be defined for GitOps workflows. Argo CD RBAC policy rules and group mappings control account permissions and role assignments, including the ability to grant administrative roles to specific local accounts. Both local accounts and OIDC-authenticated users can be governed through the same RBAC policy framework. Argo CD cluster registration creates a service account with cluster-level privileges to manage the target cluster, so administrators should review and scope those privileges to what is operationally required.

Avi Load Balancer uses a combination of roles and tenants to determine user account authorization, supporting multi-tenant access control for load balancing services.

Role-based access control is available across all VCF components, supporting the principle of least privilege through granular role definitions. User accounts should be given the minimal set of privileges required for their responsibilities.

While VCF provides these technical account management mechanisms across its components, proactive account governance requires organizational policies and procedures that define account lifecycle management, periodic access reviews, temporary and guest account provisioning standards, and account termination processes. These governance activities fall outside the scope of what VCF provides as a platform.

VMware vDefend (Contributes)

Within its own management plane, VMware vDefend (vDefend) Security Services Platform (SSP) maintains two built-in local user accounts: an admin user with the Enterprise Admin role providing full management access, and an audit user with the Auditor role providing access to APIs and services for system auditing. In vDefend, SSP defines five roles at the platform level: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, enabling separation of duties across administration, auditing, security engineering, security operations, and diagnostic support functions.

SSP enforces password policies for local accounts; passwords must meet defined complexity requirements and can be changed or reset through the Platform and Instance Management interfaces. Remote users and remote user groups are managed through the System > User Management interface, where administrators assign and modify roles. SSP supports directory-managed accounts through external identity providers such as Active Directory over LDAP and OpenLDAP, extending account management to enterprise identity sources; local accounts remain available even when external identity providers are disconnected.

This coverage is limited to vDefend's own management-plane accounts. Organization-wide account management for individual, group, system, service, application, guest, and temporary accounts across all technology assets is outside vDefend's scope and must be addressed through dedicated identity and access management platforms.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides account management mechanisms for the accounts it directly governs: the DSM administrator account, DSM user accounts (local and LDAPS-federated), database owner accounts, and the internal service account DSM uses to authenticate to VMware vCenter.

DSM supports two identity sources for user accounts. Local users are created directly within DSM using an email address as the login username and a password. LDAPS users are federated from a configured directory server, allowing organizations to manage DSM access through their existing identity infrastructure. Administrators can configure one or both identity sources depending on organizational requirements. For LDAP-federated accounts, DSM supports group-based access control by assigning roles to Directory Service Groups, so that group membership in the directory server determines DSM access. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager.

DSM implements role-based access control with two role types. The DSM Administrator role has full visibility and maintenance capabilities across all data services and is responsible for managing DSM settings including LDAPS and SMTP configuration, database backups, and high availability settings. The DSM Administrator also manages namespaces and permissions for database ownership. The DSM User role allows individuals to provision and manage their own databases and perform database lifecycle operations while having no visibility into other users' data services. DSM User roles support namespace-level access controls that can be configured at the time a user account is created, scoping access to specific Supervisor namespaces. This separation restricts administrative capabilities to designated personnel and scopes each user to the resources they own.

DSM user accounts maintain `failed_login_count`, `last_failed_login_time`, `locked_state_start_time`, and `force_password_change` attributes to enforce account lockout and password management policies. These fields track authentication failures, record when an account entered a locked state, and flag accounts that must change their password at the next login. This is configured under Administering Data Services Manager > Managing LDAP Users in Data Services Manager > Create Directory Service Groups Using the Data Services Manager UI.

The initial DSM administrator account is created during deployment of the DSM Provider Appliance and is mandatory; it cannot be deleted. When access needs to be suspended without disrupting running databases, administrators can reset a local user's password and delegate management of the user's databases to a different user rather than deleting the account.

For database-level accounts, DSM allows database owners to set or change the database administrator password at any time while the database is online. DSM also supports LDAPS user creation for PostgreSQL database authentication and access control, enabling directory-managed credentials for database access rather than locally maintained passwords.

DSM introduces SQL Server as a managed database engine, with specific account management controls for SQL Server instances. DSM deactivates the default `sa` account and uses a reserved internal account, `dsm_mgmt`, with `sysadmin` privileges for management operations. The `dsm_mgmt` account restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context. DSM uses contained database users for SQL Server database access, so users authenticate directly against the database rather than through a server-level login. For SQL Server clusters in Active Directory environments, DSM requires a service account that is a standard Active Directory user and a member of the Domain Users group. DSM can also be configured with a privileged Active Directory account to automate the management of service principal names (SPNs) and DNS records for SQL Server clusters. The `dbo` user is mapped to administrator-controlled identities for SQL Server database access.

DSM maintains an internal service account for authentication to vCenter. This account is required for DSM to provision and manage infrastructure resources. DSM maintains service account rotation logs that administrators can review to diagnose vCenter authentication failures. Administrators should monitor for alerts indicating that the service account has expired, as an expired service account causes ongoing DSM operations to fail.

DSM's account management capabilities address the technical layer of this control within its scope. Broader account governance (including formal provisioning and deprovisioning procedures, periodic access reviews, approval workflows for account creation and role changes, and lifecycle management for temporary or guest accounts) requires organizational processes that operate outside DSM. Organizations should establish procedures for reviewing DSM account assignments, managing LDAPS group membership to reflect current job roles, and deprovisioning access when personnel change responsibilities.

VMware Avi Load Balancer (Meets)

Avi Load Balancer maintains its own account management plane on the Avi Controller, distinct from the underlying VCF infrastructure. User accounts are organized into two categories: local users, whose credentials are stored on the Controller, and remote users, who authenticate through an external authentication, authorization, and accounting (AAA) server such as LDAP or Active Directory. The admin account is a special system account used for initial setup that remains locally authenticated even when the system is configured for remote authentication. Local accounts remain available even if external identity providers such as LDAP or OpenLDAP become disconnected, providing a resilient fallback path for administrative access.

Account management operations are gated by role-based access control: configuring or managing user accounts requires write access to the Accounts section, as defined by the role assigned to the managing account. Avi provides predefined roles that can be customized or extended by administrators with appropriate access. Each account can be scoped to specific tenants and assigned different roles within each tenant through Tenant and Role assignment, supporting both centralized administration and delegated management across multi-tenant deployments. When a user has access to multiple tenants, the system places them into a default tenant after login. If no additional tenants have been created, all new user accounts are automatically added to the admin tenant. In the VCF for Avi integration, a Provider or Load Balancer Administrator manages resource assignments to enforce quotas and resource boundaries within organization-managed mode.

User Account Profiles govern account attributes and access controls. All users are attached to the Default-User-Account-Profile by default, which enforces standard lockout thresholds and password policies. Administrators can assign the No-Lockout-User-Account-Profile for accounts that require uninterrupted access, and can create custom UserAccountProfile objects to tailor security policies for different user populations. In the VCF for Avi integration, the system manages two specific accounts for password updates: admin and vcfops-admin, providing a defined account scope for VCF-integrated deployments.

Account lifecycle operations available through the Controller include account creation, deletion, deactivation, and reactivation. Deletion removes an account from the system entirely. Deactivation suspends access without deleting the account record, and reactivation restores access for a previously deactivated account. These operations are available only to users with write access to the Accounts section, scoping account management authority to authorized administrators. The Avi SaaS Controller supports service account configuration for programmatic and automated access, extending account lifecycle management to service identities within the Avi-managed plane.

Control AC.L2-3.1.3

> Control the flow of CUI in accordance with approved authorizations.

SCF Controls: DCH-03, IAC-08, NET-04, NET-18

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of access control list (ACL) mechanisms and network traffic restriction capabilities that contribute to data flow enforcement, though full ACL governance across physical and virtual infrastructure requires organizational processes and may benefit from VMware vDefend for advanced stateful firewall rule sets.

At the network infrastructure layer, VCF uses vSphere Distributed Switches to centrally manage VLAN assignments, port group policies, and traffic shaping rules across all hosts in a workload domain. Distributed switches support traffic shaping policies that limit the bandwidth of incoming traffic, helping restrict which traffic types and volumes can traverse each network segment. Distributed port groups and uplink port groups also support a Traffic Filtering and Marking Policy, where per-rule actions can be set to Allow, Drop, or Tag traffic based on defined match criteria, providing rule-based traffic enforcement at the virtual switch level. Traffic segmentation is built into VCF's architecture: management, vMotion, vSAN, and NFS traffic each run on dedicated VLANs and VMkernel ports, and the vMotion network must be distinct from the vSAN network. This separation restricts which traffic types can traverse each segment by design. Private VLANs (PVLANs) provide additional Layer 2 isolation within a single VLAN through virtual network segmentation on distributed virtual switches, limiting communication between VMs even on the same segment. Distributed switches also support VLAN-based SPAN (VSPAN) for virtual distributed port mirroring, which aids in monitoring and validating traffic flows. At the ESX host level, a built-in firewall operates on a deny-by-default basis, closing all ports except those an administrator explicitly designates as authorized, giving each host an independent network access control point.

NSX extends these capabilities with software-defined networking constructs including segments, Tier-0 and Tier-1 gateways, and Virtual Private Clouds (VPCs). NSX Tier-0 gateways can be configured with linked Tier-1 gateways to create multi-tier topologies, enabling route-based traffic restrictions between network tiers. NSX edge gateways handle north-south routing. With vDefend deployed, North-South Firewall Rules on these gateways provide traffic protection, and an NSX project's default gateway firewall and distributed firewall rules (a vDefend capability) govern the default behavior of north-south and east-west traffic for workloads in that project. VPCs are self-contained virtual network environments that provide an abstraction layer for setting up isolated virtual private cloud networks with their own topology, IP address management, and permission models, allocatable to discrete projects in a self-service consumption model. NSX Manager enforces approved authorizations for controlling the flow of management information within network devices based on information flow control policies.

NSX also provides data flow enforcement at the load balancer tier through its Access List Control (ALC) feature. The NSX load balancer compares all traffic flowing through it with ACL statements, which either drop or allow the traffic based on configured rules. This gives administrators another enforcement point for restricting network traffic to only what is authorized.

At the Consumption layer, VMware Kubernetes Service (VKS) and the Supervisor extend ACL enforcement to containerized workloads through Kubernetes NetworkPolicy resources, which function as Layer 3/4 ACLs for pod-level traffic. NetworkPolicy objects specify allowed ingress and egress traffic by pod selector, namespace selector, IP block, port, and protocol; pods not selected by any NetworkPolicy receive no restriction by default, making explicit policy deployment necessary to enforce a default-deny posture across a cluster. VKS clusters run Antrea as the default CNI plugin, which implements NetworkPolicy enforcement through the AntreaPolicy feature gate and provides per-policy and per-rule packet and byte count statistics through the NetworkPolicyStats capability, giving administrators visibility into which policies are actively restricting traffic. For VKS clusters using NSX VPC networking, NSX-backed network policies apply distributed ACLs at the hypervisor level, extending enforcement beyond the CNI layer. The ovn-kubernetes Transparent network mode similarly supports distributed ACLs applied via Kubernetes NetworkPolicy resources. For Layer 7 traffic control within VKS clusters, the Istio service mesh standard package provides a pluggable policy layer and configuration API supporting access controls, rate limits, and quotas based on workload identity; when deployed in ambient mode with strict mutual TLS, all service-to-service

traffic within the mesh is subject to authentication before authorization checks apply, restricting lateral movement to explicitly permitted paths.

For file-level and storage data flow isolation, the Supervisor uses ACLs to isolate file share access within supervisor namespaces, restricting data access between workloads running in different namespaces. vSAN file services support managing ACLs on SMB shares using the MMC tool, giving administrators granular control over which users and systems can access shared storage resources. Administrators should be aware that ACL-based file share isolation in the Supervisor carries a risk of IP spoofing, which should be addressed through complementary network controls when deploying file shares in multi-tenant environments. Argo CD deployments on the Supervisor implement network segmentation and firewall rules to control communication between Argo CD components, following the principle of restricting inter-component traffic to only what each component requires. The Harbor container registry standard package enforces role-based access control over artifact access, complementing network-layer ACLs with image-level access restrictions.

For object-level access control, VCF Automation maintains an ACL table that defines which users can access specific defined entities. System administrators with the Manage General ACL right can create, modify, and remove ACL entries through the accessControls API. Those with the View General ACL right can audit ACL assignments on specific entities. Access to runtime defined entities is controlled through rights bundles and ACL entries. This ACL mechanism works alongside role-based access controls so that rights determine what actions a user can perform while ACLs determine which objects those actions apply to.

VCF Operations for Networks supports ACL visibility through its network assurance and verification capabilities, which allow administrators to validate that ACL configurations are applied as intended across the managed environment. This includes the ability to verify ACL configurations on supported physical network equipment such as Cisco ASR routers, helping validate that physical and virtual network access controls are consistent.

For workload-level traffic enforcement with stateful firewall rules, microsegmentation, and deep packet inspection, VMware vDefend and Gateway Firewall extend VCF's networking foundation with fine-grained Layer 2-7 policy enforcement. Organizations that require ACL governance beyond what VCF provides natively should establish processes for ACL review cycles, change management for firewall rules, and regular validation of both physical and virtual network access controls.

VMware vDefend (Meets)

VMware vDefend provides the primary data flow enforcement mechanism within VCF through its Distributed Firewall, Gateway Firewall, and Security Intelligence capabilities. These capabilities function as software-defined access control lists governing traffic between workloads, segments, and external networks.

The vDefend distributed firewall enforces Layer 2-7 access policies at the vNIC level on every workload. Administrators define firewall rules that explicitly permit or deny traffic based on source and destination groups, ports, protocols, application identity, user identity via Active Directory integration through Identity Firewall, and fully qualified domain names (FQDN filtering). Because enforcement happens at the workload's virtual network interface, traffic is filtered before it reaches the physical network, and policies follow the workload as it moves between hosts. The Application Connectivity Strategy's "Allow Intra, Deny Other Traffic" mode automatically generates an intra-group ALLOW rule with optional logging plus a default ANY/ANY/DROP rule to isolate the group, providing a structured default-deny posture that restricts traffic to only what is explicitly authorized.

URL filtering provides an additional access control layer, enabling rule-based restrictions based on URL categories, URL reputation scores, and custom URL lists applied to both HTTP and HTTPS traffic. Identity Firewall rules can specify source users or groups, destination resources, services, and context profiles to allow or deny traffic based on Active Directory group membership. These rules support Allow and Reject actions and can be applied to physical devices where users log in, as well as to tier-0 and tier-1 gateways. Role-based access control within the Distributed Firewall governs who can create or modify firewall rules, restricting policy changes to authorized personnel.

The vDefend gateway firewall provides stateful North-South traffic inspection at Tier-0 and Tier-1 gateways, enforcing ACL-equivalent rules on traffic entering or leaving network segments. The Gateway Firewall supports Identity Firewall integration with Active Directory for identity-based access control at the perimeter. Together, the Distributed and Gateway Firewalls address both East-West (inter-workload) and North-South (perimeter) data flow enforcement.

Security Intelligence, hosted on the Security Services Platform, supports ACL governance by observing traffic flows between applications and environments. Security Intelligence classifies flows as allowed, blocked, or unprotected and generates policy recommendations with segmentation strategy actions of Allow (creates a default traffic flow allow rule) or Drop (creates a default traffic flow drop rule). When a security policy is published, a rule is automatically generated to allow intra-application traffic. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, helping administrators identify unauthorized communication patterns and tighten ACL governance over time.

The Security Services Platform governs access to Security Intelligence operations through role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Three permission levels apply across operations: Full Access (Create, Read, Update, and Delete), Read, and None. This restricts policy recommendation and enforcement actions to authorized security personnel.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory

integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

Avi Load Balancer provides network-layer access control list (ACL) enforcement at the application delivery layer through Network Security Policies attached to virtual services. These policies evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. Rules reference named IP Groups, which are reusable collections of IP addresses, IP ranges, and IP network prefixes. A Network Security Policy that denies traffic stops further policy evaluation, so ACL denials take effect before any downstream HTTP Security, Request, or Response policies execute.

Administrators configure Network Security Policies on individual virtual services through the Avi Controller. IP Groups are managed centrally and can be referenced across multiple virtual services, providing a scalable method for applying consistent ACL rules across the environment. The Avi Controller API supports programmatic creation and modification of Network Security rules that match on IP address and apply IP Groups to control access, enabling automated ACL governance through scripts or orchestration systems.

At Layer 7, Avi WAF rule actions support pass (allow) and deny (block) options for controlling traffic based on policy matches, extending data-flow enforcement to the application layer. Avi Load Balancer also supports OAuth/OIDC authorization policies that can match token scope attributes and request paths using CONTAINS and BEGINS_WITH match criteria, enabling granular, path-based access control for API endpoints.

The Avi Controller enforces IP Access Lists on its own management interfaces by programming Linux IP tables on the Controller host, restricting network-layer access to specified management endpoints. These lists, configured under Administration > Controller Access Settings, limit which client IP addresses may reach the Controller API and UI.

These mechanisms scope Avi's ACL enforcement to traffic transiting its virtual services and to Controller management-plane access. ACL governance for east-west and other network traffic not flowing through Avi virtual services relies on VMware vDefend and VCF network controls.

Control AC.L2-3.1.4

> Separate the duties of individuals to reduce the risk of malevolent activity without collusion.

SCF Controls: HRS-11

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides granular role-based access control (RBAC) across its component products, giving organizations the technical foundation to implement and enforce separation of duties policies. While VCF does not define SoD policies on its own, it supplies the authorization mechanisms that make duty separation enforceable at the infrastructure layer.

VMware vCenter implements fine-grained authorization through a permissions and roles model applied to the vSphere object hierarchy. Administrators can create custom roles with specific privilege assignments, controlling exactly which actions a user or group can perform on specific vSphere objects. Permission propagation allows these assignments to cascade through the object tree, so access boundaries can be drawn at any level of the infrastructure. When a role is assigned directly to an individual user, that assignment takes precedence over any role assigned to a group to which the user belongs, allowing administrators to grant more restrictive or more permissive access to specific individuals without modifying group-level assignments. vCenter ships with system-defined roles that cannot be modified or deleted, including a Read Only role limited to three system-defined privileges (System.Anonymous, System.View, and System.Read) and an administrator role that provides an intermediate authorization level for users who manage vCenter configuration and control functions. If a predefined role does not match operational requirements, administrators can define new roles containing only the minimum set of required privileges, supporting least-privilege assignment aligned with duty boundaries. PowerCLI cmdlets such as New-VIRole and Set-VIRole allow programmatic creation and modification of roles, enabling consistent and auditable role management across environments. The privilege checks recorder feature allows administrators to monitor and query the privileges checked during vCenter operations, which helps build least-privilege custom roles tailored to particular workflows.

VCF Operations extends RBAC with its own set of predefined and assignable roles. Each user must have a unique account with one or more roles assigned, and administrators can assign roles to individual users or to user groups with a defined scope for each role. Predefined roles in VCF Operations include privileges for create, read, update, and delete actions on components such as dashboards, reports, administration, capacity, policies, problems, symptoms, alerts, user account management, and adapters. The ContentAdmin role can manage all content, including views, reports, dashboards, and custom groups. This separation of administrative functions allows organizations to restrict operational staff to monitoring and reporting while reserving configuration and policy changes for designated administrators. VCF Operations also integrates with vCenter by sending its roles as privileges within the vCenter Global privilege group, requiring a vCenter administrator to assign those roles to users, which creates a natural two-party authorization step for cross-product access.

VCF Automation extends role-based access control with both organization-wide and project-level role assignments. Predefined roles include Organization Administrator, Organization User, Organization Auditor, Project Administrator, Project User, Project Advanced User, and Project Auditor. At the project level, users can be assigned as administrators, members, or viewers. Organization Administrators have broad management rights including certificate management, content libraries, and approval policies, while Organization Auditors have read-only access for review purposes. VCF Automation also supports approval policies that require designated approvers to hold specific role combinations, adding a workflow-level separation step for provisioning and deployment actions. The System Administrator role in VCF Automation provides granular permissions across dozens of functional areas including API tokens, approvals, audit, blueprints, catalog, cloud accounts, deployments, extensibility, and more.

NSX supports creating custom roles with granular permission assignments based on operational requirements, allowing network administration duties to be separated from compute and storage administration. vSAN covers RBAC and permissions management through its Security Configuration Guide, supporting storage-specific duty boundaries. vSphere also supports configuring separate key providers for different departments or organizational units, supporting granular access control to encryption keys that aligns with duty separation requirements for cryptographic operations. VCF Operations Orchestrator supports group-based permission management where users without an assigned role can view only their own workflow runs.

Together, these RBAC capabilities allow an organization to assign distinct roles for compute administration, network configuration, storage management, security policy, monitoring, and cloud automation across VCF's component products. By granting each team or individual only the privileges required for their function, organizations can enforce duty separation that requires collusion between multiple privileged accounts to perform unauthorized actions. The organization remains responsible for defining SoD policies, determining which duties must be segregated, and assigning personnel to the appropriate roles. VCF provides the technical enforcement layer that restricts users to their granted privileges.

VMware Private AI Services (PAIS) provides several role-based access control mechanisms that support the implementation of Separation of Duties across the AI infrastructure stack.

VCF Automation, which PAIS uses to deliver self-service provisioning of GPU-accelerated VMware Kubernetes Service (VKS) clusters and Deep Learning VMs, defines distinct project-level roles including Project Administrator, Project Advanced User, and Project Auditor with differentiated privilege levels. These roles allow organizations to separate the individuals who configure AI infrastructure from those who consume it and those who review activity. At the platform tier, VCF Automation separates provider-level operations, which require a `PROVIDER_ADMIN_ACCESS_TOKEN`, from organization administrator operations, which require a `TENANT_ADMIN_ACCESS_TOKEN`. This token distinction means that infrastructure-wide actions and organization-scoped actions must be performed under different credentials by different principals.

PAIS enforces access control through OIDC group-based authorization. The `authorizedGroups` field in the `PAISConfiguration` custom resource specifies which OIDC groups can access the service, restricting access to designated personnel. PAIS can be configured with only one OIDC provider, so all group-based authorization decisions flow through a single auditable path. PAIS users are organized in groups, with a groups claim included in the Access Token and a groups scope created in the OIDC configuration, giving organizations a mechanism to map personnel categories to access levels. The `PAISConfiguration` custom resource is defined as a CRD YAML file with sections for storage policy, CA trust bundles, database connection, OIDC provider integration, and ingress, and access control uses OIDC provider groups with configurable claim names for group identification in the organization namespace.

The observability layer carries its own role separation. Grafana for PAIS supports OIDC-driven role assignment using a configurable role attribute path expression: users whose OIDC groups match the configured access group receive the Admin role, while remaining authenticated users receive the Viewer role. This restricts who can modify dashboards and alert configurations from those who can only read metrics.

For Deep Learning VM and PAIS deployment, a VI administrator must configure a GPU-accelerated workload domain and clusters with support for vSphere Supervisor and VCF Automation before PAIS is installed on a Supervisor for an organization. Separately, the organization administrator must assign the required user role before any user can provision Deep Learning VMs or upload to the model gallery. This two-step requirement separates the actor who manages platform prerequisites from the actor who grants provisioning access to individual users.

The organization must define its SoD policy, decide which personnel occupy which roles, and configure the OIDC provider with appropriate group memberships to reflect those assignments. PAIS supplies the technical mechanisms; the design and maintenance of the SoD structure itself is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend supports Separation of Duties within its management plane through differentiated role-based access control across Security Services Platform, Security Intelligence, Distributed Firewall policy management, and the VCF Automation firewall administration layer.

Security Services Platform defines five distinct roles with non-overlapping permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Security Intelligence applies the same role structure within its management surface. Each role carries differentiated capabilities, preventing any single administrator from controlling all aspects of security operations without oversight.

In 9.1, VCF Automation introduces a Firewall category under rights that governs access to Distributed Firewall, Tenant Gateway Firewall, VPC Gateway Firewall, and VPC Security Profile management. The Organization Administrator role requires

all eight rights across these firewall categories, while custom roles can be configured to grant narrower combinations of manage and view rights per firewall tier. This allows organizations to assign separate personnel for firewall rule management versus read-only visibility, and to separate responsibility across north-south and east-west firewall functions. Administrative rights in VCF Automation 9.1 are primarily governed by predefined roles rather than granular custom project-level rights, keeping privilege delegation bounded.

VMware vDefend implements a persona-based security rule model with three distinct administrative tiers: the Provider Admin manages global resources and high-precedence rules in the shared infrastructure space, the Project Admin orchestrates security policy within a project, and the Organization Admin manages tenant-level resources and groups. Tenant-level groups are owned and managed by the Organization Admin, while Project Admins focus on groups within their dedicated VPCs, providing structural administrative separation between provider-tier and tenant-tier firewall policy management.

Access to Distributed Firewall monitoring features, including Firewall Insights, is restricted to Enterprise Admin, Security Admin, and Security Operator roles, limiting who can observe security telemetry to designated personnel.

VMware vDefend's SoD controls apply within its own management plane. Organizational SoD enforcement spanning identity governance, staffing decisions, and cross-system access management is outside the scope of a network security product.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports separation of duties for replication and disaster recovery operations through role-based access control that augments vCenter roles with PNR-specific permissions. PNR adds several predefined roles to vCenter that are available in the role drop-down for assigning permissions to users and user groups. Each role includes a defined set of privileges that allows users to complete specific actions while restricting access to resources belonging to other users.

By default, the vCenter administrator role inherits all PNR and vSphere Replication privileges upon installation. PNR also supports assigning protection and recovery roles to users or user groups that do not hold vCenter administrator rights, allowing those users to perform protection and recovery operations without granting full vCenter administration. When a user requires privileges for both PNR and vSphere Replication operations without holding vCenter administrator rights, the recommended approach is to add the user to two separate user groups, each assigned the appropriate role, so the combined privileges are explicit and auditable. Users granted the vCenter administrator role after PNR installation must have PNR roles manually assigned on PNR objects, so that elevated platform roles do not automatically convey replication-administration rights to those users.

PNR enforces additional duty separation across the recovery workflow. Testing a recovery plan and running a recovery plan require separate privilege assignment to help prevent unintended changes that take significant time and effort to reverse. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to automatic-protection users or groups, allowing protection responsibilities to be delegated independently of plan execution.

The Clean Room Orchestrator component within PNR adds its own role model with Organization-level roles and service-specific roles. Access to the Clean Room Orchestrator is governed by Global Console Admin and Recovery Admin service roles, separating overall console administration from recovery operations within the isolated recovery environment. Service-specific roles can be assigned to users in addition to Organization-level roles, allowing organizations to delegate clean-room responsibilities without granting broader administrative scope. PNR also applies resource isolation on shared recovery sites to maintain separation between different organizations' virtual machines.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a role-based access control (RBAC) system that organizations can use to implement Separation of Duties across the Avi control and data planes. The Avi for VCF guide identifies role-based separation of duties as a core design principle, enabling application teams to autonomously consume load-balancing services using resources assigned to their organization.

The Avi Controller supports three privilege levels for each resource: Write (full create, read, modify, and delete access), Read (view-only access without modification capability), and No Access (which restricts the user from reading or listing the resource).

entirely). Administrators can create custom roles that assign these privilege levels independently for each system resource, enabling precise allocation of capabilities to specific personnel without granting broader access than required. Roles are combined with tenant assignments to define the complete authorization profile for each user, making it possible for a team member responsible for virtual service operations to hold write access to load balancing resources while holding no access to certificate management or WAF policy configuration. Permission categories cover two main areas: Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management).

The Extended Granular RBAC system provides additional access scoping through label-based permissions for cloud objects. When no filters are configured, a user can access all objects according to the privileges in the assigned role. Granular RBAC per field allows administrators to restrict write access to specific sub-resources within objects, enabling fine-grained separation of configuration responsibilities. Virtual services also support RBAC configuration during creation, allowing granular access control for managing and monitoring individual applications independently.

In VCF organization-managed mode, a Provider or Load Balancer Administrator manages resource assignments to organizations to enforce quotas and resource boundaries. At the data plane level, Service Engine groups are an inherent method of providing data plane isolation, and Service Engine Group allocation at the project level keeps each project within its designated boundaries. A service provider can allocate isolated Service Engines to each tenant or place multiple tenants in the same group depending on resource sharing requirements.

For Global Server Load Balancing (GSLB), both predefined and custom-defined roles are available. Function-specific roles such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` can be assigned to user accounts with tenant-level scope, allowing separate personnel to manage GSLB group membership configuration independently from health monitoring configuration.

The License Hub implements three distinct roles: Enterprise Admin (performs all operations), Auditor (views information and tracks activity without making changes), and Support Bundle Collector (collects system logs and diagnostics). This structure provides built-in separation of duties between operational and read-only audit functions for licensing management.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) implements RBAC by assigning tenants and roles to user accounts. HealthMonitor resources in AKO are scoped to a specific tenant, and the AKO CRD Operator manages namespace-scoped resources with tenant isolation for multi-tenancy support.

Organizations should identify which duties require separation based on their operational and compliance requirements, then configure Avi roles, tenant assignments, Service Engine group boundaries, and organization-managed mode settings to enforce those separations.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control AC.L2-3.1.5

> Employ the principle of least privilege, including for specific security functions and privileged accounts.

SCF Controls: IAC-16, IAC-16.1, IAC-21, IAC-21.1, IAC-21.3

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered role-based access control (RBAC) across its component products, giving organizations granular mechanisms to restrict and control privileged access rights. These technical controls form a strong foundation for a privileged account management program, though full PAM implementation requires additional organizational processes and tooling beyond what VCF provides natively.

VMware vCenter implements fine-grained privilege-based access control where individual privileges can be grouped into roles and mapped to users or groups on specific inventory objects. Administrators can create custom roles with granular privilege assignment and configure permission propagation across the vSphere object hierarchy. For example, a custom role can allow a user to encrypt virtual machines but not decrypt them by selectively granting Cryptographic Operations privileges. Only a System Administrator can modify the rights in a predefined role. These privilege requirements apply uniformly regardless of how a client application accesses server content, whether through the vSphere Client, CLI, or SDK. The vSphere Web Services API Permission object enforces this model programmatically, enabling automated governance of role assignments. The Administrator role is required for full vCenter interface access, and the platform guidance recommends restricting this role to only those users who require access to all objects and actions in the environment. At the appliance management layer, access to the vCenter Appliance Management Interface and the vCenter appliance shell is restricted to root or a user with super administrator role, where root is the default super administrator user. Bash shell access for non-root users holding the super administrator role can be enabled by running ``shell.set --enabled true`` from the appliance shell.

Authentication is centralized through VCF SSO, which provides token-based authentication across VCF components. VCF SSO supports identity federation with external identity providers through SAML 2.0 and OIDC protocols, enabling integration with enterprise authentication systems and multi-factor authentication. When using an external identity provider, users first obtain a JSON Web Token (JWT) from the provider, which is then exchanged for a SAML token. VCF SSO integrates with a VCF Identity Broker to manage authentication for VCF Instance components. Solution users (service accounts used for component-to-component communication) authenticate using certificates rather than passwords, and VCF SSO supports multiple authentication methods including username token, X.509 certificate, and holder-of-key token authentication. This centralized authentication model removes the need for direct access to VMware ESX hosts for routine administrative tasks.

VCF Operations enforces its own RBAC model where users can only perform the actions that their assigned permissions allow. A vCenter user must hold either the vCenter Admin role or a specific VCF Operations privilege such as PowerUser, assigned at the root level in vCenter, to log in to VCF Operations. Administrators in vCenter receive mapped roles in VCF Operations during registration, but these accounts only receive a specific role on the root folder if it is explicitly assigned. The administrators role should be reserved for users who need access to objects and actions across the entire environment.

VCF Automation extends access control through entitlements and access control lists (ACLs). Organization users can use only those rights from their roles that are published to their organizations, restricting lateral privilege expansion. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs through the accessControls API. Entity-type access can be granted to specific users and organizations, and system administrators must create entitlements using user criteria to manage access to projects and catalog items in the Service Catalog. VCF Automation project access is governed by pre-defined roles that scope what operations each user can perform within a project.

NSX provides RBAC through user role assignments that can be configured for local user accounts and users authenticated from identity management providers such as Active Directory over LDAP. NSX VPC user role assignments are managed from the User Management page. NSX Manager also supports local authentication where users authenticate using the PAM stack on the Unified Appliance, and local user passwords are secured using default Linux/PAM libraries with hashed and salted

storage. The admin user can manage account creation, deletion, and deactivation through the CLI or UI. vSAN similarly supports RBAC and permissions management for authentication and authorization.

VCF Operations uses a CloudAdmin role model that restricts access to platform-level operations. It supports ADMIN role accounts authenticated with username and password, and its System Administrator rights include granular controls over approvals, audits, certificates, and other administrative functions. VCF Operations provides a password management interface accessible through the Security menu, where administrators assigned the Administrator role can rotate account passwords and remediate service account passwords for integrated components. VCF Operations maintains a root user account and a super user (vcf) account that require ongoing password management. The VCF Operations API exposes a credentials endpoint at /v1/credentials that can be queried to retrieve vCenter root credentials, and if VCF Operations is not operational, these credentials can be recovered from the file-based backup. Default password complexity rules enforced through the Linux PAM module require at least 12 characters with mixed case, digits, special characters, and at least five different characters.

The VCF consumption layer, which encompasses VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere Namespaces, extends privileged access management across both the platform management plane and the Kubernetes workload layer. At the vSphere Namespace level, permissions are assigned to VCF SSO users and groups through three roles: Can View (read-only), Can Edit (provisioning and operating workloads), and Owner (full control including namespace deletion). The Owner role is available only with VCF SSO authentication. A VCF SSO user granted the Edit permission on a vSphere Namespace is automatically assigned the cluster-admin role for any VKS cluster deployed in that namespace, meaning namespace-level permission decisions directly determine cluster-level administrative rights. The VCF CLI enforces these role boundaries and returns a Forbidden error when a user lacks sufficient permissions on the vSphere Namespace for Supervisor or VKS cluster access. Administrative operations such as activating Supervisor Services or deleting a service registration require the Manage Supervisor Services privilege on the VMware vCenter system. Access assignments can be managed programmatically through the vSphere Automation REST API, and authentication for Kubernetes contexts can use either VCF SSO or external OpenID Connect providers.

Within VKS clusters, Kubernetes RBAC controls API server authorization through Role, ClusterRole, RoleBinding, and ClusterRoleBinding objects. RBAC rules specify fine-grained permissions by defining apiGroups, resources, and verbs (get, list, watch, create, update, patch, delete), and Role objects can further restrict access to specific named resources using the resourceNames field. ServiceAccounts can be bound to Roles or ClusterRoles via RoleBindings, enabling workloads to receive only the minimum permissions required to function. Granting cluster-admin to all ServiceAccounts cluster-wide is strongly discouraged because it allows any application full cluster access and grants any user with read access to Secrets the ability to create privileged pods; per-namespace permission management is the recommended approach. Cluster operators should restrict permissions that allow users or ServiceAccounts to escalate privileges through workload creation, and should carefully control authorization for CustomResourceDefinitions that govern ServiceAccount usage, ConfigMap mounting, or volume mounting. Kubernetes guidance recommends creating least-privilege access even for administrators, with broader access such as cluster-admin reserved for break-glass scenarios. For VKS clusters using a versioned ClusterClass, IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege at the identity layer. Dynamic Resource Allocation APIs should be controlled via RBAC to restrict access based on user persona.

Pod-level privilege control is available through Pod Security Admission (PSA) profiles enforced per namespace. The Privileged PSA level provides unrestricted permissions and allows known privilege escalations, making it appropriate only for trusted system workloads in controlled namespaces; the Baseline and Restricted profiles apply progressively tighter constraints. Security contexts within pod and container specifications allow configuration of runAsUser, Linux capabilities, and seccomp profiles to restrict the runtime permissions of individual containers. Kubernetes AppArmor profiles can further restrict per-program access privileges on Linux nodes. When requirePasswordOnSudo is configured on a VKS cluster, administrative sudo operations require explicit password entry. Namespaces that host privileged workloads should establish and enforce appropriate access controls to maintain least-privilege principles. The vmware-system-restricted Pod Security Policy, applied through RoleBindings, restricts which workloads service accounts within a namespace can run.

The consumption layer includes additional access control mechanisms for specific service types. The Secret Store Supervisor Service enforces RBAC across administrator, DevOps engineer, and application tenant roles for managing and distributing

sensitive data within VKS clusters, and Kubernetes recommends configuring least-privilege access to Secret objects through RBAC policies. Argo CD, which can be deployed as a Supervisor Service for GitOps-based workload management, supports local account authentication with global RBAC policies that define role-based access through policy rules and group mappings. For Windows workloads on VKS, Group Managed Service Accounts (GMSA) provide automatic password management, simplified service principal name management, and the ability to delegate management to other administrators; a service account must be bound to a cluster role via RoleBinding to authorize pods to use a specific GMSA credential specification. Access to Supervisor control plane nodes via SSH requires root user credentials through vCenter, which organizations should track and manage as a privileged access path reserved for troubleshooting operations.

To build a complete privileged account management program around VCF, organizations need to layer additional processes and tools on top of these platform capabilities. VCF does not natively provide session recording for privileged access, just-in-time privilege elevation, or automated access reviews. Organizations should implement policies governing who receives privileged roles, periodic recertification of privileged accounts, monitoring of privileged session activity, and integration with a dedicated PAM solution for credential vaulting and checkout workflows where required.

VMware Private AI Services (PAIS) provides AI-workload-specific mechanisms to restrict and control privileged access to its services, model artifacts, and AI resources. These operate on top of the foundational identity and access management that VCF supplies through VCF SSO and the VCF Automation role framework.

Access to Private AI Services is gated through OIDC group-based authorization. Administrators specify allowed groups in the authorizedGroups field of the PAISConfiguration custom resource when activating Private AI Services in an organization namespace through kubectl, or through the oidc-authorized-groups setting when activating through the VCF Automation UI. Only user accounts that are members of the specified groups, such as group-for-pais-access-01 or group-for-pais-access-02, can access the service. The OIDC configuration includes a groups claim in the access token and a groups scope, so group membership is enforced as part of the authenticated session.

The Grafana observability interface for Private AI Services applies role differentiation through OIDC group membership. Administrators configure the grafana-oidc-role-mapping property to assign the Admin role to users that match a specified group attribute and the Viewer role to all other authenticated users. This separates operators who can modify dashboards from those who can only view metrics.

Access to AI catalog items in VCF Automation is scoped by project-based permissions. PAIS catalog items are shared only with selected project members, and DevOps engineers must receive explicit permissions from organization administrators before they can request GPU-accelerated VMware Kubernetes Service (VKS) clusters, deep learning VMs, or other AI resources. The Private AI Services Quickstart setup itself requires organization administrator credentials to access the VCF Automation organization UI, and VI administrators need vCenter privileges to deploy deep learning VM templates on a vSphere cluster. Programmatic access to VCF Automation uses provider administrator and tenant administrator access tokens obtained from the Provider Management UI, with API tokens that must be saved locally for subsequent calls.

The PAIS Model Gallery uses Harbor project access controls to restrict which users can read or write the ML models and training data stored in the registry. Harbor project membership and role assignments determine who can read or write model artifacts, and Harbor registry read-write permissions on a project are required to store models. PAIS model endpoints support authentication through the harbor-pull-secret-readonly mechanism to control access to container images stored in private registries, and the oras login command authenticates to a private Harbor registry using user name and password credentials for resource push and pull operations.

PAIS Knowledge Bases extend privileged access controls to the retrieval data sources that ground model responses. Confluence data sources use either a user name and password or a personal access token configured under the Confluence administrator's settings, Google Drive folders that act as data sources must be shared with the PAIS service account using view-only permissions, and personal access tokens generated from user account settings are used for programmatic access to Knowledge Bases and data sources. Remote MCP servers integrated with Private AI Services can optionally use static authentication tokens to control access to specialized data and capabilities.

VMware vDefend (Contributes)

VMware vDefend implements role-based access control across its management plane through the Security Services Platform (SSP). SSP defines five built-in roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Permission levels range from Full Access (Create, Read, Update, and Delete) to Read-only or no access, depending on the role and operation. The Enterprise Admin role grants full authority over deployment, configuration, authentication and authorization settings, and backup operations. Modifying role assignments requires Admin privileges, and editing remote user or group role assignments requires LDAP to be configured as an authentication provider.

The two predefined local accounts, admin and audit, map to the Enterprise Admin and Auditor roles respectively, limiting each account to its designated functional scope. LDAP user account passwords are managed remotely by administrators, keeping credential management under organizational control.

Beyond its management plane, vDefend's Distributed Firewall (DFW) supports an Identity Firewall (IDFW) feature that enforces network access controls based on Active Directory user identity. Administrators create security groups in Active Directory and configure DFW rules that allow or deny user access to application servers based on group membership, applying role-based access controls at the network layer.

vDefend's Malware Prevention Service applies additional access restrictions to its service VMs: SSH access is disabled by default on the Malware Prevention Service virtual machine and must be explicitly activated by a vCenter administrator when needed for troubleshooting, then deactivated after use. The Malware Prevention Service VM ships with a default root password that must be changed on first login.

vDefend's contribution to this control is scoped to its own management interfaces and network-layer access enforcement. Controlling privileged access across the broader IT environment, identity lifecycle governance, and access controls for systems outside vDefend's domain require organizational processes and tooling beyond what vDefend provides.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports least privilege through role-based access control with a defined set of predefined roles and the ability to clone and customize roles for narrower operational scope. The 9.1 release consolidates Site Recovery Manager and vSphere Replication management under a single permissions model where PNR augments vCenter roles and permissions with additional permissions that allow detailed control over PNR-specific tasks and operations. PNR also verifies permissions on the remote vCenter instance as part of its access control validation, so privilege assignments are evaluated at both sites.

By default, PNR restricts login access to vCenter administrators; other users must be explicitly granted access by an administrator through the PNR interface. Users or user groups assigned a PNR role who are not vCenter administrators do not obtain vSphere Replication privileges, because PNR roles do not include the privileges of vSphere Replication roles. A user who is not a vCenter administrator but requires privileges to perform both PNR and vSphere Replication operations should be added to two user groups, one for each role type, to avoid granting vCenter administrator privileges.

vSphere Replication uses role-based access control with predefined roles that can be cloned and customized by adding or removing privileges based on organizational needs. PNR supports role propagation to child objects in the inventory hierarchy, allowing administrators to extend privileges from parent objects such as folders to all virtual machines within them, or to assign permissions at specific inventory levels without propagation when narrower scope is required. When permissions are assigned without propagation, users must have at least Read-only permission on all parent objects in the vCenter inventory.

PNR for VCF Automation access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, aligning RBAC with VCF Automation tenancy boundaries. Namespace unpair operations require Organization Administrator role authorization. In shared recovery site configurations, PNR restricts users from changing roles or assigning permissions for objects not dedicated to their own use, which helps prevent unauthorized privilege escalation across tenants, and the vCenter administrator manages PNR permissions so that each user has sufficient privileges to configure and use PNR but no user has access to resources belonging to other tenants.

PNR requires separate privilege assignment for testing a recovery plan and running a recovery plan, which helps prevent unintended changes at both sites that would require significant time and effort to reverse. PNR roles that allow users to run commands on PNR Server should be assigned to trusted administrator-level users only, and PNR server access should be limited to administrators to reduce the number of accounts available to an attacker. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to the automatic protection user or user groups for managing automatic protection permissions.

For the 9.1 Clean Room Orchestrator, at least one user must be assigned the Organization Owner role to enable administrative access to all resources in the Organization, with additional roles available for narrower delegation. VCF Operations orchestrator workflows for PNR require administrator credentials to access and execute, which restricts non-administrative users from performing sensitive recovery operations through the orchestration interface.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides role-based access control that restricts privileged access to database platform resources. The platform defines two built-in roles: DSM Admin and DSM User. The DSM Admin role is a super user role with full access to all data services in the environment, while the DSM User role restricts users to viewing and managing only the objects they own. This separation means that standard database consumers cannot affect or view resources belonging to other users or managed by administrators. The DSM console enforces this separation by restricting the views and actions available to each user based on their assigned role.

Privileged access within DSM is further scoped through namespaces. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to only those assigned workspaces. This namespace-level scoping provides a granular mechanism for controlling who can access which database workloads. Namespace RBAC is enforced at the platform level, preventing users within a shared namespace from accessing resources in other namespaces.

Role and user management is performed through the vSphere Client Permissions interface under the DSM Configure tab, and through the DSM administrator UI Permissions view, where administrators can create, monitor, and manage configured users. DSM supports both local users and LDAPS-authenticated directory service groups, enabling organizations to align DSM role assignments with their existing enterprise identity management systems. Directory Service Groups can be assigned either the DSM Admin or DSM User role. When local and LDAPS users share the same username, login precedence must be considered to avoid authentication conflicts.

At the platform infrastructure level, DSM uses a dedicated VMware vCenter service account rather than persisting administrator credentials. During initial setup, the deploying user must provide local vCenter administrator credentials. DSM uses those credentials to create a dedicated vCenter service account and then discards the original credentials after successful registration. Ongoing operations use only the service account, which is configured with the minimum permissions required for service account creation, plug-in registration, and resource management. The service account credentials for the target vCenter can be verified and updated in Settings > System Settings under Target vCenter.

For SQL Server databases, DSM applies additional engine-level privileged access controls. DSM deactivates the default sa account and uses a reserved internal account, dsm_mgmt, with sysadmin privileges for management operations. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full system privileges. When Windows Authentication is configured for SQL Server, DSM requires a Privileged Account configured in Active Directory to automate management of service principal names (SPNs) and DNS records.

Because DSM relies on vCenter for underlying infrastructure privilege management, achieving full coverage of this control requires organizational processes that are outside DSM's scope: maintaining an inventory of privileged accounts, conducting periodic access reviews, and managing approval workflows for new privileged account requests. DSM provides the technical enforcement mechanisms for restricting privileged platform access; the organization is responsible for the operational privileged access management procedures required to fully satisfy this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a native role-based access control (RBAC) system on the Avi Controller that restricts and controls privileged access to application delivery resources. The RBAC model assigns each user a role that governs their access level, with three permission states available per resource: write, read, or no access. The No Access privilege level is a distinct state that blocks users from accessing, reading, or listing resources entirely. Administrators can create custom roles through the Controller UI that grant precisely scoped access to specific system areas, with each resource configured independently. This supports least-privilege configurations tailored to distinct operational roles such as application operators, application admins, and system administrators.

For environments requiring finer-grained control, Avi's Extended Granular RBAC applies and enforces label-based permissions on cloud objects. The `restrict_cloud_read_access` field in controller properties governs whether label-based access scoping applies to cloud object reads. Roles can be configured with `write_access` type and the resource `permission_pool` setting to restrict role privileges to specific pool sub-resources such as `subresource_pool_enabled`, providing field-level access scoping within a resource type. Auth Mapping rules can be updated to deny privileges to specific users, blocking them from obtaining any roles or tenants upon login. Multi-tenant deployments can scope access by tenant: user groups can be mapped to a limited set of tenants with read-only privileges, while separate groups hold application owner privileges within those same tenants, enabling separation of duties between groups managing different applications or environments within a shared Avi deployment.

Avi supports TACACS+ server integration for centralized authentication and role assignment. Authorization attributes from a TACACS+ server map Avi users to roles and tenants, allowing organizations to govern privileged access through their existing network access control or identity infrastructure. The Avi Controller also supports LDAP authentication with the Administrator Bind configuration for user authentication and group membership validation. LDAP user account passwords are managed remotely and set by an administrator, not locally.

Administrators can create custom user account security profiles with organization-specific thresholds for password history, login failure, session limits, and credential timeout policies. The Controller implements Super User Accounts as a separate user account security mechanism. The admin account is maintained as a locally authenticated account even in systems configured for remote authentication. The `avidebuguser` account has sudo privileges on the Avi Controller for Linux CLI access, and access to this account should be restricted to authorized personnel. Using role-based access control, the ability to export certificates and private keys must be restricted to the fewest administrators possible.

Avi Cloud Console enforces access control through two access levels: Full Access (User Administrator or Product Administrator role) and Read-Only (Site Access role), with differentiated permissions for license visibility, management, and administration operations.

When Avi is deployed in a VMware vCenter environment, the Cloud Connector uses a dedicated vCenter account configured with a minimal set of permissions. Two vCenter roles are required: one with global privileges and another with folder-level privileges. The Avi-Folder-Role scopes the account's permissions to the specific folders containing Service Engine VMs in the vCenter inventory. In VCF deployments with a vSphere Supervisor, the Avi Controller cloud configuration supports either a vCenter administrator account or a dedicated account with lesser, precisely defined permissions. The Cloud Connector role requires specific vCenter privileges covering Virtual Machine Guest Operations, Host Local Operations, and other provisioning capabilities, following the principle of least privilege for service account access to the underlying platform.

Several permissions classified under Operations and Administration are not supported for per-application label-based RBAC, including `L4POLICYSET`, `WAFPOLICYPSMGROUP`, `PINGACCESSAGENT`, `NETWORKSERVICE`, and `NATPOLICY`, among others. These permissions remain under global administration scope and cannot be delegated to application-scoped roles.

Control AC.L2-3.1.6

> Use non-privileged accounts or roles when accessing nonsecurity functions.

SCF Controls: IAC-21.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.7

> Prevent non-privileged users from executing privileged functions and capture the execution of such functions in audit logs.

SCF Controls: IAC-21.4, IAC-21.5

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several mechanisms across its component products that record and surface information about the use of privileged functions, supporting organizational efforts to audit privileged activity within the platform.

VMware vCenter includes a privilege checks recorder that monitors and records the privileges checked during vCenter operations. This recorder captures each authorization decision along with the corresponding session, user identity, managed object, and operation ID. Administrators can query recorded privilege checks through the vCenter Management API using the PrivilegeChecks service interface, which supports filtering by managed object IDs, request operation IDs, and user or group identities through the AuthorizationPrivilegeChecksFilterSpec structure. The API returns paginated results and provides a marker-based retrieval mechanism that returns all privilege checks up to or after a specified point in time. These capabilities allow organizations to examine which privileges were exercised, by whom, and against which objects, forming a detailed audit trail of privileged function execution within vCenter. The Privilege Recorder is accessible only through the API and supports workflows run by a script; there is no UI for browsing recorded privilege check data. Accessing collected data requires the Sessions.CollectPrivilegeChecks privilege to be assigned to the querying account.

VCF Operations generates audit events across a broad set of categories, including Access, Access_control, Account_management, Configuration, Data_access, Permissions, Session, and System categories. These audit logs capture actions performed through the API, user interface, and command-line interface, providing visibility into privileged operations regardless of how they are initiated. VCF Operations also provides a User Permissions Audit capability that displays the permissions assigned to users, the groups to which each user belongs, associated access groups, and the access privileges granted within each access group. This audit report can be generated and downloaded in PDF or XLS format, giving auditors a snapshot of the current privilege landscape for review against organizational policy. In addition, the System Audit capability provides an overview of the counts of objects, metrics, super metrics, applications, and custom groups managed by the VCF Operations instance, allowing administrators to track changes to the monitored environment over time.

Within the networking layer, NSX audits API calls from all sources and users. VCF Operations for Networks also maintains audit logs that are accessible from the Settings page, with log access controlled by user role. VMware ESX hosts transmit audit messages to syslog collectors for security purposes, with audit records tracking security-related activity at the hypervisor level.

The Consumption layer of VCF, which includes VMware Kubernetes Service (VKS) and the vSphere Supervisor, extends privileged-function audit coverage to the workload tier. The Kubernetes API server underlying all VKS clusters generates a security-relevant, chronological record of all API requests processed by the cluster. Audit log entries capture the requesting user or service account, the resource and operation requested, the source IP address, and the authorization outcome. The authorization.k8s.io/decision and authorization.k8s.io/reason annotations record the authorization decision and its justification for each request, providing direct traceability for privileged API calls. When constrained impersonation is in use, the AuthenticationMetadata.impersonationConstraint field in the audit event records the verb associated with the impersonation authorization, supporting oversight of delegated elevated actions. Audit policy configuration determines which requests are logged and at what verbosity, allowing operators to target high-privilege operations such as requests to cluster-scoped resources like ClusterRoles and ClusterRoleBindings. Audit backends support local log files or webhook forwarding to external log aggregation systems for retention and analysis.

VKS implements Pod Security Admission with configurable enforce, warn, and audit modes. The podSecurityStandard.audit field in ClusterClass configurations controls the Pod Security Standard level at which policy violations are logged to the API server audit log without blocking pod creation; the field accepts the values privileged, baseline, or restricted. Default VKS ClusterClass configurations ship with the audit level set to privileged, logging violations of the privileged pod security policy.

Operators can tighten this to baseline or restricted to capture a broader set of policy violations. ValidatingAdmissionPolicies that include Audit in their validationActions field produce audit annotations in the API server audit log for every policy evaluation, whether the request is admitted or denied, allowing operators to track all API calls touching a specific policy governing privileged operations. Workload identity in VKS is bound to Kubernetes ServiceAccounts at the pod level, making API access attributable and scoped so that audit records can be correlated to a specific workload identity.

Seccomp profiles extend audit coverage to the system-call level within containers running on VKS worker nodes. A seccomp profile in audit mode logs all syscalls made by a container process to the node's system kernel log without restricting any calls. Kernel audit log entries (type=1326) capture process identity information including audit UID, UID, and GID, along with process details such as PID, command, and executable path, syscall number, and execution context. These entries can be filtered by container name and process, providing visibility into privileged kernel operations that do not surface in the Kubernetes API server audit log.

Together, these capabilities provide the technical foundation for auditing privileged function execution across VCF's management, compute, networking, and workload consumption components. Organizations should establish processes to regularly review privilege check records, audit event logs, user permissions reports, and Kubernetes API server audit streams. Defining which functions are considered privileged, setting review cadences, configuring audit log backends and retention policies for VKS clusters, and integrating VCF audit data with a centralized security information and event management (SIEM) platform are organizational responsibilities that fall outside VCF's built-in capabilities.

VMware vDefend (Contributes)

Security Services Platform (SSP) implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role is designed to view information and track activity without the ability to make changes. SSP ships with two predefined local user accounts: an admin account with full management access and a dedicated audit account assigned the Auditor role, which provides access to APIs and services for system auditing. This separation allows audit personnel to review privileged activity records without holding administrative privileges.

The Auditor role has Read access to core SSP operational areas: deploy and manage, upgrade, authentication and authorization configuration, server configuration, backup and restore, and Security Intelligence activation. For Security Intelligence operations, the Auditor role has restricted access to export cancellation, segmentation policy publication, infrastructure and environment monitoring operations, and data collection configuration.

The Malware Prevention Service extends audit coverage to endpoint security activity. The Malware Prevention Dashboard provides a Process Inspections capability that displays in-memory script buffers executed by a process and a View Reports option for detailed results of process inspections submitted to the cloud for analysis. The Malware Prevention Service Auditor role has Read access to view generated events, Cloud Analysis Reports, and SIEM configuration. SSP collects specific audit log fields for process-based malware monitoring, including the verdict of in-memory script execution, the SHA256 hash of the process binary, and the parent process ID.

The Distributed Firewall (DFW) extends audit coverage to the network security policy layer. DFW rules support logging with custom tags, allowing administrators to track allowed and denied traffic and maintain a record of security policy enforcement decisions that complements the administrative audit logs in SSP.

These mechanisms contribute to the broader organizational requirement for auditing privileged function execution. Auditing across the full VCF environment also requires coordination with VMware vCenter, VMware ESX, and other platform components, each of which maintains its own privilege and activity logs. The organizational processes to aggregate, review, and act on those records are required to fully satisfy the control.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) captures audit events for privileged operations across the recovery environment. Audit events record the event name, user identity, and source IP address from which the event was initiated, along with timestamp, priority level, message content, component name, severity, configuration ID, component ID, and event type. Permission-related

events are generated when protection is configured on virtual machines, when protection groups are created or modified, and when recovery plans are executed. PNR also logs authorization error messages with timestamps and component information, and records authorization failures for remote site manager operations with method name, fault type, object reference, and privilege ID.

PNR generates named audit events for specific privileged actions. `PermissionsAddedEvent` is recorded when a permission is created for an entity, with an `IsPropagate` flag indicating whether the permission propagates down the inventory hierarchy. `PermissionsUpdatedEvent` is recorded when a permission is modified. `VmAutoprotectEvent` indicates that an Automatic Protection operation completed successfully, and `VmEligibleForUnprotectionEvent` is generated when Automatic Protection detects a virtual machine eligible for protection removal. Array Manager reconfiguration events are logged when a user edits Array Manager properties. Events are produced at Info, Warning, and Error severity levels to distinguish descriptive operational records from situations that require attention or failures.

The Protection and Recovery global console records all tasks performed by users in the organization, including task type, task ID, user identity, start time, end time, duration, and completion status. The global console also displays both system-generated events and user actions, giving a consolidated view of privileged activity across protected and recovery sites. For ransomware recovery workflows, the Clean Room Orchestrator records event timestamps and supports forwarding events to external collectors such as a data collection rule for centralized audit review.

The PNR appliance includes an `auditd` service that writes audit records to disk; this service is stopped by default and must be manually started to capture system-level audit records on the PNR host. Operational information is also recorded in PNR log files. PNR uses role-based access control to gate which users can manage recovery plans, protection groups, and replication, and roles that allow users to run commands on the Protection and Recovery Server should be assigned to trusted administrator-level users only. The Clean Room Orchestrator is administered through Global Console Admin and Recovery Admin service roles that scope user permissions for the recovery environment.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides audit logging at both the platform and database levels, giving administrators visibility into privileged actions taken across the system.

At the platform level, DSM generates system audit events for all user actions performed through the DSM UI and API, as well as actions that DSM itself initiates. These events are accessible through the System Audit Events view in the Provider interface, which is the only DSM UI location for tracking non-database-related operations and tasks. Each audit log entry records an Event Type field that identifies the category of operation performed, an Event Details column that captures operation-specific information, and a Source field that distinguishes user-initiated events (recorded by the user's email address) from events initiated by DSM without user intervention (recorded as "System"). Audit event data can be exported in CSV and XLSX formats for offline review or integration with external audit processes. Gateway Audit Logs provide an additional layer of visibility into gateway-level operations, with export capability covering all events visible to the reviewing user regardless of pagination limits.

At the database level, PostgreSQL instances provisioned by DSM include the `pgaudit` extension, which delivers audit logging functionality across all supported PostgreSQL versions. This extension supports auditing of database-level privileged operations including stored procedures and other SQL-level actions. For MySQL databases, DSM enables the `log_bin_trust_function_creators` configuration setting, which governs logging behavior for stored function creators and their associated binary log entries. For SQL Server databases, DSM supports the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements for defining custom database audits. DSM can also automatically create a simple audit for login events based on the Login Auditing option selected when creating a SQL Server cluster. The cluster administrator login is granted restricted read-only privileges and specific `ALTER` privileges for server management and auditing, limiting the scope of administrative access within SQL Server.

DSM Administrator and User roles can generate database VM logs for monitoring and audit purposes. The Permissions view in the Administrator UI supports the creation, monitoring, and management of configured users, helping administrators identify which accounts hold elevated access within the DSM environment.

DSM provides the technical mechanisms to capture audit records of privileged actions at the platform and database levels. Organizations remain responsible for defining what constitutes a privileged function for their specific environment, establishing processes for reviewing audit records, configuring forwarding to a centralized log management or SIEM system, and assigning responsibility for ongoing audit review. The audit trail DSM produces supports those organizational processes but does not substitute for them.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) records user activity and configuration changes through the Config Audit Trail, accessible in the Controller UI at Operations > Events > Config Audit Trail. The audit trail captures timestamped records of user activity events and changes to system configuration over a selected period, providing traceability for who made changes to load balancer configuration objects.

In 9.1, Avi includes a dedicated Audit local user account in the License Controller Hub. This account carries the auditor role, which provides full read access to APIs and services for system auditing. The auditor role grants Read access to view deployment and management of security services, upgrades, and authentication and authorization configuration, but cannot make configuration changes. This separation of auditing access from administrative access allows a dedicated auditor to review the system without the ability to alter it.

Privilege scope in Avi is defined through its role-based access control (RBAC) framework. Roles can be pre-defined or custom-built with granular permissions (write, read, or no access) assigned independently to each resource type, including Virtual Services, Application Profiles, SSL/TLS Certificates, GSLB Services, Service Engine Groups, and Certificate Management Profiles. The Extended Granular RBAC feature supports per-field permissions, enabling sub-resource level control over what each account can read or modify. Avi also supports label-based permissions for cloud objects, covering Operations permissions (alerts, actions, and traffic capture) and Administration permissions (controller, tenant, user, role, and system configuration management).

The Avi Controller provides an Application Security Report accessible via Operations > Reports in the Controller UI or via the CLI. These reports can be exported and downloaded for audit and compliance review.

At the data plane, the Avi Service Engine generates audit events when TCP connections to clients are closed, configurable through the CLI or API. ControlScripts, used to trigger automated actions in response to alerts, run with limited Linux subsystem privileges and read-only file system access, constraining the scope of automated privileged actions.

To fully satisfy this control, an organization must establish processes to periodically review the Config Audit Trail, correlate audit events against authorized activities, and respond to anomalous privileged actions. Avi provides the audit trail data, the RBAC framework defining what constitutes a privileged action, and the dedicated auditor role for separation of auditing access, but it does not perform autonomous review or analysis.

Control AC.L2-3.1.8

> Limit unsuccessful logon attempts.

SCF Controls: IAC-22

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides account lockout mechanisms across its management components, each with configurable thresholds, lockout durations, and automatic unlock behavior. These capabilities allow an organization to enforce limits on consecutive invalid login attempts in line with its defined security policies.

NSX Manager enforces account lockout on both its API and CLI interfaces. The API authentication policy defaults to a maximum of 5 authentication failures before lockout, with a lockout period of 900 seconds (15 minutes). The CLI interface similarly defaults to 5 maximum authentication failures before lockout, with a `cli_failed_auth_lockout_period` of 900 seconds. These values are configurable through the NSX authentication policy endpoint (`/api/v1/node/aaa/auth-policy`) and through the "set auth-policy cli" command, which exposes parameters for `lockout-period` and `max-auth-failures`. Administrators can also disable account lockout on the CLI by setting the maximum failed attempts to 0, though this is not recommended in production environments.

VMware ESX hosts implement account lockout through two advanced system settings: `Security.AccountLockFailures` specifies the maximum number of failed login attempts before an account is locked (default 5 within a 3-minute window), and `Security.AccountUnlockTime` specifies the number of seconds the account remains locked (default 900 seconds, or 15 minutes). Both settings are configurable through the VMware Host Client under `Manage > System Settings` or through the ESX advanced system settings interface. Setting `Security.AccountLockFailures` to 0 deactivates account locking entirely, which is not recommended in production environments. Administrators should note that the Direct Console User Interface (DCUI) and the ESX Shell do not support account lockout, so access through those interfaces is not subject to the same enforcement.

VCF SSO implements a configurable Lockout Policy that specifies the maximum number of failed login attempts, the time interval in which failures must occur to trigger a lockout, and the duration of the lockout. By default, VCF SSO users are locked out after five consecutive failed attempts within three minutes, and locked accounts are automatically unlocked after five minutes. Setting the unlock time to 0 disables automatic unlock and requires an administrator to manually release the account.

VCF Operations enforces account lockout with a default threshold of seven failed login attempts, or if a user enters an incorrect password three times within five minutes. The account lockout policy is activated by default for super administrator users, and this policy cannot be deactivated. Super administrator accounts are locked for approximately one hour after lockout is triggered and then automatically unlocked. VCF Operations exposes a `Locked` attribute on user accounts that indicates whether the account has been locked, allowing administrators to monitor lockout status.

VCF Operations for Networks implements a progressive lockout model. After five consecutive failed login attempts, the account is temporarily locked for 15 minutes. Each subsequent failed login attempt after the initial lockout adds an additional 15 minutes to the lockout duration. An account can remain locked for a maximum of one day if login attempts continue after the initial lockout.

VCF Automation supports account lockout through its password policy system settings. Accounts are locked after a configurable number of invalid login attempts, and an account lockout interval specifies the duration before an account is automatically unlocked. Provider administrators can also unlock a user account manually without waiting for the configured lockout interval to expire.

VCF Operations HCX locks user accounts after three failed login attempts. If an account becomes locked, it can be reset by accessing the HCX Manager through the Web Console in VMware vCenter and running the `faillock` command with the `--reset` option.

To fully satisfy this control, the organization must define its own time periods and attempt thresholds for account lockout, then configure each VCF component accordingly. The default values vary across components (3, 5, or 7 attempts depending on the

component), so a consistent lockout policy requires reviewing and aligning the settings across all management interfaces. The organization should also establish procedures for monitoring lockout events and handling account unlock requests.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) maintains account lockout state for local user accounts through dedicated tracking fields. DSM records `failed_login_count`, `last_failed_login_time`, `locked_state_start_time`, and `force_password_change` on each local user account, providing DSM administrators with visibility into failed login activity, account lock status, and pending password-change requirements. These fields are accessible through the DSM administration interface in the "Managing LDAP Users in Data Services Manager" section of the administration guide.

When a local user account becomes locked, DSM provides two recovery paths. Administrators can manually reset a locked account through the DSM administration console. DSM also exposes a "Forgot Password" link on the login screen that allows users to initiate a password reset via email; reset links are active for 20 minutes. This self-service path is available only if an SMTP server has been configured in the DSM settings. If no SMTP server is configured, self-service password recovery is unavailable, and all locked accounts require direct administrator intervention.

For users who authenticate through LDAPS, DSM delegates authentication and lockout enforcement to the external directory service. The lockout threshold, time window, and automatic unlock behavior for LDAPS-authenticated users are governed by the organization's LDAP or Active Directory configuration, not by DSM. LDAPS users who need to reset a password must contact their LDAPS administrator rather than using the local password reset mechanism.

Organizations deploying DSM should configure lockout policies in their directory services for all LDAPS-authenticated users, configure SMTP to support self-service account recovery for local users, and establish administrator procedures for unlocking local accounts when self-service recovery is not available.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes a native account lockout mechanism for the Avi Controller administrative identity plane, configured through User Account Profiles. Each profile defines three lockout settings: Max Authentication Failures (the maximum number of consecutive failed login attempts before the account is locked), the Evaluation Period (the time window, in seconds, within which failures are counted toward lockout), and the lockout duration (the period the account remains locked after reaching the threshold). These settings are accessible through the Controller UI under Administration > User Account Security and through the Avi REST API.

The Default-User-Account-Profile ships with `max_login_failure_count` set to 20 and an `account_lock_timeout` of 30 minutes. Organizations can modify the failure threshold and lockout duration by editing the default profile or by creating a custom User Account Profile and assigning it to specific users. A built-in No-Lockout-User-Account-Profile sets Max Authentication Failures to 0, which disables lockout for any account assigned to it; when this setting is 0, the Evaluation Period and Lockout Period values have no effect. Auditors should verify that accounts assigned to the No-Lockout-User-Account-Profile carry an explicit authorization exception, as this profile bypasses the lockout control.

The Avi GSLB administrative interface has a parallel lockout configuration, where a specified number of authentication failures triggers an account lockout for a configured duration. This is controlled by the `login-failure-lockout-duration` setting in the GSLB configuration; the default lockout duration is 30 minutes.

Organizations using remote authentication sources such as LDAP, TACACS+, SAML, or RADIUS for Controller access will rely on the lockout policies of those external directories rather than on Avi's own profile settings. The organization is responsible for configuring Max Authentication Failures and the Evaluation Period to reflect its defined policy thresholds and time periods.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.9

> Provide privacy and security notices consistent with applicable CUI rules.

SCF Controls: SEA-18, SEA-18.1, SEA-18.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides configurable logon banner and system use notification capabilities across its management interfaces, allowing organizations to display approved notification messages before granting access.

NSX Manager supports configuring a security banner or message of the day. A separate login user agreement banner can be activated to display at every login. When enabled, only users with Enterprise Admin roles can modify the banner content, restricting unauthorized changes to the notification text. This banner can be configured with organization-specific language covering acceptable use policies, monitoring notices, and legal disclaimers. NSX login user agreement banner configuration is recommended for organizations with security compliance requirements. In federated environments, each Global Manager and Local Manager maintains its own login user agreement banner configuration, allowing site-specific messaging.

VCF Operations for Networks provides configurable login message banners through both the web UI and the CLI. Administrators can configure custom message text through the System Configuration settings, where login banners can be enabled or deactivated via a toggle button on the Settings page. When login banners are enabled, VCF Operations for Networks supports requiring users to click an explicit consent check box to indicate acceptance of terms and conditions before proceeding, providing a documented acknowledgment mechanism. A separate user consent form can also be configured with a title and content message that requires users to agree before logging in. The set-banner CLI command configures both the SSH pre-login banner for the support user and the post-login banner for the console user, with support for quoted text and newline characters for multi-line messages.

VCF Operations (the monitoring and analytics platform) can display a login message when users access the login page, with the option to require explicit user consent for terms, conditions, or mandatory notices before proceeding.

VCF Automation for VM Apps supports enabling a Notice and Consent Banner through administrator configuration in Workspace ONE Access. This is configured through the Workspace ONE Access administrative console by setting the CertificateAuthAdapter with an Enable Consent Form before Authentication setting. The banner informs users of monitoring and data inspection policies before they access the automation interface.

VMware ESX supports configurable SSH connection banner messages that display when users connect via SSH. A separate welcome message can also be configured for display to users accessing ESX hosts. These settings are exposed as host system properties that can be monitored and enforced through VCF Operations.

vSphere Supervisor cluster configuration supports a login banner message displayed to users upon authentication, configurable through the cluster setup parameters.

These banner capabilities span VCF management components at the network, compute, operations, automation, and Kubernetes layers. Administrators should configure banners on each management interface with the organization's approved notification text and enable consent requirements where available.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides configurable Login Banner and Message of the Day mechanisms that apply to all administrative access paths: the Controller web UI, CLI, and SSH. The Login Banner is displayed before authentication completes, meaning it is presented to all users attempting access regardless of whether their credentials succeed. The Message of the Day is displayed after a successful login through any of these interfaces. Both messages are configured in Administration > System Settings and take effect on the next login session.

The Login Banner text is fully customizable and can contain any organizational-approved system use notification, including statements about authorized use, monitoring, and consent. Together, these two mechanisms satisfy the requirement for a pre-

login system use notification across all supported administrative interfaces of Avi Load Balancer, with no dependency on the underlying VCF platform beyond network access to the Controller.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.10

> Use session lock with pattern-hiding displays to prevent access and viewing of data after a period of inactivity.

SCF Controls: IAC-24, IAC-24.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF components provide session timeout and automatic logout capabilities rather than true session lock functionality. Session lock, which freezes the current session display and requires re-authentication to resume, is not natively supported by VCF management interfaces. VCF's session management controls terminate idle sessions and require users to re-authenticate.

NSX Manager explicitly does not support session lock. The documented guidance is to use the workstation operating system's screen lock to initiate a session lock when accessing NSX Manager. NSX Manager does support session timeout and automatic user logout, and idle sessions time out automatically. Administrators can also delete idle sessions through the API. These timeout mechanisms terminate inactive sessions, which forces re-authentication but does not preserve the session state in a locked condition.

ESX hosts provide two configurable shell-level session timeout settings. The ``UserVars.ESXiShellInteractiveTimeOut`` setting logs out users from idle interactive ESX Shell sessions after a configurable period of inactivity. The ``UserVars.ESXiShellTimeOut`` setting controls shell availability and disables the ESX Shell service entirely after a specified period, preventing new logins until the service is re-enabled. Both settings can be configured through the vSphere Client, VMware Host Client, or DCUI.

VMware vCenter provides session management through the SessionManager managed object, which controls user access through methods for logging in, obtaining a session, and logging out. Each session is associated with the authenticated user account for the duration of the session. The SessionManager uses a session ID as a temporary substitute for username and password, limiting exposure of the principal's credentials during active sessions. SessionManager also defines the visibility of many objects, and session-specific objects are not visible outside the session in which they were created. While vCenter manages session lifecycle, the session lock behavior depends on the client interface and the workstation operating system.

VCF Operations for Networks provides a configurable user session timeout value that administrators can adjust according to organizational requirements, with a range from 15 minutes to 24 hours and a default of 15 minutes. Defining a Release Session Request is recommended when using session authentication to log out sessions, reduce session leaks, and improve security. These capabilities allow organizations to enforce inactivity-based session termination aligned with their defined time periods.

For command-line access through VCF PowerCLI, the `WebOperationTimeoutSeconds` setting can be configured at session scope using the `Set-PowerCLIConfiguration` cmdlet. This allows administrators to control how long PowerCLI sessions remain active before timing out, and the setting can be reverted to its initial value.

For API-based access, service accounts authenticate using API access tokens. The VCF Automation API refresh token is valid for 90 days and can be used to generate new access tokens when the access token expires. If rotation is activated, each refresh token grant call returns both a new access token and a new refresh token, invalidating the original refresh token. Users can also revoke API tokens through the User preferences page. This token lifecycle provides time-bounded session control for programmatic access.

Organizations should configure workstation-level screen lock policies through their endpoint management tools (such as Group Policy for Windows systems) to provide the session lock behavior that VCF's web-based management interfaces do not natively implement. VCF's session timeout settings should be configured to align with the organization's defined inactivity period, and workstation screen lock timeouts should be set to equal or shorter intervals.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides session timeout and termination mechanisms at two layers: the administrative control plane (the Avi Controller) and the application data plane (virtual services and Kubernetes ingress).

For administrative access to the Avi Controller GUI and REST API, the User Account Security settings include a configurable idle timeout, accessible under User Authentication and Authorization > User Account Security > User Account Self-Service > Configuring Idle Timeout for Admin Access to GUI and API. This setting terminates sessions that have been inactive for an administrator-defined period, after which the administrator must re-authenticate before regaining access. Administrators can also explicitly invalidate all active sessions using the shell `--clear-sessions` command. The Maximum Concurrent Login Sessions feature, configured through the `max-concurrent-login-sessions` setting in the `UserAccountProfile` object (manageable via CLI or REST API), limits the number of simultaneous active sessions per user account. The default value of 0 disables concurrent session limiting; organizations should set this to a non-zero value appropriate for their environment.

For application sessions managed through Avi virtual services, the Auth Credentials Cache Expiration setting controls the maximum time a client's authentication credentials remain cached. This bounds the window during which a previously authenticated client can access resources without re-presenting credentials, supporting time-bounded session validity for application traffic. Organizations should configure the HTTP Cookie Persistence timeout to address cases where a client browser does not clear session cookies when a session ends or the browser is closed.

For application workloads using OAuth or OIDC-based authentication, Avi's RP-Initiated Logout support allows a logout event to clear the user's session details from the session database. Subsequent access attempts initiate the OAuth login flow, requiring users to provide credentials again before accessing protected resources.

For Kubernetes workloads managed through the Avi Kubernetes Operator (AKO), the `SSORule` custom resource definition (CRD) provides session timeout controls for virtual services handling OAuth/OIDC and SAML authentication. The `cookieTimeout` parameter specifies the authorized session cookie expiration period, controlling how long an OAuth or OIDC session remains valid before the user must re-authenticate. The `useIdpSessionTimeout` property allows the Identity Provider to control the Service Provider session duration through the `SessionNotOnOrAfter` field in the SAML `AuthNStatement`, enabling organizations to delegate session lifetime enforcement to their external IdP.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.11

> Terminate (automatically) a user session after a defined condition.

SCF Controls: IAC-25

Aggregate Coverage: Meets

VCF (Meets)

VCF provides automated session termination and inactivity timeout mechanisms across its management interfaces, APIs, and component products. These controls operate at multiple layers of the platform to log out users after configurable periods of inactivity or at session end.

At the hypervisor layer, VMware ESX includes a Host Client Session Timeout setting that controls the duration before an inactive Host Client session is terminated. Administrators can configure this value through the ESX security configuration to align with organizational inactivity policies. The ESX Shell, used for console and SSH administrative access, has a separate idle timeout controlled by the ESX-Shell-idle-timeout advanced system setting (UserVars.ESXShellInteractiveTimeOut), which independently terminates inactive shell sessions.

VMware vCenter uses token-based session management through VCF SSO. Security tokens have a default expiration interval of 30 minutes, after which the session is no longer valid and the user must re-authenticate. The vCenter SessionManager managed object controls user access to the server through methods for logging in, obtaining a session, and logging out, providing both automatic expiration and programmatic session termination capabilities. When any session ends, the associated authentication token is invalidated. The vCenter Appliance Management Interface also enforces a session timeout, expiring idle login sessions after 10 minutes by default. The vSphere Client enforces its own session timeout that defaults to 120 minutes of inactivity and is configurable through the session.timeout parameter.

NSX Manager supports session timeout and automatic user logout. Idle sessions time out automatically, and upon session termination or user logout, users are redirected to the login page. The idle session timeout is configurable, and administrators can also delete idle sessions using the /api/session/destroy API command. When a user logs out, NSX Manager immediately destroys the session identifier and removes the session cookie from the reverse-proxy, limiting session identifier reuse. Session IDs and tokens for each session are unique and expire after the user logs out or after a period of inactivity.

VCF Operations enforces a user session timeout that defaults to 15 minutes and can be modified to match organizational requirements. VCF Operations for Networks allows configuration of the user session timeout with a value range from 15 minutes to 24 hours, giving administrators flexibility to set inactivity thresholds appropriate for their environment. VCF Operations also recommends defining a Release Session Request when using session authentication to log out sessions and reduce session leaks.

The VCF Automation Provider Management Portal automatically logs out users after more than 25 minutes of inactivity. VCF Automation also supports API token expiration, with access tokens expiring after 30 days and API tokens expiring after 90 days by default. At the organization level, deactivating a VCF Automation organization terminates the sessions of all users currently logged in to that organization, providing an administrative mechanism for bulk session termination.

At the Kubernetes consumption layer, the VMware Kubernetes Service (VKS) and vSphere Supervisor enforce bounded session lifetimes through multiple token expiration mechanisms. The Kubernetes API server enforces a maximum validity duration for all service account tokens through the --service-account-max-token-expiration parameter, which caps token lifetimes server-side regardless of what a requesting client specifies. Tokens generated via the TokenRequest API accept an expirationSeconds parameter, and the TokenRequestStatus includes an expirationTimestamp confirming when the credential expires. Projected service account tokens mounted into pods default to one hour of validity, with a minimum enforced duration of 600 seconds, and are automatically rotated by the kubelet before expiry; when rotation is not possible, the token expires and subsequent requests from the workload are rejected. User access to vSphere namespaces and VKS clusters is authenticated through VCF SSO, which provides the OIDC token that kubectl and other API clients use; when that token expires, the user must re-authenticate without administrator intervention.

Streaming sessions opened through the Kubernetes API, including `kubectl exec`, `kubectl attach`, and `port-forward` connections, are governed by the kubelet's `streamingConnectionIdleTimeout` parameter, which automatically closes any streaming connection that has been idle for the configured duration. In VKS clusters provisioned through the ClusterClass API, `streamingConnectionIdleTimeout` is exposed as a configurable variable in the `kubeletConfiguration` ClusterClass variable block, with a default of 10 minutes. For ingress traffic routed through the Contour package, idle HTTP connections are terminated when they exceed the `timeouts.connection-idle-timeout` value, and idle HTTP streams are closed when they exceed `timeouts.stream-idle-timeout`; both are configurable in the Contour package configuration and apply to all traffic passing through the ingress layer.

At the API layer, the vSphere Web Services API provides a `SessionManager` with explicit logout methods to close authenticated sessions. The VCF Operations PowerShell plug-in offers a `closeSession` method to terminate sessions by session ID. These programmatic interfaces allow automated tools and scripts to enforce session cleanup as part of operational workflows.

Across all components, VCF provides both configurable inactivity timeouts for interactive sessions and explicit session termination capabilities through management interfaces and APIs. The default timeout values vary by component but are set to enforce session termination within reasonable inactivity windows, and all are adjustable to meet organization-defined policies. Auditors evaluating a VCF deployment should verify the timeout values configured for each management component as well as the Kubernetes API server `--service-account-max-token-expiration` parameter and the kubelet `streamingConnectionIdleTimeout` for VKS clusters.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides session termination through two distinct planes: the management plane (Avi Controller) and the data plane (Service Engines handling application traffic).

For management sessions, the Avi Controller enforces a configurable Session Timeout that specifies the maximum number of minutes an administrative session can remain idle before the Controller terminates it automatically (Administration > System > Access Settings). When a UI session expires due to timeout or logout, the Controller displays a login screen requiring reauthentication. When an API session ends due to timeout or logout, the next API call fails validation. CLI sessions are terminated silently on expiration; the next command typed triggers re-validation of a new CLI session. The Controller also enforces the `api_force_timeout` setting, which bounds the maximum duration of portal API sessions (24 hours by default). The Avi Controller generates `USER_LOGOUT` events in the audit event log, providing a record of session termination activity for administrative users. When the maximum concurrent session count is reached, administrators can also forcibly invalidate existing sessions using the shell `-clear-sessions` command.

For application sessions proxied through Avi virtual services, the TCP Fast Path Profile includes a configurable Session Idle Timeout parameter. When an application-layer flow is idle for the configured period, the Service Engine terminates it and sends a TCP reset to both the client and the server.

For applications using OAuth 2.0 and OpenID Connect (OIDC) for client authentication, Avi supports Relying Party (RP)-initiated logout. When a user logs out, Avi, acting as the OAuth client, redirects the user agent to the Identity Provider's end session endpoint (configured via the `end_session_endpoint` parameter in the `oauth_profile`) to terminate the session at the Identity Provider level. The logout URI is configurable via the `logout-uri` parameter, and a `post_logout_redirect_uri` can be configured to direct users to a defined location after logout. Upon logout, Avi clears the user's session details from the session database. After RP-initiated logout completes, the user must provide credentials again to access resources.

In Kubernetes environments using the Avi Kubernetes Operator (AKO), the `SSORule` CRD provides OAuth/OIDC session cookie timeout configuration via the `cookieTimeout` property in `oauthVsConfig` (specified in minutes, with a default of 120 seconds). The `/oauth/logout` endpoint is available for OAuth session termination through the `SSORule` CRD configuration.

When Avi is deployed with Avi Cloud Console, session logout from the Cloud Console is separate from Broadcom IDP session logout. Users who log out of the Cloud Console must also log out from the Broadcom support portal to fully terminate their Broadcom IDP session. Auditors evaluating organizations using Avi Cloud Console should verify that users understand this distinction and that operational procedures account for it.

Auditors should verify the Session Timeout setting in the Avi Controller under Administration > System > Access Settings and confirm that the `api_force_timeout` value aligns with organizational policy. For virtual services using OIDC client authentication, auditors should review the OAuth Profile configuration to confirm that the `end_session_endpoint` and `logout-uri` parameters are set.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Not supported directly for this control: VMware Data Services Manager. This product does not currently provide the capability this control requires.

Control AC.L2-3.1.12

> Monitor and control remote access sessions.

SCF Controls: NET-14, NET-14.1, NET-14.5

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several built-in mechanisms for controlling and securing remote access to infrastructure components across the platform.

Centralized identity and authentication. All administrative access to VCF components flows through authenticated interfaces with centralized identity management via VCF SSO. VCF SSO supports identity provider federation, allowing vCenter to replace its built-in identity source with an external identity provider such as AD FS, Azure AD, or Okta. This integration enables organizations to enforce their existing authentication policies, including multi-factor authentication, across VCF management interfaces. VCF SSO provides centralized authentication that reduces the need for direct ESX host login with local credentials.

SSH access controls. ESX hosts include the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. SSH access is also available for NSX Manager, VCF Operations appliances, and cloud proxy instances. VCF Operations Cloud Proxy disables SSH by default, requiring initial access through the vCenter console before SSH can be enabled. When SSH is active on VCF Operations nodes, a restricted access banner is displayed to users upon connection. ESX host advanced options allow administrators to configure shell timeouts and host client session timeouts, limiting the duration of interactive remote sessions. For VCF Automation deployments, remote access supports both password and public-private key authentication via SSH, providing a stronger alternative to password-based login. VCF Operations orchestrator can also register a public key on an SSH host to enable key-based authentication.

DCUI and lockdown mode. ESX supports configuration of the DCUI.Access setting, which specifies which users can override lockdown mode and access the Direct Console User Interface. When lockdown mode is enabled, this restricts the set of accounts that can interact with the host locally or through the DCUI, reducing the available remote management surface. ESX hosts support an Exception Users list for lockdown mode, providing granular control over which accounts retain access during restricted operation. ESX supports two lockdown mode levels: Normal mode keeps the DCUI service running and allows local console access alongside vCenter management, while Strict mode stops the DCUI service entirely and restricts access to vCenter only. ESX Shell and SSH services operate independently of lockdown mode and must be separately deactivated, since lockdown mode itself does not restrict those services.

Console and management access. Access to ESX hosts requires login at the host's HTTPS URL as a user with the Administrator role. Virtual machine console access via the VNC protocol can be individually enabled or disabled through the RemoteDisplay.vnc.enabled setting in vCenter, giving administrators control over which remote console methods are available. The virtual serial port proxy can act as a gateway to enforce security policies for remote serial port connections. Management port access on network devices within the VCF environment must be password protected, and console port access must require authentication.

Role-based access control for remote sessions. Role-based access control governs what authenticated users can do once connected. vCenter allows creation of custom roles with granular privilege assignment and permission propagation to vSphere objects. The CloudAdmin role model in VCF Automation restricts administrative scope. NSX implements RBAC to restrict system access to authorized users by assigning roles with specific permissions, including the ability to create custom roles that suit operational requirements. NSX Federation also supports RBAC across federated environments. These layered RBAC controls enforce granular permissions on remote sessions across the platform.

Remote access to provisioned workloads. Remote sessions to provisioned machines in VCF Automation for VM Apps require connecting to the machine's IP address or FQDN and authenticating with a username and password. VCF Automation cloud templates also support remoteAccess authentication using public-private key pairs with SSH key input parameters.

These controls give administrators granular ability to enable, disable, and restrict specific remote access methods across VCF infrastructure. However, defining which remote access methods are organization-approved, establishing policies governing their use, and conducting periodic reviews of remote access configurations are organizational responsibilities that fall outside VCF's scope.

VMware Private AI Services (PAIS) provides mechanisms for controlling remote access to its AI workload components, supporting the organizational processes for defining and reviewing approved access methods.

PAIS enforces user access through OIDC group-based authorization. Access is granted only to user accounts belonging to groups listed in the `authorizedGroups` configuration (and the `oidc-authorized-groups` setting when activation is performed through the VCF Automation UI). Group names such as `group-for-pais-access-01` are specified on the OIDC provider, and HTTPS-based communication to the OIDC provider is required. PAIS also uses a CA trust bundle (`ca-trust-bundle`) for secure communication with external services and databases, including Harbor registries and MCP servers. When PAIS is consumed under VMware vCenter 8.x, VCF SSO must be configured to access Private AI Services namespaces and their resources from VCF Automation; under vCenter 9.x or later this SSO step is not required.

Deep Learning VMs (DL VMs) deployed through VCF Automation require user password configuration and support optional SSH public key authentication for remote administrator access. DL VMs are exposed through LoadBalancer services that provide public IP addresses and mapped ports for SSH on port 22 and JupyterLab notebook access on port 8888. DL VMs that include the NVIDIA Triton Inference Server use the same password and SSH public key authentication pattern, and are accessed over SSH as the `vmware` user. The PyTorch profile for DL VMs restricts JupyterLab to the local machine only by default, listening on port 9400, which reduces the remote attack surface for development notebooks.

API access to PAIS administrative endpoints goes through authenticated channels. The VCF Consumption CLI authenticates to VCF Automation endpoints using an API token, the FQDN or IP address of the endpoint, and an optional CA certificate for TLS verification. The `vcf context create` command issued through this CLI requires the same credentials, and VCF Automation Provider Management exposes an API Token endpoint that allows provider administrators to create and manage API tokens. VCF Automation organization administrator access tokens are obtained through a POST request to a sessions endpoint using Basic authentication. PAIS provides a dedicated VCF Automation API endpoint for registering vCenter instances using Bearer token authentication, and Broadcom recommends using the FQDN of the vCenter instance rather than its IP address when registering it.

For AI agent and knowledge base integrations, PAIS adds review controls on remote endpoints. Remote MCP servers connected to PAIS must be accessible over HTTP or HTTPS using the Streamable HTTP or Server-Sent Events transport, can optionally use static authentication tokens, and require examination and approval of their tools and capabilities before use in agents. The PAIS Agent Builder maintains a list of approved tools for use in AI agents when connecting to MCP servers, giving administrators a control point over which remote services agents are allowed to call. Microsoft SharePoint data sources used as PAIS Knowledge Bases require username and password authentication and are limited to SharePoint On-Premises deployments.

For model artifact distribution, the PAIS Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models, and the `oras login` command authenticates to a private Harbor registry using username and password credentials before any push operations.

VMware vDefend (Contributes)

VMware vDefend contributes to remote access governance through network-level enforcement and behavioral detection. The Distributed Firewall (DFW) can enforce policies controlling which sources and protocols, such as SSH and RDP, may reach management interfaces, while Identity Firewall (IDFW) adds user-aware policy enforcement for remote user groups. IDFW supports Virtual Desktop Infrastructure (VDI) environments, Remote Desktop Session Hosts (RDSH), and physical machines, where multiple users may log in simultaneously; in RDSH deployments, administrators create Active Directory security groups to allow or deny user access to application servers through DFW rules based on the user's assigned role. IDFW supports the multi-user RDSH use case for both TCP and UDP protocols.

The Security Services Platform (SSP) includes Security Intelligence, which detects suspicious behavior for remote connections such as telnet, SSH, and VNC, providing visibility into remote access activity. SSP also correlates lateral movement events with subsequent infection-type activity, such as detecting RDP connections from one workload to another followed by command-and-control activity originating from the destination.

SSH access to Malware Prevention Service virtual machines is disabled by default and must be explicitly activated by the vCenter administrator. SSH to these service VMs uses key-based authentication with a public-private key pair; a public key is required at deployment time and a private key is required to initiate an SSH session. Administrators should deactivate SSH access once troubleshooting or debugging tasks are complete.

Role-based access control within SSP limits which users can administer vDefend components remotely. SSP defines five built-in roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles can be assigned to individual remote users or remote user groups, including Active Directory groups, integrating with existing enterprise directory services for remote administrator management. CLI commands for Distributed IDS/IPS must be run on ESX hosts, with available commands and viewable modes differing based on the user's assigned role.

Defining organization-approved remote access methods, VPN provisioning, and centralized remote access governance remain outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several native mechanisms for controlling remote administrative access to the Controller and Service Engines. Administrators reach the Avi Controller through SSH for command-line management or through the HTTPS-based web UI and REST API. SSH is also the secure channel used between the Controller and Service Engines for management communication.

To restrict which hosts may initiate remote access sessions, the Client Management Access feature allows configuration of separate IP allowlists for SSH clients, CLI shell clients, external HTTP(S) clients, and external SNMP clients. Each allowlist accepts individual IP addresses, ranges, or IP groups. Separate IP access lists must be configured per management interface to restrict access through each channel individually. The web interface, SSH daemon, CLI Shell, and SNMP each require their own access list configuration.

SSH management sessions also support configuration of allowed HMAC algorithms. Administrators can restrict which HMAC algorithms are accepted for SSH clients rather than relying on the default of allowing all standard HMACs. This capability restricts the set of cryptographic options available during SSH session establishment.

For Service Engine remote access, Avi supports SSH key-based authentication. By default, Service Engines allow direct SSH access using the system's admin credentials; this default should be reviewed and restricted through allowlists and key-based authentication to align with site access policies.

For identity binding, Avi supports remote authentication through LDAP, TACACS+, and SAML. Administrators configure an Authentication Profile and, optionally, a Mapping Profile that binds enterprise directory group membership to Avi roles. When remote authentication is active, local user login can be retained as a fallback for emergency access or deactivated entirely to enforce remote authentication for all administrator logins.

In Kubernetes deployments, Avi Kubernetes Operator (AKO) Custom Resource Definitions (CRDs) can be governed through Kubernetes Role-Based Access Control (RBAC) policies to restrict which users and groups may configure ingress routing rules and load balancing resources.

The organization must designate approved remote access methods in policy, document them, and conduct periodic reviews to verify that allowlists, HMAC algorithm restrictions, and authentication profiles remain consistent with current access requirements.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.13

> Employ cryptographic mechanisms to protect the confidentiality of remote access sessions.

SCF Controls: NET-14.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in cryptographic mechanisms that protect the confidentiality and integrity of remote access sessions across its networking, management, and workload migration layers.

All VCF management communications are encrypted in transit using TLS. VCF components support TLS, and FIPS-validated cryptographic modules are used across the platform. VCF Automation runs in FIPS-compliant mode by default, using the BouncyCastle FIPS 2.0.0 cryptographic module. VCF Operations for Networks uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, validated by the NIST Cryptographic Module Validation Program (CMVP), and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. The VMware vCenter appliance uses VMware's Boring Crypto Module version 6.0, a FIPS 140-2 validated module supporting AES, ECDSA, HMAC, RSA, and SHA2 variants. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant. VCF Operations supports a FIPS Security Mode that applies additional algorithm and cipher prerequisites across the platform when enabled. Administrators should be aware that self-signed certificates and private keys generated using OpenSSL are not FIPS-compatible, so organizations operating in FIPS-enforced environments should use certificates from a FIPS-compliant certificate authority or key generation process. These protections apply to all remote management sessions, including browser-based access to vCenter, VCF Operations, and other VCF component consoles. Access to VMware ESX hosts is available through HTTPS, and SSH access to infrastructure components such as VCF Operations Cloud Proxy is disabled by default, with the first login required through the vCenter console.

The VMware Kubernetes Service (VKS) and vSphere Supervisor, which form the consumption layer of the VCF platform, apply cryptographic protections to all remote access paths reaching Kubernetes infrastructure. All client connections to the Kubernetes API server use TLS, and the `--tls-cipher-suites` and `--tls-min-version` parameters allow administrators to restrict connections to the cipher suites and protocol versions that meet organizational requirements. Each Supervisor node runs a kubelet that exposes HTTPS endpoints; the tlsCipherSuites` and `tlsMinVersion` fields in the KubeletConfiguration similarly control the permitted cipher suites and minimum protocol version for kubelet connections. The kube-scheduler also supports cipher suite restriction through the --tls-cipher-suites` parameter, and Kubernetes hardening guidance recommends providing an explicit preferred cipher suite list to prevent negotiation of weaker algorithms. When Contour is deployed as a standard package on VKS clusters, it provides TLS termination for inbound application traffic, and the tls.minimum-protocol-version` and `tls.maximum-protocol-version` parameters in the Contour configuration file bound the protocol versions accepted from remote clients. When Istio is deployed as a standard package, it enforces mutual TLS between services within the mesh; the meshMTLS.minProtocolVersion` setting establishes a floor on the protocol version for inter-service encrypted communication and defaults to TLS 1.2, with TLS 1.3 available as an option. VKS on Supervisor maintains TLS certificates that underpin the cryptographic infrastructure for secure cluster communications. Direct administrative access to Supervisor control plane nodes requires authenticating through VMware vCenter as the root user, constraining that access path to an encrypted channel and tying it to vCenter's authentication controls. Secure login configuration for vSphere Supervisor requires either distributing the vCenter root CA certificate to client machines or replacing the Supervisor VIP certificate with one signed by a CA that client machines already trust.`

For site-to-site and remote access VPN, NSX provides IPSec VPN capabilities with configurable cryptographic schemes. The IPSec VPN service is available on both Tier-0 and Tier-1 gateways, allowing organizations to establish encrypted tunnels for traffic between VCF environments and external locations. Configuration of L2 VPN and IPSec VPN tunnels between Tier-1 gateways within the same project or across different projects in the same NSX deployment is also supported, providing flexibility for multi-site and multi-tenant architectures. Both route-based and policy-based IPSec VPN configurations are available. IPSec VPN sessions support pre-shared key (PSK) or certificate-based authentication, and administrators can select a security compliance suite that applies predefined, non-modifiable IKE and IPSec profiles. When a compliance suite is

selected, the authentication mode is automatically set to certificate-based, and the associated IKE and IPsec security profiles cannot be manually edited, reducing the risk of misconfiguration. For certificate-based authentication, the certificate details for the IPsec session must be configured in the associated local endpoint.

NSX Layer 2 VPN connections are secured with route-based IPsec tunnels between the L2 VPN server and L2 VPN client. The IPsec VPN Phase 2 encapsulation mode is configured to tunnel mode, which encrypts the entire original IP packet including the header. When configuring IPsec between two sites, the two VPN endpoints must be set up with matching attributes, and L2 VPN Client sessions require configuration of a remote IP address for the IPsec tunnel along with a peer code generated from the L2 VPN Server service. For L2 VPN, the FIPS compliance suite applies pre-configured cryptographic parameters with Perfect Forward Secrecy enabled.

VCF provides flexible PKI options for certificate management underpinning these encrypted sessions. Certificate options range from fully automated issuance within VCF to integration with enterprise PKI infrastructure using Certificate Signing Requests (CSRs) or direct certificate uploads. The vCenter certificate management API allows programmatic generation of CSRs and replacement of TLS certificates. VCF Operations certificate management supports replacing default certificates with enterprise CA certificates, CA configuration, and CSR generation, with auto-renewal available for VMCA, MSCA, and OpenSSL CA. The Fleet Management interface provides a centralized Certificates screen for renewing, importing, replacing certificates, or activating auto-renewal. VCF Operations also monitors the status and expiration of Platform, Root, STS, and TLS certificates. Before using the Microsoft Certificate Authority with a pre-configured template, it is recommended to configure least privilege access to Microsoft Active Directory Certificate Services using a restricted service account.

Encrypted vSphere vMotion protects VM migration traffic. For virtual machines that are not encrypted, encrypted vMotion can be set to Disabled, Opportunistic (use encryption when supported, the default), or Required (do not migrate if encryption is unsupported). vSphere vMotion always attempts to use encryption when migrating encrypted virtual machines. Encrypted vMotion can migrate either encrypted or unencrypted virtual machines within a disk cluster or between disk clusters using Storage vMotion.

VMware Private AI Services (PAIS) on VCF provides cryptographic protections across its AI service endpoints, VMware Kubernetes Service (VKS) clusters, and Deep Learning VM access channels.

PAIS instances expose their APIs over TLS using a self-signed certificate whose CA certificate is stored in the `pais-ingress-default` Kubernetes Secret in the PAIS namespace. Clients retrieve this certificate using `kubectl get secrets/pais-ingress-default -o yaml` and configure it before connecting. The PAISConfiguration custom resource supports configurable CA bundle references through the `spec.clientTls.caBundleRefs` field, allowing operators to pin trust anchors for OIDC provider and Harbor registry authentication, with separate trust bundles recommended per application and periodic refresh required before certificate expiration. The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication, and the PAIS Prometheus observability endpoint uses self-signed certificate authentication with TLS sourced from the same `pais-ingress-default` Secret.

When connecting remote MCP servers to PAIS over HTTPS, PAIS requires that the issuer certificate be added as a CA trust bundle, restricting connections to endpoints with verified certificates. Remote MCP servers may optionally present static authentication tokens. PAIS also uses CA trust bundles for secure connections to external services and to the pgvector database server provided by VMware Data Services Manager (DSM).

VKS clusters provisioned by PAIS use the FIPS-compliant cluster topology version `v1.33.1-vmware.1-fips-vkr.2`, which engages FIPS-validated cryptographic modules for control plane and worker communications. This requirement applies to both connected and disconnected PAIS deployments.

Deep Learning VMs and Triton Inference Server workloads support SSH public key authentication. Keys can be supplied during VM deployment through the `public-keys` OVF property, which populates the default user's `~/.ssh/authorized_keys` file and removes reliance on password-based access for remote VM login. The VCF Consumption CLI used to manage PAIS namespaces authenticates to VCF Automation endpoints using an API token, FQDN, and an optional CA certificate for TLS verification. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and linked data sources over the same TLS-protected endpoints.

Platform-level network encryption for remote access, including VPN and segment-level encryption, is provided by the underlying VCF platform. See VCF Coverage for those capabilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) applies cryptographic protection to the channels through which it manages paired sites and moves data between them. PNR uses TLS certificates and private keys to protect network communication and to authenticate with peer servers. The Protection and Recovery Appliance terminates TLS through an envoy proxy, and the minimum TLS protocol version is configurable by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file. Replication of virtual machine data between sites supports optional network-level encryption, and PNR can protect and recover virtual machines that are themselves encrypted, applying that protection through both array-based protection groups and vSphere Replication protection groups.

Authentication to vCenter and to remote PNR sites is brokered through VCF SSO. PNR acquires a holder-of-key SAML token from VCF SSO and presents it in cryptographically signed requests to remote services. The Configure Remote Site workflow imports certificates of the remote vCenter to establish trust for the cross-site connection, and the appliance prompts for VCF SSO credentials when an operator initiates operations that affect both sites.

PNR does not provide the network-layer VPN that connects paired sites. The product documentation requires that the connection between the local and remote sites of a Protection and Recovery pair be private, such as a VPN provisioned outside PNR. For isolated recovery environments used during cyber recovery operations, VMware recommends that workload user access be performed through VPN or a Remote Desktop Client rather than direct public internet exposure of recovered services.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.14

> Route remote access via managed access control points.

SCF Controls: NET-14.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF, through its NSX networking component, provides managed network access control points via Edge gateways, IPsec VPN, Layer 2 VPN, and Virtual Private Cloud (VPC) capabilities that concentrate remote access through defined, centrally administered entry points.

NSX Edge gateways are the managed access control points for north-south traffic entering and leaving VCF workload domains. All external traffic traverses these gateways, where administrators can apply vDefend rules, Network Address Translation (NAT), and routing policies. The vDefend gateway firewall supports Layer 3 and Layer 4 rules and can be configured to allow specific services such as HTTPS, DNS, NTP, and ICMP. When an NSX project is created, the system automatically establishes default vDefend and Distributed Firewall rules governing the behavior of north-south and east-west traffic for workloads in that project. This architecture routes remote access to VCF-hosted workloads through defined control points rather than allowing arbitrary connectivity.

For site-to-site remote connectivity, NSX provides IPsec VPN services configurable on both Tier-0 and Tier-1 gateways. VPN services operate in tunnel mode, with endpoints explicitly configured with matching security attributes, remote IP addresses, and designated subnets for which traffic is tunneled. Two session types are available: policy-based IPsec VPN defines specific traffic selectors, while route-based IPsec VPN supports traffic routing via static routes or routes learned dynamically over a virtual tunnel interface (VTI) using BGP. Both types support pre-shared key and certificate-based authentication. Within NSX projects, each Tier-1 gateway supports one IPsec service with static routes for route-based VPN; dynamic routing with BGP over VTI is not supported on project Tier-1 gateways.

NSX supports predefined security compliance suites for IPsec VPN sessions. When a compliance suite is selected, the authentication mode is automatically set to certificate-based, and the IKE profile and IPsec profile are locked to system-defined values for the selected suite. These suites configure the IKE version, encryption algorithm, digest algorithm, and Diffie-Hellman group, preventing misconfiguration of VPN tunnel parameters and enforcing consistent cryptographic settings across VPN connections.

NSX also supports Layer 2 VPN, which secures connections using route-based IPsec tunnels between L2 VPN server and client components. L2 VPN sessions are bound to specific Tier-0 or Tier-1 gateways, and both intra-project and cross-project VPN tunnels can be configured within an NSX deployment. VPN endpoint configuration requires explicit specification of the subnets behind each endpoint, restricting which network segments are reachable through the tunnel and providing granular control over what remote users can access.

NSX Virtual Private Clouds (VPCs) provide additional access control by creating self-contained network environments with their own permission models, topology, and IP address management. Each VPC subnet can be configured with an access mode of Public (allowing traffic to and from external networks), Private (allowing outbound traffic but blocking inbound external traffic), or Private Transit Gateway (allowing access between private subnets within the same NSX project via a transit gateway). Centralized connection configurations at the VPC boundary provide access to NSX networking services including NAT and VPN, and to vDefend when deployed, giving administrators control over the directionality and scope of network access for each VPC segment.

VCF management components follow a pattern of restricted remote access. Management interfaces for vCenter, VCF Operations, and ESX hosts reside on separate management networks, with vSphere Distributed Switches providing centralized, consistent network policy enforcement across all hosts. SSH access is disabled by default on VCF Operations Cloud Proxy, requiring initial access through the vCenter console before remote management is configured. ESX hosts provide controllable SSH services (TSM-SSH) that can be started and stopped as needed, limiting remote administrative access to periods when it is required. ESX hosts also support Lockdown Mode, which routes host management operations

through vCenter as a centralized access control point; in Normal Lockdown Mode, DCUI, ESX Shell, and SSH access is restricted to administrator-privileged Exception Users configured via the DCUI. Access advanced system setting, while Strict Lockdown Mode disallows all direct host access entirely. ESX Shell and SSH services operate independently of Lockdown Mode and must be separately deactivated, since Lockdown Mode itself does not restrict those services.

To fully satisfy this control, the organization must establish policies and network architecture that route all remote access through these managed VPN and gateway services. VCF provides the technical mechanisms for managed access control points, but enforcement that no remote access bypasses these control points requires network design decisions, perimeter controls, and operational procedures that fall outside the platform itself.

VMware vDefend (Contributes)

VMware vDefend (vDefend) Gateway Firewall provides stateful north-south traffic inspection at NSX Edge gateways, which are the managed access control points for traffic entering and leaving VCF workload domains. All external traffic traversing these gateways is subject to Gateway Firewall rules, enabling administrators to enforce security policies on remote access traffic at the network boundary before it reaches internal workloads.

For environments using NSX Virtual Private Clouds (VPCs), the VPC Security Profile provides centralized Gateway Firewall policy management for both north-south and east-west traffic flows. The Gateway Firewall can be activated for VPCs through the NSX UI or NSX API, and the North-South activation setting controls whether gateway rules are enforced. The NSX API VPC Security Profile response includes distinct `north_south_firewall` and `east_west_firewall` configuration objects, giving administrators fine-grained control over which traffic flows pass through the gateway access control points and how policy is applied.

In multi-tenant environments, the Transit Gateway Firewall provides centralized control and policy consistency across VPCs within an NSX Project. Project Admins can manage gateway firewalls for their own dedicated VPCs; the Transit Gateway Firewall handles cross-VPC and north-south enforcement from a centralized control plane. This architecture channels remote access traffic through a defined set of managed control points rather than permitting direct access to workload networks. VPCs must always be instantiated within an NSX Project, which means the gateway firewall coverage point is structural to the deployment model.

The VPN termination, IPSec configuration, and routing infrastructure that directs remote access traffic to these control points are NSX platform capabilities. vDefend's contribution is the security inspection and policy enforcement applied at those control points once traffic arrives.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.15

> Authorize remote execution of privileged commands and remote access to security-relevant information.

SCF Controls: NET-14.4

Aggregate Coverage: Contributes

VCF (Contributes)

This control requires restricting execution of privileged commands and access to security-relevant information via remote access to only compelling operational needs. VCF provides several technical capabilities that contribute to meeting this requirement, though organizational policies and procedures are also needed to define what constitutes a "compelling operational need" and to enforce those boundaries.

ESX hosts support the TSM-SSH service, which can be started and stopped to enable or disable SSH access on a per-host basis. This allows administrators to keep SSH disabled during normal operations and enable it only when direct host-level access is required for troubleshooting or maintenance. ESX hosts also support configuration of users who can override lockdown mode and access the Direct Console User Interface (DCUI) through the DCUI.Access setting, restricting which accounts can perform privileged operations at the host level. Advanced options on ESX hosts include shell timeout and DCUI timeout settings, which automatically terminate idle remote sessions after a configured period, reducing the window during which privileged commands can be executed remotely. ESX Lockdown Mode restricts access to the DCUI, ESX Shell, and SSH to users listed as Exception Users with administrator privileges on the host; strict lockdown mode takes this further by disallowing all direct host access and requiring all operations to proceed through vCenter. The ESX Shell and SSH services operate independently of lockdown mode and must be separately deactivated, since lockdown mode itself does not restrict those services. Access to the ESX host management interface requires login as a user with the Administrator role, gating remote host-level operations behind explicit privilege assignment.

VCF enforces privilege requirements on system objects regardless of how a client application accesses server content, whether through the vSphere Client, command-line interface, SDK, or PowerCLI. The same role-based access restrictions apply to remote API calls, scripted sessions, and graphical client connections. The AuthorizationManager controls access to specific server objects based on the permissions associated with those objects, providing a consistent authorization boundary across all remote access methods. The vCenter authorization model applies consistent security control regardless of operational context, so remote sessions are subject to the same privilege checks as local ones.

vCenter implements role-based access control that supports creation of custom roles with granular privilege assignment and permission propagation across the vSphere object hierarchy. This enables administrators to define narrowly scoped roles that grant only the specific privileged commands needed for a given operational function. Privileges are fine-grained access controls that can be grouped into roles, which are then mapped to users or groups. Specific privileged operations are gated by dedicated privilege sets. For example, only users assigned the Cryptographic Operations privileges can perform cryptographic operations, restricting sensitive key management and encryption tasks to authorized personnel regardless of their access method. This pattern of privilege-gated operations extends across the platform, allowing organizations to limit which remote users can execute specific categories of privileged commands.

VCF Operations implements role-based access control where users can only perform the actions their assigned permissions allow. VCF Operations enforces privilege-based access control that restricts users without appropriate privileges from viewing collected data for managed objects. Sensitive information within VCF Operations orchestrator plug-ins is not accessible through scripting properties and methods; instead, it can be stored in orchestrator configuration elements or external password vaults, limiting exposure of security-relevant data during remote automation workflows. VCF Operations Orchestrator also supports SecureString type input parameters for sensitive data such as passwords in day 2 operation request forms.

VCF Operations Cloud Proxy has SSH access disabled by default, requiring the first login to be performed via the vCenter console. This default-off approach for remote access to infrastructure management components reduces the remote attack surface and restricts remote privileged access to cases where it has been explicitly enabled. vCenter can also enable or disable

access to VM consoles via the VNC protocol through the `RemoteDisplay.vnc.enabled` setting, providing control over remote console access to virtual machines.

NSX Manager implements RBAC to restrict system access to authorized users by assigning roles with specific permissions. NSX audit logging records API access details and cannot be disabled, providing a persistent record of remote privileged operations performed through the NSX management plane. VCF CLI enforces permission-based access control, returning a Forbidden error when users attempt operations without the required permissions.

Audit logging supports monitoring of remote privileged activity across the platform. Privilege checks can be filtered and retrieved by managed object IDs, request operation IDs, principals, privileges checked, and session identifiers, allowing administrators to review which privileged operations were performed remotely and by whom. The Privilege Recorder REST API exposes this capability, allowing targeted query of privilege check records by session, user, managed object, and operation. VCF Operations audit logging can filter data according to User ID, User Name, Auth Source, Session, Client IP, Category, and Message, enabling targeted review of remote administrative actions.

Management traffic isolation is a recommended practice within VCF deployments. The Fleet Level Components on Dedicated Management Network Model provides isolation from other networks and can be used to have separate security for the fleet level management network while using a VLAN-backed distributed port group. Management networks should be placed on dedicated VLANs accessible only to administrators, and vMotion traffic should be separated on non-routable networks. These network-level controls limit the paths through which remote privileged access can occur.

Full restriction of privileged remote commands to compelling operational needs requires organizational policies and processes that define when remote privileged access is justified, which roles are authorized for remote privileged operations, and how remote sessions are reviewed. VCF provides the RBAC, session controls, default-off remote access posture, auditing, and network isolation capabilities that support enforcement of those policies.

VMware Private AI Services (PAIS) provides several access control mechanisms that restrict remote access to AI infrastructure components and AI-specific sensitive data.

PAIS access is controlled through OIDC group-based authorization. The `authorizedGroups` configuration restricts access to PAIS endpoints to user accounts that are members of explicitly named groups on the OIDC provider, such as `group-for-pais-access-01`. Administrators configure group membership in the organization's OIDC identity provider before activating PAIS in a namespace, scoping remote access to the AI service layer to a defined set of authorized identities. The same OIDC authorized-groups model applies whether PAIS is activated through the `kubectl` command or through the VCF Automation user interface.

Deep Learning VM (DL VM) deployments through VCF Automation require user password configuration and support optional SSH public key authentication for remote management sessions on standalone DL VMs and Triton Inference Server VMs. Cloud-init configuration applies restricted file permissions on DL VM bootstrap material, including 0600 on network configuration files. PAIS model endpoints support authentication through `harbor-pull-secret-readonly` to control access to container images stored in private Harbor registries, and the `oras login` command uses username and password credentials for registry push operations. Knowledge Base data sources that draw on external systems use scoped credentials: Amazon S3-compatible stores rely on access keys with list and read permissions on the configured bucket, and SharePoint On-Premises sources use user name and password authentication. Remote MCP servers connected to PAIS can optionally use static authentication tokens to restrict access to the tool surface exposed to PAIS agents.

DL VMs expose DCGM Exporter GPU metrics on public network interfaces by default. Operators can restrict the exposure to localhost only by setting the `export_dcgmm_to_public` property to `false` in the VM configuration, after which the metrics endpoint is reachable solely at `127.0.0.1:9400`.

VCF Automation API access for PAIS uses Bearer-token authentication on the `cloudapi sessions` endpoint, and provider administrators manage API tokens through the Provider Management UI under `My Account > API Token`. The VCF Consumption CLI authenticates to VCF Automation endpoints using an API token, FQDN or IP address, and an optional CA certificate for TLS verification. VCF Automation enforces catalog item permissions that require DevOps engineers to obtain

authorization from an organization administrator before they can provision GPU-accelerated VMware Kubernetes Service (VKS) clusters or AI workloads, applying a permission gate to privileged provisioning operations. Secrets such as the private container registry password are managed through Administer > Certificates & Secrets > Secrets in VCF Automation. The VCF Automation VimServer connection to VMware vCenter requires vCenter administrator credentials and must be enabled for supervisor discovery, and initial access to PAIS requires authentication to the management-domain vCenter as administrator@vsphere.local.

Privileged command execution at the infrastructure layer, including vCenter, VMware ESX, and Supervisor operations, is governed by the underlying VCF platform and VCF SSO rather than by PAIS. Organizational policies must establish what constitutes a compelling operational need and align role assignments and group membership accordingly to meet the full intent of this control.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to restricting privileged command execution via remote access by enabling microsegmentation policies through the Distributed Firewall (DFW) and Gateway Firewall, controlling which remote sources can reach management interfaces and application servers. Administrators can enforce least-privilege network access rules that limit remote connectivity to only those systems and users with a compelling operational need.

Role-based access control (RBAC) within the Security Services Platform governs access to administrative functions. The Security Services Platform requires Admin privileges to access User Management and modify role assignments. Named roles carry defined and differentiated permissions: the Security Engineer role holds full access to export flows, infrastructure and application monitoring operations, Security Intelligence data collection configuration, and traffic flow visualization; the Security Operator role holds restricted permissions for the same categories. Role assignments can be scoped to individual remote users or remote user groups through the System > User Management interface.

Identity Firewall (IDFW) rules scope network-layer access by user group membership, limiting connectivity to remote users whose Active Directory group membership matches the rule criteria. In Remote Desktop Session Host (RDSH) environments, administrators create Active Directory security groups and apply DFW rules to allow or deny access to application servers based on assigned role, enforcing role-based network access control for remote desktop scenarios.

Privileged labels in the DFW provide a tamper-proof mechanism for anchoring firewall rules to immutable labels, restricting virtual machines from moving out of security groups and maintaining the integrity of least-privilege access policies.

SSH access to the Malware Prevention Service VM is disabled by default and must be explicitly activated by a VMware vCenter (vCenter) administrator for each host in ESX host clusters activated for Distributed Malware Prevention service. When activated, SSH uses key-based authentication with a public-private key pair, requiring a public key at deployment time and a private key to initiate sessions. After troubleshooting tasks complete, the vCenter administrator should deactivate SSH access to the VM.

Distributed IDS/IPS CLI commands run on ESX hosts, and the viewable modes and available commands differ based on the assigned role and rights of the user, applying RBAC to diagnostic CLI access paths.

Controlling what privileged commands users may execute once a permitted session is established, and enforcing session recording or privileged access management workflows, remain outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms that restrict remote privileged access and access to security-relevant information at both the Controller (management plane) and Service Engine (data plane) layers.

For Controller access, Avi supports SSH-based remote administration with role differentiation between standard users and Super User privilege holders. Non-admin users can access the Linux CLI via SSH with restricted permissions, while the Super User privilege is required to launch a full CLI shell directly on the Controller.

Access to Service Engine shells is the most sensitive remote access path in an Avi deployment and is controlled through a dedicated secure tunnel mechanism. Direct SSH admin access to Service Engines can be disabled entirely by setting

admin_ssh_enabled to false via the Avi Controller CLI. When remote Service Engine shell access is operationally necessary, Super User privilege holders can access a Service Engine shell using the attach serviceengine command after SSH authentication to the Controller.

Avi Controller's Extended Granular RBAC scopes administrative authority to specific resources using label-based markers and distinct permission categories. The restrict_cloud_read_access field in controller properties controls whether users can read cloud objects outside their permitted scope. The allow_unlabelled_access parameter in role objects controls whether a role can act on unlabeled objects, and WRITE_ACCESS permissions on Service Engine Groups can be restricted to specific datacenters and management networks. At the object level, write access to security-relevant objects such as SSL/TLS certificates, certificate management profiles, virtual services, and application profiles can be granted independently, supporting a least-privilege model for access to sensitive configuration data.

For Kubernetes deployments, Avi Kubernetes Operator (AKO) Custom Resource Definitions can be further protected using Kubernetes Role-based access control (RBAC) policies to restrict access to specific groups of users, giving operators fine-grained control over who can modify load balancing routing rules and related configuration.

Organizations should define what constitutes a compelling operational need for remote privileged access and establish governance processes to enforce and review that threshold. Avi provides the technical mechanisms for restricting and channeling privileged remote access, but the determination of when such access is authorized requires organizational policy decisions that extend beyond the platform's access controls.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.16

> Authorize wireless access prior to allowing such connections.

SCF Controls: NET-15

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.17

> Protect wireless access using authentication and encryption. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

----- CHAPTER THREE PAGE 15 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: NET-15.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.18

> Control connection of mobile devices.

SCF Controls: MDM-01, MDM-02, MDM-06, MDM-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend's Distributed Firewall, Gateway Firewall, and Identity Firewall provide network-layer access control mechanisms that can restrict which organizational resources mobile device traffic is permitted to reach within the VCF environment. The Distributed Firewall enforces microsegmentation policy at Layer 2 through Layer 7, including application identity and FQDN-based filtering that can limit mobile device access by destination hostname or domain. URL filtering adds a further access control layer based on URL categories, URL reputation, and custom URL lists, which can restrict the web destinations reachable by mobile device traffic. The Identity Firewall extends network-layer enforcement by enabling identity-based access control: firewall rules are tied to Active Directory user and group membership, so policies follow the user rather than the device IP address. Identity Firewall rules can be created with Active Directory group members as the source and applied to physical devices where users log in, allowing the same user-group policies to govern workstation and mobile-device sessions. Context-aware rules can, for example, block specific protocols for designated user groups. The Gateway Firewall provides north-south access control and can enforce isolation between project boundaries, denying inter-project communication except for designated infrastructure traffic. VMware vDefend does not provide full MDM policy enforcement such as device configuration management or compliance posture assessment, but it contributes a network-layer control boundary for mobile device access.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.19

> Encrypt CUI on mobile devices and mobile computing platforms.23

SCF Controls: MDM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.20

> Verify and control/limit connections to and use of external systems.

SCF Controls: DCH-13, DCH-13.1, DCH-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered set of authorization, access control, and tenant isolation mechanisms that help organizations restrict how external parties interact with data within the environment. While VCF does not itself manage processing agreements or perform external security assessments, its technical controls enforce the boundaries that such governance processes define.

VCF's authorization model is built on the principle that every principal must be authenticated and authorized before accessing any object or performing any operation. VCF SSO provides centralized, token-based authentication for all management interfaces. Identity federation through OIDC-compliant external identity providers (such as Okta or AD FS) allows organizations to extend their existing authentication policies to VCF access. The Authorization Code grant type is supported and is compatible with multi-factor authentication, while the Password grant type is flagged as something to avoid for third-party application authentication. The VCF Identity Broker provides a centralized authentication source for VCF components, and VCF Operations supports VCF SSO integration for centralized management of federated access through unified identity configuration. At the per-host level, the VMware Host Client supports a configurable login banner that can display an access restriction warning and require explicit user acceptance of terms of use before authentication is permitted, providing a mechanism for communicating authorized use boundaries to anyone accessing VMware ESX hosts directly.

The VMware vCenter AuthorizationManager controls access to server objects based on the permissions associated with each object, allowing administrators to grant, modify, and revoke permissions by associating privileges with specific users or groups. Authenticated users can only view objects or invoke operations on the server that match the permissions assigned to their account. The vCenter authorization model provides consistent security control regardless of operational context, meaning that whether access originates from an internal or external party, the same permission checks apply.

Role-based access control (RBAC) is enforced across VCF components including vCenter, NSX, ESX, and VCF Operations. In VCF Operations, each user must have a unique account with one or more roles assigned, and users can only perform actions that their permissions allow. In VCF Automation, organization-level access controls restrict which users and organizations can interact with specific entity types, and organization users can use only those rights from their roles that are published to their organizations. VCF Automation defined entity access control supports granular permissions through View (read-only), Edit (create and modify), and Full Control (create, view, modify, and delete) rights that can be assigned to user roles. The Avi Load Balancer similarly determines user authorization based on the combination of roles and tenants assigned to the account. User criteria can be configured to prevent specific users from accessing particular projects or catalog items.

For multi-tenant environments, VCF Automation organizations provide infrastructure isolation, quotas, and chargeback capabilities. NSX multi-tenancy enables project-level isolation of networking configurations, restricting each tenant's visibility to only their own objects. These controls allow administrators to technically restrict external parties from storing, processing, or transmitting data within VCF until access has been explicitly granted.

For third-party integrations, VCF enforces credential and role requirements at the point of access. A user adding third-party data sources in VCF Operations for Networks must provide appropriate device credentials and hold a specific role such as Network Operator. VCF Operations Orchestrator allows organization administrators to manage authorizations for users interacting with orchestrator capabilities, and the orchestrator can import TLS certificates from external systems to establish secure connections. Organization administrators can manage and revoke API tokens issued to tenant users, providing direct control over programmatic access granted to external parties.

Data isolation is enforced at multiple levels. The ESX Agent Manager restricts solutions so they can only access data about ESX agencies they themselves create, preventing one solution from accessing another solution's data on the same host. Encryption privilege separation further restricts sensitive operations: only administrators with explicit encryption privileges can

perform encryption and decryption tasks on vSAN data-at-rest encryption, limiting who can handle protected data regardless of their other administrative roles.

Verifying that external parties have implemented required security controls (part 1 of this control) and retaining processing agreements (part 2) are organizational governance activities outside VCF's scope. Organizations must establish their own verification procedures and agreement management processes, using VCF's technical controls to enforce the access decisions those processes produce.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides several mechanisms that contribute to governing how external parties and technology assets, applications, and services (TAAS) are used to store, process, and transmit data.

The vDefend distributed firewall (DFW) and Gateway Firewall (GFW) enforce network-level policies governing which external parties and external services are permitted to communicate with internal systems, restricting unauthorized data flows to and from external TAAS and third-party services.

Security Services Platform (SSP) maintains a centralized inventory of current organizational IT assets, including servers, software, and network devices along with their configurations. SSP classifies assets into infrastructure assets, regions, zones, environments, and applications, and identifies whether application assets are critical or regular. This classification gives administrators the context needed to define appropriate network-level controls on external data flows. Platform Inventory monitors asset operational state, collects VM tags with their scopes for asset tracking, and organizes assets by region and zone.

SSP manages certificate infrastructure for external connectivity. Web proxy certificates identify the proxy servers used to connect securely to external services. CA bundles establish trust for communicating with external services, including the Malware Prevention Service when enabled. SSP rejects certificates or configurations using deprecated cryptographic algorithms or weak key lengths for external connections. License Hub also supports importing CA bundles to establish trust for communicating with external services.

The Security Segmentation workflow in SSP identifies risky application protocols that transmit data in cleartext and recommends restricting or blocking them as part of segmentation policy. Administrators can review segmentation analysis, classify application assets as critical or regular, and publish environment rules, inventory assets, and policies to enforce controls on external data flows.

vDefend TLS Inspection supports External TLS Decryption for traffic destined to external services the enterprise does not own, making decrypted traffic available for IDS/IPS, Malware Prevention, and URL Filtering inspection.

vDefend does not directly govern contractual or legal obligations with external parties, but it enforces the network-layer technical controls that reflect those obligations.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.21

> Limit use of portable storage devices on external systems.

SCF Controls: DCH-13.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AC.L2-3.1.22

> Control CUI posted or processed on publicly accessible systems.

SCF Controls: CLD-01, CLD-02, CLD-06, CLD-10, DCH-15, HRS-01, HRS-05, HRS-05.1, HRS-05.2, WEB-01, WEB-02, WEB-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cloud management controls that address security, compliance, and operational governance for cloud instances across private and hybrid cloud environments.

VCF Automation delivers policy-based governance for provisioning and scaling a multi-tenant private cloud. Administrators define infrastructure-as-a-service offerings while maintaining control through policies that govern what resources can be deployed, where they can be deployed, and under what conditions. Cloud accounts in VCF Automation are the configured permissions that the platform uses to collect data from regions or data centers and to deploy cloud templates to those regions, establishing a permissions-based model for all cloud operations. Approval policies provide governance control over deployment and day 2 action requests, requiring designated approvers before deployments are provisioned from specific cloud templates. Approval policies can be scoped to the organization level. Resource quota policies cap resource consumption at the project level by specifying scope-level limits for each resource, and cloud zone limits reject deployments that would exceed configured thresholds. When provisioning machines, sensitive parts of the cloud configuration support encryption using a secret versioning scheme, restricting exposure of credentials and other sensitive data during deployment. Passwords in cloud config scripts can be marked as sensitive and encrypted, and input properties in cloud templates can include an encrypted flag to keep passwords encrypted in deployment request details. VCF Automation Kubernetes Management extends this governance to containerized workloads by supporting security policies that can be assigned to clusters and enforced across the organization.

The VMware Cloud services platform manages common requirements for all cloud services, including authentication and user roles. This centralized identity and access management layer applies consistent security policies across cloud service consumption. Role-based access control is available across VCF components. NSX implements RBAC to restrict management access by assigning roles with specific permissions across networking, inventory, and system management domains, and supports custom role creation. VCF Operations provides its own RBAC model with configurable roles and permissions for monitoring and management functions. Cloud administrators can assign tags to existing security groups and incorporate those groups into cloud templates, enabling standardized network security controls across deployments. For NSX-based environments, administrators can add existing security groups or define new ones directly within cloud template design, embedding network security into the provisioning workflow. On-demand security groups are supported for NSX when used with the NSX policy manager.

The Consumption layer of VCF, comprising VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these cloud management controls to containerized workloads. VKS provisions workload clusters that are secure by default, drawing on vSphere security features built into VMware vCenter and VMware ESX to establish a security baseline before application workloads are deployed. Kubernetes RBAC uses Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to scope permissions within and across namespaces, providing fine-grained access control at the Kubernetes API level. Namespace isolation provides boundary enforcement between tenants, with resource quotas and limit ranges constraining what each namespace can consume. Pod security is governed through Kubernetes Pod Security Admission, which supports Baseline, Restricted, and Privileged profiles configurable with audit, warn, and enforce modes, allowing organizations to block known attack vectors at the platform level while auditing and warning on more restrictive policies. VCF provides unified management of VMs, Kubernetes clusters, and other resources through a single, consistent API, supporting centralized governance and configuration of cloud instances across the environment.

VCF Operations includes a security and compliance capability that measures infrastructure configurations against built-in benchmarks, including the VCF Security Baseline and the DISA STIG. Compliance scanning detects violations, highlights risk areas, and provides remediation recommendations. Organizations can also create and import custom benchmarks to evaluate

configurations against their own security standards. The VCF Operations security dashboard surfaces security posture information in a single view.

VCF Operations monitors the health, performance, and capacity risks of connected cloud environments through integration with VCF Automation, giving administrators visibility into the operational posture of deployed cloud instances. VCF Operations includes integrations with multiple cloud providers by default, enabling consistent monitoring and management across hybrid environments. Configuration change tracking identifies settings that have changed from their baseline through drift detection, and each change is traced to the authenticated user who initiated it with a timestamp. Audit events capture platform interactions including user logins, capability checks, and configuration modifications across vSphere, vSAN, and NSX resources. Kubernetes audit logging within VKS, with configurable audit policy and webhook or log backends, captures Kubernetes API server activity to support accountability and review of cluster operations. VKS supports integration with Wiz, which provides cloud security posture management and cloud workload protection capabilities for continuous security monitoring of deployed Kubernetes workloads, including identification of security risks and compliance deviations.

All VCF components support syslog forwarding to external SIEM systems for centralized security monitoring and log retention. VCF Operations supports syslog configuration including enabling, disabling, adding, editing, and deleting syslog servers, with the ability to map syslog servers to platforms, alerts, or collectors. VCF Log Management includes pre-built content packs with dashboards and alerts for VCF components. ESX hosts generate audit logs capturing authentication attempts, configuration changes, and administrative actions at the hypervisor level.

VCF Operations provides a unified, non-disruptive TLS certificate management system for centralized control of certificates across all components in the VCF private cloud. Certificate lifecycle management and rotation are handled through the same interface, which exposes REST APIs for managing trusted certificates. VCF Encryption Management allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks in the VCF environment, giving organizations control over the encryption of their cloud workloads.

VCF Automation's All Apps organizations offer application teams a set of built-in cloud services to provision VMs, Kubernetes, networking, volumes, Secret Store, databases, container registries, external DNS, certificates, and AI workloads. These services can be consumed on a self-service basis through a curated catalog, with governance policies enforcing security and compliance requirements on every provisioned resource. Organizations in VCF Automation support policy-based governance on usage of resources. The Secret Store service enforces role-based access control for administrators, DevOps engineers, and application tenants when managing and distributing sensitive data across the platform. The Argo CD Supervisor Service manages application secrets securely outside of Git and enforces access controls across all CI/CD pipeline components. The vSphere Supervisor VM Service enables virtual machines to securely access secrets through a disk-based sidecar injection mechanism that keeps credentials out of the VM image. Kubernetes Secrets within VKS clusters are protected by etcd encryption at rest.

A PowerShell CloudServices module provides cmdlets for programmatic VMware Cloud Services management, supporting automation of cloud governance tasks. VCF PowerCLI version 12.4.0 and later also provides low-level cmdlets for all available VCF API services through the vSphere Automation SDK for PowerShell.

For organizations using ServiceNow, VCF Operations integrates through a management pack that creates ServiceNow incidents, alerts, or events and associates them with their Configuration Item in the CMDB. VCF Automation also provides a ServiceNow ITSM plug-in supporting approval workflows, support ticket creation, and deployment tracking within ServiceNow.

VMware vDefend (Contributes)

VMware vDefend (vDefend) provides network security controls that contribute to securing cloud instances in line with industry practices. While cloud management spans compute governance, identity management, compliance scanning, and operational monitoring, vDefend addresses the network security dimension through multiple integrated capabilities.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level across all workloads running on VCF. Security policies follow workloads regardless of network location, enabling zero-trust segmentation that limits lateral movement between cloud instances. Administrators define firewall rules using security groups, tags, and dynamic

membership criteria, allowing policy to adapt automatically as workloads are provisioned or relocated. Privileged Labels provide a tamper-proof mechanism that anchors firewall rules to immutable labels, preventing virtual machines from leaking out of their assigned security groups. Identity Firewall can be enabled on compute clusters to extend policy enforcement to Active Directory user and group identity, enabling security rules that follow users across workloads. The Gateway Firewall extends protection to north-south traffic at Virtual Private Cloud (VPC) boundaries, and Pre-defined Security Strategies allow administrators to define a baseline security posture for VPCs to establish consistent protection policies.

vDefend integrates with VCF Automation to allow organizations to define and enforce security postures for workloads within self-service private cloud environments. Groups in vDefend map cloud constructs from VCF Automation into the underlying vDefend infrastructure, enabling policy recognition and enforcement on VPCs, Groups, and virtual machines within namespaces. This integration maintains consistent security postures as workloads are provisioned through automation workflows.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention for cloud workloads. Organizations can import custom signatures or integrate with third-party threat feeds, including industry-specific Information Sharing and Analysis Centers (ISACs). Virtual patching capabilities allow deployment of protective signatures before vendor patches are available, reducing the exposure window for cloud instances. In federated deployments, a Global Manager provides centralized management for blocking malicious traffic across all connected Local Manager sites, maintaining and propagating untrustworthy IP address lists based on historical behavior patterns.

Malware Prevention through Advanced Threat Prevention (ATP) inspects files traversing east-west and north-south network paths. Malware Prevention profiles can be configured to send files to the VMware vDefend ATP Cloud Service for cloud-based analysis, or to process files locally without cloud analysis, without requiring agents on individual instances. Security policies can be defined, propagated, and enforced across Bare Metal servers through Security Services Platform, extending consistent enforcement across physical infrastructure.

Security Services Platform (SSP) is a modern microservices platform that hosts features that collect, ingest, and correlate network traffic data. SSP includes Security Intelligence, which allows administrators to accept or modify inferred classifications of compute entities as network infrastructure or non-infrastructure services, supporting accurate security policy planning. SSP maintains a centralized repository of current organizational IT assets, including servers, software, and network devices with their configurations, providing an authoritative inventory for policy planning purposes. Network Detection and Response (NDR) provides behavioral analysis and anomaly detection across east-west traffic flows, identifying threats that signature-based detection may miss. NDR data sharing to the vDefend ATP Cloud Service is activated by default and can be configured through System > Privacy, allowing organizations to control whether data is shared to the cloud where data residency requirements apply. SSP has high availability capabilities by default and supports scaling out individual services, including Analytics, Data Storage, Messaging, and Metrics, through System > Platform & Features > Core Services.

Together, these capabilities address the network security requirements within a broader cloud management control framework, providing workload-level enforcement, threat detection, and traffic visibility for cloud instances.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides access segmentation mechanisms for multi-tenant disaster recovery environments, particularly in shared recovery site configurations where multiple organizations or business units recover workloads to a common site.

In 9.1, the PNR service controller is designed to translate user intent into orchestrated calls across protection components while managing multi-tenant isolation as an explicit architectural function.

In a shared recovery site deployment, the VMware vCenter administrator manages permissions so that each user has sufficient privileges to configure and operate PNR for their own protected site while restricting access to resources belonging to other users. PNR includes a Multi-Tenancy Considerations and Configuration section documenting how administrators should scope permissions across deployments. Each user is assigned a separate virtual machine folder in the vCenter inventory on the shared recovery site, with permissions configured to prevent any other user from placing virtual machines in it. Dedicated resource pools, datastores, and networks are assigned to each user, and permissions are configured consistently with those

on folders. Permission propagation on the root folder, data centers, and hosts is restricted to prevent unintended access across different organizations' resources.

For environments with multiple PNR deployments on a single vCenter, administrators must configure different automatic protection accounts per PNR instance and assign permissions that split the vCenter inventory to simulate a multi-tenant environment. This approach segments the automated operations performed by each deployment instance. When multiple PNR deployments share the same underlying storage array, the best practice is to create separate user accounts on the storage arrays for each PNR deployment and use different LUNs per server to maintain logical separation.

The vSphere Replication component of PNR provides an additional RBAC layer with granular roles. The VRM Virtual Machine Replication User role can be assigned with propagation to enable users to configure replication between specific sites and access designated datastores on target sites. The VRM Replication Viewer role allows viewing of replication configuration without modification rights. These roles require separate user accounts on each participating site before assignment.

The Cyber Recovery capability within PNR supports physical isolation of recovery environments. The clean room should be configured with dedicated compute resources and isolated networks. PNR supports directing the same protected virtual machine to two different sites, enabling physical separation between a disaster recovery site and a clean room.

Administrators should be aware that the shared recovery site model assumes trust between the vSphere sites, and users cannot be completely isolated from each other even when their individual resources are isolated. If the deployment requires complete separation between all users, a shared recovery site configuration is not suitable and separate PNR deployments with dedicated infrastructure should be used instead.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that contribute to the implementation of cloud management controls for database-as-a-service workloads deployed on VCF.

Data service policies are a central control mechanism in DSM. Administrators define and configure these policies to govern how database clusters are provisioned, what infrastructure resources they may consume, and which organizational standards apply. When integrated with VCF Automation, data service policies can be applied across multiple tenants or organizations, with each tenant or organization required to adhere to its prescribed configurations. Administrators can tailor policies to specific requirements and assign them to one or more organizations, supporting consistent governance across a multi-tenant environment. The DSM UI provides a dedicated interface for configuring policies for each supported database type, including SQL Server in addition to PostgreSQL and MySQL. This policy enforcement model gives platform administrators a mechanism for translating organizational cloud management standards into operational constraints that apply at provisioning time.

Infrastructure policies in DSM control the placement of database VMs within storage and determine which VM classes and datastores are used when database clusters are created. Cloud Administrators configure which infrastructure policies are available within each consumption namespace, restricting database provisioning to resources and configurations that meet organizational standards. This limits how Cloud Users can consume database capacity without requiring explicit administrative approval for each individual deployment.

DSM manages instance certificates for database clusters and establishes TLS connections to both the DSM Provider VM and individual database instances. Administrators can add trusted certificate authorities to the OS trust store to verify connections, and a Cloud Administrator must obtain and save a TLS certificate for secure communication between the Consumption Operator and the DSM provider before enabling self-service consumption. DSM also establishes secure connections to VMware vCenter using certificate validation, providing certificate-based authentication across the management plane.

Database provisioning in DSM is self-service within the bounds set by the Cloud Administrator. Cloud Users deploy database clusters through Kubernetes-native resources in namespaces configured and controlled by the Cloud Administrator. This model delegates provisioning authority to end users while preserving administrative control over the infrastructure and policies available to them. The Consumption Operator, installed and managed by the Cloud Administrator, is the mechanism through which this bounded self-service access is enabled.

Meeting this control fully requires the organization to establish and maintain a cloud management program that defines security standards, monitors compliance posture, and updates policies as requirements evolve. DSM's policy enforcement capabilities support that program for database workloads, but the broader governance activities, including risk assessments, vendor management reviews, and cross-service compliance monitoring, remain organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides enforcement mechanisms at the virtual service level that organizations can use to control access to publicly facing application endpoints. Network security policies applied directly to virtual service VIPs establish the front-end security boundary for any Avi virtual service exposed to the internet, allowing administrators to define which source addresses, protocols, and connection types are permitted through the Service Engine before requests reach backend workloads.

At the HTTP application layer, Avi's HTTP security policies provide rule-based request control. Rules can match on request attributes and enforce blocking actions, such as returning an HTTP 403 response with a custom response body, configured via the `http_security_action_send_response` setting. This allows Avi to block specific classes of traffic at the load-balancer boundary before requests reach application servers. Content rewrite profiles, associated with HTTP(S) virtual services through the `content-rewrite-profile` setting, enable modification of HTML content within request and response bodies, providing an additional mechanism to manage application-layer content delivery.

For globally distributed deployments using Avi's Global Server Load Balancing (GSLB), Avi includes settings to explicitly distinguish public from private service exposure. GSLB Client Groups, configured under Infrastructure > GSLB > Sites, classify clients as public or private to drive routing and access decisions. Client classification is determined solely by these Client Groups. In NAT-aware public-private GSLB configurations, the `private-list` setting designates known private client addresses so that all unlisted addresses are treated as public by default. A separate `publish_vip_to_public_zone` flag in the cloud configuration controls whether a virtual service VIP with a private IP is published into a public DNS zone, providing a discrete toggle for controlling internet-facing DNS exposure of Avi services.

Organizations must define which content or services should be publicly accessible, classify data accordingly, and configure Avi policies to enforce those decisions. Avi provides the technical enforcement layer; content governance policies and configuration management remain organizational responsibilities.

Control AC.L3-3.1.2e

> Organizationally Controlled Assets

SCF Controls: AST-02, DCH-06.2, IAC-08, PES-03

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the `SrmAdministrator` or `SrmProtectionGroupsAdministrator` role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an allowedInfrastructurePolicies list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics

data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control AC.L3-3.1.3e

> Secured Information Transfer

SCF Controls: AST-02.8, AST-04, NET-02.3, NET-04

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of

members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at ports.broadcom.com, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Meets)

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides network-layer access control list (ACL) enforcement at the application delivery layer through Network Security Policies attached to virtual services. These policies evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. Rules reference named IP Groups, which are reusable collections of IP addresses, IP ranges, and IP network prefixes. A Network Security Policy that denies traffic stops further policy evaluation, so ACL denials take effect before any downstream HTTP Security, Request, or Response policies execute.

Administrators configure Network Security Policies on individual virtual services through the Avi Controller. IP Groups are managed centrally and can be referenced across multiple virtual services, providing a scalable method for applying consistent ACL rules across the environment. The Avi Controller API supports programmatic creation and modification of Network Security rules that match on IP address and apply IP Groups to control access, enabling automated ACL governance through scripts or orchestration systems.

At Layer 7, Avi WAF rule actions support pass (allow) and deny (block) options for controlling traffic based on policy matches, extending data-flow enforcement to the application layer. Avi Load Balancer also supports OAuth/OIDC authorization policies that can match token scope attributes and request paths using CONTAINS and BEGINS_WITH match criteria, enabling granular, path-based access control for API endpoints.

The Avi Controller enforces IP Access Lists on its own management interfaces by programming Linux IP tables on the Controller host, restricting network-layer access to specified management endpoints. These lists, configured under Administration > Controller Access Settings, limit which client IP addresses may reach the Controller API and UI.

These mechanisms scope Avi's ACL enforcement to traffic transiting its virtual services and to Controller management-plane access. ACL governance for east-west and other network traffic not flowing through Avi virtual services relies on VMware vDefend and VCF network controls.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control AT.L2-3.2.1

> Ensure that managers, systems administrators, and users of organizational systems are made aware of the security risks associated with their activities and of the applicable policies, standards, and procedures related to the security of those systems.

SCF Controls: HRS-04.2, SAT-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AT.L2-3.2.2

> Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities.

SCF Controls: HRS-04.2, SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AT.L2-3.2.3

> Provide security awareness training on recognizing and reporting potential indicators of insider threat.

SCF Controls: SAT-03.6, THR-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AT.L3-3.2.1e

> Advanced Threat Awareness

SCF Controls: SAT-02.2, SAT-03, SAT-03.2, SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AT.L3-3.2.2e

> Practical Training Exercises

SCF Controls: SAT-03.1, SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AU.L2-3.3.1

> Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

----- CHAPTER THREE PAGE 18 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: MON-02, MON-10

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running rsyslog. vCenter event streaming to a remote syslog server is activated through the `vpxd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components

provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend retains security event data generated by its own features across defined periods. Network Detection and Response (NDR) collects and retains detection events and campaign data for 12 months. For active subscriptions, IDS events, network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year, and for 90 days following subscription expiration. Security Services Platform (SSP) stores intrusion events and flow data for 30 days each. The IDS/IPS monitoring view retains detailed logs for the last 14 days. SSP provides the `ssp_flow_storage.avg_flow_storage_ratio` metric, which gives operators visibility into the ratio of current retention days to predicted full days for flow storage.

For forwarding events to external systems, vDefend Distributed IDS/IPS can be configured to send IDS events to external syslog consumers; this setting is disabled by default and must be explicitly enabled. Syslog messages from vDefend appliances conform to RFC 5424, and messages from ESX hosts conform to RFC 3164. SSP can be configured to collect and transmit log messages to a remote syslog server. Identity Firewall Event Log Sources can be integrated with VCF Log Management for centralized logging and monitoring.

VMware vDefend is not an organization-wide log retention or SIEM solution. Meeting statutory, regulatory, and contractual retention periods requires organizations to forward vDefend events to a dedicated log management or SIEM platform, where custom retention policies can be applied.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations.

Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the ``log()`` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as ``event_id=CONFIG_CREATE`` or ``event_id=CONFIG_UPDATE`` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control AU.L2-3.3.2

> Ensure that the actions of individual system users can be uniquely traced to those users, so they can be held accountable for their actions.

SCF Controls: MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventType and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP address of the request, with the userAgent field providing additional context for service-to-service calls. Syslog log messages from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields.

when the LogAgentConfiguration Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the responseStatus field, which contains the HTTP response status code indicating success or failure; at the RequestResponse audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for VirtualMachineService resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record UserName, ModuleName, Operation, and Operation status with timestamps and request identifiers. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the user field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using esxcli system syslog commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The Syslog.global.auditRecord.remote parameter enables forwarding ESX audit records to the remote syslog collector specified by Syslog.global.logHost. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the vpxd.event.syslog.enabled option in the vCenter Management Interface; forwarded events carry the fields eventId, createTime, eventType, severity, user, target, chainId, and desc. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in /var/log/audit/audit.log. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the --audit-log-path, --audit-log-maxage, --audit-log-maxbackup, and --audit-log-maxsize flags; audit events can also be forwarded in real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part

of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/di.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and

malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) produces structured event logs that capture the information elements required for audit trail analysis.

PNR events are identified by named event types that indicate what occurred. vSphere Replication generates typed audit events when virtual machines and hosts are configured for or removed from replication, with event types including `com.vmware.vcHms.replicationConfiguredEvent`, `com.vmware.vcHms.replicationUnconfiguredEvent`, `com.vmware.vcHms.hostConfiguredForHbrEvent`, and `com.vmware.vcHms.hostUnconfiguredForHbrEvent`. Protection group and consistency group lifecycle changes are recorded with assigned severity levels: adding or removing a consistency group

from a protection group records an Info-level event, and consistency group errors or warnings record an Error-level event. Authorization errors are logged with timestamps and component information for security tracking. Each event type has a corresponding alarm that PNR can trigger if the event occurs.

Events include timestamps for time-based correlation. Login events record timestamp, log level, component, operation ID, and session details including userName and loginTime. Logout events record timestamp, user identity, source IP address, and operation ID. The Clean Room Orchestrator event details panel displays event severity, timestamp, target system information for replication or failover tasks, and event description.

Events are associated with specific objects, including protection groups, consistency groups, virtual machines, datastores, and sites, establishing where the event occurred and what was affected. The PNR global console displays all events occurring in the system, including both system-generated events and user actions. vSphere Replication maintains an audit log at /opt/vmware/support/logs/hms/hms-audit.log on the appliance, with broker logs at /opt/vmware/support/logs/hbr on the appliance and at /var/run/log on VMware ESX hosts.

Login events include the userName and loginTime fields, establishing the identity and session context of the user. Logout events record user identity and source IP address. The SrmDpxAgentUser role enables the DPX agent service to log events to VMware vCenter Event Manager.

Error-level events distinguish failed or abnormal conditions from informational state changes. Consistency group errors and warnings generate Error-level events; normal lifecycle transitions such as configuring replication or adding datastores record at the Info level. Snapshot task completion is logged and accessible through the Snapshot log interface in the Clean Room event details panel.

The PNR Appliance supports forwarding log files to a remote syslog server. Event forwarding to VCF Log Management version 9.0 or later is supported for centralized collection and retention. Clean Room Orchestrator events can be forwarded for external analysis, with event payloads that include timestamp, priority, message, component name, severity, configuration ID, component ID, and event type. Documented event forwarding destinations for Clean Room events include VCF Log Management, Microsoft Sentinel, and Splunk Cloud.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at /var/log/tdm/provider/audit/ with filenames in the format gateway-audit-timestamp.log. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint /api/analytics/logs retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control AU.L2-3.3.3

> Review and update logged events. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

----- CHAPTER THREE PAGE 19 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: CFG-02, CFG-02.1, CFG-02.9, MON-01, MON-01.16, MON-01.8, MON-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure

components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to

restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgm_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs, and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the

postgrescluster-allow-non-ssl-system-users setting in the advanced-system-config ConfigMap within the dsm-system namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control AU.L2-3.3.4

> Alert in the event of an audit logging process failure.

SCF Controls: MON-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in mechanisms to detect log processing failures, alert operations personnel, and support remediation of disruptions across its monitoring stack.

VCF Operations monitors the health of its own alerting and log processing infrastructure. When no SNMP targets are configured for alert delivery, VCF Operations generates a critical alert (`vmwSNMPNotConfiguredEvent`), flagging that the alerting pipeline is not operational. It also generates critical alerts for invalid SNMP connection events (`vmwSNMPConnectionInvalidEvent`). At the network layer, VCF Operations monitors the status of the NSX Management Node SNMP Service and generates a warning-severity alert when the service stops running. NSX-T itself generates an alert event when the Syslog Service has stopped running on NSX-T Manager nodes. The NSX Manager Logging Monitor adds a further detection mechanism through the System Health Agent framework, tracking each log's generation rate and rotation settings to estimate how long log data will be retained and raising log duration alarms when abnormal rates risk flushing log data before it is collected, so operators can intervene before records are lost. These self-monitoring capabilities detect failures in the event log processing and alert delivery chain before administrators need to discover them manually.

The alert framework in VCF Operations supports definitions built from one or more symptom sets. Symptom definitions identify conditions on attributes, properties, metrics, and events. The framework supports multiple event types relevant to log processing failures, including System Degradation, Data Availability, Collector Down, and Object Error. Administrators can create alert definitions with tighter symptom parameters to track problems before users encounter further issues. Recommendations can be attached to alert definitions so that engineers know how to resolve the alert when it fires, providing clear remediation guidance tied to specific failure conditions. Alerts are generated when collected data for an object is compared against the alert definitions for that object type and the defined symptoms evaluate to true.

For alert delivery, VCF supports multiple notification channels. vCenter can send both SNMP traps and email notifications when alarms are triggered, with configurable recipient addresses and subject lines. The vCenter SNMP agent supports SNMPv1, v2c, and v3 trap formats, including SNMPv3 with all security levels. VCF Operations supports outbound SNMP trap notifications to up to four destinations and can filter notifications based on defined criteria. As a fallback, VCF Operations can log alerts to a file on each of its nodes, providing an on-node record that persists even if external alert delivery is disrupted. This multi-channel approach helps ensure that alerts about log processing disruptions reach the appropriate personnel even if one delivery mechanism is impaired.

VCF Operations provides log-based alerting through Symptom Definitions, accessible under Infrastructure Operations > Configurations. Administrators can create log-based conditions and symptoms that trigger alerts when specific log patterns are detected, including patterns that indicate log processing failures or disruptions. The Log File plug-in supports notification rules that filter and route alerts to the appropriate teams. Log-based alert definitions can monitor host systems for specific conditions such as cluster performance failures, and they generate alerts when those conditions are detected. These alerts can be forwarded to external monitoring systems via SNMP traps.

VCF Log Management is a centralized log collection platform that pulls tasks, events, and alerts from vCenter instances and receives syslog feeds from ESX hosts. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs. This centralized architecture makes it possible to detect when expected log streams stop arriving, which is itself an indicator of a log processing failure. When audit record transmission is active on ESX hosts, the syslog daemon (`vmsyslogd`) emits records documenting its own operational status, including daemon start, stop, and error conditions, enabling detection of syslog service disruptions at the host level. vCenter event streaming to a remote syslog server is configured via the `vpzd.event.syslog.enabled` option in the vCenter Management Interface.

VCF Operations logs task execution details including Script Return Result status, script names, target object types, parameters passed, and unexpected exceptions. When automated remediation tasks fail, these logs provide the diagnostic detail needed to understand what went wrong and why. Task events are displayed in the messages area, allowing administrators to troubleshoot failed tasks directly.

Adapters for external monitored systems and the REST API are inbound channels for collecting events from external sources. VCF Operations correlates a subset of events published by monitored systems and delivers them as faults. Fault symptoms can be defined based on these events and added to alert definitions, so failures in external log sources are surfaced within the central monitoring platform. For organizations that forward logs to external SIEM systems via syslog, any disruption in log forwarding is itself a monitorable condition, since VCF components generate alerts when syslog services stop running.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) clusters include instrumentation to detect and report log processing failures in workload environments. The Kubernetes API server exposes the `apiserver_audit_error_total` metric, which counts audit events dropped due to export errors, and the companion `apiserver_audit_event_total` metric, which tracks total audit event volume; a sustained rise in the error count relative to the event count indicates a failure in the audit export pipeline. When Prometheus is installed as a standard package on a VKS cluster, Prometheus instances are configured to send alerts to Alertmanager in the `tanzu-system-monitoring` namespace. Alertmanager is deployed as a StatefulSet with multiple replicas in that namespace, and administrators can configure alert rules targeting these metrics to route notifications to designated personnel when audit event exports fail. Prometheus discovers Alertmanager pods through Kubernetes service discovery, filtering by namespace, app label, and component label.

VKS clusters include Fluent Bit logging agents for cluster-wide log collection and forwarding. Fluent Bit supports output to Syslog, HTTP, Elasticsearch, Kafka, and Splunk destinations, so disruptions in log forwarding are detectable through the health of the centralized log collection infrastructure. For workloads running in vSphere Namespaces, the LogAgentConfiguration Custom Resource streams logs to a remote Syslog server once applied to the namespace; each log message includes namespace name, pod UID, pod name, container name, and ESX host name as metadata fields, allowing operations teams to correlate forwarding gaps with specific workloads or nodes.

The Node Problem Detector provides a SystemLogMonitor daemon that monitors system logs and reports problems to the API server as NodeConditions or Events, according to predefined rules covering log sources such as filelog, kmsg, and kernel logs. This surfaces node-level log source failures as cluster events that can be queried or routed through alert management infrastructure. In Kubernetes audit logging batch mode, if the rate of incoming events overflows the buffer, events are dropped without notification from the logging subsystem itself, which makes metric-based monitoring of `apiserver_audit_error_total` the primary signal for detecting silent audit pipeline failures. VM Operator logs record reconciliation events for VirtualMachineService resources in VKS clusters, providing additional log sources for troubleshooting provisioning and service failures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides event logging with configurable alarms that can alert administrators to operational failures across the disaster recovery environment. Each event type has a corresponding alarm that can be configured to send email notifications, SNMP traps, or execute a script when triggered, giving administrators multiple channels to reach appropriate personnel when problems occur. For email notifications, mail settings must be configured in the vCenter Settings menu before alarm-triggered notifications function. PNR also requires an administrator email address to be configured during appliance registration with vCenter.

The PNR Server logging level can be configured to one of five levels: error, warning, info, verbose, or trivia, by modifying the log configuration. Error and warning levels capture conditions that indicate problems in the environment. When recovery plan execution encounters failures, PNR logs diagnostic details in the recovery site server logs, including plan identifiers, plan names, and detailed error messages with fault codes.

The PNR Appliance can forward log files to a remote syslog server for centralized log analysis and monitoring. vSphere Replication maintains separate audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` for tracking security-relevant events, including authorization errors with timestamps and component information.

The Clean Room Orchestrator provides an additional monitoring layer for ransomware recovery workflows. Administrators can configure email alerts for critical events in the clean room environment. The orchestrator can forward events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud; event forwarding to VCF Log Management requires version 9.0 or above.

VCF Operations provides an alert system that notifies administrators when specific symptoms of monitored objects are detected, including health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. In environments with more than one vCenter, PNR displays all events from PNR servers registered as extensions.

PNR logs when a protected consistency group has errors or warnings, recording this as an Error-level event. These mechanisms surface operational failures and log-related disruptions as part of broader recovery environment monitoring. Dedicated log pipeline health monitoring and log processing failure detection are provided by the underlying VCF platform monitoring stack.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports log processing failure detection and personnel notification through its audit record failure logging capability and event alerting framework.

Avi Controller and Avi Service Engine explicitly record audit record failures for three log destinations: Events, Syslog, and Splunk. The failure categories captured include initiation and termination of trusted channel connections, failure of trusted channel functions, unsuccessful certificate validation attempts, client authentication failures, SSH session establishment failures, and identification of the initiators and targets of failed trusted channel establishment attempts. This capability is configured in the Application Monitoring section of the Avi documentation under Audit Logging > Audit Record Failures.

When log processing failures or system events occur, Avi Controller can route notifications to four destinations: the local Controller UI (displayed as colored bell icons), email, syslog, and SNMP trap servers. These notification channels are configured under Operations > Notifications in the Controller UI. Avi supports both SNMPv2c and SNMPv3 protocols for SNMP trap notifications, and SNMP notification channels can be configured with TLS encryption and strict certificate verification for secure transport. The Avi Controller cluster leader issues SNMP trap notifications and supports multiple SNMP servers, providing redundancy for alert delivery. The Syslog-Audit-Persistence alert action template is available for configuring alert actions that stream events to external syslog servers, which can feed into a centralized log management or SIEM platform.

Auditors should be aware of two scoping boundaries when evaluating this control. First, Avi debug logs and Event Logs are not transmitted to remote syslog servers through the OS-level syslog configuration; Event Logs require the Syslog notification configuration within the Controller UI or API-based export. Second, configuring Syslog notifications in Avi Controller pushes alerts to syslog servers but does not export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to be pushed from the Controller to a remote destination.

Auditors verifying this control should confirm that Alert Actions are configured in the Operations section of the Avi Controller UI, that notification destinations (email addresses, SNMP trap server addresses, or syslog server targets) are defined, and that organizational runbooks or response procedures define who receives these alerts and what remediation steps follow.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control AU.L2-3.3.5

> Correlate audit record review, analysis, and reporting processes for investigation and response to indications of unlawful, unauthorized, suspicious, or unusual activity.

SCF Controls: MON-02, MON-02.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog commands`. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running rsyslog. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for

centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend Network Detection and Response (NDR) correlates detection events into campaigns, comparing new detection data against existing events to identify related activity. Campaigns provide a view of a threat by correlating detection events to identify the different stages of an attack, and security analysts can view and triage threat campaigns through a campaign timeline. NDR supports SIEM integration, sending campaign and event logs to a connected SIEM in real time, allowing network security event data to be exported for broader correlation with other enterprise data sources.

Security Intelligence detects and categorizes suspicious events using MITRE ATT&CK tactics and techniques, recording event occurrences during selected time periods, and provides a View Full Event History capability that displays all events associated with a given signature ID and intrusion severity. Security Intelligence also correlates IDS events from the same source and destination hosts to connect related events and build a broader picture of an attack. This structured, MITRE-tagged event data can support SIEM-based analysis and enterprise-wide threat correlation.

The Security Services Platform (SSP) can be configured to forward log messages to external syslog servers for centralized log collection. SSP syslog configuration supports TCP, TLS, and UDP protocols and allows administrators to specify server address and port, integrating with existing SIEM ingestion pipelines. NDR Sensors report metrics covering health, traffic trends, and data processing activity, available as point-in-time measurements or aggregated data over time.

vDefend correlates only technical network security data and has no capability to ingest or correlate non-technical information such as HR records, physical access logs, or operational data. Satisfying the full scope of this control, which requires correlation of both technical and non-technical information across the enterprise, requires an external SIEM or equivalent platform.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The SrmDpxAgentUser role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at /opt/vmware/support/logs/hms/hms-audit.log and broker logs at /opt/vmware/support/logs/hbr on the Appliance and at /var/run/log on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog\_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control AU.L2-3.3.6

> Provide audit record reduction and report generation to support on-demand analysis and reporting.

SCF Controls: MON-02, MON-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend provides event log generation and monitoring capabilities across its security components in 9.1, directly supporting anomaly detection and assessment within the network security domain.

The IDS/IPS subsystem generates detailed security event logs for event analysis. Remote syslog must be configured on ESX hosts to receive IDS/IPS events exported directly from those hosts; the `ids_events_to_syslog` setting controls whether IDS/IPS events are forwarded to external syslog consumers (the default is disabled). vDefend components write log data to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts, enabling

consistent ingestion by syslog-compatible platforms. The Security Explorer Computes view in Security Intelligence provides a full record of all IDS/IPS events for analysis over a 30-day timeframe. Security Intelligence also provides a View Full Event History capability that displays all events associated with a given signature ID along with their intrusion severity. The Threat Event Monitoring dashboard in Security Services Platform displays the trend in intrusion events over time, categorized by Intrusion Severity, giving security teams visibility into detection activity patterns.

Malware Prevention Service generates structured event logs with detailed metadata per file analysis event. Event log fields include the verdict (BENIGN, malicious, or other classification status), a numeric risk score, malware classification, malware family, error codes and messages, HTTP domain, HTTP method, user agent, file upload status, submission status, analysis completion status, and gateway identification. File event statistics appear on the Monitor & Plan > Overview > Threat Monitoring dashboard in Security Services Platform, with graphs covering a configurable time period (defaulting to the last hour).

Network Detection and Response (NDR) generates and sends event logs to a SIEM endpoint when a detection event occurs, enabling integration with external correlation and reporting platforms.

The Security Services Platform Monitor & Plan Overview dashboard provides a view of security posture that includes the latest security segmentation report, flow trends, a summary of detected suspicious traffic events, pending actions, and current settings requiring attention. Security Intelligence generates bar graphs showing the number of anomalies detected, categorized by severity. The Policy Recommendations section tracks Security Intelligence recommendations with status indicators such as Ready to Publish, allowing security teams to act on recommended policy changes.

vDefend Identity Firewall Event Log Sources can be integrated with VCF Log Management for centralized logging and monitoring. VCF Log Management supports Top-N queries using Interactive Analytics, enabling report generation from the aggregated log streams that vDefend supplies. VCF Log Management handles organization-level scheduled report generation, while vDefend provides the network-security-specific event data and dashboards that feed those reporting workflows.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The SrmDpxAgentUser role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at /opt/vmware/support/logs/hms/hms-audit.log and broker logs at /opt/vmware/support/logs/hbr on the Appliance and at /var/run/log on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides event log generation and reporting capabilities that support detection and assessment of anomalous activities within the database-as-a-service layer.

DSM's primary audit interface is the System Audit Events view, accessible through the System Audit section in the Provider UI. This view is the only location in the DSM interface where administrators can track non-database-related operations and tasks. Each audit entry records a Component field identifying the DSM component that performed the operation, an Event Type field identifying the nature of the audited event, Event Details providing operation-specific information, Event Time in UTC, and a Status field indicating the outcome of the event. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention, enabling attribution of each audit record to a specific actor. Standard Kubernetes audit events are also captured through the Gateway Audit Logs capability.

Audit events can be exported in CSV or XLSX format using the ACTIONS dropdown menu in the System Audit Events view. Exports include all events visible to the requesting user regardless of page size, covering the Component, Event Type, Event Details, Event Time (UTC), Status, and Source fields. These exports can be brought into external reporting and analysis tools to support audit review and anomaly assessment.

For persistent retention, DSM archives gateway audit log files periodically to an S3 repository subpath when a default S3 provider log repository is configured. Audit log files are also stored locally on the Provider VM at /var/log/tdm/provider/audit/ in files named with a gateway-audit-timestamp.log format, supporting direct access for investigation. Support bundles can be generated and downloaded to aggregate control plane and data plane logs from a database cluster for diagnosis. The Provider VM also includes a System Logs capability for managing system log collection.

DSM provides operational monitoring that can surface indicators of abnormal behavior. The Monitoring tab for database instances displays metrics including Active Connections, Data Disk Usage, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage %, InnoDB Reads and Writes, and Command Reads and Writes, with the time range adjustable through the Time Range Last dropdown. The Alerts pane in the Monitoring tab surfaces triggered alerts. DSM raises metrics-based alerts when metrics are successfully collected from a database cluster, status-condition-based alerts for critical failure conditions including database engine degradation and backup failures, and real-time alerts for resource or connectivity issues to support root cause identification. Webhook-based alerting supports integration with external notification systems for threshold-triggered database monitoring events. DSM can also be monitored through VCF Operations for additional troubleshooting and status visibility.

Satisfying this control fully requires organizational processes to review exported audit data and monitoring output, establish baselines for normal activity, and investigate deviations. DSM does not include built-in anomaly detection, correlation, or security information and event management capabilities. Organizations typically forward DSM logs to a centralized log management platform for automated detection and reporting at scale.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog\_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in

SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control AU.L2-3.3.7

> Provide a system capability that compares and synchronizes internal system clocks with an authoritative source to generate time stamps for audit records.

SCF Controls: MON-07.1, SEA-20

Aggregate Coverage: Meets

VCF (Meets)

VCF provides time synchronization across all platform components using Network Time Protocol (NTP), with Precision Time Protocol (PTP) available for workloads requiring sub-microsecond accuracy.

At the foundation layer, NTP service must be configured on all VMware ESX hosts. This is configured through the VMware Host Client by navigating to Manage > System tab > Time & date > Edit NTP Settings. The NTP client must be enabled by selecting the "Use Network Time Protocol" radio button, and the NTP service startup policy should be set to "Start and stop with host" so that time synchronization is maintained across host reboots. Using at least three NTP servers is a best practice for ESX host time synchronization, providing resilience against any single time source becoming unavailable. VMware Knowledge Base article 317537 provides detailed guidance on ESX host NTP configuration, and article 318888 provides procedures for verifying time synchronization across ESX host environments. ESX also supports PTP configuration through the HostDateTimeSystem, giving administrators a choice between NTP and PTP depending on the precision requirements of the environment.

VMware vCenter must also be configured with NTP to maintain clock synchronization with managed ESX hosts. Time synchronization between vCenter and ESX hosts is a stated requirement for VMware Infrastructure operation. Consistent time across these components is critical for accurate logging, troubleshooting, and event correlation. The NTP daemon should be activated on ESX hosts for this reason. For environments running vSphere Supervisor, the same NTP servers must be configured for the vCenter instance, all hosts in the cluster, NSX, and the Supervisor.

VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor extend NTP synchronization to Kubernetes control-plane and worker nodes through the ClusterClass variable framework. When provisioning VKS clusters using the Cluster v1beta1/v1beta2 API, administrators specify NTP servers in the `osConfiguration.ntp.servers` parameter (VKS 3.2.0 and later) or in the `ntp` cluster variable (VKS 3.1.0 and earlier); both parameters accept an array of NTP server hostnames or IP addresses. If left unset, VKS nodes inherit default NTP server addresses from the Supervisor, which in turn derives its time configuration from the underlying infrastructure. Post-creation changes to NTP server configuration require manually updating the ClusterClass cluster variable, as NTP changes are not automatically propagated to running clusters; administrators should account for this in change management processes. Clock accuracy within VKS clusters is operationally significant: clock skew between control-plane and worker nodes can cause DaemonSet rollout progress to be reported incorrectly when `spec.minReadySeconds` is in use, and correct timestamps are required for Kubernetes audit log reliability, certificate validity checks, and bootstrap token expiry enforcement.

VCF Operations is the central point for NTP configuration across VCF core components. When you update the NTP server configuration through VCF Operations, it propagates the change to VCF Operations itself, all vCenter instances, ESX hosts, NSX Manager nodes, and NSX Edge nodes. If an NTP update fails for any component, VCF Operations rolls back the NTP settings for the failed component. NTP configuration changes go through a precheck validation step before deployment. VCF management components can also be configured to use the ESX NTP server for time synchronization through the `time-sync-mode` setting, allowing centralized time management where management components inherit their time from the underlying ESX infrastructure.

VCF Operations supports two NTP synchronization modes: self-managed synchronization, where all nodes synchronize with the primary and replica node, or external NTP server synchronization using a URL or IP address. The NTP setting synchronizes time across VCF Operations cluster nodes. When configuring VCF SSO integration, NTP should be configured to synchronize the server system time of the identity source and VCF Operations. The `ntp sync` command is available to force synchronization of NTP settings within VCF Operations.

NSX Manager appliances require NTP server configuration. NSX recommends using a node profile to configure NTP for all appliances rather than configuring each one individually. If NTP is configured individually on an NSX appliance, the same NTP server must be used on all appliances to maintain consistency. NTP is recommended for all NSX environment components regardless of which NSX features are in use.

VCF Operations for Networks depends on clock synchronization with NTP for service health; if the system clock drifts out of sync, some services may become unhealthy or stop working. HCX similarly requires a valid NTP server with synchronized time for integrated systems operations.

VCF provides built-in tools for validating time synchronization status. The SoS (Suite of Services) Utility offers an `--ntp-health` option that verifies whether the time on VCF components is synchronized with the NTP server configured in the VCF Installer appliance, allowing administrators to validate synchronization without relying on external tools. VCF Health Diagnostics also monitors NTP configuration data across VCF components and provides per-component NTP status information.

Accurate time synchronization across the platform is a prerequisite for TLS and VCF SSO communication, Kerberos authentication (which fails on clock skew), certificate validation, and consistent log timestamps for auditing and troubleshooting.

For workloads requiring higher precision than NTP provides, vSphere supports a precision clock device that gives a virtual machine access to the system time of the primary ESX host. PTP is also available for environments requiring sub-microsecond accuracy on a local area network. When an ESX host is configured for PTP, the NTP service must not be running concurrently; NTP and PTP are mutually exclusive at the host level.

VMware vDefend (Contributes)

VMware vDefend both depends on and validates time synchronization across its enforcement and management components. Accurate clock synchronization is a prerequisite for time-based firewall policy enforcement, log correlation, certificate validation, and secure communications throughout the vDefend stack.

vDefend (DFW) and vDefend (GFW) support time-based firewall policies that allow administrators to define rules that activate or deactivate based on configurable time windows. Network Time Protocol (NTP) service must be running on each transport node when using time-based rule publishing in either the Distributed Firewall or the Gateway Firewall. Time windows for both can be configured to use either Coordinated Universal Time (UTC) or the local time of the transport node. Gateway Firewall time windows support either a weekly or one-time frequency. When local time zones are used for DFW policies, the entire time window must fall within the same UTC calendar day. For Edge transport nodes, if the time zone is changed after the node is deployed, the Edge node must be reloaded or the data plane service restarted for the new time zone to take effect.

Identity Firewall, which enforces access policies based on Active Directory user identity, has additional time synchronization requirements. When using Identity Firewall event log scraping to track user login events, NTP must be correctly configured across all participating devices. Administrators should schedule Active Directory full synchronization during off-peak or non-business hours, as a full sync can take considerable time.

Security Services Platform (SSP), the management and orchestration layer for vDefend, requires accurate time synchronization for certificate validation, log correlation, and secure communications to function correctly. The SSP installer validates time synchronization as part of its deployment prerequisites and requires configuration of one or more NTP servers, which can be updated if they become unreachable. For bare metal deployments, the bare metal server should be configured to use the same NTP server as SSP to maintain consistent time synchronization across all components.

Network Detection and Response (NDR) sensor appliances require NTP to be configured and synchronizing before they can successfully register with SSP. Administrators should verify NTP synchronization status using the `get clock` command on the NDR sensor CLI before initiating registration. The NDR sensor monitoring view within SSP displays the NTP servers configured for each sensor, providing visibility into time synchronization configuration across deployed sensors.

SSP Segmentation Monitoring can monitor NTP infrastructure services on UDP/123, providing visibility into time synchronization infrastructure health alongside other monitored services. SSP Inventory tracks environment synchronization

status and identifies environments that are timed out or out of sync, supporting troubleshooting of time-related connectivity issues.

Accurate timestamps across all vDefend components are necessary for correlating security events across the Distributed Firewall, IDS/IPS, malware prevention, and NDR capabilities. When investigating a security incident, analysts rely on consistent timestamps to reconstruct the sequence of events across multiple enforcement points.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides native time synchronization mechanisms within the Protection and Recovery Appliance. The appliance supports three configurable time synchronization modes: NTP, which enables direct synchronization against administrator-specified NTP server addresses; Host, which synchronizes with the underlying ESX host time via VMware Tools; and Disabled. In NTP mode, administrators configure the appliance to synchronize directly with the organization's authoritative time source, independent of the underlying VCF platform's host-level NTP configuration.

PNR enforces clock alignment across its server components through the maximum-clock-skew setting, which defines the maximum allowed time difference between server clocks (default: 20 seconds). Time zone and time synchronization settings are editable through the appliance configuration interface when network time settings change.

For VCF Automation environments, the Protection and Recovery Proxy also requires explicit NTP server configuration, specified as an IP address or FQDN. PNR deployment guidance recommends using a persistent synchronization agent such as network time protocol daemon (NTPD), W32Time, or VMware Tools time synchronization to maintain consistent time across recovery infrastructure and avoid conflicts in time management across systems.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) integrates NTP synchronization as a core operational requirement across all of its managed components. DSM requires configuration of a Network Time Protocol (NTP) service with a reliable time source to synchronize the clocks of all deployed VMs. Administrators configure NTP servers through the System Settings interface in the DSM UI, and DSM mandates that the Provider Appliance and all managed database instances use the same NTP server. Both the Provider Appliance and database cluster nodes communicate with NTP servers over UDP on port 123.

DSM enforces UTC as the standard time representation for maintenance policies and support bundle timestamps, reducing ambiguity in scheduled operations and log interpretation. DSM MySQL instances support configurable time zone settings, with UTC as the default value.

DSM monitors synchronization health at two levels. When NTP synchronization fails on the Provider Appliance, DSM generates an `NTP_SYNC_FAILED` global alert; administrators can resolve this by verifying and correcting the NTP servers field in System Settings. DSM also generates an `NTP_NOT_APPLIED` alert when NTP settings from the system configuration do not apply to a database instance, indicating that the database time is not being refreshed or synchronized. Together, these alerts surface clock synchronization failures within DSM's scope and make them actionable rather than silent.

DSM does not control clock synchronization for the broader infrastructure on which it runs, including ESX hosts, VMware vCenter, and network devices. Organizations must configure and maintain NTP synchronization for those layers independently through vCenter and ESX host configuration.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) maintains synchronized clocks across its Controller and Service Engine components through a configurable NTP stack. Administrators specify NTP servers in the Controller system configuration via the `ntp_configuration.ntp_servers` setting, accessible through the Controller UI, API, or CLI. The Controller synchronizes its own clock against the configured NTP servers, and Avi Service Engines in turn synchronize their clocks with the Controller by default, or directly with an NTP server configured at the cloud level. In Avi for VCF deployments, public NTP servers are used by default, making explicit NTP configuration optional when public NTP access is available; in most enterprise environments, administrators should configure the organization's approved NTP servers explicitly.

For VM-deployed Service Engines, NTP servers can also be configured directly at the Service Engine level via the `ntp-servers` setting, enabling them to synchronize independently with NTP infrastructure where needed. For bare metal (LSC) deployments, Service Engine time synchronization supports `ntpd` (Network Time Protocol daemon) and `chronyd` as NTP daemon implementations, selectable via the `ntp_daemon` setting. NTP traffic uses UDP port 123 on the management interface.

Avi monitors time synchronization health continuously. Service Engines synchronize with configured NTP servers at startup and periodically monitor synchronization status. When synchronization fails, Avi raises an event until synchronization is restored, providing administrators with ongoing visibility into the time synchronization status of the load balancing infrastructure.

One configuration requirement applies to VM deployments: when Avi Controller and Service Engine VMs run on VMware ESX hosts, ESX host time synchronization must be disabled for those VMs. Allowing both the hypervisor VMware Tools time sync mechanism and the in-guest NTP daemon to operate simultaneously causes clock conflicts. The Avi documentation requires that ESX time synchronization be disabled on all Avi Controller and Service Engine virtual machines so that NTP is the sole time authority for those VMs.

In Avi for VCF deployments, NTP server addresses can be configured when deploying a vSphere Supervisor with the Avi Load Balancer, supporting consistent time synchronization across the VCF environment.

Administrators responsible for this control should configure the `ntp_configuration.ntp_servers` field in Avi Controller system settings with the organization's approved NTP servers, verify that Service Engines are synchronized, and confirm that ESX time synchronization (VMware Tools) is disabled for the relevant VMs.

Control AU.L2-3.3.8

> Protect audit information and audit logging tools from unauthorized access, modification, and deletion.

SCF Controls: MON-02, MON-03.1, MON-08

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Contributes)

VMware vDefend generates structured security event logs across its Distributed Firewall, Gateway Firewall, IDS/IPS, and Malware Prevention components, with several mechanisms that support protection of those logs from suppression or loss.

The Security Services Platform audit log is enabled by default and cannot be disabled through configuration. All access events to the Security Services Platform, including access to the License Hub, are recorded in these audit logs, preventing log suppression at the platform level.

The Distributed IDS/IPS can be configured to forward events directly to external syslog consumers via the `ids_events_to_syslog` setting; this forwarding is disabled by default and requires explicit configuration. When remote syslog is enabled on ESX hosts, IDS/IPS events are exported directly from those hosts to external receivers. vDefend components write log files to `/var/log`, with syslog messages conforming to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Gateway Firewall isolation rules log blocked traffic attempts to the `unifiedsyslog.log` file on Edge Nodes.

Malware Prevention produces structured event logs in JSON format that include standard attributes (date, log level, module) along with detailed file analysis metadata: file hashes (SHA256, SHA1, and MD5), file type, file size, inspection timestamp, client and server VM identifiers, submission source, detection status, verdict, analysis status, malware classification, malware family, HTTP domain, HTTP method, and user agent. These records capture the full analysis lifecycle, including file intercepted, verdict cache hit, local static analysis submission, cloud dynamic analysis submission, verdict obtained, and policy enforced events. In 9.1, the Malware Prevention Service can be configured to forward logs to a remote logging server using TLS encryption with mutual certificate authentication (requiring server CA certificate, client CA certificate, client certificate, and client key), providing an off-appliance copy of event records with in-transit protection.

Identity Firewall event log sources can be integrated with VCF Log Management for centralized log collection and monitoring, providing an additional path to off-appliance log preservation.

Protection of forwarded or archived logs from unauthorized access and modification at rest is outside vDefend's scope and depends on the receiving log management or SIEM platform's controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) produces structured audit logs that record platform-level and gateway-level operations, and provides several mechanisms that contribute to protecting those logs from unauthorized access and loss.

At the platform level, DSM maintains gateway audit log files on the Provider VM at `/var/log/tdm/provider/audit/`, with individual files named using a timestamp format (`gateway-audit-timestamp.log`). Local retention covers the last five days of log files; once files are successfully uploaded to a configured S3 repository, DSM removes them from the local filesystem after five days. Each log entry captures structured fields including Component, Event Type, Event Details, Event Time (UTC), Status, and Source. The Source field records the email identifier of the user who initiated the operation, or "System" for events initiated by DSM without user intervention. The System Audit Events view, accessible through the Provider interface, is the designated location for reviewing non-database-related platform operations. Access to the Provider interface is scoped to the administrative role, restricting which users can read or interact with the system-level audit record.

DSM supports offloading audit logs to external storage as the primary mechanism for durable protection. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to an S3 subpath named "gateway audit." DSM does not delete audit logs stored in the S3 repository, which means the archived log record persists beyond the five-day local retention window. Externalizing audit logs to S3 separates the log record from the Provider VM that generated it, reducing the risk that a compromise or failure of the Provider VM affects the integrity or availability of the audit trail. Organizations apply bucket-level access controls and retention policies on the S3 repository to restrict who can read, modify, or delete the archived logs.

DSM supports log forwarding, allowing DSM logs to be sent to a centralized log management or security information and event management (SIEM) platform via the System Logs capability. Forwarding logs to an external system provides a second copy of the audit record under access controls and integrity protections that are independent of the DSM platform itself.

For SQL Server databases provisioned through DSM, the SQL Server data service uses server-level DDL triggers to restrict the file paths available for audit logs, limiting where audit log files can be written. DSM supports enabling audit logging for SQL Server with configurable levels of auditing for system logins and a configurable log retention period. DSM can automatically create a simple audit for login events based on the Login Auditing option selected during cluster creation. For custom audit requirements, the standard T-SQL `CREATE AUDIT` and `CREATE AUDIT SPECIFICATION` DDL statements are available.

DSM can generate and download log bundles that aggregate relevant logs from database VMs, supporting diagnosis and out-of-band preservation of the operational log record.

Audit events can be exported from the System Audit Events view in CSV or XLSX format using the ACTIONS menu. Exports include all events visible to the authenticated user regardless of pagination, supporting external archival and out-of-band preservation of the audit record.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the ``log()`` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as ``event_id=CONFIG_CREATE`` or ``event_id=CONFIG_UPDATE`` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control AU.L2-3.3.9

> Limit management of audit logging functionality to a subset of privileged users.

SCF Controls: MON-02, MON-08.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized collection and management of security-related event logs across all platform components. Every major subsystem supports syslog forwarding to external log aggregation infrastructure, enabling integration with any SIEM or centralized logging platform that accepts standard syslog input. In addition, VCF Log Management provides a built-in log aggregation and analysis capability within the platform itself.

VMware ESX hosts can be configured to send syslog messages to a remote log server using the `esxcli system syslog config set` command, specifying the target server IP address and port. ESX syslog messages conform to RFC 3164. Configurable syslog log levels allow administrators to tune the verbosity of forwarded events using `esxcli system syslog` commands. The syslog directory location on ESX hosts is controlled through the `Syslog.global.logDir` parameter. The `Syslog.global.auditRecord.remote` parameter separately controls whether security audit records are transmitted to the remote hosts configured in `Syslog.global.logHost`. ESX hosts maintain local logging with configurable retention and rotation policies, maintaining six log files that rotate at each power-cycle by default or at a configured file size. When the configured file limit is reached, the oldest file is deleted. The ESX Dump Collector and vSphere Syslog Collector can be configured to redirect ESX memory dumps and system logs to a network server for persistent log storage.

VMware vCenter provides syslog forwarding through both its management API and direct configuration. The vCenter Management API exposes endpoints to set the syslog forwarding configuration (PUT), retrieve the current configuration (GET), and test the connection with remote syslog servers (POST). vCenter syslog forwarding supports TCP, UDP, TLS, and RELP protocols, giving administrators flexibility in how log data is transmitted to the collection infrastructure. The remote syslog target must be a server running `rsyslog`. vCenter event streaming to a remote syslog server is activated through the `vpzd.event.syslog.enabled` option in the vCenter Management Interface, and the Appliance Management Interface supports a maximum of three remote syslog destination hosts. vCenter retains performance data with configurable intervals and automatic purge policies.

NSX Manager can export syslog to a remote server with configurable protocol, port, and log level. NSX audit logs, which record security-related events such as logon, logoff, and access to resources, are sent directly to the configured remote syslog server. NSX Manager audit logs also record failed login attempts with username and timestamp information, and log user account role changes for remote users authenticated through identity sources. Each audit log entry contains the timestamp, source, result, and a description of the event. API calls from all sources and users are audited, and each audit log associated with an API call includes a request ID parameter for traceability. This logging is always enabled and cannot be disabled. NSX also captures logical switch messages and other operational events in its audit log. On ESX hosts, NSX syslog data is stored in `/var/log/nsx-syslog` and can be forwarded alongside other host logs. NSX Manager syslog supports TLS protocol on port 6514 for encrypted log transmission.

VCF Log Management is the centralized log collection platform within the VCF stack, gathering logs from vCenter, ESX hosts, NSX, VCF Operations, and VCF Operations for Networks. It can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts through its Log Collections configuration. VCF Log Management provides an analysis interface where administrators can search and filter log events, create queries based on timestamp, text, source, and structured fields, and build dashboards for operational and security scenarios. Content packs for VCF components provide pre-built dashboards, alerts, and queries for common use cases, including a content pack for VCF Operations for Networks. Log-based alert definitions allow administrators to trigger notifications when specific log patterns are detected.

VCF Operations supports centralized log collection and editing of log sources through Infrastructure Operations, under Configurations and Log Collection. VCF Operations Host System Properties allow configuration of a remote syslog host for centralized log collection. The audit log in VCF Operations is integrated with syslog, and the syslog collector can be

configured to collect all audit logs. VCF Operations can also send user activity audit logs to an external syslog server. Audit logs capture administrative actions carried out through the API, the user interface, and the CLI, including regular CRUD operations and login/logout alerts. Note that SSH login logs are not captured in VCF Operations audit logs; SSH logs can be found in `/var/log/auth.log`. VCF Operations supports outbound integrations that distribute alerts and log data to external systems via email, SNMP traps, REST webhooks, log files, and Slack notification plugins.

VCF Operations for Networks supports centralized log collection and editing of log sources through its own Infrastructure Operations configuration. Remote syslog servers must be configured to accept syslog traffic over UDP. All platform servers in a VCF Operations for Networks cluster use the same remote syslog server, though individual collectors can be pointed to different remote syslog servers. The audit log in VCF Operations for Networks is integrated with syslog.

Additional VCF components also support centralized log forwarding. The Foundation Load Balancer supports forwarding logs to a syslog server via IP address configuration, with certificate-based secure communication for log forwarding. VCF Operations HCX supports configuring a remote syslog server that receives logs from both the HCX manager and appliance virtual machines, and appliances deployed after adding the external syslog server automatically forward log messages. VCF Identity Broker supports log collection as well.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) clusters running on vSphere Supervisor, provides its own log collection and forwarding capabilities that integrate with the broader platform logging infrastructure. Kubernetes audit logging within VKS generates a security-relevant, chronological record of cluster activity, documenting the sequence of API calls made by users, applications, and the control plane. This includes authentication events, authorization decisions, resource creation and modification, and user impersonation requests, with each impersonation request recorded individually in the audit log. Audit verbosity is governed by a Kubernetes audit policy that specifies which events to capture and at what level of detail; available backends for writing audit records include log files at `/var/log/kubernetes/audit/` and external webhook endpoints. Kubernetes system component logs are configurable for verbosity, ranging from coarse-grained error reporting to fine-grained trace output covering HTTP access logs, pod state changes, and other operational detail. Fluent Bit is available as a standard package for VKS clusters and serves as the log forwarding agent. Once deployed as a DaemonSet on every node, Fluent Bit collects Kubernetes container logs, API audit logs, Linux daemon logs, and Linux authentication logs, then forwards them to a configured destination. Supported forwarding destinations include Syslog (port 514 for UDP, port 6514 for TCP), HTTP endpoints, Elasticsearch, Kafka, and Splunk. When integrated with VCF Log Management, Fluent Bit forwards over the CFAPI protocol; VCF Log Management accepts log forwarding connections on HTTPS port 9543 or HTTP port 9000 at the `/api/v2/events` endpoint. A logging management server must be deployed and accessible from the VKS cluster to receive, store, and analyze forwarded logs; the Consumption layer provides the collection and forwarding mechanisms rather than the SIEM itself. The Supervisor control plane also forwards its VM system logs to external syslog servers in RFC 5424 format over TCP, managed by Fluent Bit pods in the `vmware-system-logging` namespace whose status can be queried using `kubectl` commands.

For workloads running as vSphere Pods within vSphere Namespaces, administrators configure the `LogAgentConfiguration` custom resource to stream syslog messages directly to a remote syslog server. Log messages from vSphere Pods include structured metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling precise attribution and filtering at the receiving SIEM or log aggregation platform.

VCF also aligns with global compliance logging requirements: auditable events are logged across the platform. This baseline of audit event generation feeds into the centralized collection mechanisms described above.

VMware vDefend (Meets)

VMware vDefend's Security Services Platform (SSP) restricts access to event log management through role-based access control. SSP defines five distinct roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role is scoped to viewing and tracking system activity without administrative access, keeping log review separate from configuration authority. Modifying role assignments requires Enterprise Admin privileges, so access to user management is restricted to authorized personnel.

Role assignments can be applied to both local accounts and directory-managed remote users or user groups, allowing log access rights to be scoped to personnel with a specific business need. SSP audit logs are enabled by default and cannot be disabled, providing a persistent record of access and administrative activity.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates security-relevant event logs and supports forwarding them to centralized log collection and SIEM platforms through multiple native mechanisms.

The Protection and Recovery Appliance provides built-in syslog forwarding to remote syslog servers. The forwarding configuration supports a selectable transport protocol and a configurable destination port (default 514). PNR includes a test message capability to verify that a remote syslog server is receiving messages before relying on it operationally. REST API endpoints are available for managing syslog configuration, including endpoints to list all configured syslog servers, update syslog server settings, and send test messages programmatically.

PNR's event subsystem integrates with VMware vCenter, registering protection and recovery-specific events in the vCenter event infrastructure. Each event type has a corresponding alarm that PNR can trigger when the event occurs, enabling automated notification and downstream forwarding through vCenter's event pipeline to external SIEM platforms. PNR logs security-relevant events including login activity with timestamps, user identity, session keys, and locale information; authorization error messages with timestamps and component identification; and protection group configuration changes. The `SrmDpxAgentUser` role enables the DPX agent service to log events directly to vCenter Event Manager.

The Clean Room Orchestrator component supports native event forwarding to VCF Log Management (version 9.0 or later), Microsoft Sentinel, and Splunk Cloud. Integration with Microsoft Sentinel uses Data Collection Rules (DCR) and Data Collection Endpoints (DCE) within an Azure Log Analytics Workspace, with DCE and Log Analytics Workspace required in the same Azure subscription and resource group. Splunk Cloud integration is configured using a Splunk URL and authentication token. Clean Room Orchestrator logs events for protection group creation and deletion, replication tasks, and snapshot operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type.

vSphere Replication, as a PNR component, maintains audit logs at `/opt/vmware/support/logs/hms/hms-audit.log` and broker logs at `/opt/vmware/support/logs/hbr` on the Appliance and at `/var/run/log` on VMware ESX hosts. vSphere Replication generates typed audit events for host and virtual machine replication configuration and unconfiguration changes, using structured event type identifiers.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides role-based access control that scopes access to audit log viewing and management functions based on user role assignments. DSM defines two roles: the DSM Admin role, which grants super-user access to all data services and administrative functions including the System Audit Events view and log management settings; and the DSM User role, which restricts access to only the objects owned by that user within the assigned namespaces. Users in the DSM User role cannot access the System Audit Events view or log management configuration settings. The DSM console enforces these restrictions directly, limiting the views and actions available to those permitted for the logged-in user's role.

The System Audit Events view is accessible through the Provider interface and is the only location in the DSM UI where non-database-related operations and tasks can be tracked. Because this view resides in the Provider interface, access to it is scoped to users assigned the DSM Admin role. Administrators assign roles to users either directly through local user creation in the DSM UI or through Directory Service Groups mapped to LDAP users via LDAPS integration, enabling group-based access control for organizations with directory service infrastructure.

Gateway audit log files are stored on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`. These logs track user read and write operations to DSM data services or infrastructure objects performed in the DSM UI or through the DSM Gateway Kubernetes interface, covering both UI-driven and API-driven management activity. Each log entry records the Source field as either a user identifier (Email ID) for user-initiated events or System for events initiated by DSM without user intervention. When a default S3 provider log repository is configured, DSM

archives these files periodically to an S3 subpath named "gateway audit." The Log Forwarding setting in DSM's Settings area, configurable by Admins, controls whether logs are forwarded to external log management systems. Provider Log Storage settings require an Access Key credential for authentication to the object store. Audit events can be exported in CSV or XLSX format through the ACTIONS drop-down menu in the System Audit Events view, and exports include Component, Event Type, Event Details, Event Time (UTC), Status, and Source fields.

For SQL Server data services, DSM provides additional log access controls. When creating a SQL Server cluster, DSM can automatically configure a Login Auditing option that creates a simple audit for login events. DSM also uses server-level DDL triggers to restrict the file paths available for audit logs, and the internal `dsm_mgmt` management login operates within a secure, isolated context to prevent administrative operations from being accessible to or exploitable by users with general database privileges.

For this control to be fully met, organizations need to implement a formal process for identifying personnel with a specific business need to access event log management functions, document that authorization, and review it periodically. Access to the underlying Provider VM file system and the S3 storage bucket where logs are archived should also be controlled at the infrastructure level, as those paths are outside DSM's own access controls. DSM's RBAC provides the technical mechanism to scope log management access to Admin-role users, but the assignment of that role must be governed by an organizational policy tying role grants to documented business justification.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the ``configure systemconfiguration`` CLI command or through the Controller Settings interface. The ``syslog_servers`` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in `SYSLOG_RFC5425_ENHANCED` format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the ``log()`` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as ``event_id=CONFIG_CREATE`` or ``event_id=CONFIG_UPDATE`` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Control CA.L2-3.12.1

> Periodically assess the security controls in organizational systems to determine if the controls are effective in their application.

SCF Controls: CPL-02, CPL-02.1, CPL-03, IAO-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CA.L2-3.12.2

> Develop and implement plans of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational systems.

SCF Controls: IAO-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CA.L2-3.12.3

> Monitor security controls on an ongoing basis to ensure the continued effectiveness of the controls.

SCF Controls: CPL-02, THR-01, THR-03

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters. Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CA.L2-3.12.4

> Develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.28

SCF Controls: IAO-03, IAO-03.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CA.L3-3.12.1e

> Penetration Testing

SCF Controls: VPM-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CM.L2-3.4.1

> Establish and maintain baseline configurations and inventories of organizational systems (including hardware, software, firmware, and documentation) throughout the respective system development life cycles.

SCF Controls: AST-01, AST-02, CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts

for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the

subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CM.L2-3.4.2

> Establish and enforce security configuration settings for information technology products employed in organizational systems.

SCF Controls: CFG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the Security.PasswordQualityControlPwquality setting on ESX hosts, including parameters such as minlen=15, maxrepeat=3, maxclassrepeat=4, difok=4, and enforce_for_root. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. `AppArmor` and `SELinux` provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as `ConfigMaps` and `Secrets`.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references `ConfigMaps` containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

VMware vDefend (Contributes)

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,

and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the advanced-system-config ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control CM.L2-3.4.3

> Track, review, approve or disapprove, and log changes to organizational systems.

SCF Controls: CHG-01, CHG-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's change management program, though the program itself must be established and governed through organizational policy and process.

VCF Operations is the central lifecycle management engine for the platform. It coordinates updates across the full stack and requires a precheck before applying any update to verify that the environment is ready. Lifecycle management tools within VCF Operations support planning updates so that administrators can schedule maintenance windows and make changes with minimal disruption to services. When updates are available, VCF Operations Fleet Management displays them through its Lifecycle view, where administrators can select a VCF instance and review pending VCF Operations updates.

vSphere Lifecycle Manager (vLCM) provides centralized lifecycle management for ESX hosts, drivers, firmware, and add-on software. vLCM uses desired-state configuration with a single image per cluster to maintain consistency across infrastructure components. Upon remediation, the image is installed on all hosts in the cluster, replacing the older baseline and baseline group approach from Update Manager. vLCM synchronizes to its download sources, including VCF Operations, on a regular and automatic basis. The Update Manager module provides PowerCLI cmdlets for downloading patches, creating and modifying baselines, and scanning and remediating hosts and virtual machines. Together, these components provide a structured, repeatable process for applying changes to the infrastructure.

VCF Operations extends change management support through configuration drift detection and source control integration. The Configuration Drifts feature tracks changes in product configurations over time and compares them against assigned desired values, providing scheduled drift detection for VMware vCenter and cluster objects to proactively detect configuration deviations from the desired state. Configuration Drifts Templates can be integrated with a source control repository (GitHub or GitLab), which enables versioning, auditing, and management of configuration templates. This integration supports change control with reviews and can be incorporated into continuous integration and continuous deployment pipelines for automated testing and validation of configuration changes. VCF Operations orchestrator also supports pushing local change sets to a Git repository, where each change set can consist of one or more modified orchestrator objects, providing a traceable record of automation changes. VCF Operations audit logging tracks each configuration change to the authenticated user who initiated the change or scheduled the job that performed it, allowing data center administrators to determine who changed what and when.

VCF Automation includes workflow capabilities with approval policies that require project administrators to review changes to deployed catalog instances before they take effect. This allows organizations to integrate change approval into their operational workflows. For organizations that use ServiceNow for IT service management, the ServiceNow ITSM Plug-in for VCF Automation integrates deployment lifecycle actions (such as power operations, lease changes, ownership transfers, and deployment edits) with ServiceNow change workflows. This allows VCF operational changes to be routed through an organization's existing ITSM change approval processes. Policy management capabilities within VCF Automation allow Organization Administrators to create, update, and manage policy definitions, providing a governance layer for controlling what changes are permitted within the platform.

NSX Global Manager provides change validation by checking proposed configuration changes against both Global Manager and Local Manager configurations before they are applied, reducing the risk of conflicting or disruptive network changes in federated environments.

Role-based access control across VCF components restricts who can make configuration changes. Audit logging across the platform captures change activity for review, including vDefend firewall audit logs that capture both old and new values for modified security policies and VCF Operations audit events that record interactions such as configuration modifications, logins, and capability checks.

VMware vDefend (Contributes)

VMware vDefend provides configuration change control mechanisms within its network security policy domain, contributing to governance of technical configuration changes for firewall rules, IDS/IPS settings, and microsegmentation policies.

Security Services Platform includes a deployment wizard that conducts thorough validations before implementing any configuration changes, verifying that configurations are correct and compatible before they take effect. This pre-deployment validation reduces the risk of misconfigurations that could disrupt network security enforcement or create unintended policy gaps. Security Intelligence extends this with staged policy enforcement, where initial policy recommendations can be deployed while traffic is allowed but monitored. Administrators can verify that recommended rules do not disrupt legitimate operations before enabling full enforcement, providing a controlled transition path for firewall policy changes.

Security Intelligence includes a Monitoring capability that checks for changes in the scope of input entities every hour when enabled. This change detection helps administrators understand when underlying conditions have shifted and policies may need updating. Security Intelligence also tracks the number of new configurations per configuration type on an hourly basis, providing visibility into the rate and scope of policy changes across the security environment.

In multi-site deployments, vDefend enforces a hierarchical configuration model through the Global Manager and Local Manager architecture. In federated environments, the Global Manager centrally manages IDS/IPS signatures, profiles, Distributed Firewall (DFW) and Gateway Firewall (GFW) policies, oversubscription settings, and syslog settings across all mapped Local Managers. Settings configured on a Local Manager remain local to that site and are not propagated to other managers, supporting site-specific change control while preserving global policy consistency.

vDefend provides a draft-based publishing model that gives administrators explicit control over when policy changes take effect. Administrators can create manual drafts of firewall configurations, save them as new configurations or updates to existing ones, and lock them with a required comment before publishing. When a draft is published, vDefend automatically saves an auto draft that captures the configuration state immediately before the publish operation. This auto draft is a rollback mechanism, allowing administrators to restore the previous firewall policy state by republishing it if an applied change produces unintended results. Auto drafts and manual drafts can also be cloned and saved for additional change management flexibility.

vDefend IDS/IPS provides a bulk edit feature for system signatures that includes a Reset action, allowing administrators to restore default signature configurations when changes need to be reversed.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display

messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support configuration change control for managed database infrastructure. System-wide settings are accessible only to DSM administrators through the Settings view in the Provider interface and the Dashboard, which restricts who can initiate configuration changes. This role-based access model limits changes to infrastructure policies, VM class definitions, network settings, and directory service configuration to authorized personnel.

DSM supports controlled change scheduling through its Maintenance Policy, which allows administrators to configure a start date and duration window for applying software updates to DSM appliances and the DSM plug-in. The Maintenance Policy editor is accessible from the Version & Upgrade section under the DSM System tab in both the vSphere Client and the DSM UI. The policy cannot be modified while a Provider Appliance software update is in progress, preventing changes to the update schedule during active operations. For database minor-version upgrades, DSM provides a separate maintenance window setting with a default configuration of six hours beginning each Saturday at 23:59, giving administrators control over when updates are applied to individual database instances.

DSM's Operations tab provides visibility into the progress of database configuration changes as they are applied. System configuration is managed through a `dsmsystemconfig` Custom Resource within the gateway that can be inspected via SSH access to the appliance VM, allowing administrators to review applied settings and verify configuration state.

Certain configurations are intentionally protected from modification after initial deployment. The Management Network for the Provider VM cannot be changed after deployment. Infrastructure policies actively in use by a database cannot have existing settings modified, though new compute resources can be added to them. Policies not currently assigned to any database can have settings changed at any time. Certain MySQL parameters are restricted from user modification by design. System-level settings cannot be modified when applying DSM system settings fails, providing a safety constraint against partial configuration changes.

DSM does not provide a formal change management workflow with approval routing, change ticketing, or mandatory review steps. Satisfying this control fully requires organizations to establish governance procedures that operate alongside DSM's technical controls, including formal change authorization processes, documentation requirements, and post-change verification practices that DSM itself does not enforce.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control CM.L2-3.4.4

> Analyze the security impact of changes prior to implementation. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

----- CHAPTER THREE PAGE 22 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: CHG-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CM.L2-3.4.5

> Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems.

SCF Controls: CHG-04, TDA-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support the separation of development, testing, and operational environments, though the organizational policies and governance processes that define environment boundaries and enforce segregation must be established independently.

VCF workload domains provide infrastructure-level separation, allowing administrators to deploy distinct domains for development, testing, and production workloads with independent compute, storage, and networking configurations. Each workload domain operates with its own resource boundaries and management policies, and configuration settings appropriate for one environment tier may differ from those used in another. VCF documentation explicitly notes that configuration appropriate for development environments may not be suitable for production environments within the same deployment.

VCF Operations includes an environment classification feature that allows administrators to tag Business Application environments as Development, Production, Staging, Test, or DR. This classification enables differentiated monitoring and management across environment tiers. Administrators can configure custom groups with distinct alert policies and capacity calculations for production environments versus testing environments, allowing each tier to operate under monitoring rules appropriate to its purpose. The VM Performance and VM Contention dashboards note that development environments can tolerate a small amount of contention in CPU and memory, while production environments should not, reinforcing the need for distinct operational treatment per environment.

VCF Automation provides organizational and project-level isolation boundaries that map naturally to environment separation. Each organization in VCF Automation operates in an isolated environment with dedicated network setup and network isolation, where users can access only allocated services and resources. Within an organization, projects create additional isolation boundaries between teams, and namespace-level isolation adds a further layer of separation. Security groups and vDefend firewall rules support network isolation between project environments. When stronger isolation is required between environment tiers, multiple projects or organizations can be used; when isolation requirements are lower, fewer projects simplify the operating model. These constructs give administrators the building blocks to enforce separation between development, testing, and production workloads.

NSX Projects enable isolation of networking and security configurations for multiple departments or organizational units within a single NSX deployment, allowing network-level separation between environment tiers. NSX multi-tenancy isolates security and networking objects across tenants, supporting the use of separate tenant configurations for development, testing, and production environments.

vSphere provides workload isolation at multiple levels. Each VM runs as an isolated system protected from interference by other VMs or workloads. Resource pools isolate virtual machine performance from other users of the same pool. Namespaces provide additional isolation for containerized workloads, and administrators can assign different port groups as the network for each namespace, providing layer 2 isolation between namespaces. Cross-namespace communication is blocked unless explicitly permitted. vSphere Auto Deploy requires secure network separation between the production network and the management or deployment networks, making this separation a prerequisite for stateless or stateful ESX host provisioning workflows.

The VCF CLI supports context-based environment switching, enabling administrators to move between local development, staging, and production clusters without requiring constant configuration updates. This helps maintain clear boundaries between environments during day-to-day operations and reduces the risk of accidental changes to production systems.

VCF also supports a test-before-production discipline across several components. VCF Operations allows test runs before final deployment to verify that management packs collect correct data and accurately represent the target system. The documentation recommends testing newly created configuration files for the Management Pack for Aggregator with a test instance before applying them to production systems. For VM-based workloads on vSphere Supervisors, administrators are directed to create production images with the latest patches and required security settings that follow corporate security policies, establishing a controlled promotion path from development to production. Administrators can also configure more restrictive VIB acceptance levels for ESX hosts in production than for hosts in testing environments, limiting which software packages can be installed on production infrastructure.

vSphere administrators set guardrails for the policy and governance of VMs, delivering VM resources such as VM classes and VM templates to DevOps engineers. This separation of administrative and consumer roles restricts who can modify production infrastructure versus who can consume resources in development or testing namespaces.

Defining which environments are designated as development, testing, or production, establishing access policies for each, and managing the lifecycle of changes across those environments requires organizational processes beyond what VCF provides. VCF supplies the isolation mechanisms and classification tools; the organization must define the policies that govern how those mechanisms are used.

VMware vDefend (Contributes)

VMware vDefend provides network-level enforcement mechanisms that support separating development, testing, and operational environments, reducing the risk of unauthorized access or cross-environment changes.

The Distributed Firewall enables environment isolation through microsegmentation, dividing the data center into broader security zones such as production, development, testing, and PCI environments. Distributed Firewall rules are enforced at the vNIC level, so environment boundaries are maintained even when workloads from different environments share the same physical hosts or network segments. The Gateway Firewall in vDefend can enforce isolation between projects by denying all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP, while permitting internal team communication within isolated development virtual private clouds.

Security Services Platform provides purpose-built tools for defining environment hierarchies and configuring segmentation policies. Administrators define environments by specifying which virtual machines, IP addresses, distributed virtual port groups, and network segments belong to each environment using CSV files, which Security Intelligence uses to create groups and apply appropriate tags. When implementing environment pair controls, the recommended approach is to apply a broad block policy between sensitive pairs such as Testing and Production as an initial step, then identify all inter-environment flows and add specific policies before enforcing a strict block. Security Intelligence administrators can monitor traffic leakage between environments, establish permitted exceptions, and apply lockdown protection rules to control inter-environment traffic.

The Security Segmentation Score provides a quantitative view of segmentation coverage. The Environment Protection component evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test, contributing five points to the overall score. The security segmentation score breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies. The Environments monitoring window shows the total number of inter-environment pairs and how many are without inter-environment policies. Segmentation Planning supports the design phase by allowing administrators to publish environments together with related applications to maintain proper correlation between them. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy, including regions, zones, and virtual machines, to verify that the environment hierarchy is correctly defined before enforcement begins.

For Virtual Desktop Infrastructure deployments, Security Services Platform recommends isolating VDI servers from server-based traffic patterns and preventing separate VDI environments from communicating with one another.

Defining which workloads belong to which environment, determining which environment pairs may communicate, and managing the lifecycle of configuration changes across environments require organizational processes and decisions that vDefend does not govern. vDefend enforces the network boundaries once those decisions are made.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces configuration restrictions through a role-based access control (RBAC) model that restricts the ability of users to make unauthorized changes to disaster recovery configurations. PNR defines predefined roles with distinct privilege sets, and administrators can create custom roles by cloning existing ones and removing specific privileges to enforce least-privilege access.

PNR provides predefined roles including the Protection and Recovery Administrator and the Protection Groups Administrator, each granting a specific set of privileges over protection groups, recovery plans, and site configuration. The Protection and Recovery Administrator role is required to add or modify roles that restrict or grant user access; this role cannot edit inherited permissions, establishing a boundary on privilege escalation. Certain roles allow users to run commands on the Protection and Recovery server, and the product documentation recommends these roles be assigned only to trusted administrator-level users.

PNR also includes a Test Administrator role, a constrained role that allows users to run and monitor recovery plan tests without the ability to configure protection on virtual machines, create protection groups or recovery plans, or execute recovery or reprotect operations. This role supports separation of duties by enabling test-execution responsibilities to be delegated without granting configuration change privileges.

For operations that configure protection on virtual machines, users must hold explicit permissions on both the protected and recovery site VMware vCenter instances. Site-wide permission assignments must be added on a per-site basis with corresponding permissions required at both sites. In shared recovery site configurations, users must not be allowed to change roles or assign permissions for objects that are not dedicated to their own use. PNR restricts users from renaming, moving, or deleting data centers or hosts in shared recovery site configurations, adding a structural boundary on unauthorized infrastructure modification.

Protection groups in PNR can only be edited on the source site. On the peer site, the protection group is in dormant or recovery state and cannot be edited until the data protection group is active. Protection groups cannot be edited while in Reprotecting state. These state-based restrictions limit the window during which configurations can be changed.

Protection groups can be configured with immutability mode, which blocks modification or deletion of the protection group after immutability is enabled. This option provides a configuration-level lock that is independent of role assignments and restricts changes to protection definitions even by users with administrative access.

PNR Advanced Settings, accessible under Site Pair > Configure > Advanced Settings, are restricted to users with adequate privileges. Users without sufficient permissions cannot view or change custom settings that affect the operation of protection and recovery features.

PNR server access is restricted to administrators only to reduce the number of accounts available for unauthorized access. Users who have their permission removed on a protected site are blocked from continuing operations, and the product returns a permission denial error when users without appropriate privileges attempt restricted operations. Users must have permissions to perform IP customization and in-guest OS callout operations during the recovery process.

vSphere Replication supports similar restriction capabilities. The VRM Administrator role can be cloned and modified to remove specific privileges, creating a custom role with a narrower permission set. The VRM Replication Viewer role restricts users from performing any modifications to configured replication or replication sites, and users assigned this role receive a permission denial error when they attempt operations that require higher privileges.

When PNR is deployed with VCF Automation, access is controlled through role-based permissions assigned to Provider Administrators, Organization Administrators, Project Administrators, and Project Advanced Users, providing a tiered permission model for multi-tenant environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that restrict the ability of users to make unauthorized configuration changes within its database-as-a-service platform. These controls span access scoping, policy enforcement, and technical guardrails on configuration parameters.

DSM's role-based access control model establishes clear boundaries for who can change what. The DSM Administrator role retains broad change authority, while users assigned the DSM User role can view and manage only the objects they own. When assigning the DSM User role, administrators can restrict access to one or more specific namespaces, limiting the scope of any changes a user can make to only those namespaces. For databases created in the default namespace, only the database owner can change database VM resources such as compute configuration; in other namespaces, users with namespace access may also change resources for databases within their assigned scope. Only the database owner can perform administrator password changes for databases under their management.

Data service policies give administrators a structured way to define and enforce configuration restrictions across data services and tenants. For MySQL and PostgreSQL, the "Disallow Custom Database Options" setting fully restricts users from adding any database parameters, removing that option from the user interface entirely. Alternatively, administrators can create an allowlist of approved parameters, limiting users to selecting only from that pre-approved set. For SQL Server databases, data service policies support an "Allow with a List" option that restricts users to a specific allowlist of approved parameters. Policies can be enforced across different tenants, supporting consistent configuration standards across multi-tenant environments. Before a policy is created or modified, DSM displays any violations that would occur if the policy were applied to existing databases, giving administrators a review step before changes take effect.

PostgreSQL databases support host-based authentication (HBA) configuration, which allows administrators to define rules restricting which hosts can connect and with what authentication method. DSM restricts the system-defined pgadmin user from being used to enforce host-based access restrictions in the `pg_hba.conf` file because the system evaluates pre-existing authentication entries for that user before custom rules; administrators who require specific host-based restrictions must create a separate custom login rather than relying on the system-defined account.

Infrastructure policies provide additional guardrails. When an infrastructure policy is actively in use by a database, its existing settings cannot be changed; only new compute resources with corresponding parameters can be added. VM classes that are associated with an infrastructure policy cannot be edited. IP pools associated with an active infrastructure policy are similarly restricted to adding new IP ranges only; no other parameters can be changed while the pool is in use. Users must have appropriate DSM permissions to configure infrastructure policies at all.

For SQL Server, DSM uses an internal `dsm_mgmt` management login that restricts users from accessing or modifying system-level objects. The cluster administrator login is granted restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full privileges, limiting the scope of changes that can be made through that account.

DSM also enforces that system-level settings cannot be modified, and certain database engine parameters cannot be changed or set by users regardless of their role; any attempted user changes to those parameters are automatically overwritten.

DSM contributes to this control by providing role-scoped access, policy-based configuration enforcement, and technical immutability for certain settings and active configurations. The broader organizational change control process, including defining approval workflows, maintaining a change request system, and enforcing separation of duties for modifying the policies themselves, remains outside DSM's scope and requires organizational governance processes and tooling beyond the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms at the application delivery layer to support separation between development, testing, and operational environments. The primary isolation mechanism is Avi's multi-tenant architecture: a single Avi Controller cluster can host each environment in a dedicated tenant with RBAC-enforced access boundaries, or organizations can deploy separate Controller clusters per environment. Controller cluster topology supports this separation; each Controller cluster can be configured as a one-node cluster for development and testing, or a three-node cluster for production, giving organizations a clear infrastructure-level distinction between environment tiers.

Within a single-cluster deployment, Avi's tenant model provides administrative isolation, scoping visibility and access to objects within tenant boundaries. Service Engine Groups provide data-plane isolation: virtual services for test and production environments should be deployed on different Service Engine Groups, so application traffic from test workloads is handled by different data-plane VMs than production traffic, reducing the risk of cross-environment data flows. An administrator can

deploy virtual services for the same application in both test and production environments on different Service Engine Groups within the same tenant, or across separate tenants for stronger isolation.

In 9.1, the Avi for VCF integration adds dedicated environment isolation constructs. Service Engine Group allocation within VCF Automation blueprints for Layer 4 and Layer 7 virtual services provides operational isolation, keeping each project within its designated boundaries. Namespace allocation in the Avi Controller similarly scopes each project's resources. In Organization-Managed Mode, organization administrators manage their own Service Engine Group configurations and infrastructure settings, reinforcing the organizational boundary between environment owners. VCF Automation integration supports infrastructure-as-code workflows, which can be used to apply consistent environment configurations across development, testing, and production tiers.

Service Engine deployments using dedicated management mode provide network isolation between data and management traffic, separating the management plane from application traffic paths.

Organizations should define which Avi tenants map to which environments, establish RBAC policies that restrict personnel from operating across environment boundaries, and configure distinct Service Engine Groups for each tier. The Avi Controller's configuration audit log supports review of whether environment boundaries have been respected during configuration changes.

Control CM.L2-3.4.6

> Employ the principle of least functionality by configuring organizational systems to provide only essential capabilities.

SCF Controls: CFG-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of configuration controls that restrict systems to only essential capabilities by controlling ports, protocols, and services across the platform stack.

At the hypervisor layer, VMware ESX hosts include a built-in host firewall that controls which ports and services are accessible. The firewall supports specification of allowed hosts through the `allowedHosts` parameter, so administrators can limit which IP addresses may connect to specific services. Services such as SSH (TSM-SSH) can be individually started or stopped through the VMware Host Client, giving administrators direct control over which management services are running. ESX lockdown mode restricts host access so that all management is performed through VMware vCenter, with an Exception Users list for controlled overrides when direct host access is needed. ESX also supports disabling unexposed features through isolation configuration parameters, removing functionality that is not needed in the environment.

Port groups on distributed switches are communication boundaries where security policies can be configured. Each port group carries its own security policy settings, including controls over promiscuous mode, MAC address changes, and forged transmits. Administrators can modify these policies to restrict which types of network traffic virtual machines are permitted to generate or receive. Each port group can also be assigned a VLAN ID to restrict traffic to a logical Ethernet segment. SpoofGuard and switch security profiles can be applied to distributed port groups to prevent traffic spoofing and enforce network security policies at the virtual switch layer. Distributed port groups also support Port Blocking Policies, which allow administrators to selectively block ports from sending or receiving data, including blocking all ports within a group simultaneously. Traffic Filtering and Marking Policy can be applied at the individual distributed port or uplink port level to permit or stop traffic flows through virtual machines, VMkernel adapters, and physical adapters. Port-level configuration overrides on distributed virtual switches are deactivated by default, so permitting per-port policy exceptions requires deliberate administrator action. The virtual serial port proxy provides an additional gateway that enforces security for remote serial port connections, restricting access to only authorized communication paths.

Management traffic is isolated on dedicated networks. The Fleet Level Components on Dedicated Management Network model uses VLAN-backed distributed port groups to provide isolation from other networks. NSX allows configuration of services with port and protocol pairing, and these services can be referenced in firewall rules to allow or block specific types of traffic.

The platform documents explicit port requirements for each component. When vSAN is enabled on a cluster, required ports are added to ESX firewall rules and configured automatically, keeping firewall configuration aligned with actual service requirements rather than leaving unnecessary ports open. VCF Operations Cloud Proxy requires only ports 4505, 4506, and 8443 via TCP for application monitoring, establishing a minimal set of allowed network communication paths. These defined port lists give administrators a clear baseline of what must be open rather than relying on permissive defaults.

VCF Operations supports firewall hardening, which when activated restricts network access to internal services, limiting exposure to only the ports and protocols required for operation. A service discovery policy setting controls whether the system actively discovers services on the network; disabling this policy reduces the attack surface by preventing unnecessary service enumeration, though administrators should be aware that turning it off changes the security posture of the operating system. For orchestration functions, VCF Operations enforces privilege requirements where ports below 1024 can only be opened with superuser privileges on Linux systems, providing an inherent restriction on which processes can bind to well-known service ports. VCF Operations also collects ESX security properties including service running status, firewall rulesets, service policies, and disabled protocols when the vSphere Hardening Guide policy is applied, giving administrators visibility into the least-functionality posture of each host.

The Security Configuration Guide provides recommendations for disabling unnecessary services and enabling security features on ESX hosts as a baseline for least-functionality configuration.

At the workload consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor enforce least functionality across compute, kernel, and network dimensions for containerized workloads. Pod Security Admission (PSA), enabled by default in Supervisor clusters running VKS 1.25 and later, enforces Kubernetes Pod Security Standards at the namespace level. Administrators configure each namespace with an enforcement profile from three options: Privileged (no restrictions), Baseline (blocks known privilege escalation paths), and Restricted (heavily restricted, following pod hardening practices). Each profile supports three independent modes: enforce (rejects non-compliant pods at admission), audit (records violations in the audit log without blocking), and warn (surfaces policy warnings to the requesting user without blocking), allowing operators to gain visibility into policy gaps before tightening enforcement. The Restricted PSA level requires containers to drop all Linux capabilities, blocks host networking, host PID, and host IPC namespaces, restricts volume types to a safe subset, disallows privilege escalation by setting `allowPrivilegeEscalation` to false, and requires a defined Seccomp profile. Supervisor applies the `vmware-system-restricted` Pod Security Policy by default to VKS clusters, which blocks privileged container access, helps prevent root escalation, and restricts permitted volume types; standard packages such as Contour also reference this policy so that system components operate under the same restricted constraints. VKS Cluster Management Security Policies provide an additional management layer for pod security within VKS clusters; when creating a security policy, the Restricted pod security policy template offers a preconfigured tight security context that constrains pod privileges and capabilities across the cluster.

Kubernetes pod and container security context configuration allows administrators to add or drop specific POSIX kernel capabilities through the `securityContext.capabilities` field, restricting which kernel operations individual containers may exercise. Pods can be configured with Seccomp profiles that filter the system calls available to containers; the `RuntimeDefault` profile applies the container runtime's default system call filter and blocks calls not required by typical applications, while custom profiles allow more precise control. The Restricted Pod Security Standard makes a defined Seccomp profile mandatory for compliant workloads. Supervisor also supports SELinux, which restricts access to files, applications, ports, and processes through labels and security policies enforced on tagged processes, and AppArmor profiles that restrict a container's abilities by enforcing a defined set of rules and restrictions on process behavior at the kernel level. On Ubuntu and Photon nodes in VKS clusters, AppArmor additionally controls file system access and network access, extending mandatory access control across multiple resource dimensions beyond process behavior alone. These mechanisms operate independently of Kubernetes admission controls and provide a defense-in-depth layer for workload capability restriction. Kubernetes ephemeral containers disallow ports, `livenessProbe`, and `readinessProbe` fields, further restricting their capabilities relative to standard containers.

Network-level least functionality for VKS workloads is enforced through Kubernetes NetworkPolicy objects, implemented by Antrea or NSX-based CNI plugins in Supervisor, which restrict ingress and egress traffic at the pod and namespace level by port, protocol, and peer selector. Cluster administrators can restrict the IP address ranges allowed for Kubernetes Services through centralized management of ServiceCIDR resources, reducing the scope of reachable service endpoints across the cluster. Access to control plane ports such as the etcd API port should be restricted at the network level to only specified and trusted IP address ranges. VKS control plane nodes enforce a set of default inbound firewall rules that administrators cannot override, covering only the ports required for control plane operation, including TCP 6443 for the kube-apiserver, TCP 2379-2380 for etcd, TCP 22 for SSH, TCP 179 for BGP, and TCP 10100 for the kapp-controller, among others. The kubelet `allow-privileged` flag controls whether privileged containers are permitted on cluster nodes. The Istio CNI plugin, configurable through the `istioCNI.enabled` setting, manages pod network interfaces and enforces network policies without requiring privileged containers, reducing the need for elevated privileges in service mesh deployments. Kubernetes guidance documented in Supervisor materials states that access control components operating with high privileges should be isolated from general workloads using namespace boundaries, so that privilege is scoped to where it is operationally required.

VCF Automation provides security groups that define isolation settings for on-demand private or outbound networks, allowing administrators to restrict which services and ports are accessible within network segments. Network profiles support isolation policies defined as either on-demand or existing security groups, enabling granular control over network communication boundaries.

For ongoing compliance verification, VCF Network Operations provides a search query capability to identify firewall rules that permit any port, querying for rules where the action is set to allow and the service is configured as "any." This allows administrators to systematically find and remediate overly permissive rules that violate least-functionality principles, restricting access to only the ports and protocols that are explicitly required.

VMware vDefend (Meets)

VMware vDefend provides the primary enforcement mechanism for least functionality at the network layer, allowing administrators to configure systems so that only essential ports, protocols, and services are permitted.

vDefend (DFW) operates per workload and supports Allow, Drop, or Reject actions on traffic matching defined services with specific port and protocol pairings. Administrators build policies that permit only the traffic required for a workload's function while denying everything else. DFW policies can explicitly block insecure protocols such as Telnet, FTP, and TFTP across the data center, actively blocking protocols that should not be present in the environment. DFW governance implements a least-privilege posture by preventing overly permissive rules such as "ANY/ANY/ANY ALLOW," guiding administrators toward specific port and protocol restrictions rather than broad allow policies. Rules are processed in precedence order across multiple policy sections, giving administrators fine-grained control over which traffic categories are evaluated first.

vDefend extends least-functionality enforcement to inter-project and perimeter boundaries. Gateway Firewall rules support configurable service selection, allowing administrators to specify a blanket block on all protocols or access restricted to specific ports for selective inter-project communication. Enterprise administrators can configure inter-project isolation policies that allow only essential infrastructure protocols while denying all other inter-project communication, defining perimeter-level traffic boundaries based on what each segment actually requires.

Security Intelligence, part of the Security Services Platform, provides traffic flow analysis with protocol and port filtering. Administrators can analyze observed flows using Exclude or Match criteria, supporting up to 15 entries of single ports, port ranges, or protocols. This visibility helps administrators verify that only essential ports and protocols carry traffic and identify unexpected communication patterns that may indicate unnecessary services remain enabled. Security Intelligence also provides guidance on restricting risky application protocols that transport data in clear text, flagging these for restriction or replacement as part of the overall least-functionality posture.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the Least Functionality control through its infrastructure policy framework and data service policy allowlists, which restrict what network resources, compute configurations, and service parameters are available to database consumers.

Infrastructure policies are the primary mechanism. Each infrastructure policy requires the selection of specific network port groups for each compute resource (network-port-group setting), and at least one IP pool must be defined for each selected port group (ip-pools setting). This constrains which network segments database instances can attach to, restricting consumers from selecting arbitrary network endpoints. Infrastructure policies must be explicitly enabled before they become available for database provisioning; policies that are not yet ready for use can be kept deactivated (infrastructure-policy-enabled setting), which limits which network configurations are offered to consumers at any given time. DSM also validates infrastructure policy IP ranges against system configuration networks, detecting and rejecting overlapping configurations before they take effect.

Data service policies build on infrastructure policies to create a tiered allowlisting mechanism. Each data service policy requires the selection of at least one infrastructure policy, and in the self-service consumption model, the DataServicePolicy custom resource's allowedInfrastructurePolicies field enumerates precisely which infrastructure policies authorized consumers may use. Database users cannot select infrastructure configurations outside the approved set defined by administrators. Infrastructure policies also filter storage policies to display only those compatible with the designated compute resources, further narrowing the options available at provisioning time.

Infrastructure policies create broader resource guardrails as well: the overall policy framework restricts the quality and quantity of resources DSM users can consume from vSphere clusters, and database clusters are deployed with infrastructure and storage policies that enforce isolation and resource constraints from the moment they are provisioned.

Data service policies support an "Allow with a List" option, which creates a specific allowlist of approved parameters that users can select from during provisioning. SQL Server data service policies extend this pattern: they require selection of at least one infrastructure policy and restrict instance provisioning and server-level configuration, including Active Directory integration and high availability settings, to administrators only.

For PostgreSQL databases, DSM provides an additional connection control capability. The Block Database Connections operation can stop existing client connections and block new ones from being established, with exemptions only for monitoring, replication, and internal service traffic. This allows administrators to restrict access to a database instance to only the services required for continued operation.

DSM's contribution to this control is scoped to the database-as-a-service layer. Restrictions on ports, protocols, and services at the network perimeter, host, or hypervisor level depend on the underlying VCF platform, NSX networking configuration, and vDefend firewall policies outside DSM's direct control. Organizations should complement DSM's policy framework with platform-level network security controls to fully address the Least Functionality requirement.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides mechanisms for restricting ports, protocols, and services at the application delivery layer, supporting least-functionality configurations for application traffic and management access.

At the application traffic layer, each virtual service accepts traffic only on explicitly configured service ports. The per-Service-Port profile configuration (ApplicationProfile or NetworkProfile) can be overridden on a per-service-port basis for advanced use cases. Virtual Service Network Security Policies can match on service port to filter traffic based on TCP service ports on which the virtual service is listening, allowing administrators to explicitly permit or block traffic by protocol and port on a per-virtual-service basis.

For Controller management access, Avi provides several mechanisms to restrict access to management channels. The Client Management Access configuration allows administrators to define allowed SSH clients, allowed CLI shell clients, allowed external HTTP(S) clients, and allowed external SNMP clients separately, each scoped to specific IP addresses, ranges, subnets, or IP groups. Management channels not included in the configured allowlist are blocked. This configuration is accessible through the Securing Management IP Access workflow in the Controller UI under System settings. Trusted host profiles can be configured to restrict which hosts are permitted to access the Controller, providing an additional layer of host-identity-based access restriction. The Controller also limits the allowed ciphers and HMACs for management sessions, reducing the cryptographic surface exposed on each management channel.

Security groups for Avi Controller and Service Engines specify the protocol ports for which traffic is permitted between components, providing a defined port inventory that administrators use to scope surrounding network controls.

These capabilities apply at the application delivery boundary. Least-functionality controls for the underlying compute, storage, and network virtualization layers are provided by VCF, which is rated Meets for this control.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CM.L2-3.4.7

> Restrict, disable, or prevent the use of nonessential programs, functions, ports, protocols, and services. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

CHAPTER THREE PAGE 23 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: CFG-03.1, CFG-03.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for periodically reviewing system configurations to identify unnecessary or non-secure functions, ports, protocols, and services. These capabilities span configuration drift detection, compliance benchmarking, software image validation, dedicated review dashboards, and scheduled reporting.

VCF Operations includes a Configuration Drift feature that provides scheduled drift detection for VMware vCenter instances and vSphere clusters. Configuration templates define the desired state for each setting, and the Detect Drift function compares current values against template values, displaying any deviations in a drift dashboard. Drift detection can be scheduled to run automatically, and drift status reports can be downloaded for review. Configuration templates can also be integrated with a source control repository to support versioning, auditing, and change control of the desired configuration state.

For structured configuration review workflows, VCF Operations provides a suite of eight Configuration Review dashboards that form an integrated optimization flow. These dashboards are designed as a set and should be used together when conducting configuration review cycles. They include the Consumer Optimize it?, Consumer Correct it?, Consumer Update it?, Provider Optimize it?, and Provider Update it? dashboards, among others. Each dashboard presents configuration data in a list view format that can be reviewed independently, allowing administrators to systematically work through configuration items that require attention. The dashboards surface configuration elements that deviate from expected baselines, allowing reviewers to identify settings that need correction or optimization. The Network Configuration dashboard specifically targets network-related configuration review, displaying network configurations that need attention and including five bar charts focused on critical security settings. This provides a consolidated view of network security posture, making it straightforward to identify non-secure configurations across the environment's networking layer.

For security-specific configuration review, VCF Operations continuously monitors infrastructure against compliance benchmarks. The VMware SDDC Benchmark monitors objects for violations of the vSphere Security Configuration Guide, vSAN Security Configuration Guide, and NSX Security Configuration Guide. These benchmarks include both automated compliance assessments and manual checks based on industry-standard best practices. Non-compliant objects and their associated violations are identified automatically, giving administrators a clear view of where configurations have deviated from security baselines.

At the host level, VCF Operations provides the Configure Host Security Config Data workflow, which allows administrators to selectively enforce host security hardening rules by configuring individual configuration elements under Enforce Options. This supports both the review of current host configurations against hardening standards and the remediation of non-compliant settings. VCF Operations also collects VMware ESX security properties including service running status, firewall rulesets, service policies, and TLS disabled protocols when the vSphere Hardening Guide policy is applied.

VCF provides granular control over port group security policies at the virtual networking layer. Security policies on port groups can be reviewed and modified to control behaviors such as promiscuous mode, which governs whether virtual machines can monitor traffic on the port group. Reviewing and restricting these settings is part of identifying and disabling unnecessary or non-secure network functions.

vSphere Lifecycle Manager (vLCM) adds another layer of periodic review by defining a desired software image for each cluster and performing compliance checks to determine whether hosts conform to that image. When the current state of a host differs

from the desired specification, vLCM can apply remediation to bring the host back into compliance. For baseline-based deployments, the compliance check schedule can be configured with a specific frequency and starting point, allowing organizations to align automated checks with their periodic review cadence. vSphere Host Profiles provide a complementary mechanism by capturing a reference host's complete desired configuration state and verifying that other ESX hosts conform to it, covering the full range of host configuration settings beyond software image compliance.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), the platform provides analogous mechanisms for periodic configuration review at the cluster and workload level. Kubernetes role-based access control configurations, including Roles, ClusterRoles, RoleBindings, ClusterRoleBindings, and ServiceAccounts, should be reviewed at defined intervals; Kubernetes documentation recommends access reviews at intervals no greater than 24 months, with guidance on what to examine during each review. Security Technical Implementation Guides for VKS components, including Supervisor and Kubernetes releases (VKrs), are available through Tanzu STIG Hardening and provide hardening benchmarks that serve as baselines for periodic configuration reviews. Administrators can compare current settings against the relevant STIG to identify configurations that deviate from hardening requirements, including enabled features or services that should be restricted.

Pod Security Standards, configurable at the namespace level through the `podSecurityStandard` variable, support three enforcement modes that aid ongoing configuration visibility: audit mode records policy violations in the Kubernetes API server audit log without rejecting workloads, allowing administrators to observe which pods are running outside of hardened profiles between review cycles; warn mode issues warnings at admission time for non-compliant pods; and enforce mode blocks non-compliant pods outright. Each mode can be pinned to a specific Kubernetes minor version or set to track the latest, giving administrators explicit control over when stricter checks take effect across namespaces. Seccomp profiles, applied at the pod and container level via security contexts, restrict which Linux system calls workloads are permitted to make, reducing the kernel attack surface for running containers. The Security Profiles Operator can manage and distribute seccomp, AppArmor, and SELinux profiles at scale across clusters, supporting consistent configuration review and enforcement across large deployments. Harbor, available as a standard package for VKS clusters, provides vulnerability scanning of container images and policy-based access control for registries, with scan results informing periodic reviews of the software components running in clusters.

VKS cluster management also provides out-of-the-box security policy templates, including baseline and restricted profiles, that mirror Pod Security Standards. These templates give administrators a defined policy baseline against which cluster configurations can be evaluated during periodic reviews, helping identify workloads or namespaces operating outside an expected security profile.

To support periodic scheduling of configuration reviews, VCF Operations report generation can be configured with a periodicity of every two weeks or on monthly intervals. This allows organizations to establish a regular cadence for generating configuration review reports, which can then be used to drive remediation activities. Alert definitions within VCF Operations can be configured to monitor infrastructure for configuration changes or deviations. Custom alert policies can be created to govern how alert definitions are evaluated, including which virtual machines and related hosts to monitor. VCF Operations tracks whether the same alert has been triggered on an object in the past 30 days to help distinguish recurring problems from new issues. Combined with proactive monitoring capabilities that continuously track the state of the environment, VCF provides both scheduled and ongoing mechanisms for configuration oversight.

VMware Private AI Services (PAIS) centralizes its configuration in the `PAISConfiguration` custom resource, a YAML-defined Kubernetes artifact that governs the configurable aspects of the platform. Operators have a single, versioned object that can be examined, patched with `kubectl patch PAISConfiguration`, or updated through the VCF Automation UI to reflect the intended state of the platform. This gives administrators a discrete configuration surface to review and adjust during periodic baseline checks.

PAIS supports client TLS configuration with CA bundle references for OIDC provider and Harbor authentication through the `clientTls.caBundleRefs` field. Administrators can review the configured trust bundles and rotate them in step with the organization's certificate lifecycle. Harbor registries are the recommended image and model registry for PAIS deployments,

with OCI-compliant registries from other vendors also supported, giving operators a defined artifact set to examine for unnecessary repositories or stale content.

Observability is configured through the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource, which activates Prometheus metrics collection with a configurable storage class and a metrics retention period that defaults to 14 days. LLM traces can be sent to an OpenTelemetry Collector through the same configuration surface. PAIS Controller metrics are exposed at a Prometheus endpoint on the `pais-controller-manager` service, and a Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for visualization in VCF Operations or Grafana. These surfaces give operators the data needed to detect anomalies, identify idle or underutilized GPU devices in passthrough mode, monitor vGPU licensing status, and flag pods with frequent container restarts during periodic reviews.

Model Gallery supports validation and upload of ML models, including evaluation of a model's performance and safety against inference requests for malicious behavior before deployment. The Gallery assigns a unique digest to each revision when the same model is pushed multiple times, giving administrators a stable identifier to use when reviewing which model versions are present and active across organizations and environments.

Periodic review of PAIS configurations depends on organizational processes to define review schedules, document configuration baselines, and act on findings. PAIS provides the configuration surfaces and observability tooling; the cadence and scope of review are organizational responsibilities the platform does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend provides several capabilities that support the periodic review of security configurations to identify unnecessary or non-secure functions, ports, protocols, and services within the network security domain.

Security Intelligence, a capability within the Security Services Platform (SSP), continuously analyzes network traffic flows and generates policy recommendations based on observed communication patterns. Recommendation analysis jobs progress through status states including Waiting, Discovery in Progress, Ready to Publish, and Published. Administrators should review generated recommendations when the status reaches Ready to Publish before publishing them to enforcement. When the applied-to scope of a security policy changes, or when new effective members are added or removed from the originally selected entities, existing Security Intelligence recommendations should be reviewed and rerun to reflect the updated environment. This recommendation engine identifies rules that may be overly permissive or unnecessary based on actual traffic patterns, directly supporting the periodic review process described in this control.

The vDefend documentation recommends that administrators periodically audit and remove unused or outdated Distributed Firewall policies and rules, using flow inactivity data and Security Intelligence recommendations to identify stale rules that can be safely removed. Policy Recommendations can be reviewed through the Monitoring Applications interface before being published, and the Review and Rerun interface allows administrators to revisit recommendations when environment changes are detected.

The Security Overview Dashboard provides a Configuration tab that summarizes the current state of all security policies, including counts and links for Firewall Policies, IDS/IPS Policies, Malware Prevention Policies, and TLS Inspection Policies. This centralized view gives administrators a starting point for periodic configuration reviews across all vDefend policy types.

The Security Intelligence Flow Insights Dashboard provides selectable time period options from real-time to the last month, and the Flow Trends panel supports analysis over the last 24 hours, last week, and last month. These views help administrators identify ports, protocols, and services that are no longer actively used and may be candidates for removal from firewall policies.

SSP collects host-level security monitoring statistics tracking the top ten ports and protocols by packet count at a given point in time, providing a data-driven view of the most active communication paths on each transport node. Security Intelligence continuously monitors infrastructure services to detect new servers in the environment. The IDS/IPS engine combines port verification with application identification to detect obsolete or non-secure protocols in active use, directly supporting the identification of protocols that should be disabled.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides administrators with mechanisms to inspect and verify system configuration, supporting periodic review of settings. The primary configuration review surfaces are the System Settings tab (accessible via Settings in the DSM UI) and the `dsmsystemconfig` Custom Resource, which can be inspected via SSH access to the appliance VM. Together, these surfaces expose the current state of DSM configuration including network settings, credentials, certificates, and service parameters. The System Settings tab includes an NTP servers field that can be verified and corrected as part of any configuration review, giving administrators confirmation that time synchronization settings match the intended configuration.

DSM's network architecture is built around specific VDS network port groups with defined ports and protocols. The infrastructure policy and VM class system bounds the configuration space for database deployments, limiting which datastores, network segments, and resource classes can be used. DSM also detects and prevents network overlap between infrastructure policy IP ranges and system configuration networks, surfacing configuration conflicts automatically rather than requiring manual discovery. This constrained configuration model reduces the surface area that periodic review must cover.

The Global Alerts page and database-level alert system surface configuration-related issues in real time, with continuous performance monitoring to identify root causes and service impacts. Alert settings for CPU Health, Data Disk Health, System Disk Health, and Max Connections are configurable at the database level, with separate threshold values for warning and critical alerts. The Operations tab tracks the progress of database configuration change tasks, providing an audit trail of what changed and when. DSM can forward metrics to an external metrics target server, a configuration that requires verifying server address, port configurations, authentication type, credentials, and certificates; administrators can review these settings as part of a periodic check on outbound integration configuration.

DSM provides a system support bundle that can be generated and downloaded to collect diagnostic information for troubleshooting system configuration failures. The database maintenance window, which defaults to six hours starting each Saturday at 23:59 and can be refined with a Monthly Occurrences setting to target specific weeks within a month, defines a scheduled touchpoint where administrators can confirm configuration state in conjunction with software update activities.

Periodic review as a formal process, including scheduled intervals, documented findings, and tracking of disabled services, is an organizational responsibility. DSM provides the configuration visibility, alerting infrastructure, and diagnostic tooling to support that process, but the scheduling, documentation, and remediation workflow must be established and maintained by the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides visibility and control mechanisms that support periodic review of its application delivery configurations. These capabilities cover inspecting current settings, reviewing historical changes, and modifying configurations to restrict non-secure protocols and ports.

The Avi Controller maintains a Config Audit Trail that presents a filtered view of all configuration changes and user activity events over a selected time period. Administrators can use the Config Events overlay in Service Engine Analytics to correlate traffic changes with configuration modifications, identifying whether a shift in traffic patterns was caused by a specific configuration update. Avi Controller event logs support retention for one year to maintain audit trails of configuration changes.

For application security posture review, Avi Load Balancer provides an Application Security Report that can be generated using the CLI for a specified virtual service, with status tracking for the report generation process. WAF evaluation reports cover periods up to seven days, giving administrators a structured way to assess recent application security activity as part of a periodic review cycle.

At the configuration level, each virtual service that handles secure connections requires an SSL/TLS profile that explicitly defines the supported ciphers and protocol versions. Administrators can modify this profile to disable non-secure options. Virtual service Application Profile or Network Profile settings can be overridden on a per-service-port basis for granular configuration control. The Avi Kubernetes Operator (AKO) extends this capability to Kubernetes environments: the L4 CRD

Rule supports SSL profiles, SSL key and certificate references, and PKI profiles for securing pool connections, and AKO computes a dependency checksum across health monitor dependencies to detect configuration drift.

The Alert feature in Avi Load Balancer processes system events and metrics against user-defined rules and generates alerts that initiate configured actions such as sending an email, a syslog message, or an SNMP trap. This supports notification workflows when configuration-related events occur.

The scheduling and documentation of periodic reviews is an organizational responsibility. Avi Load Balancer provides the mechanisms to inspect and modify its own configurations but does not automate the review cadence or enforce a review schedule.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CM.L2-3.4.8

> Apply deny-by-exception (blacklisting) policy to prevent the use of unauthorized software or deny-all, permit-by-exception (whitelisting) policy to allow the execution of authorized software.

SCF Controls: CFG-03.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform-level mechanisms that contribute to application allowlisting and denylisting, primarily through network-layer application identity controls, Kubernetes workload admission policies, content governance, and deployment authorization workflows. VCF does not include a host-level application control agent (such as an OS-native allowlist or denylist enforcement engine), so organizations should complement these controls with endpoint-level solutions for full coverage.

The distributed firewall in VMware vDefend, a separate product that extends NSX security functions, supports enforcement based on application identity (App-ID), which classifies network traffic by application rather than by port or protocol alone. App-ID enforcement allows administrators to allow or deny applications regardless of the port they use, or to force applications to run only on their standard ports. This reduces north-south and east-west attack surface by restricting traffic to appropriate applications on open ports. Advanced App IDs require a custom context profile to be used in firewall rules. Firewall exclusion lists allow administrators to specify VMs or IP addresses that are exempt from firewall application rules. NSX itself provides route filtering through prefix lists with permit and deny actions to control traffic routing. vSphere distributed virtual switches independently support a Traffic Filtering and Marking policy that can be configured to allow or drop traffic on individual distributed ports and uplink ports without requiring NSX, providing an additional network-layer enforcement point available to platform administrators.

VMware Kubernetes Service (VKS) provides cluster management security policies with configurable enforcement actions. Administrators can set policies to Deny, which fully enforces the policy and rejects admission requests that contain violations. A Dry Run mode is available for testing policies without enforcement, and a Warn mode provides immediate feedback on potential denials without blocking container scheduling. These enforcement modes allow administrators to build and validate an allowlist posture for Kubernetes workloads before moving to full enforcement. VKS also supports image registry policies that deny admission requests when policy violations are detected, functioning as an image-level allowlist that restricts container workloads to only those sourced from approved registries. By defining which registries are trusted and denying images from all others, administrators establish an explicit allow/deny posture for containerized applications. VKS Cluster Policy Management also includes a built-in baseline security policy that enforces privileged container blocking, applying a default restriction independently of any custom policy definitions.

Pod Security Admission (PSA) provides namespace-level enforcement of workload configurations as a distinct Consumption-layer control. VKS clusters running release v1.26 and later use PSA with mode enforce at level restricted by default, applying the most restrictive Kubernetes Pod Security Standard profile. Administrators configure PSA per namespace using labels such as pod-security.kubernetes.io/enforce, and the three policy levels (Privileged, Baseline, and Restricted) can be combined across enforcement modes: for example, applying enforce at Baseline while setting audit and warn at Restricted simultaneously rejects non-conforming workloads and surfaces warnings about those not meeting the stricter standard. The vmware-system-restricted Pod Security Policy, a VMware-specific built-in control, does not permit privileged access to pod containers, blocks escalations to root, and requires specific security contexts; workloads are granted access through ClusterRoleBinding or RoleBinding, giving administrators control over which service accounts may run under that restricted profile.

ValidatingAdmissionPolicy provides CEL-based validation rules that reject non-conforming Kubernetes resources before they are persisted to the API server. The policy's resourceRules specify which API groups, operations, and resources fall within its scope, allowing administrators to codify acceptable workload configurations as a declarative allowlist for pod and deployment specifications. MutatingAdmissionPolicy can transform submitted resources to conform to policy requirements before admission proceeds. Linux Security Modules (LSMs) complement these admission controls with per-process execution restrictions on VKS cluster nodes. AppArmor restricts a container's access to resources by enforcing a profile that dictates the

rules and restrictions the containerized process must adhere to; profiles run in either enforcing mode, which blocks access to disallowed resources, or complain mode, which reports violations without blocking. On Ubuntu and Photon nodes, AppArmor provides mandatory access control covering container capabilities, file system access, and network access. SELinux restricts access to files, applications, ports, and processes using labels and security policies, and can be configured to deny the `module_request` permission to containers, blocking the kernel from loading modules. Seccomp profiles restrict the system calls available to container processes; the Supervisor secret injection agent enforces a `RuntimeDefault` seccomp profile on VKS workloads. Kubernetes itself enforces a deny-by-default authorization model in which all parts of an API request must be allowed by some authorization mechanism in order to proceed. The Kubernetes authorization configuration file approach also supports specification of explicit Deny rules on authorization failures, allowing fine-grained control over individual authorization chains. Within VKS clusters integrated with the Antrea CNI, distributed firewall policies in the Application tier support Allow, Drop, and Reject actions on pod-to-pod traffic, extending application-level traffic control within the cluster beyond what namespace-scoped networking alone provides. Kubernetes `NetworkPolicy` resources provide a namespace-level deny-by-default network posture: a `NetworkPolicy` that selects all pods but specifies no egress rules creates a deny-all-egress baseline for that namespace, after which additional policies add allow rules to open specific traffic paths. The `DenyServiceExternalIPs` admission controller restricts Service resources from using `LoadBalancer` types or `ExternalIPs` fields, limiting which applications can be exposed externally through those mechanisms.

Content Libraries in VMware vCenter support `SecurityPolicies` instances that define security policy rules for library content. An OVF security policy can be applied to protect library items, and if a content library is protected by a security policy, all library items must be compliant. This provides governance over the VM templates, OVFs, and ISO images available for deployment, allowing administrators to control which approved content is available and restricting the use of unapproved images. Supervisor local content libraries support applying a Security Policy at creation time, providing equivalent governance for VKS cluster release images in internet-restricted environments where restricting image sources to an approved set is required.

VCF Automation provides two policy mechanisms that control what actions and deployments are permitted. Day-2 action policies restrict which users can run selected actions on deployments, limiting destructive or costly changes to the individual actions those users are entitled to perform. Approval policies are enforced before deployment begins, blocking a deployment from consuming infrastructure resources or making changes until the request is approved. Hard enforcement mode requires mandatory approval before deployment actions proceed. Together, these policies provide workflow-based gates for controlling which applications are deployed and what modifications are allowed.

The authorization model in vCenter provides role-based access control with granular privilege assignment. Custom roles with specific privileges can be created and propagated to vSphere objects, restricting which operations users can perform on managed objects. This limits the ability to install or modify software within the environment. Administrators can also create roles that exclude the Virtual machine > Guest operations privilege to restrict users from running commands inside virtual machines through the vCenter management plane, reducing the risk of unauthorized software execution within guest environments. ESX Agent Manager further restricts operations on ESX agent virtual machines to users with specific privileges. For example, powering off an ESX agent requires the `EAM.Modify` privilege, which limits unauthorized changes to platform-level agents on ESX hosts.

Organizations deploying VCF should complement these platform-level controls with host-level and endpoint application control solutions to achieve full allowlist/denylist enforcement across all layers of the stack, including the operating systems of workload VMs.

VMware vDefend (Contributes)

VMware vDefend (DFW) contributes to application access control at the network layer through explicit allowlist and denylist enforcement on workload traffic flows. DFW rules support four actions: Allow, Block, Reject, or Jump To Application. A default-deny posture drops all traffic not explicitly allowed, protecting application groups from unauthorized communication.

The 9.1 DFW Application Connectivity Strategy provides structured policy templates for common allowlist and denylist postures. The Allow Intra, Deny Other Traffic strategy generates an intra-group ALLOW rule using the `ALLOW_INTRA` and `ALLOWLIST` APIs plus a default ANY/ANY/DROP rule, enforcing strict isolation for application groups. The Allow Outbound,

Deny Other Traffic strategy generates a specific egress ALLOW rule (application group to any) plus a default DROP rule, permitting only authorized outbound communication. The Deny List strategy allows all traffic by default with optional logging, supporting environments where observed-traffic baselining is the initial posture. ALLOW EGRESS rules can be individually configured with Allow or Drop actions to control whether application entities may initiate external communication. Centralized Transit Gateway Firewall rules can enforce inter-project isolation by denying all inter-project communication except designated infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

Identity Firewall supports user identity-based access controls with Allow and Reject actions for specified user groups, services, and destinations, extending allowlist and denylist enforcement to user context through Active Directory integration.

Security Services Platform Application Protection in Strict Mode enforces application-level firewall rules across all workloads except infrastructure, with coverage scoring based on workload coverage, traffic coverage, and lock-down policies. Security Intelligence recommends granular application-level rules that allow only authorized traffic between environment pairs, helping administrators build explicit allowlist policy from observed flows.

Host-level application execution controls, such as OS-level application allowlisting (AppLocker, SELinux), are outside vDefend's scope and must be addressed by endpoint security tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides explicit allow and deny mechanisms at the application traffic layer through its Web Application Firewall (WAF), DataScript programmable control plane, and Bot Management module.

Avi WAF policies define rules with two fundamental actions: pass, which allows a request to proceed, and deny, which blocks it. The WAF supports ModSecurity-compatible SecRule directives that can deny requests based on client IP address, with transformation functions such as `IpToCountryCode` available to enforce geographic restrictions on a per-request basis. The WAF Application Rules feature, accessible through the Avi Cloud Console's Application Rules Service, provides a library of application-layer protections targeting known vulnerabilities with associated CVEs; these rules are automatically updated so that newly identified application weaknesses are blocked without manual intervention.

Avi WAF's Positive Security model allows administrators to define explicitly permitted application behavior. Positive Security Group rules specify what requests are allowed and block everything outside that defined envelope, providing a positive-security allowlist alongside the rule-based model. The WAF Allowlist feature provides an additional positive-security mechanism. Administrators configure Allowlist rules that match on client IP, IP Groups, HTTP path, or other criteria, and assign one of three actions. The BYPASS action permits the request without executing any further WAF rules. The CONTINUE action passes the request back for normal WAF processing. DETECTION MODE overrides the policy mode for that specific request, enabling logging without blocking. IP Groups can be referenced directly in Allowlist rules so that all traffic from a designated set of client addresses receives consistent bypass or enforcement treatment. Allowlist rules support client IP matching with `Is` and `Is Not` operators, enabling both inclusive patterns (allow these specific sources) and exclusive patterns (allow any source except these). The WAF Allowlist can also be configured to allow access from internal networks and to bypass WAF inspection for authorized security scanners that access the application directly.

HTTP method allowlisting is configured in the Pre-CRS rules of a WAF policy so that custom method restrictions are applied before Core Rule Set evaluation. Application-specific exclusions can be configured through the CRS Exception list, enabling selective bypass of Core Rule Set protections for designated applications or paths.

For request-level programmatic control, Avi DataScript provides scriptable access enforcement running at the Service Engine. A DataScript can check client IP addresses against a named IP Group and terminate connections from blocked clients while logging the violation. String Group functions with key-value pair configuration support allowlist-based authorization by checking user credentials against an authorized group and returning an HTTP 403 response for requests from users not in the authorized set. DataScript TLS fingerprint validation can restrict access to clients matching an expected fingerprint value, enabling access control based on client application characteristics.

The Bot Management module provides a separate allowlist, configurable through the `botdetectionpolicy` CLI command, with conditions and bot-specific actions that supplement WAF-based controls.

At the Service Engine level, TCP Wrappers configuration with default deny rules in `/etc/hosts.deny` restricts network-level access to data-plane VMs, providing a host-layer control on connectivity to Service Engine instances.

For Kubernetes workloads, the Avi Kubernetes Operator (AKO) enforces a `securityContext` configuration that runs containers as a non-root user, disallows privilege escalation, drops all Linux capabilities, and applies a `RuntimeDefault seccomp` profile, implementing a restrictive execution environment for the operator itself.

The control's full scope includes host-based application execution control, meaning mechanisms that restrict which applications are authorized to run on endpoint or server operating systems. That dimension is addressed at the platform layer by VCF through ESX host integrity controls and vSphere security policies. Avi's contribution is at the application traffic layer: allowing or denying inbound requests and connections based on client identity, IP address, network origin, geographic source, and application path criteria defined in WAF policies, DataScripts, and Bot Management rules.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CM.L2-3.4.9

> Control and monitor user-installed software.

SCF Controls: CFG-05, END-03

Aggregate Coverage: Meets

VCF (Meets)

VCF restricts the ability of non-privileged users to install unauthorized software through appliance-level restrictions, role-based access control, code signing enforcement, and managed software lifecycle controls across all platform components.

At the infrastructure layer, VCF management appliances enforce strict software installation controls by design. NSX Manager has a built-in admin account that has access rights to all NSX resources but does not have rights to the underlying operating system to install software or hardware. NSX upgrade files are the only files permitted for installation on the appliance. The NSX user account is similarly restricted and cannot install software or hardware on the operating system. This means that even the most privileged NSX user cannot install arbitrary software on the underlying operating system, and non-privileged users have no path to do so.

At the hypervisor layer, VMware ESX enforces code signing to restrict installation and execution of unauthorized software. Secure Boot validates that only signed code runs during the boot process, and VIB acceptance levels control which software packages can be installed on hosts. When cloning an ESX image profile, the acceptance level for software packages can be set to VMware Certified, restricting the host to only packages that have passed VMware's certification process. vSphere Lifecycle Manager (vLCM) maintains approved software baselines and remediates drift by applying a desired software state to each host in a cluster whose current state differs from the desired specification. Hosts run only the software versions and VIBs that administrators have explicitly approved. vLCM consumes software updates from a managed depot rather than allowing individual components to be installed ad hoc. Direct access to the ESX host console can be restricted through lockdown mode, which limits the ability of users to bypass centralized controls. Lockdown mode supports an exception users list and DCUI access override configuration for controlled administrative access when needed.

VCF's privilege model across vSphere, VMware vCenter, VCF Operations, and VCF Automation enforces the principle of least privilege through role-based access control (RBAC). vSphere implements authentication and authorization mechanisms to restrict access to virtual infrastructure components. Privileges within the platform are static and do not change for a given product version, which means users cannot escalate their own privilege set. Administrators can define custom roles that contain only the minimum set of required privileges, restricting what actions non-privileged users can perform. If no predefined role meets the needs of a particular user or application, administrators create a role with only those privileges needed rather than granting broad access. To specifically restrict users from installing software within virtual machine guest operating systems, administrators can create a custom role that excludes the Virtual machine > Guest operations privilege. By default, a user with the Administrator role can interact with files and applications within the guest operating system of a virtual machine; removing this privilege from non-administrative roles helps prevent such users from running commands or transferring files inside guests.

VCF Operations follows the same model. The administrators role should be assigned only to specific users who must access objects and perform actions across the entire environment. Local VCF Operations users and vCenter users should be configured with only the privileges they need, avoiding overly permissive role assignments that could allow unauthorized actions. VCF Automation extends this approach by allowing administrators to grant access to specific entity types only to designated users and organizations, restricting what resources users can interact with. Software components within the environment require explicit authorization to perform operations on behalf of a user. VCF Automation for VM Apps enforces permission-based access to the Deployments page, restricting deployment and resource management to consumers who hold the necessary permissions.

Authentication occurs centrally through VCF SSO, and direct ESX host access is restricted. VCF Operations integrates with VCF SSO for centralized user and group authentication and management. This centralized identity model limits the ability of

users to bypass RBAC by connecting directly to individual hosts. VCF Operations also restricts platform-level operations through the ADMIN role model, requiring a user with the ADMIN role to perform administrative operations.

VCF Operations controls software depots for upgrade, patch, and install binaries, keeping software distribution under administrative control rather than allowing individual users to introduce unapproved packages. It supports online and offline depots, and the VCF Download Tool manages binary distribution when VCF Operations is not connected to a depot. Online depots are reached using a download token generated on the Broadcom Support Portal to access available binaries. This centralized depot model means that software enters the environment only through controlled, administrator-managed channels.

At the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor enforce a layered set of Kubernetes-native controls that restrict workload admission, access authorization, and runtime confinement. RBAC-enforced authorization governs who may create, update, or delete workloads in each namespace. No authenticated user can create privileged or unprivileged pods in a VKS cluster until the cluster administrator explicitly binds that user to an appropriate Pod Security Policy (for VKS releases through v1.24) or configures Pod Security Admission (for v1.25 and later). VKS v1.26 and later apply Pod Security Admission with mode enforce at level restricted by default, which blocks at admission time any workload that does not satisfy the Restricted profile. Non-privileged users cannot modify namespace-level Pod Security Admission labels without the namespace update or patch permission, which only trusted, privileged users should hold. For earlier VKS releases, the vmware-system-restricted default Pod Security Policy blocks privileged access to pod containers, blocks escalation to root, and restricts volume types and non-root user identities. The vmware-system-privileged policy is available for administrators only and must be explicitly granted; granting it cluster-wide to all authenticated users disables native security controls and is documented as a configuration to be used only with caution. Installing standard packages on VKS clusters requires a service account with explicit RBAC permissions, and administrators should create least-privileged kubeconfigs that reserve cluster-admin access for break-glass scenarios.

Pod security context controls allow administrators to enforce that containers do not gain additional privileges at runtime. Setting allowPrivilegeEscalation to false in a container's security context blocks privilege escalation; Linux capabilities can be explicitly dropped through the capabilities field, allowing administrators to scope container permissions to only what a workload requires. Containers can also be configured to run as a non-privileged user; the securityContext runAsNonRoot and runAsUser fields restrict container processes from executing as root. The seccompProfile field can be set to RuntimeDefault, which applies the container runtime's default seccomp profile and restricts the system calls a container process can make. Linux seccomp restricts the individual system calls a process may invoke, providing sandboxing of process privileges without granting all root privileges. Kubernetes AppArmor profiles applied through security context restrict the access privileges of individual programs within a container by confining them to a limited set of resources. Pod Security Standards at the Baseline and Restricted levels block unprivileged processes from loading kernel modules, which limits the ability of workloads to extend the kernel with unauthorized functionality.

Content libraries in vSphere Supervisor support applying a Security Policy when the library is created, which restricts the VM images available for VM Service workloads to an administrator-controlled set. In internet-restricted environments, local content libraries with security policies applied further limit available images to those an administrator has explicitly published. A registry must be explicitly allowed by the platform administrator to be trusted by the platform before container images can be pulled from it. Administrators should create VM images with the latest patches and required security settings that follow corporate security policies before publishing them to the content library for production use.

Software installation behavior inside guest operating systems by users with local guest-OS privileges sits outside VCF's reach. VCF restricts software introduction through the management surfaces it controls (vCenter, NSX Manager, VCF Operations, VCF Automation, VKS) and through the centralized depot model; in-guest install controls such as Windows local-admin enforcement, Linux package management policy, and application allowlisting agents are guest-OS responsibilities deployed inside the VM.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies role-based access controls that restrict software installation and activation activities to users with explicitly assigned privileged status. Several layers of privilege enforcement exist across the platform's operational surface.

Deploying the DSM Provider Appliance requires a user with the vSphere Administrator role, which has exclusive responsibility for deploying the appliance and managing DSM VM updates. This prerequisite is enforced at the deployment step and cannot be bypassed by standard user accounts.

Within DSM, activating or deactivating supported data service versions (such as PostgreSQL, MySQL, or SQL Server) is restricted to DSM administrators. Standard DSM Users cannot activate new data service versions. SQL Server instance provisioning and server-level configuration management, including Active Directory integration and high availability configuration, are also restricted to DSM administrators only.

At the database level, activating or deactivating PostgreSQL extensions requires the PostgreSQL SUPERUSER role. Extensions cannot be added by ordinary database users, which restricts the installation of additional database-level software components to specifically privileged accounts. For MySQL databases, DSM revokes the create and update privileges on objects in the mysql system schema for database users, preventing unauthorized modification of system-level components. For SQL Server databases, DSM grants the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full privileges. The `dsm_db_user` custom database role denies TAKE OWNERSHIP on the database to prevent privilege escalation.

The DSM administrator UI includes a Permissions view where administrators create, monitor, and manage user accounts and role assignments. DSM User role assignments can be scoped to one or more specific Supervisor namespaces, further limiting what operations a given user can perform within the platform.

Configuring infrastructure policies, which govern where and how database resources are provisioned, requires a vSphere administrator with appropriate DSM permissions. These policies are enforced automatically during provisioning operations.

The broader requirement to prohibit unauthorized software installations across all systems and workloads in an environment requires organizational processes and controls at the infrastructure layer that extend beyond DSM's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CM.L3-3.4.1e

> Authoritative Repository

SCF Controls: AST-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in configuration management capabilities that function as a CMDB-like technology for the virtual infrastructure, along with multiple integration points for external CMDB platforms such as ServiceNow.

VCF Operations maintains an inventory of configuration items across the environment, tracking objects such as compute hosts, virtual machines, datastores, switches, services, and applications. Each configuration item is associated with a class that defines its properties, and VCF Operations tracks relationships between items (depends on, runs on, exchanges data). VCF Operations for Networks extends this tracking across applications, clusters, databases, load balancer services, network adapters, and translation rules. The CMDB configuration includes rules for dependency graph traversal, and administrators can customize discovery behavior, such as enabling name-based VM search to discover applications without requiring workload relations. Historical inventory metrics capture configuration property changes over time, providing a record of how assets evolve.

For organizations using ServiceNow, the Management Pack for ServiceNow in VCF Operations synchronizes metrics and properties from VCF Operations resources to the ServiceNow CMDB. It maps VCF Operations identifiers, properties, and metrics to ServiceNow columns for datastore entities and other resource types, and provides user-defined CMDB visibility within VCF Operations. The cmdbSync adapter supports configurable sync methods (including a populate-and-delete mode), object identification sources such as MOID, custom field mappings, and name filters based on regex patterns that control which resources are synchronized and how they appear in the CMDB. CMDB Sync requires access to the sys_db_object table in ServiceNow. VCF Operations for Networks adds the ability to integrate with ServiceNow CMDB as a data source, fetching application and tier details and retrieving CMDB statistics through the ServiceNow API.

VCF Automation provides a complementary CMDB integration path. Enterprise users can integrate VCF Automation with ServiceNow or similar ITSM and CMDB platforms for compliance purposes. The VCF Automation ITSM Plug-in supports CMDB reconciliation to keep configuration items current as resources are provisioned and modified. VCF Automation for VM Apps can create CMDB configuration items in ServiceNow via the /api/now/table endpoint, posting VM configuration data including hostname, CPU count, memory, deployment ID, disk size, location, VMware vCenter UUID, VM state, and owner. This allows newly provisioned virtual machines to be automatically registered in the CMDB as part of the deployment workflow.

VCF Operations also includes a Configuration Drifts feature that functions as a built-in configuration governance mechanism. This feature monitors configuration changes across vCenter instances and vSphere clusters, comparing current values against assigned configuration template values to detect deviations from the desired state. Drift detection can be scheduled to run proactively, and results are displayed in the Configuration Drift dashboard where administrators can view and compare specific settings that have changed. Configuration drift templates can be integrated with a source control repository, enabling versioning, auditing, and formal management of configuration baselines.

At the vSphere layer, vSphere Configuration Profiles provide cluster-level configuration management by capturing a desired configuration state as a JSON document, continuously checking host compliance against that state, and allowing administrators to set up alarms that notify via email or SNMP traps when configuration drifts are detected. vSphere Host Profiles complement this by capturing a pre-configured and validated reference host's configuration as a managed object, which can then be applied to configure other hosts in the environment.

At the Consumption layer, the Kubernetes API server within VMware Kubernetes Service (VKS) and vSphere Supervisor clusters maintains authoritative configuration records for all workloads and cluster components in etcd. Every Kubernetes object type, including Deployments, Namespaces, ConfigMaps, Secrets, ServiceAccounts, RBAC bindings, NetworkPolicies, and StorageClasses, is represented as a declarative manifest that administrators can retrieve at any time using kubectl. StatefulSet controllers record configuration history through ControllerRevision objects, enabling rollback and version tracking

for stateful workloads. VKS cluster security configurations are immutable and persistent by design, replacing manual node-level configuration with a consistent, deterministic configuration record. For organizations adopting GitOps, the Argo CD Supervisor Service enables infrastructure and application configurations to be stored in a Git repository as the source of truth; Kubernetes object configuration should be maintained in source control and versioned alongside the resources it configures, producing a durable, auditable record of configuration intent that is continuously reconciled against actual cluster state. Argo CD continuously monitors the live application state against the desired state in Git, identifying and reporting any deviations as OutOfSync, and provides both a CLI and a web-based UI for defining applications and visualizing Kubernetes configurations. Sync status and health state are tracked per deployed resource, giving administrators visibility into configuration conformance across VKS clusters. Kubernetes audit logging records API server operations and should be enabled with archived output on a secure server, creating an event trail of configuration changes across the cluster. VCF Automation's Tenant Portal extends resource visibility into the consumption layer, allowing administrators to view and manage discovered machines, storage volumes, and network resources organized by deployment and resource type, and to filter and act on individual resources under Consume > Deployments > Resources.

The organizational decisions around CMDB governance, including which assets to track, how to classify configuration items, and how to maintain data quality, remain outside VCF's scope.

The Kubernetes and Supervisor APIs are an authoritative configuration data source for Kubernetes-managed assets rather than a full enterprise configuration management database; they do not inventory physical hardware or non-Kubernetes assets, so organizations typically integrate this data into a broader CMDB.

VMware Avi Load Balancer (Contributes)

The Avi Load Balancer Controller maintains an internal configuration database that is the authoritative store for all Avi-managed objects within the application delivery layer. The database records configuration information for tenants, virtual services, pools, policies, and accounts, providing structured asset tracking scoped to the load balancing and application delivery functions. This database is the storage layer for all system settings and configurations in Avi Controller, accessible through both the Controller CLI and REST API, giving operators and automation tooling a programmatic way to retrieve and audit configuration details for any Avi-managed object.

For auditors assessing CMDB practices, Avi provides complementary mechanisms. The Controller CLI `configure` command provides access to show subcommands for viewing all configuration objects and system state, including application persistence profiles, application profiles, authentication profiles, backups, cloud configurations, and cluster settings. The Controller REST API endpoint `PUT api/systemconfiguration` enables programmatic retrieval and update of system configuration, allowing external CMDB platforms to pull structured configuration data and maintain up-to-date asset records for all Avi components. Configuration can also be exported and backed up with passphrase encryption of all sensitive fields, producing point-in-time snapshots suitable for import into a third-party CMDB or asset management system.

Avi Load Balancer events provide a record of configuration changes over time and are the foundation of configuration automation within the platform. The Config Events overlay in Service Engine Analytics enables administrators to correlate traffic changes with configuration modifications, such as changes to virtual service security settings, supporting governance requirements by providing a traceable record of configuration state changes within the Avi control plane.

In VCF deployments, Avi adds specific integration capabilities relevant to configuration governance. Organization-Managed Mode allows organization administrators to manage their own Service Engine Group configurations and infrastructure settings within boundaries defined by the VCF Automation Provider Management Portal, which enables provider administrators to specify regions, organizations, and capacity allocations. After upgrading components in a VCF deployment, a drift check against VCF Operations, vCenter, and NSX Manager is required to verify configuration consistency, providing a structured mechanism for detecting configuration drift across the integrated stack.

Organizations deploying Avi in a VCF environment typically integrate Avi configuration data with an enterprise CMDB to achieve unified asset tracking across the full infrastructure stack, with VCF's own inventory mechanisms covering the compute, storage, and networking layers while Avi covers the application delivery layer objects.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control CM.L3-3.4.2e

> Automated Detection

SCF Controls: CFG-02.2, CFG-02.8, CFG-06, CFG-06.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms for detecting, attributing, and responding to unauthorized configuration changes across its component products.

VCF Operations performs daily checks that compare current configuration settings against authorized changes executed during defined change windows. When settings do not match the expected baseline, administrators are alerted to investigate the discrepancy. Beyond periodic checks, VCF Operations raises a Configuration Change alert whenever any property of a monitored entity changes, giving administrators immediate visibility into modifications across the managed infrastructure. This detection capability works in conjunction with VCF's requirement that configuration updates be performed only during maintenance windows, establishing a clear boundary between authorized and unauthorized changes. The VCF security baseline provides an additional reference point for evaluating both default and non-default configurations, helping organizations identify deviations that may indicate unauthorized modifications. vSphere Configuration Profiles can also be configured to trigger alarms for cluster and host configuration out-of-compliance events, notifying administrators via email or SNMP traps; the `com.vmware.vclIntegrity.ClusterConfigurationOutOfCompliance` event is used to fire these alarms when a cluster configuration falls out of compliance. At the VMware Kubernetes Service (VKS) layer, the cluster management system generates an Incompatibility insight on the Policy Insights page when it detects a Gatekeeper installation that was not deployed through cluster management, flagging unauthorized component deployments for administrative review.

Audit logging across VCF components supports incident investigation when unauthorized changes are detected. VCF Operations audit logging tracks each configuration change to an authenticated user, recording the principal identifier of the user who initiated the change, the object affected, and the time of the modification. The NSX management plane audits configuration changes to security policies and firewall rules (the Distributed Firewall and Gateway Firewall are provided by vDefend, a separate product layered on NSX), capturing the username of the user making the change, the resource being modified, and the timestamp. Changes to local user accounts in NSX Manager are also audited. User permission changes can be tracked to determine when they were made and by whom. Kubernetes audit logging in VKS clusters records every write request to the Kubernetes API server, covering configuration changes to Deployments, ConfigMaps, Secrets, Roles, RoleBindings, and VKS-specific objects such as TanzuKubernetesCluster and VirtualMachine resources; each event captures the requesting identity, the action taken, the object affected, and the outcome. Pod Security Admission (PSA) in VKS clusters supports an audit mode that logs security-policy violations without rejecting pods, feeding violation events into operator dashboards and audit streams. These audit trails provide the attribution data needed to investigate unauthorized changes as security incidents.

VCF also provides preventive controls that restrict unauthorized device-level changes. The `isolation.device.edit.disable` setting restricts unauthorized modification of devices on virtual machines, and the `isolation.device.connectable.disable` setting restricts unauthorized removal and connection of devices. These settings reduce the attack surface by limiting what changes can be made to VM hardware configurations outside of approved processes. At the Kubernetes API layer, `ValidatingAdmissionPolicy` and `MutatingAdmissionPolicy` can inspect write requests before they are persisted and reject those that do not conform to defined configuration baselines; `ValidatingAdmissionPolicy` is the preferred mechanism for preventing specific kinds of changes to resources, such as protecting platform namespaces from deletion. Tooling that manages ApplySet-based configurations is expected to refuse mutations from other tools, enforcing configuration ownership and reducing the risk that unauthorized changes persist undetected.

For remediation, VCF has both automated and manual response capabilities. The auto-remediation feature in the Management Pack for VCF Operations Orchestrator can enforce host security hardening rules automatically, reverting unauthorized changes to host configurations without manual intervention. The Configure Host Security Config Data workflow allows administrators to selectively enforce specific hardening rules through configurable enforcement options. VMware

vCenter configuration export provides a mechanism to revert to the last known good configuration when unauthorized changes are discovered, restoring the environment to a validated state. The vSphere Distributed Switch configuration can similarly be exported and saved as a backup file; if unauthorized changes are made to switch policies or host associations, the saved configuration file can be used to restore the distributed switch to its prior state. For the Kubernetes workload layer, VKS enforces immutability for platform-managed resources: system-managed Kubernetes ConfigMaps are not intended to be user-modifiable, and any unauthorized modifications are automatically overwritten by the platform. Organizations can deploy GitOps tooling such as Argo CD, available as a vSphere Supervisor Service, to continuously reconcile cluster configuration against a declared source of truth in Git, automatically reverting configuration drift and maintaining a complete change history for auditing and rollback.

Integration with external security information and event management (SIEM) platforms allows configuration change events to be correlated and escalated through an organization's incident response process. The vSphere Security Configuration Guide recommends using SIEM tools for monitoring vSphere components, and VCF Operations receives change event information from adapters configured for external applications, supporting centralized event correlation. Kubernetes audit log streams from VKS clusters can be forwarded to a SIEM or log aggregation platform, where configuration change events from the Kubernetes API server join the broader incident response workflow. DISA STIGs are available for vSphere Supervisor and VMware Kubernetes Releases (VKRs), providing hardening requirements that establish the configuration baseline against which deviations in the Kubernetes layer are measured.

VMware vDefend (Contributes)

VMware vDefend contributes to detecting and responding to unauthorized configuration changes within its security policy domain through draft management, signature tracking, and policy validation mechanisms.

The Distributed Firewall uses a draft-based configuration model. Configuration changes are staged as drafts before publishing, and an auto-draft is created during each publish operation, allowing administrators to restore the previous published configuration by republishing that auto-draft. Drafts can be locked with a required comment, adding an explicit authorization step and an attribution record for configuration changes.

For IDS/IPS signature management, vDefend provides a bulk Reset function that restores selected signatures to their default configuration, giving administrators a direct path to reverse unauthorized signature changes. The IDS/IPS Global Signature Management view tracks signatures that have been globally changed by users, including excluded signatures, providing visibility into which signature settings have been modified. The Global Manager can manage signature version deployment across Local Manager sites, providing centralized oversight of signature configuration.

Security Services Platform validates configurations through its deployment wizard before implementing changes, reducing the likelihood of erroneous or unauthorized configurations being applied. Initial security policies published through Security Services Platform cannot be modified from the user interface after publishing, providing an immutability control for baseline segmentation policy. When configuration synchronization between Security Services Platform and NSX Manager fails or degrades, the platform displays a config agent health alarm in the NSX user interface, signaling that configuration state may be inconsistent.

These capabilities address configuration change detection, rollback, and remediation within vDefend's security policy domain. Broader incident response orchestration, cross-infrastructure configuration drift detection, and escalation workflows are handled by VCF Operations and integration with external SIEM and ITSM platforms.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides audit logging, access controls, and alerting mechanisms that support detection and investigation of unauthorized configuration changes within the recovery and replication environment.

PNR logs Array Manager reconfiguration events when a user edits Array Manager properties, creating an auditable record of changes to storage-level protection configuration. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration functions, restricting the ability to make infrastructure-level configuration changes to authenticated administrators. Configuration files within the Protection and Recovery environment contain settings that

affect the security posture of the environment; these files must not be modified outside of supported procedures, and PNR explicitly documents this requirement.

Protection and Recovery permissions can be modified from the unified user interface on both the protected and recovery sites, allowing permission changes to be reviewed and managed from a central location. Role-based access control in PNR restricts modification privileges to specific roles, narrowing the set of principals who can alter protection group, recovery plan, or system configuration, making unexpected changes easier to identify.

The PNR Global Console alerts administrators to site misconfigurations that require investigation, including expired snapshot schedules, replication errors such as missing virtual machines, and connectivity issues between protected and destination sites. These alerts provide an operational signal that can surface unintended or unauthorized configuration changes.

Administrators should configure alarms on PNR configuration and permission change events and integrate these with their incident response infrastructure so that unauthorized modifications can be identified and triaged through the organization's security incident process.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains a Config Audit Trail that records all user activity and configuration changes over a selectable time period. This trail is accessible through the Avi Controller at Operations > Events > Config Audit Trail and provides a history of who changed what and when. Administrators can review this trail to identify configuration changes that fall outside authorized activity.

At the event level, Avi generates CONFIG_CREATE and CONFIG_DELETE events that include client_IP and user_agent fields, enabling attribution of each change to the initiating source. When syslog forwarding is configured, these events can be sent to an external SIEM or alerting platform, supporting automated detection of unexpected changes and integration with organizational security incident workflows.

The Service Engine Analytics interface includes a Config Events overlay that allows administrators to correlate traffic changes with configuration modifications. This overlay helps identify whether a change in observed traffic behavior was caused by a configuration change, such as modifications to virtual service security settings, helping narrow the scope of incident investigation.

Avi also supports configuration warnings through the Enable Configuration Warnings setting, which notifies users of supported configuration changes. Alert configurations can be customized to set severity levels and descriptions, allowing operators to tune which events trigger notifications and how those notifications are routed.

Responding to unauthorized configuration changes as formal security incidents requires organizational processes, including incident classification, escalation procedures, and investigation workflows, that Avi does not orchestrate. Avi provides the detection and notification inputs that those processes consume.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control CM.L3-3.4.3e

> Automated Inventory

SCF Controls: AST-02.9

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in configuration management capabilities that function as a CMDB-like technology for the virtual infrastructure, along with multiple integration points for external CMDB platforms such as ServiceNow.

VCF Operations maintains an inventory of configuration items across the environment, tracking objects such as compute hosts, virtual machines, datastores, switches, services, and applications. Each configuration item is associated with a class that defines its properties, and VCF Operations tracks relationships between items (depends on, runs on, exchanges data). VCF Operations for Networks extends this tracking across applications, clusters, databases, load balancer services, network adapters, and translation rules. The CMDB configuration includes rules for dependency graph traversal, and administrators can customize discovery behavior, such as enabling name-based VM search to discover applications without requiring workload relations. Historical inventory metrics capture configuration property changes over time, providing a record of how assets evolve.

For organizations using ServiceNow, the Management Pack for ServiceNow in VCF Operations synchronizes metrics and properties from VCF Operations resources to the ServiceNow CMDB. It maps VCF Operations identifiers, properties, and metrics to ServiceNow columns for datastore entities and other resource types, and provides user-defined CMDB visibility within VCF Operations. The cmdbSync adapter supports configurable sync methods (including a populate-and-delete mode), object identification sources such as MOID, custom field mappings, and name filters based on regex patterns that control which resources are synchronized and how they appear in the CMDB. CMDB Sync requires access to the sys_db_object table in ServiceNow. VCF Operations for Networks adds the ability to integrate with ServiceNow CMDB as a data source, fetching application and tier details and retrieving CMDB statistics through the ServiceNow API.

VCF Automation provides a complementary CMDB integration path. Enterprise users can integrate VCF Automation with ServiceNow or similar ITSM and CMDB platforms for compliance purposes. The VCF Automation ITSM Plug-in supports CMDB reconciliation to keep configuration items current as resources are provisioned and modified. VCF Automation for VM Apps can create CMDB configuration items in ServiceNow via the /api/now/table endpoint, posting VM configuration data including hostname, CPU count, memory, deployment ID, disk size, location, VMware vCenter UUID, VM state, and owner. This allows newly provisioned virtual machines to be automatically registered in the CMDB as part of the deployment workflow.

VCF Operations also includes a Configuration Drifts feature that functions as a built-in configuration governance mechanism. This feature monitors configuration changes across vCenter instances and vSphere clusters, comparing current values against assigned configuration template values to detect deviations from the desired state. Drift detection can be scheduled to run proactively, and results are displayed in the Configuration Drift dashboard where administrators can view and compare specific settings that have changed. Configuration drift templates can be integrated with a source control repository, enabling versioning, auditing, and formal management of configuration baselines.

At the vSphere layer, vSphere Configuration Profiles provide cluster-level configuration management by capturing a desired configuration state as a JSON document, continuously checking host compliance against that state, and allowing administrators to set up alarms that notify via email or SNMP traps when configuration drifts are detected. vSphere Host Profiles complement this by capturing a pre-configured and validated reference host's configuration as a managed object, which can then be applied to configure other hosts in the environment.

At the Consumption layer, the Kubernetes API server within VMware Kubernetes Service (VKS) and vSphere Supervisor clusters maintains authoritative configuration records for all workloads and cluster components in etcd. Every Kubernetes object type, including Deployments, Namespaces, ConfigMaps, Secrets, ServiceAccounts, RBAC bindings, NetworkPolicies, and StorageClasses, is represented as a declarative manifest that administrators can retrieve at any time using kubectl. StatefulSet controllers record configuration history through ControllerRevision objects, enabling rollback and version tracking

for stateful workloads. VKS cluster security configurations are immutable and persistent by design, replacing manual node-level configuration with a consistent, deterministic configuration record. For organizations adopting GitOps, the Argo CD Supervisor Service enables infrastructure and application configurations to be stored in a Git repository as the source of truth; Kubernetes object configuration should be maintained in source control and versioned alongside the resources it configures, producing a durable, auditable record of configuration intent that is continuously reconciled against actual cluster state. Argo CD continuously monitors the live application state against the desired state in Git, identifying and reporting any deviations as OutOfSync, and provides both a CLI and a web-based UI for defining applications and visualizing Kubernetes configurations. Sync status and health state are tracked per deployed resource, giving administrators visibility into configuration conformance across VKS clusters. Kubernetes audit logging records API server operations and should be enabled with archived output on a secure server, creating an event trail of configuration changes across the cluster. VCF Automation's Tenant Portal extends resource visibility into the consumption layer, allowing administrators to view and manage discovered machines, storage volumes, and network resources organized by deployment and resource type, and to filter and act on individual resources under Consume > Deployments > Resources.

The organizational decisions around CMDB governance, including which assets to track, how to classify configuration items, and how to maintain data quality, remain outside VCF's scope.

The Kubernetes and Supervisor APIs are an authoritative configuration data source for Kubernetes-managed assets rather than a full enterprise configuration management database; they do not inventory physical hardware or non-Kubernetes assets, so organizations typically integrate this data into a broader CMDB.

VMware Avi Load Balancer (Contributes)

The Avi Load Balancer Controller maintains an internal configuration database that is the authoritative store for all Avi-managed objects within the application delivery layer. The database records configuration information for tenants, virtual services, pools, policies, and accounts, providing structured asset tracking scoped to the load balancing and application delivery functions. This database is the storage layer for all system settings and configurations in Avi Controller, accessible through both the Controller CLI and REST API, giving operators and automation tooling a programmatic way to retrieve and audit configuration details for any Avi-managed object.

For auditors assessing CMDB practices, Avi provides complementary mechanisms. The Controller CLI `configure` command provides access to show subcommands for viewing all configuration objects and system state, including application persistence profiles, application profiles, authentication profiles, backups, cloud configurations, and cluster settings. The Controller REST API endpoint `PUT api/systemconfiguration` enables programmatic retrieval and update of system configuration, allowing external CMDB platforms to pull structured configuration data and maintain up-to-date asset records for all Avi components. Configuration can also be exported and backed up with passphrase encryption of all sensitive fields, producing point-in-time snapshots suitable for import into a third-party CMDB or asset management system.

Avi Load Balancer events provide a record of configuration changes over time and are the foundation of configuration automation within the platform. The Config Events overlay in Service Engine Analytics enables administrators to correlate traffic changes with configuration modifications, such as changes to virtual service security settings, supporting governance requirements by providing a traceable record of configuration state changes within the Avi control plane.

In VCF deployments, Avi adds specific integration capabilities relevant to configuration governance. Organization-Managed Mode allows organization administrators to manage their own Service Engine Group configurations and infrastructure settings within boundaries defined by the VCF Automation Provider Management Portal, which enables provider administrators to specify regions, organizations, and capacity allocations. After upgrading components in a VCF deployment, a drift check against VCF Operations, vCenter, and NSX Manager is required to verify configuration consistency, providing a structured mechanism for detecting configuration drift across the integrated stack.

Organizations deploying Avi in a VCF environment typically integrate Avi configuration data with an enterprise CMDB to achieve unified asset tracking across the full infrastructure stack, with VCF's own inventory mechanisms covering the compute, storage, and networking layers while Avi covers the application delivery layer objects.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L1-b.1.v

> Identify information system users, processes acting on behalf of users, or devices

SCF Controls: IAC-02, IAC-04, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the

sso:<username>@<domain> convention. The AuthorizeWithSelectors feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include authorization.k8s.io/decision and authorization.k8s.io/reason, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (``pais-authentication-id``), and the scopes ``openid``, ``groups``, and ``offline_access``. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The ``authorizedGroups`` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, ``group-for-pais-access-01`` or ``group-for-pais-access-02``). The ``oidc-groups-claim`` setting names the claim used to identify group membership in the Access Token, and ``oidc-extra-audiences`` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the ``grafana-oidc-role-mapping`` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that

record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the dbo user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (dsm-auth-creds), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC `UserInfo` endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control IA.L1-b.1.vi

> Authenticate (or verify) the identities of those users, processes, or devices, as a prerequisite to allowing access to organizational information systems

SCF Controls: IAC-02, IAC-04, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in

ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `sso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group membership in the Access Token, and `'oidc-extra-audiences'` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `'grafana-oidc-role-`

mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the

minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the `dbo` user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (`dsm-auth-creds`), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC `UserInfo` endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control IA.L2-3.5.1

> Identify system users, processes acting on behalf of users, and devices.

SCF Controls: IAC-02, IAC-04, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers. Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the

sso:<username>@<domain> convention. The AuthorizeWithSelectors feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include authorization.k8s.io/decision and authorization.k8s.io/reason, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (``pais-authentication-id``), and the scopes ``openid``, ``groups``, and ``offline_access``. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The ``authorizedGroups`` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, ``group-for-pais-access-01`` or ``group-for-pais-access-02``). The ``oidc-groups-claim`` setting names the claim used to identify group membership in the Access Token, and ``oidc-extra-audiences`` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the ``grafana-oidc-role-mapping`` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that

record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the dbo user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (dsm-auth-creds), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC `UserInfo` endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control IA.L2-3.5.2

> Authenticate (or verify) the identities of users, processes, or devices, as a prerequisite to allowing access to organizational systems.

SCF Controls: IAC-02, IAC-04, IAC-15.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized authentication, authorization, and auditing through VCF SSO, which acts as the identity broker for all VCF management components. All user and service authentication flows through VCF SSO, providing a single point of control for identity management across VMware vCenter, VMware ESX, NSX, VCF Operations, and VCF Automation. VCF SSO is configured via the VCF Operations console and provides a unified authentication source for VCF components.

VCF supports multiple authentication mechanisms for organizational users. VCF SSO issues SAML tokens for authenticated sessions and supports multiple authentication context methods, including PasswordProtectedTransport (password over HTTPS) and holder-of-key tokens that embed security artifacts for delegation scenarios. vCenter supports built-in identity source authentication using local domain credentials and basic authentication through the OAuth 2.0 Password grant type when federated to an external identity provider. VCF SSO also supports the use of SSPI (Security Support Provider Interface) for client authentication.

Identity federation with enterprise identity providers (via SAML or OIDC) enables organizations to extend their existing AAA infrastructure to VCF. Federating vCenter to an enterprise identity provider supports multifactor authentication and automatic registration and termination of users across services. vCenter has documented federation configurations for specific providers including Okta and PingFederate. VCF SSO also supports the System for Cross-domain Identity Management (SCIM) protocol for automating the exchange of user identity information between identity domains and external identity providers.

Organizations using Microsoft Active Directory can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure. VCF Automation allows each organization to define its own identity provider that it shares with other applications; users authenticate to the identity provider to obtain a token that they then use to log in to the organization. Every organization in VCF Automation has its own identity source for user import. The Supervisor component supports registration of external OIDC identity providers for authentication using Pinniped, which inspects upstream identity tokens from the external provider to determine user identity and group membership before passing that information to the Kubernetes API server. Supervisor can be configured with any OIDC-compliant provider, including Okta, Workspace ONE Access, and Dex, to authenticate users connecting to VMware Kubernetes Service (VKS) clusters. Custom ClusterClass configurations for VKS clusters can be used to authenticate developers using existing corporate identity systems. The Kubernetes API server also supports integration with organizational authentication infrastructure such as LDAP or Kerberos through authentication plugins, enabling Supervisor to participate in existing centralized identity management. An Identity API is available to programmatically authenticate and manage the authorization provider, supporting automated identity lifecycle management.

Authorization is enforced through role-based access control across all VCF components. vCenter maps authorization levels to groups and roles, providing consistent security controls regardless of operational context. VCF verifies what objects principals have access to as part of its authorization model. NSX has a set of built-in roles including Enterprise Admin, Auditor, Cloud Admin, Cloud Operator, Network Admin, Network Operator, Project Admin, Security Admin, and others. Local guest user accounts in NSX have the Auditor role by default, and only a user with the Enterprise Admin role can create new local guest user accounts. VCF Automation provides Organization Administrator, Organization Auditor (read-only), and Organization Owner roles, along with the ability to create custom roles scoped to an organization. Organization Administrators can view the rights associated with roles and create roles local to their organization. For Kubernetes workloads, vSphere Supervisor supports Namespace Owner, Edit, and View permission roles that allow consumers of vSphere Namespaces to provision VKS clusters and vSphere Pods using kubectl. Kubernetes RBAC evaluates Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings against the username, UID, group membership, and extra fields supplied by authenticator modules to determine whether a request is permitted. Users authenticated through external OIDC providers are referenced in

ClusterRoleBindings using the `oidc:user@example.com` naming convention; users authenticated through VCF SSO use the `sso:<username>@<domain>` convention. The `AuthorizeWithSelectors` feature gate passes field and label selector information to authorization webhooks, supporting more granular per-resource authorization decisions. User impersonation is governed by Kubernetes RBAC: the "impersonate" verb on user, group, and ServiceAccount resources under authentication.k8s.io allows designated administrators to act on behalf of other principals in a traceable manner. Kubernetes also distinguishes human user accounts, whose identities are managed externally by the identity provider, from ServiceAccounts, which are namespace-scoped API objects used by automated workloads and processes; separating their lifecycle management supports differentiated audit strategies for each category. IAM role trust policies for VKS clusters can be scoped to specific service accounts and namespaces to enforce least privilege.

VCF provides role-based visibility into policy enforcements. The Organization Administrator and Organization Auditor roles can view policy enforcements within their organizations. VCF's logging infrastructure captures authentication and authorization events across management components. The Kubernetes API server records API server activity with structured per-event metadata. Audit annotations include `authorization.k8s.io/decision` and `authorization.k8s.io/reason`, which record each authorization decision and its human-readable justification in the audit log, providing per-request traceability of who performed what action and how the authorization decision was reached. An audit event is logged for each impersonation request, enabling tracking of how impersonation is used over time. Audit rules can be configured to alert on specific events, such as concurrent reading of multiple Secrets by a single user. Authentication context, including username and group memberships, can be retrieved and logged using `kubectl auth whoami` for verification purposes. Administrators can use `kubectl auth can-i` with user impersonation to determine what actions other users are permitted to perform.

Service-to-service authentication uses certificate-based Principal Identity users rather than password credentials. Principal identity user certificates must be SHA256-based and use RSA/DSA message algorithm with 2048 bits or above key size. Each VCF component registers with VCF SSO as a solution user. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and also supports LDAP authentication sources for additional monitoring and management access.

Additional Consumption-layer services extend the AAA model to workload infrastructure. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control for container image artifacts and artifact security policies. The Secret Store Supervisor Service enforces RBAC across administrators, DevOps engineers, and application tenants for access to secrets and credentials. Argo CD, deployable as a Supervisor Service, supports OIDC authentication with PKCE via the `enablePKCEAuthentication` field and defines access through global RBAC policies using policy rules and group mappings.

While VCF provides the technical mechanisms for authentication, authorization, and audit, centralizing these capabilities requires the organization to deploy and manage an external identity provider (such as Active Directory or an OIDC-compliant provider), define identity governance policies, and establish processes for user lifecycle management including provisioning, periodic access reviews, and de-provisioning. Role assignment procedures and access review processes are organizational responsibilities that fall outside VCF's direct control.

VMware Private AI Services (PAIS) integrates with an external OIDC identity provider to authenticate organizational users accessing AI infrastructure on VCF. The `PAISConfiguration` custom resource is configured with an OIDC authentication block specifying the issuer URL, the client ID (`'pais-authentication-id'`), and the scopes `'openid'`, `'groups'`, and `'offline_access'`. When a region is created for a supervisor in PAIS, an identity provider is automatically created in VMware vCenter for that supervisor, establishing a consistent authentication entry point for AI workloads. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator, who supplies the issuer URL and client ID.

Authorization for PAIS is enforced through OIDC group-based access control. The `'authorizedGroups'` setting in the `PAISConfiguration` restricts service access to user accounts that belong to designated OIDC groups (for example, `'group-for-pais-access-01'` or `'group-for-pais-access-02'`). The `'oidc-groups-claim'` setting names the claim used to identify group membership in the Access Token, and `'oidc-extra-audiences'` accepts additional OAuth 2.0 client IDs that PAIS will recognize when validating tokens. Grafana, used for PAIS metrics visualization, extends the same model through the `'grafana-oidc-role-`

mapping` configuration: users in a designated PAIS access group are assigned the Admin role automatically, while remaining authenticated users receive the Viewer role.

Harbor Registry imposes its own credential boundaries for AI artifact access. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. Processes that push artifacts to Harbor authenticate using the `oras login` command with username and password credentials. Knowledge Base integrations support per-source authentication: Confluence connections accept a user name and password or a personal access token, and SharePoint On-Premises connections use user name and password authentication. These mechanisms restrict access to organizational AI artifacts and reference data to authorized accounts.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the

minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses the authentication component of this control through a two-tier identity model. DSM supports both local user accounts and LDAPS-integrated directory service accounts, and administrators can configure one or both identity sources simultaneously. Local users are authenticated by matching their email address and validating their password directly within DSM. LDAPS users are authenticated by matching the email domain name against the registered LDAPS server and validating credentials against the directory service. DSM can be configured to use an LDAP server for both authentication and authorization of platform-level users.

Authentication for the managed databases is handled through database-native mechanisms that DSM exposes and configures. PostgreSQL databases use host-based authentication (HBA), with rules managed through DSM. The HBA configuration applies ordered matching rules where the first entry matching the connection type, client address, requested database, and user name is applied. The default final entry uses SCRAM-SHA-256, providing strong password-based authentication; an optional LDAP entry can also be included. MySQL databases support LDAPS integration using a simple authentication plug-in, with a unique LDAPS user entry per user and support for Active Directory authentication. PostgreSQL and MySQL databases also support LDAPS user accounts linked to organizational directory services, with LDAPS user creation managed through the DSM interface.

DSM adds SQL Server as a supported database engine. SQL Server clusters support two administrator identity types: SQL User credentials and Windows Principal accounts for clusters integrated with Active Directory. DSM's Active Directory integration supports Kerberos-based authentication for domain-joined SQL Server clients, allowing tools such as SQL Server Management Studio running on a Windows machine to authenticate using domain credentials. DSM maps the `dbo` user, the database object owner, to administrator-controlled identities for SQL Server database access. SQL Server clusters can also use contained database users, where each user authenticates directly against the database rather than a server-level login, keeping identity information self-contained within the database.

Authorization is handled through a role-based model. DSM provides two platform-level roles, DSM Admin and DSM User, which determine the capabilities available to each user within the DSM management interface and API. Custom user roles can be configured for directory service group members, providing scoped monitoring and management access. The Permissions view in DSM supports the creation, monitoring, and management of configured users, giving administrators visibility into who has access. Role assignments also affect behavior in database operations; DSM automatically establishes trust between primary and secondary PostgreSQL instances for Admin-role users, while User-role accounts require manual trust establishment.

DSM produces audit records covering both user-initiated and system-initiated actions. Audit events are generated for actions performed through the DSM UI and API, and each audit log entry includes a Source field identifying the initiating entity: either a user's email address or "System" when the action was initiated by DSM itself. Gateway Audit Logs provide visibility into gateway-level events, and the System Audit Events view is the designated location in the DSM UI for tracking nondatabase-related operations and tasks. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create a simple audit for login events.

In self-service consumption deployments, the DSM Consumption Operator authenticates with the DSM infrastructure using a dedicated authentication secret (`dsm-auth-creds`), providing a defined authentication path for Kubernetes-native database provisioning.

DSM's authentication, authorization, and audit capabilities are scoped to the DSM platform and its managed databases. Centralized AAA for the broader organizational user population, including account lifecycle management, privileged access governance, and enterprise-wide log aggregation, requires organizational identity governance programs and security tooling outside DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC `UserInfo` endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control IA.L2-3.5.3

> Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.24 25

SCF Controls: IAC-06, IAC-06.1, IAC-06.2, IAC-06.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF supports multi-factor authentication (MFA) for privileged account access through identity provider federation. VCF does not include a built-in MFA mechanism, but its authentication architecture is designed to integrate with external identity providers that enforce MFA policies for all privileged users.

VCF SSO can be configured with an external identity provider using Generic SAML 2.0 or OIDC protocols. The VCF Identity Broker integrates with the selected identity provider for user authentication, enabling organizations to connect enterprise identity platforms such as Okta, Entra, or Ping to VCF SSO. Once configured, all VCF SSO-authenticated access to VCF management interfaces, including VMware vCenter, NSX Manager, and VCF Operations, flows through the external identity provider, which can enforce MFA as part of the authentication process. The identity provider must be configured for VCF SSO before enabling VCF SSO for VCF Operations and VCF Automation.

At the vCenter layer, identity provider federation provides the mechanism for MFA enforcement. Federating vCenter to an enterprise identity provider provides flexible authentication options, including MFA. The native vCenter MFA capability has been deprecated in favor of leveraging the external identity provider's authentication mechanisms, which can support passwords, MFA, and biometrics depending on the provider's configuration. The OAuth 2.0 Authorization Code grant type used in federated authentication is compatible with MFA. The VCF Identity Broker also supports the Authorization Code grant type, and it should be used instead of the Password grant type, which operates as a single-factor method and is incompatible with MFA requirements. When federation is configured with the Authorization Code flow, privileged users authenticating to vCenter through AD FS or other supported providers are subject to whatever MFA policies the identity provider enforces. Organizations should ensure that API integrations, automation workflows, and SDK clients use the Authorization Code grant type rather than the Password grant type when MFA is required.

VCF Automation supports integration with multiple identity provider types, including LDAP, SAML, OIDC, and VCF SSO, for user authentication and access control. Users can be imported from SAML, OIDC, or VCF SSO identity providers using the name identifier format supported by the SAML identity provider. VCF Automation also supports remapping users between SAML, LDAP, and OIDC identity provider types. When VCF Automation is configured to use a SAML identity provider for authentication, the MFA policies enforced by that provider apply to VCF Automation access as well.

VCF's role-based access control model defines several privileged roles across components. In vCenter, the Administrator system role includes all privileges including cryptographic operations, and the CloudAdmin role provides host switch-level and platform-level operations permissions. In VCF Automation, the Assembler Administrator role has full read/write access to the UI and API, and the cloud administrator role is required to manage cloud accounts and organizations. VCF Operations for Networks access requires the Cloud Administrator role. When identity federation is in place, users holding any of these privileged roles must authenticate through the federated identity provider, where MFA can be required.

Service-to-service authentication between VCF components uses certificate-based solution user accounts, which operate outside the federated authentication and MFA flow. These accounts are not interactive user sessions and are not subject to MFA policies.

To implement MFA for privileged accounts in a VCF environment, administrators should configure VCF SSO with an external identity provider that enforces MFA, federate vCenter to that identity provider, and ensure that all privileged user access routes through the federated authentication path. Because VCF does not enforce MFA itself, the organization must deploy, configure, and maintain the external identity provider with appropriate MFA policies.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L2-3.5.4

> Employ replay-resistant authentication mechanisms for network access to privileged and non-privileged accounts.

SCF Controls: IAC-02.2

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several authentication mechanisms that are inherently resistant to replay attacks across its management interfaces, APIs, and service-to-service communication paths.

VCF SSO supports SAML 2.0 as its primary authentication protocol for identity provider integration and user access to management interfaces. SAML assertions are digitally signed, time-bounded, and scoped to a specific audience, which makes captured assertions unsuitable for reuse by an attacker. Administrators can configure VCF SSO to use Generic SAML 2.0 or specific SAML context options depending on the identity provider in use. The PasswordProtectedTransport authentication context method requires credentials to be transmitted over HTTPS, providing transport-layer replay protection. Identity federation with external identity providers through SAML or OIDC inherits whatever replay-resistant mechanisms the enterprise identity provider implements, including nonce-based challenges and time-bound assertions.

VMware Kubernetes Service (VKS) clusters, running on the vSphere Supervisor, inherit the platform's replay-resistant authentication framework at the Kubernetes workload layer. VKS clusters support VCF SSO and OIDC-compliant external identity providers for cluster access. For external OIDC providers, VKS clusters use the Pinniped authentication service to broker connections between the Kubernetes API server and the identity provider, inheriting the provider's replay-resistant properties such as time-bounded tokens and nonce binding. The VKS API server includes an authentication webhook pod that validates user authentication tokens on every API request, rejecting any token whose expiry has passed regardless of its cryptographic validity. The VCF Consumption CLI automatically renews access token credentials using a refresh token, keeping the active access token window short-lived without requiring manual reauthentication.

The VMware vCenter API infrastructure supports holder-of-key security tokens through the LoginByToken method. Holder-of-key tokens embed security artifacts that tie the token to the presenting party, requiring proof of possession of a private key associated with the token. Intercepting the token alone is insufficient for authentication because the presenting party must demonstrate it holds the corresponding key material. This mechanism is used for programmatic and service-to-service authentication within the VCF platform.

VCF also supports Kerberos authentication in environments integrated with Active Directory. Kerberos uses time-stamped tickets and session keys that are bound to specific client-server pairs, making replayed tickets detectable. VCF documentation recommends synchronizing system clocks across the environment to avoid Kerberos authentication failures caused by clock skew, with a default tolerance of 5 minutes. This confirms that Kerberos ticket validation, including its time-based replay protections, is actively enforced. VCF Operations orchestrator plug-ins can be configured with Kerberos authentication through the krb5.conf file.

The VCF SSO client API provides challenge-response authentication through the Security Support Provider Interface (SSPI). In SSPI authentication, the client sends an issue request containing credentials, the server uses its security provider to authenticate the client, and if additional negotiation is required, the server embeds a challenge in its response. The client then sends a challenge request back to complete the exchange. Challenge-response protocols generate unique values for each authentication exchange, so a captured response from one session cannot be replayed in another.

NSX Manager supports session-based authentication using JSESSIONID cookies, which reduces repeated credential transmission while maintaining authenticated state. NSX Manager authentication mechanisms are designed to resist replay attacks.

VMware ESX (ESX) supports bidirectional CHAP authentication for iSCSI and iSER storage adapters, where both the storage initiator and the target authenticate each other using challenge-response exchanges. This extends replay-resistant

authentication to storage fabric access paths, which auditors should verify are using mutual CHAP rather than one-way authentication or no authentication.

For webhook and API security, VCF Automation secures webhook behavior requests using hash-based message authentication codes (HMAC), a mechanism that validates the authenticity and integrity of HTTP requests. HMAC-authenticated requests include a computed signature that is tied to the request content, so replaying or tampering with requests is detectable.

For service account and API access, VCF uses access tokens that rotate after each use. Access tokens normally last one hour and are derived from a refresh token that normally lasts 90 days but can be revoked earlier. If rotation is activated, making a refresh token grant call returns both a new access token and a new refresh token, and the original refresh token is invalidated. This rotation pattern limits the window during which a captured token remains valid and, when single-use rotation is enabled, renders captured tokens useless after their first use. The VCF Automation API uses authentication tokens (csp-auth-token) for API requests, and users can revoke API tokens through the User preferences page.

VCF Operations supports single sign-on authentication, allowing token reuse within a session without re-entering credentials while relying on the underlying replay-resistant token exchange. VCF Operations for Networks supports token-based authentication for its management interfaces, providing replay-resistant access control for network management operations.

For CI/CD workloads running through the Argo CD Supervisor Service, OIDC authentication supports PKCE (Proof Key for Code Exchange) through the enablePKCEAuthentication field in the Argo CD spec.oidc configuration. PKCE binds each authorization code exchange to the specific client session that initiated the flow, blocking authorization code interception and replay in OAuth 2.0 authorization code flows. Service-to-service authentication within Kubernetes workloads on VKS clusters can use the Kubernetes TokenRequest API to generate short-lived credentials scoped to a specific audience and time window; Kubernetes hardening guidance recommends implementing short token lifespans to reduce the replay window if a credential is captured. Where workloads integrate with HashiCorp Vault through the Harness CI/CD Supervisor Service, Vault can generate dynamic short-lived credentials rather than long-lived static tokens, limiting exposure to credential replay.

Across management interfaces, APIs, service-to-service communication paths, Kubernetes workloads, and storage fabric access, VCF provides native replay-resistant mechanisms that include digitally signed and time-bounded SAML assertions, holder-of-key security tokens, Kerberos time-stamped tickets, SSPI challenge-response exchanges, HMAC-signed webhook requests, rotating API access tokens, bidirectional CHAP, Pinniped-brokered OIDC flows with per-request token validation, PKCE-bound authorization code exchanges for CI/CD, TokenRequest API short-lived credentials, and Vault-generated dynamic secrets. VCF documentation recommends migrating API, SDK, and CLI access from Simple Authentication to token-based authentication where possible. The VCF SSO configuration pages in VCF Operations and VMware vCenter provide the settings for selecting the authentication protocol in use.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) operates at the application delivery layer and provides multiple mechanisms that support replay-resistant authentication for both management plane access and application workloads traversing the load balancer.

For management plane access, the Avi Controller supports remote authentication via LDAP, TACACS+, and SAML, with the ability to deactivate local user login when remote authentication is enabled. SAML authentication delegates to a centralized identity provider (IdP), verifying user identity without storing credentials on client devices. SAML assertions carry timestamps and unique assertion IDs that the IdP and Avi use to detect and reject replayed assertions. The Avi Controller also supports token-based and session-based authentication for REST API access through the Avi Python SDK. In the Avi for VCF deployment, the Avi Controller provides a POST /api/authtoken endpoint for generating authentication tokens with configurable validity duration in hours, bounding the window during which a captured token could be reused.

For secure channel communication between the Avi Controller and Service Engines, Avi enforces configurable token timeouts via the secure_channel_controller_token_timeout setting, limiting the lifetime of authentication tokens used in the control plane. When the Avi Controller cluster enters a manual recovery state, secure channel credentials for all Avi Service Engines are revoked, requiring fresh authentication before those engines can resume normal operation.

For web applications and API traffic, SAML authentication can be enforced at the virtual service boundary. Authentication rules support Default Authentication (enforce SAML on rule match) and Skip Authentication (bypass for specified paths), allowing operators to apply path-specific policies. WAF authentication rules also support configurable custom actions when rule conditions are matched.

The Auth Credentials Cache Expiration setting controls the maximum allowed lifetime of cached client authentication state, limiting the window during which stale cached credentials could be reused. Avi Controller also provides the AUDIT_COMPLIANCE_EVENT mechanism to log authentication failures for audit purposes, supporting detection of replay attempts.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L2-3.5.5

> Prevent reuse of identifiers for a defined period.

SCF Controls: IAC-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L2-3.5.6

> Disable identifiers after a defined period of inactivity.

SCF Controls: IAC-15.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides account deactivation capabilities across its management components, but does not include a built-in automated mechanism to detect and disable accounts based on inactivity duration. The manual deactivation features across the platform supply the technical foundation that an organization can build upon to satisfy this control when paired with external identity governance processes or tooling.

NSX Manager ships with three default inactive local user accounts (audit, guestuser1, and guestuser2), which can be deleted, activated, or deactivated through the Local Users tab in the NSX Manager UI. The admin user or any user with the Enterprise Admin role can activate or deactivate any local user account except for the built-in admin account, which cannot be deactivated.

VMware vCenter supports account deactivation at both the VCF SSO and local user account levels. VCF SSO user accounts can be deactivated through the vCenter management interface; a deactivated account remains in the identity store but the user cannot log in until an administrator reactivates it. For vCenter local user accounts managed through the Appliance Shell, administrators can use the ``localaccounts.user.set --username <username> --status disabled`` command to disable a specific account, or restore access by setting the status back to enabled.

VCF Operations provides account activation and deactivation controls. Administrators can deactivate user accounts through the Activated field or a disable checkbox, which stops the user from accessing VCF Operations features. The account can be reactivated later if needed.

VCF Automation provides similar capabilities at both the user and user group level. Organization administrators can disable users, which deactivates their access to the organization and stops them from logging in. Provider-level users can also be deactivated, after which the user cannot log in to VCF Automation. Disabling a user in VCF Automation does not remove them from the organization, and their access can be reactivated at a later time. User accounts can also be deleted entirely when no longer required.

For service accounts, VCF implements automatic token expiration as a form of time-bound access control. Service accounts authenticate using API access tokens that rotate after each use. Access tokens normally last one hour and are based on a refresh token that normally lasts 90 days. Refresh tokens can be revoked earlier and optionally rotated with each access token request. This token lifecycle provides an automated mechanism that limits the duration of service account access without manual intervention.

Within the Consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor provide automated mechanisms for managing service account credential lifetimes. The Kubernetes control plane includes the LegacyServiceAccountTokenCleanup feature gate, which enables automatic purging of Secret-based service account tokens that have not been used within a configurable inactivity period. The inactivity window is set through the ``--legacy-service-account-token-clean-up-period`` flag on the kube-controller-manager, configurable via the ``LegacySATokenCleanerConfiguration.CleanUpPeriod`` field; the default retention period is one year. The companion LegacyServiceAccountTokenTracking feature marks unused auto-generated tokens as invalid when they are not mounted by any pods and have remained unused for the configured period, at which point the cleanup controller removes them. For workloads using projected service account tokens, the ``projected.sources.serviceAccountToken.expirationSeconds`` parameter sets a bounded validity window for each token, limiting its active lifetime regardless of usage patterns; organizations should prefer short-lived projected tokens over long-lived Secret-based tokens. For human user access to VKS clusters, VCF SSO is the default authentication backend and can integrate with Active Directory and LDAP systems; inactivity-based account disabling for human users is enforced at the identity provider level and flows through VCF SSO into the VKS authentication layer.

VMware ESX hosts provide time-based access controls for ESX Shell access. The ESX Shell availability timeout can be configured so that the service deactivates and prevents new logins after a specified period, and the idle timeout setting automatically logs out users from inactive interactive sessions. These settings limit the duration of shell access when manual deactivation has not been performed.

To fully satisfy this control, organizations should integrate VCF's identity sources with an external identity provider such as Active Directory, LDAP, or an OIDC provider that supports automated detection of inactive accounts and time-based disabling policies. VCF's local account deactivation features can then be used to enforce disabling actions identified by the external governance process, giving administrators the ability to respond to specific account management needs directly within the platform.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L2-3.5.7

> Enforce a minimum password complexity and change of characters when new passwords are created.

SCF Controls: IAC-10.1

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces password complexity, length, and lifespan requirements across its component stack, with each component providing configurable password policies.

At the platform level, VCF uses the Linux PAM (Pluggable Authentication Module) framework to enforce default password complexity rules. The default policy requires passwords of at least 12 characters containing at least one lowercase letter, one uppercase letter, one digit, one special character, and at least five different characters. The PAM module limits password entry attempts to a maximum of three retries before returning an error. On VMware ESX hosts, the password complexity policy is enforced for the root user, helping maintain strong credentials on the hypervisor layer.

VMware vCenter's built-in authentication service, VCF SSO, enforces a password policy for local domain accounts with a default password lifetime of 90 days, configurable through the VCF SSO password policy settings in vCenter. For users authenticated through external identity sources such as Active Directory, password restrictions, expiration, and account lockout are governed by the identity source domain rather than VCF SSO policies.

NSX Manager and NSX Edge enforce password complexity through Linux PAM modules. Default requirements include a minimum of 12 characters (maximum 128), at least one lowercase letter, one uppercase letter, one numeric character, one special character, and at least five different characters. NSX Edge adds restrictions against dictionary words, palindromes, and monotonic character sequences of more than four. All of these parameters are configurable through the NSX Authentication Policy Settings or the NSX Manager API, including minimum and maximum password length, required count of uppercase, lowercase, special, and numeric characters, password uniqueness, and hashing algorithm. NSX Manager enforces a retry limit of three attempts when setting a new password. For password lifespan, NSX Manager supports configuring password expiration with a range from 1 to 9,999 days.

VCF Operations applies password complexity requirements at multiple levels. The admin user account requires a minimum of 15 characters with at least one uppercase letter, one lowercase letter, one digit, and one special character. The default password strength policy allows configuration of the minimum password length starting at eight characters. The password policy settings are managed through Administration > Global Settings > User Access > Password Policy, which provides controls for password strength, password change policy, and account lockout. VCF Operations locks user accounts based on the password lockout policy, with a default threshold of seven failed login attempts, or if a user enters an incorrect password three times within five minutes. VCF Operations for Networks locks a user account after five consecutive failed login attempts for 15 minutes.

VCF Automation supports its own password policy system settings, including account lockout after a configurable number of invalid login attempts. The lockout interval specifying the duration before automatic unlock is also configurable. Provider administrators can unlock a user account manually without waiting for the lockout interval to expire. VCF Automation passwords require a minimum of 15 characters.

VCF Operations provides centralized password lifecycle management for all VCF components. Administrators can rotate passwords on demand or schedule automatic rotation on a recurring basis. During rotation, VCF Operations generates a randomized password that conforms to the component's password policy and re-establishes the relevant component integrations automatically. The VCF Operations UI offers preset rotation intervals, and the API supports custom scheduling. VCF Operations also provides a password remediation capability through the Security > Password management interface, allowing administrators to update service account credentials and synchronize passwords when they have drifted out of sync between components.

The VCF API supports managing the local accounts global password policy in vCenter. The `Invoke-GetLocalAccountsGlobalPolicy` and `Invoke-SetLocalAccountsGlobalPolicy` operations allow administrators to retrieve and update the vCenter password policy programmatically through the vSphere Automation SDK for PowerShell.

VCF documentation recommends setting passwords following a common set of requirements across all accounts. While individual components support different password parameters and defaults, administrators can align password policies across the environment to establish a consistent security posture. The combination of enforced defaults, per-component customization options, password expiration controls, and centralized rotation provides the mechanisms needed to enforce complexity, length, and lifespan requirements for password-based authentication throughout the VCF stack.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces password complexity, length, and lifespan requirements for its management interface accounts, contributing to the organization's password-based authentication posture.

Security Services Platform (SSP) is the centralized management console for vDefend. SSP enforces password policies for local user accounts: admin and audit user passwords require a minimum of 12 characters and a maximum of 128 characters, and must contain at least one uppercase letter, one lowercase letter, one numeric character, and one special character. The same complexity criteria apply during password changes and resets. Local user passwords are valid for 180 days; a notification banner appears in the SSP UI 30 days before expiration to prompt users to update their password. Installer user passwords are valid for 60 days. The License Hub component of SSP also enforces password complexity requirements during local password change operations.

SSP supports integration with directory services, including Active Directory over LDAP and OpenLDAP. When remote users or remote user groups are configured through LDAP, SSP applies the password expiration settings configured in the directory service; password expiry for these accounts cannot be modified from the SSP UI. SSP uses Authelia, an open-source authentication and authorization server, to handle authentication requests, including two-factor authentication and single sign-on.

For Identity Firewall, vDefend uses an LDAP password to authenticate connections to the directory service used for identity-based policy enforcement.

vDefend is a network security product and not a general-purpose identity management system. Its management interfaces enforce password complexity, length, and lifespan policies for vDefend administrative access. Satisfying this control fully requires applying equivalent password policies across all systems within the organization's environment, which is an organizational responsibility beyond vDefend's scope.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) enforces password complexity and length requirements for all local user accounts. Local user passwords must contain a minimum of 8 and a maximum of 20 characters, including at least one uppercase letter, one lowercase letter, one number, and one special character from the set `(?!@#$$%^&*)`. These requirements apply both at account creation and at every subsequent password reset; DSM rejects any new password that does not satisfy all criteria before accepting the change. Administrators can set the `force_password_change` flag on individual local user accounts to require a password reset at the next login, supporting periodic credential rotation and post-provisioning hygiene workflows.

The root account for the DSM provider VM carries its own complexity requirements: a minimum of 15 and a maximum of 32 characters, requiring at least one uppercase letter, one lowercase letter, one number, and one special character. These constraints are enforced during OVA deployment, so the appliance cannot be instantiated with a weak root credential. The root password expiry date must be set to a valid future date and cannot be configured to never expire, making root credential rotation mandatory. DSM checks root password status at regular intervals and generates a `ROOT_USER_PASSWORD_EXPIRE_SOON` alert when the credential is approaching expiration, giving administrators advance notice before a reset is required.

For PostgreSQL database instances managed by DSM, the default host-based authentication (HBA) configuration applies the `scram-sha-256` algorithm, a salted challenge-response mechanism that avoids transmitting cleartext passwords during

authentication. Custom `pg_hba.conf` entries also default to `scram-sha-256` as the password-based authentication method. Local user management passwords within the DSM platform are encrypted using PGP symmetric encryption with dedicated keys (`PGCRYPTO_PASSWORD` and `PGCRYPTO_ALGORITHM`).

DSM supports both local user authentication and LDAPS-based directory service authentication for platform access. Local users are authenticated by validating the email address and password against DSM's internal store. When LDAPS is configured, password lifecycle management, including organizational complexity and lifespan policies, is delegated to the directory service. PostgreSQL and MySQL database instances can independently be configured for LDAP or Active Directory authentication, allowing database-level credential management to align with enterprise directory policies. For PostgreSQL, the Enable Directory Service Authentication toggle on the database creation form activates this integration when a default directory service is configured. Administrators should configure LDAPS where enterprise password governance policies must extend to database-level credentials, or rely on DSM's built-in local user password policy where directory integration is not used.

For SQL Server database instances, DSM supports SQL User authentication with standard SQL Server logins and passwords. The DSM privileged service account used for automated SQL Server tasks must be configured with its password policy set to Never Expire to prevent service interruptions; administrators should account for this service account exception when reviewing password lifespan policies across DSM-managed database instances.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) enforces password-based authentication controls through the Avi Controller's administrative identity plane, addressing complexity, length, and lifespan for locally authenticated accounts.

The Controller's strong password enforcement feature requires each password to contain at least one uppercase character, at least one lowercase character, at least one numeric character, and at least one special character from the allowed set. The Controller rejects passwords consisting of sequences of adjacent keyboard keys. These requirements apply to both newly created accounts and to existing accounts when a user changes their password. Complexity enforcement is controlled through the `password_strength_check` setting, which the Controller applies at the portal level regardless of the administrative interface used.

The minimum permissible password length is configurable through the `minimum_password_length` setting. The Controller enforces a minimum of 8 characters by default; administrators can raise this threshold via the REST API or CLI. The Avi License Hub enforces stricter length requirements for its admin and audit accounts: a minimum of 12 characters and a maximum of 128 characters.

Password expiration is enforced through user account profiles using the `password_expiration_days` setting. The Default-User-Account-Profile sets password expiration at 365 days. The Controller displays a notification banner in the UI 30 days before a password expires to prompt renewal. The expiration period is configurable per profile.

Password history enforcement restricts users from reusing recent passwords by comparing proposed updates against a configurable list of previous password hashes. The history count is configurable from 1 to 10 previous passwords, with a default of 5.

Locally authenticated users change their own password through the My Account menu, which requires entry of the current password before accepting a new one. Administrators can generate a random password for a local user account or input a new password manually during a password reset. User-initiated password recovery through the GUI is supported when SMTP email is configured.

These controls apply to locally authenticated Avi Controller accounts. For administrators who authenticate against external directories such as LDAP, password complexity and lifespan are managed by those external directories.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IA.L2-3.5.8

> Prohibit password reuse for a specified number of generations.

SCF Controls: IAC-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered authentication infrastructure that supports secure management of authenticators across the platform's components and the Kubernetes workload consumption layer, though the broader organizational policies governing authenticator lifecycle management require processes and governance beyond what VCF itself provides.

VCF Identity Broker integrates with a selected identity provider for user authentication, establishing trust through metadata exchange between the service provider and the identity provider. This centralized approach allows organizations to manage authenticators through their existing identity management systems rather than maintaining separate credential stores for each VCF component. VCF SSO provides a single sign-on environment where a user provides credentials once, and components in the environment perform operations based on the original authentication. Administrators can federate VMware vCenter with an enterprise identity provider, which enables multifactor authentication (MFA), automatic user provisioning and deprovisioning, and token-based authentication that reduces the risk of credential exposure. VCF SSO supports SCIM (System for Cross-domain Identity Management) for automating user identity exchange across identity domains, and named providers including Okta are supported through the identity provider federation mechanism. When configured for identity provider federation, the external provider handles all authentication mechanisms, including passwords, MFA, and biometrics, delegating full authenticator management to the organization's existing identity infrastructure. The Authorization Code grant type in VMware Identity Broker supports MFA workflows, while the Password OAuth 2.0 grant type is incompatible with MFA requirements, so organizations should use the Authorization Code flow when MFA is needed.

VMware Kubernetes Service (VKS) extends this identity architecture to the workload consumption layer. VKS clusters support two authentication methods: VCF SSO and any OIDC-compliant external identity provider, including Okta, so identity lifecycle management, including onboarding, offboarding, and group membership changes, can remain in the organization's central identity system. Users authenticated through an external identity provider are granted Kubernetes RBAC permissions using the `sso:<username>@<domain>` naming convention in `ClusterRoleBindings`. Custom `ClusterClass` configurations allow organizations to authenticate developers against existing corporate identity systems. When provisioning clusters based on a custom `ClusterClass`, the authentication Secret can be configured with multiple JWT issuers to support distinct identity providers simultaneously, such as Keycloak for contractors and Microsoft Entra ID for employees. At the `kube-apiserver` level, VKS supports multiple authenticator types: client certificates, bearer tokens, an authenticating proxy, and HTTP basic auth. The `--authentication-config` file provides structured control, allowing multiple JWT authenticators each with a unique issuer URL and discovery URL, and CEL expressions to map claims to user attributes and validate claims. When multiple authenticator modules are active, the first to successfully authenticate a request short-circuits further evaluation, making authenticator order significant; Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to simplify user management and reduce the risk of users retaining access after it is no longer needed. The `kube-apiserver` can also leverage existing authentication methods such as LDAP or Kerberos through plugins, and `kubectl` integrates with credential plugins for centralized operator credential management. The `system:auth-delegator` `ClusterRole` provides unified authentication and authorization flows for add-on API servers deployed into VKS clusters. Production VKS clusters should enable Kubelet authentication and authorization to restrict direct access to the kubelet API. For Windows node pools, VKS clusters support Group Managed Service Accounts (gMSA) for authenticating Windows nodes to Active Directory; gMSAs are managed by security groups that control password retrieval and delegation permissions, allowing Windows workloads to use Active Directory-managed identities.

Standard packages deployable on VKS clusters extend authenticator management to workload-level services. Argo CD, available as a standard package, supports local account authentication with global RBAC policies and OIDC authentication for federated identity, allowing GitOps workflow access to be governed through the same identity infrastructure used for cluster

access. The Harbor container registry package provides authentication and token management for artifact access, with role-based access control restricting image push and pull operations.

VCF Operations integrates with VCF SSO for centralized authentication through an identity provider. NSX Manager can be configured to authenticate users from identity management providers or through a directory service such as Active Directory over LDAP or OpenLDAP. NSX authentication best practices include integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions. NSX Manager requires authentication prior to establishing a management connection for administrative access. The VCF Automation Provider Management Portal supports authentication via local users and SAML users, and Organization Administrators use credentials configured during organization creation to access their respective organizations.

For local accounts, each VCF component enforces password complexity and lifecycle policies. NSX Manager requires passwords of at least 12 characters with uppercase, lowercase, numeric, and special character requirements, enforced through Linux PAM modules. Each NSX user password has an expiration date tracked by NSX, with a default expiration period of 90 days. Password expiration is configurable between 1 and 9,999 days. VCF Operations enforces a minimum of 15 characters with similar complexity rules. VCF Automation passwords must also be at least 15 characters in length.

VCF provides configurable account lockout policies across its components. VCF Operations locks accounts after five consecutive failed login attempts for 15 minutes. A separate policy locks VCF Operations accounts if a user enters an incorrect password three times within five minutes. VCF Automation supports account lockout in password policy system settings, which locks user accounts after a configurable number of invalid login attempts. VCF Automation also provides a configurable account lockout interval that specifies the duration before an account is automatically unlocked, and provider administrators can unlock a user account manually without waiting for that interval to expire.

For service-to-service authentication, VCF uses certificate-based credentials. VCF SSO supports X.509 certificate authentication, and vCenter extensions can authenticate using `loginExtensionByCertificate()` with an extension key certificate. Provider management accounts authenticate using API access tokens that rotate after each use. VCF Automation provides service accounts with the same access restrictions as user API tokens, so service accounts cannot perform user management or create refresh tokens. NSX supports Principal Identity certificates for cloud management platform integration, requiring SHA256-based certificates with RSA/DSA message algorithm and 2048-bit or larger key sizes. At the Kubernetes layer, service account authentication uses bearer token secrets generated automatically for service accounts. Kubernetes hardening guidance recommends setting short lifetimes on certificates and automating their rotation, and recommends using an authentication provider that controls how long issued tokens remain valid; using short-lived Secrets helps detect or limit the impact of credential exposure. The `system:masters` group functions as a break-glass super-user group that bypasses the RBAC authorization layer and should be reserved for emergency access scenarios only.

VCF Operations provides API endpoints for trusted certificate management and displays certificate expiration status for each workload domain through its Certificates tab. NSX supports non-disruptive certificate rotation in VCF and later, allowing certificate replacement without service interruption.

VCF also provides visibility into authenticator usage through audit logging. User authentication details are viewable in VCF Operations, including user name, successful or failed authentications, and events such as user login and guest operation authentication. This logging supports detection of compromised or misused authenticators.

While VCF provides the technical controls for authenticator strength, complexity, expiration, lockout, and rotation within its own components, as well as identity provider integration for MFA enforcement and centralized authentication, and the VKS consumption layer provides configurable multi-method kube-apiserver authentication, external identity provider integration, short-lived credential support, and gMSA for Windows workloads, the broader organizational policies for initial authenticator issuance, periodic credential rotation schedules, revocation upon personnel changes, and mapping authentication strength requirements to data classification levels require processes and governance outside VCF's scope.

VMware Private AI Services (PAIS) provides authentication mechanisms specific to its AI infrastructure components, integrating with externally managed identity systems to control access to AI services, model endpoints, and training data.

PAIS uses OIDC-based authentication as its primary access control mechanism. The PAISConfiguration custom resource configures the OIDC provider with issuerUrl, clientId, and scopes including openid, groups, and offline_access. Access is restricted to user accounts whose membership matches OIDC groups listed in the authorizedGroups field, and the Access Token carries a groups claim that PAIS validates against the authorized group list. The OIDC configuration also supports configurable group claim names and Extra Audiences for additional OAuth2.0 clients that PAIS will accept when validating the Access Token.

The PAISConfiguration custom resource supports client TLS for outbound authentication to the OIDC provider and Harbor registry, configured through the worker.clientTls.caBundleRefs field. This binds certificate-based trust to identity provider and registry connections so that authentication exchanges are integrity-checked against approved CAs.

Authenticator management for the Harbor registry that stores AI models and artifacts follows a credential-based pattern. The oras login command authenticates to a private Harbor registry using username and password credentials for artifact push operations, and docker login is used for pushing models to Harbor projects through the Model Gallery. Harbor project access capabilities restrict access to the sensitive data that is used to train and tune models. Model endpoints support authentication through harbor-pull-secret-readonly to control access to container images stored in private registries, and Harbor model retrieval requires certificate-based trust in addition to credential authentication.

Internal service-to-service authentication is addressed at the component level. PAIS authenticates to the OpenTelemetry Collector using a Kubernetes Secret containing Authorization Bearer tokens and custom headers, and the LLM Traces flow uses the same pattern with semi-colon separated headers. The PAIS MCP server supports custom HTTP headers including User-Agent and Authorization headers for API authentication, and remote MCP servers can optionally use static authentication tokens. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication.

For Knowledge Base data sources, PAIS supports authentication to Confluence using either a username and password or a personal access token, configured according to the Confluence administrator's settings. Personal access tokens are generated from user account settings and used for programmatic access to Knowledge Bases and data sources. Microsoft SharePoint data sources require username and password authentication, with support limited to SharePoint On-Premises deployments.

Deep Learning VMs deployed through self-service catalog items in VCF Automation, when configured with the PyTorch NGC software bundle, support optional JupyterLab authentication activation for interactive notebook access.

The underlying user accounts, credential storage, password policies, and OIDC provider administration are owned by VCF SSO or an external identity provider. PAIS configures and enforces authentication using those systems but does not manage authenticator lifecycle itself.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using scram-sha-256, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS

authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different

authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L2-3.5.9

> Allow temporary password use for system logons with an immediate change to a permanent password.

SCF Controls: IAC-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered authentication infrastructure that supports secure management of authenticators across the platform's components and the Kubernetes workload consumption layer, though the broader organizational policies governing authenticator lifecycle management require processes and governance beyond what VCF itself provides.

VCF Identity Broker integrates with a selected identity provider for user authentication, establishing trust through metadata exchange between the service provider and the identity provider. This centralized approach allows organizations to manage authenticators through their existing identity management systems rather than maintaining separate credential stores for each VCF component. VCF SSO provides a single sign-on environment where a user provides credentials once, and components in the environment perform operations based on the original authentication. Administrators can federate VMware vCenter with an enterprise identity provider, which enables multifactor authentication (MFA), automatic user provisioning and deprovisioning, and token-based authentication that reduces the risk of credential exposure. VCF SSO supports SCIM (System for Cross-domain Identity Management) for automating user identity exchange across identity domains, and named providers including Okta are supported through the identity provider federation mechanism. When configured for identity provider federation, the external provider handles all authentication mechanisms, including passwords, MFA, and biometrics, delegating full authenticator management to the organization's existing identity infrastructure. The Authorization Code grant type in VMware Identity Broker supports MFA workflows, while the Password OAuth 2.0 grant type is incompatible with MFA requirements, so organizations should use the Authorization Code flow when MFA is needed.

VMware Kubernetes Service (VKS) extends this identity architecture to the workload consumption layer. VKS clusters support two authentication methods: VCF SSO and any OIDC-compliant external identity provider, including Okta, so identity lifecycle management, including onboarding, offboarding, and group membership changes, can remain in the organization's central identity system. Users authenticated through an external identity provider are granted Kubernetes RBAC permissions using the `sso:<username>@<domain>` naming convention in `ClusterRoleBindings`. Custom `ClusterClass` configurations allow organizations to authenticate developers against existing corporate identity systems. When provisioning clusters based on a custom `ClusterClass`, the authentication Secret can be configured with multiple JWT issuers to support distinct identity providers simultaneously, such as Keycloak for contractors and Microsoft Entra ID for employees. At the `kube-apiserver` level, VKS supports multiple authenticator types: client certificates, bearer tokens, an authenticating proxy, and HTTP basic auth. The `--authentication-config` file provides structured control, allowing multiple JWT authenticators each with a unique issuer URL and discovery URL, and CEL expressions to map claims to user attributes and validate claims. When multiple authenticator modules are active, the first to successfully authenticate a request short-circuits further evaluation, making authenticator order significant; Kubernetes hardening guidance recommends enabling as few authentication mechanisms as possible to simplify user management and reduce the risk of users retaining access after it is no longer needed. The `kube-apiserver` can also leverage existing authentication methods such as LDAP or Kerberos through plugins, and `kubectl` integrates with credential plugins for centralized operator credential management. The `system:auth-delegator` `ClusterRole` provides unified authentication and authorization flows for add-on API servers deployed into VKS clusters. Production VKS clusters should enable Kubelet authentication and authorization to restrict direct access to the kubelet API. For Windows node pools, VKS clusters support Group Managed Service Accounts (gMSA) for authenticating Windows nodes to Active Directory; gMSAs are managed by security groups that control password retrieval and delegation permissions, allowing Windows workloads to use Active Directory-managed identities.

Standard packages deployable on VKS clusters extend authenticator management to workload-level services. Argo CD, available as a standard package, supports local account authentication with global RBAC policies and OIDC authentication for federated identity, allowing GitOps workflow access to be governed through the same identity infrastructure used for cluster

access. The Harbor container registry package provides authentication and token management for artifact access, with role-based access control restricting image push and pull operations.

VCF Operations integrates with VCF SSO for centralized authentication through an identity provider. NSX Manager can be configured to authenticate users from identity management providers or through a directory service such as Active Directory over LDAP or OpenLDAP. NSX authentication best practices include integrating with identity providers, enabling multi-factor authentication, and defining access controls based on user roles and permissions. NSX Manager requires authentication prior to establishing a management connection for administrative access. The VCF Automation Provider Management Portal supports authentication via local users and SAML users, and Organization Administrators use credentials configured during organization creation to access their respective organizations.

For local accounts, each VCF component enforces password complexity and lifecycle policies. NSX Manager requires passwords of at least 12 characters with uppercase, lowercase, numeric, and special character requirements, enforced through Linux PAM modules. Each NSX user password has an expiration date tracked by NSX, with a default expiration period of 90 days. Password expiration is configurable between 1 and 9,999 days. VCF Operations enforces a minimum of 15 characters with similar complexity rules. VCF Automation passwords must also be at least 15 characters in length.

VCF provides configurable account lockout policies across its components. VCF Operations locks accounts after five consecutive failed login attempts for 15 minutes. A separate policy locks VCF Operations accounts if a user enters an incorrect password three times within five minutes. VCF Automation supports account lockout in password policy system settings, which locks user accounts after a configurable number of invalid login attempts. VCF Automation also provides a configurable account lockout interval that specifies the duration before an account is automatically unlocked, and provider administrators can unlock a user account manually without waiting for that interval to expire.

For service-to-service authentication, VCF uses certificate-based credentials. VCF SSO supports X.509 certificate authentication, and vCenter extensions can authenticate using `loginExtensionByCertificate()` with an extension key certificate. Provider management accounts authenticate using API access tokens that rotate after each use. VCF Automation provides service accounts with the same access restrictions as user API tokens, so service accounts cannot perform user management or create refresh tokens. NSX supports Principal Identity certificates for cloud management platform integration, requiring SHA256-based certificates with RSA/DSA message algorithm and 2048-bit or larger key sizes. At the Kubernetes layer, service account authentication uses bearer token secrets generated automatically for service accounts. Kubernetes hardening guidance recommends setting short lifetimes on certificates and automating their rotation, and recommends using an authentication provider that controls how long issued tokens remain valid; using short-lived Secrets helps detect or limit the impact of credential exposure. The `system:masters` group functions as a break-glass super-user group that bypasses the RBAC authorization layer and should be reserved for emergency access scenarios only.

VCF Operations provides API endpoints for trusted certificate management and displays certificate expiration status for each workload domain through its Certificates tab. NSX supports non-disruptive certificate rotation in VCF and later, allowing certificate replacement without service interruption.

VCF also provides visibility into authenticator usage through audit logging. User authentication details are viewable in VCF Operations, including user name, successful or failed authentications, and events such as user login and guest operation authentication. This logging supports detection of compromised or misused authenticators.

While VCF provides the technical controls for authenticator strength, complexity, expiration, lockout, and rotation within its own components, as well as identity provider integration for MFA enforcement and centralized authentication, and the VKS consumption layer provides configurable multi-method kube-apiserver authentication, external identity provider integration, short-lived credential support, and gMSA for Windows workloads, the broader organizational policies for initial authenticator issuance, periodic credential rotation schedules, revocation upon personnel changes, and mapping authentication strength requirements to data classification levels require processes and governance outside VCF's scope.

VMware Private AI Services (PAIS) provides authentication mechanisms specific to its AI infrastructure components, integrating with externally managed identity systems to control access to AI services, model endpoints, and training data.

PAIS uses OIDC-based authentication as its primary access control mechanism. The PAISConfiguration custom resource configures the OIDC provider with issuerUrl, clientId, and scopes including openid, groups, and offline_access. Access is restricted to user accounts whose membership matches OIDC groups listed in the authorizedGroups field, and the Access Token carries a groups claim that PAIS validates against the authorized group list. The OIDC configuration also supports configurable group claim names and Extra Audiences for additional OAuth2.0 clients that PAIS will accept when validating the Access Token.

The PAISConfiguration custom resource supports client TLS for outbound authentication to the OIDC provider and Harbor registry, configured through the worker.clientTls.caBundleRefs field. This binds certificate-based trust to identity provider and registry connections so that authentication exchanges are integrity-checked against approved CAs.

Authenticator management for the Harbor registry that stores AI models and artifacts follows a credential-based pattern. The oras login command authenticates to a private Harbor registry using username and password credentials for artifact push operations, and docker login is used for pushing models to Harbor projects through the Model Gallery. Harbor project access capabilities restrict access to the sensitive data that is used to train and tune models. Model endpoints support authentication through harbor-pull-secret-readonly to control access to container images stored in private registries, and Harbor model retrieval requires certificate-based trust in addition to credential authentication.

Internal service-to-service authentication is addressed at the component level. PAIS authenticates to the OpenTelemetry Collector using a Kubernetes Secret containing Authorization Bearer tokens and custom headers, and the LLM Traces flow uses the same pattern with semi-colon separated headers. The PAIS MCP server supports custom HTTP headers including User-Agent and Authorization headers for API authentication, and remote MCP servers can optionally use static authentication tokens. PAIS integrates with Grafana for metrics visualization using OIDC provider authentication.

For Knowledge Base data sources, PAIS supports authentication to Confluence using either a username and password or a personal access token, configured according to the Confluence administrator's settings. Personal access tokens are generated from user account settings and used for programmatic access to Knowledge Bases and data sources. Microsoft SharePoint data sources require username and password authentication, with support limited to SharePoint On-Premises deployments.

Deep Learning VMs deployed through self-service catalog items in VCF Automation, when configured with the PyTorch NGC software bundle, support optional JupyterLab authentication activation for interactive notebook access.

The underlying user accounts, credential storage, password policies, and OIDC provider administration are owned by VCF SSO or an external identity provider. PAIS configures and enforces authentication using those systems but does not manage authenticator lifecycle itself.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms for managing authenticators across both the administrative plane and the database layer, supporting the secure credential management aspect of this control.

For administrative access to the DSM platform, the system supports two authentication paths: local user accounts authenticated by email ID and password, and LDAPS-integrated accounts authenticated by matching the email domain against a registered LDAPS server. When directory service credentials are non-functional, DSM falls back to local user authentication, maintaining access continuity. Administrators configure and manage these authentication sources through the DSM Admin UI, which also provides a Permissions view for creating, monitoring, and managing configured users. LDAPS integration supports certificate-based validation of the directory service connection, with administrators able to upload directory service server certificates through the Admin UI to establish trusted connections. LDAP groups can be assigned roles within DSM, enabling group-based access control aligned with directory service group membership.

At the database layer, DSM supports directory service authentication for PostgreSQL, MySQL, SQL Server, and MinIO databases. For PostgreSQL, host-based authentication (HBA) rules determine how clients are authenticated, using ordered matching rules that evaluate connection type, client address, requested database, and user name. The default HBA configuration includes a final catch-all entry using scram-sha-256, with optional LDAP entries for directory-integrated authentication. This HBA configuration can be modified through the DSM interface. For MySQL databases, LDAPS

authentication is available using Active Directory Global Catalog, with support for multi-domain controller deployments via the AD Secure/SSL Global Catalog on port 3269. Directory service authentication for individual database instances can be enabled or disabled through the Enable Directory Service Authentication toggle in the database settings.

For SQL Server databases, DSM uses contained database users, where users authenticate directly against the database and identity information resides within the database. DSM supports Windows Authentication for SQL Server server-level logins through Active Directory integration, enabling Kerberos-based single sign-on for clients joined to the same domain. SQL Server Authentication logins can also be created on all DSM clusters. Administrators configure which user types are permitted per data service policy, selecting between Windows Principal authentication using Active Directory credentials and SQL User authentication using standard SQL Server logins. An internal management login (`dsm_mgmt`) restricts access to system-level objects, keeping administrative operations within an isolated context.

DSM enforces password policies for local accounts, including complexity requirements, and applies a root password expiry on a three-month rotation cycle. For service-to-service communication, DSM uses authentication secrets (`dsm-auth-creds`) containing endpoint credentials and root CA certificates, with automatic secret generation available through the Consumption Operator installation. Prometheus metrics forwarding supports configurable authentication options, including no authentication, certificate-only authentication, basic authentication with username and password, or a combination of certificate and basic authentication.

Regarding authentication strength appropriate to data classification, DSM provides the authentication mechanisms that administrators can configure to match organizational security policies, but it does not automatically enforce differentiated authentication strength based on data classification. Organizations must define their data classification scheme and determine which DSM authentication options (local credentials, LDAPS, HBA rules, certificate validation, Kerberos) apply to each tier of sensitivity. DSM contributes the technical controls; the alignment between authentication strength and data classification requires organizational governance to establish and maintain.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides mechanisms to securely manage authenticators across two distinct planes: the Controller management plane (admin access) and the application data plane (end-user client authentication for load-balanced applications).

For the management plane, Avi maintains user accounts in two categories: local users managed directly on the Controller, and remote users authenticated through an external authentication, authorization, and accounting (AAA) server. Avi uses Authentication Profiles to configure how administrators authenticate to the Controller. Authentication Profiles support LDAP for credential validation against a directory service, SAML for federated authentication that delegates the process to a centralized identity provider (IdP), and basic authentication. The recommended approach is federated authentication, which centralizes the authentication process by delegating to an external IdP rather than managing credentials locally on the Controller. SAML profiles verify user identity without storing credentials on untrusted systems, and Avi Controller SAML authentication profiles can be integrated with Workspace ONE Access for catalog-based application access. Admin users can also authenticate using password-less SSH-based login as an alternative to password-based authentication. On every user login, the Auth Mapping Profile evaluates authorization mapping rules and updates the user record with tenant and role pairs drawn from the IdP's assertions.

For the application data plane, Avi acts as a proxy that applies client authentication policies to inbound application traffic. Supported methods include LDAP authentication (checking client credentials against a directory service), SAML single sign-on (enabling federated application access with a single credential set), OAuth and OIDC (where Avi acts as a client and resource server, with the authorization server authenticating clients and validating authorization codes before issuing tokens), and JSON Web Token (JWT) validation. The SSO Policy supports configurable Authentication Rules and Authorization Rules with path-based matching criteria, allowing different authentication requirements to be applied to different application paths. More granular authorization in OAuth/OIDC flows is available through Authorization Policies or DataScript.

Organizations configure which authentication method applies to each virtual service or application based on the sensitivity of the data accessed. Avi's Authentication Profiles and SSO Policies provide the technical enforcement points to apply different

authentication strengths across the application portfolio, but the mapping from data classification tier to required authentication method is an organizational governance decision that must be defined and maintained by the organization.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L2-3.5.10

> Store and transmit only cryptographically-protected passwords. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

CHAPTER THREE PAGE 26 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: IAC-10.5

Aggregate Coverage: Meets

VCF (Meets)

VCF protects authenticators at rest, in transit, and during use through multiple mechanisms across its component stack. The platform's approach spans credential storage and hashing, token-based session management, certificate-based service authentication, identity federation, and support for stronger authentication methods that reduce reliance on static credentials.

Passwords stored on VCF components are protected using one-way hashing. NSX Manager encrypts all passwords in its system (databases, configuration files, and log files) using a strong one-way hashing algorithm with a salt. Local user passwords on NSX appliances are secured using Linux/PAM libraries, which store hashed and salted representations in `/etc/shadow`. The NSX Manager password hash algorithm is configured to use SHA512. Other internal passwords are encrypted using a random key stored in the local filesystem.

Credential stores used by the vSphere Web Services SDK protect passwords using filesystem-level permissions, with each user having a separate backing file. The `CredentialStoreCipher` component encrypts and decrypts credential data using the `javax.crypto` libraries. Java keystores used for certificate management are password-protected. At the workload consumption layer, private container image registry credentials are stored in Kubernetes Secret objects and referenced in workload specifications to support authenticated image pulls without embedding credentials in configuration directly. Harbor Registry, deployable as a Supervisor service on VMware Kubernetes Service (VKS) clusters, enforces role-based access control to secure artifact management, and its own sensitive internal credentials (including the admin password, secret key, database password, and session integrity tokens) are scoped to specific authentication functions within the registry.

Service-to-service authentication within VCF uses certificates rather than passwords. Solution users authenticate using X.509 certificates for inter-component communication, which avoids transmitting password-based credentials between services. VCF SSO issues time-limited tokens (bearer tokens for short-term single operations, holder-of-key tokens for delegation scenarios) so that long-lived credentials are not passed repeatedly across the network. The `loginByToken` method authenticates clients using SAML tokens obtained from the SSO server. For programmatic and API-based access, VCF employs holder-of-key security tokens through the `LoginByToken` method, which binds authentication to a specific cryptographic key. This approach provides stronger authenticator protection than simple bearer tokens, which authenticate based solely on possession of the token. The distinction between these token types allows administrators to select the appropriate authenticator strength based on the sensitivity of the operations being performed.

VCF supports identity provider federation, which uses token-based authentication to minimize the risk of credential exposure. By federating authentication to an external identity provider through VCF SSO and the VCF Identity Broker, user credentials such as passwords are not stored or transmitted directly through VMware vCenter or other VCF components. This architecture reduces the attack surface for credential theft by keeping sensitive authenticators within the identity provider's controlled environment. VCF supports SAML and OIDC protocols for federation. The platform also supports the OAuth 2.0 Authorization Code grant type, which protects user credentials by keeping them within the API environment rather than exposing them over the network. This grant type is compatible with multi-factor authentication (MFA), enabling organizations to layer additional authenticator protections for access to sensitive resources.

At the workload consumption layer, VKS clusters running on vSphere Supervisor extend authenticator protection to containerized workloads. Kubernetes Secrets provide the foundational mechanism for storing authenticators such as passwords, tokens, X.509 private keys, and registry credentials; access to Secret objects is governed by Kubernetes RBAC, so

users and service accounts must have explicit permissions for specific Secrets or Secret-bearing namespaces. The Secret Store service, available as a Supervisor service, provides an externalized secret management layer with its own RBAC for administrators, DevOps engineers, and application tenants, separating secret lifecycle management from application configuration. The Kubernetes hardening documentation recommends enabling as few authentication mechanisms as possible within a cluster so that, when multiple authenticator modules are configured, the first module to successfully authenticate a request short-circuits further evaluation, reducing the surface area for credential misuse. Each JWT authenticator configured in the API server must have a unique issuer URL, and at most one JWT authenticator will attempt to cryptographically validate a given token, preventing ambiguity in validation paths. When using TokenRequest tokens for service account authentication, configuring a short token lifespan limits the window of exposure if a token is compromised. The Argo CD Supervisor Service manages CI/CD pipeline secrets outside of Git repositories with access controls enforced across all components, and supports both local account authentication with global RBAC policies and OIDC authentication for federated identity integration.

VCF supports multiple authentication methods including smart cards and certificate-based authentication, enabling organizations to deploy hardware-based authenticators for high-sensitivity environments. vSphere also supports Windows Virtualization-based Security for Windows VMs, which enables Credential Guard to isolate and harden key system and user secrets against compromise within the guest environment. The platform documentation recommends using stricter security practices than basic authentication in production environments, and notes that allowing users to accept self-signed certificates or to select certificate authorization options provides reduced security compared to other methods. These warnings guide administrators toward authenticator configurations that match the sensitivity of the data being protected.

The vSphere Web Services API supports multiple guest authentication types including NamePasswordAuthentication, SAMLTokenAuthentication, SSPIAuthentication, and TicketedSessionAuthentication. This range of authenticator types allows administrators to select authentication mechanisms appropriate to the trust level and sensitivity requirements of each use case, from integrated Windows authentication for domain-joined environments to SAML tokens for federated identity scenarios.

All management communication channels use TLS encryption, protecting authenticators during transmission. NSX Manager API service supports TLS for API communications. VCF Operations orchestrator uses TLS for encrypted communications between deployment components and HTTPS access to the web front end. VCF supports automatic renewal of TLS certificates for components using VMCA, Microsoft CA, OpenSSL, or self-signed certificates, which helps keep authentication material current and reduces the window of exposure for any single credential. Where Istio is deployed on VKS clusters, the enableStrictMTLS setting enforces mutual TLS authentication for all service-to-service communication within the mesh, protecting service account credentials from being accepted by unauthorized endpoints. The Kubernetes hardening documentation recommends setting short lifetimes on certificates and automating their rotation to limit the window of exposure if credentials are compromised.

For storage-layer authentication, vSphere supports Kerberos integration with Active Directory for NFS datastore access, providing an additional layer of protection when storage traffic traverses the network. For iSCSI storage, vSphere hardening guidance recommends configuring unique CHAP secrets per VMware ESX host so that compromise of one host cannot be used to authenticate to the storage array from another.

Backup files that may contain credential material are encrypted with a user-specified encryption passphrase, and administrators are directed to store that passphrase safely since it is required during restore operations. NSX Manager backup data can also be encrypted with a passphrase that must be provided during the restore process. Applications consuming Secrets via environment variables or volume mounts on VKS clusters are responsible for protecting authenticator values after reading them, including avoiding logging secret data in clear text or transmitting it to untrusted parties; the platform provides the access control and storage protections, while commensurate-sensitivity handling at the application level remains an organizational responsibility.

VMware vDefend (Contributes)

Within vDefend's own management interface, Security Services Platform (SSP) protects authenticators by supporting both local account credentials and directory-managed authentication via Active Directory over LDAP or OpenLDAP, with the SSP

Installer enforcing authentication, authorization, and access control as critical elements of user management. In 9.1, SSP uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities for platform administrators, giving the management plane a stronger authenticator posture commensurate with the sensitivity of the systems administrators access.

SSP implements role-based access control to limit system access based on user roles, with local user management in the License Hub restricting actions to authorized users only. Local administrative and audit user passwords are established during deployment and can be changed only by authorized users through the SSP UI or Installer UI, restricting credential modification to authenticated administrators.

At the network layer, vDefend's Identity Firewall maps authenticated user identity to IP addresses and applies Distributed Firewall rules based on Active Directory user and group membership rather than source IP address alone. Administrators can create firewall rules using AD users and groups as source criteria, enforce access controls on virtual machines and physical devices through Event Log Scraping for login detection, and apply security policies to virtual machines based on dynamic name-based criteria combined with AD group membership. These mechanisms tie network access decisions to the authenticated identity of the originating user, supporting the broader goal of restricting access to sensitive systems in proportion to their classification.

Protecting authenticators for systems and applications outside of vDefend's management plane, such as enforcing password storage standards or token lifecycle management across the broader organization, remains outside vDefend's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) protects authenticators through encrypted transport protocols, strong credential hashing, and certificate-based directory service validation across its supported database engines. These mechanisms help reduce the risk of credential exposure in transit and during authentication exchanges for both platform access and individual database connections.

For directory service integration, DSM supports LDAPS (LDAP over SSL/TLS) for both the platform UI and individual database instances. MySQL database instances support LDAPS authentication with LDAPS-specific user entries, and Active Directory authentication is conducted over the AD Secure/SSL Global Catalog port 3269 for multi-domain controller deployments. Directory service authentication is enabled or disabled per database through the "Enable Directory Service Authentication" toggle in the database settings, including on existing databases after creation. When Directory Service credentials are non-functional, DSM falls back to local user authentication to maintain administrative access continuity.

For PostgreSQL database instances, DSM configures host-based authentication (HBA) using scram-sha-256 as the default credential hashing method. Default HBA entries cover the postgres_exporter and pgadmin accounts using SCRAM-SHA-256, along with a catchall entry applying scram-sha-256 to all remaining users. Custom HBA entries are restricted to scram-sha-256, reject, and cert as the permitted authentication methods. HBA rules use ordered matching based on connection type, client address, requested database, and user name, giving administrators control over which authentication method applies to which connection patterns.

For SQL Server database instances, DSM data service policies can be configured to allow Windows Principal authentication, enabling users to authenticate using their Active Directory credentials, or SQL User authentication using standard SQL Server logins and passwords. DSM enforces an isolated internal management login (dsm_mgmt) that restricts user access to system-level objects, keeping administrative operations within a secured context separate from database user credentials.

For the platform UI, DSM first attempts to authenticate users as local users by matching the email address and validating the password. If a local user match is found, no further LDAPS processing occurs. LDAPS users are authenticated by email domain matching against the registered LDAPS server. DSM also supports mutual TLS (mTLS) authentication for metrics forwarding, enabled through the Client Certificate Authentication toggle with a client certificate and private key.

Full satisfaction of this control requires organizational policies that classify the sensitivity of information stored in DSM-managed databases, establish commensurate authenticator protection requirements such as password strength, rotation schedules, and acceptable credential storage practices, and govern credential lifecycle management beyond what the

platform itself enforces. DSM provides the technical mechanisms to implement strong authenticator protection, but determining what protection level is appropriate for a given database workload is an organizational responsibility.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides authenticator protection mechanisms across both its management plane and application delivery layer.

For the Avi Controller management plane, the product supports federated authentication via SAML, LDAP, OAuth 2.0, and OpenID Connect. SAML authentication implements federated authentication by delegating the process to a centralized identity provider (IdP), which verifies user identity without storing credentials on multiple untrusted devices. Avi guidance explicitly recommends federated authentication as the preferred pattern to centralize credential management and reduce the footprint of locally held authenticators. SAML authentication rules on the Controller support two actions: Skip Authentication, which bypasses authentication when a rule matches, and Default Authentication, which enforces SAML for matched paths, enabling sensitivity-based application of authentication requirements. LDAP authentication validates user identity against a directory service, centralizing credential storage in the organization's existing identity infrastructure. The LDAP configuration also supports Required User Group Membership enforcement, restricting access to users who belong to designated groups.

Auth Mapping Profiles provide additional control over authenticated sessions. The Avi Controller can map LDAP group memberships to specific roles and tenants, and can deny privileges entirely to specific users by updating Auth Mapping rules, preventing those users from obtaining any role or tenant assignment upon login.

For application traffic, Avi supports OAuth/OIDC flows where the authorization server authenticates the resource owner before issuing access tokens. OAuth provides secure delegated access by allowing the identity provider to issue tokens to authorized parties without requiring users to share credentials with intermediary applications. Granular authorization policies can apply additional controls on top of token-based access. JWT validation is available through configurable SSO Policies with named Authentication Rules and Authorization Rules applied per request path, allowing different authentication profiles to be assigned based on the sensitivity of the resource.

Access to SSL/TLS certificate objects, which serve as machine authenticators for virtual services, is scoped by role-based access control: only administrator accounts with write-access to certificates for the required tenant can manage those objects, reducing exposure of certificate-based authenticators.

The Avi Controller VM and Service Engine VMs rely on the underlying VCF platform for data-at-rest encryption of disk contents, including any stored credential material. Avi does not manage its own at-rest encryption; that layer is inherited from VCF's VM Encryption or vSAN Encryption capabilities.

Applying authentication protection commensurate with information sensitivity requires the organization to classify assets and define appropriate authentication requirements for each level. Avi provides the mechanisms; the organization selects and applies them based on its asset classification and risk management process.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IA.L2-3.5.11

> Obscure feedback of authentication information.

SCF Controls: IAC-11

Aggregate Coverage: Meets

VCF (Meets)

VCF obscures authentication feedback across all management interfaces and programmatic endpoints through standard credential masking, a token-based authentication architecture that minimizes direct credential exposure, and encryption of all authentication exchanges in transit.

All VCF web-based management interfaces, including the VCF Operations UI, VMware vCenter Client, and NSX Manager console, render password input fields using standard masked controls that replace typed characters with dot or asterisk symbols. This applies to every login screen and credential entry dialog across the platform. Console-based access to VMware ESX hosts similarly masks password input at the Direct Console User Interface (DCUI) and SSH login prompts through standard operating system conventions that suppress terminal echo during credential entry. Command-line tools that accept passwords follow the same echo suppression behavior.

Beyond input masking, VCF's authentication architecture reduces the frequency and scope of password exposure. Identity provider federation uses token-based authentication and minimizes credential interception risk by exchanging security tokens rather than transmitting usernames and passwords directly between components. When configured with an external identity provider, users authenticate at the identity provider's login page, and VCF receives a security assertion or token rather than the raw credentials. Security Assertion Markup Language (SAML) is used by vCenter for exchanging authentication and authorization data between parties, and vCenter LoginByToken uses SAML 2.0 assertion tokens for authentication. The VCF Identity Broker integrates with selected identity providers to enable user authentication for VCF SSO, further reducing the number of times users must enter credentials across the platform.

OAuth 2.0 support allows information exchanges among VCF web services without exposing sensitive data such as usernames and passwords. The platform documentation recommends that the Password grant type be avoided whenever possible, especially for third-party application authentication, in favor of token-based flows that do not require credentials to traverse the network in cleartext form. API clients can configure token-based authentication to communicate with the server, and the LoginByToken method authenticates clients using holder-of-key security tokens that embed security artifacts for authentication without exposing credentials. Both approaches avoid password transmission after initial token issuance.

Session identifiers are used to maintain authenticated state after initial login, so credentials are not re-transmitted with each request. Valid session identifiers establish trust with API endpoints without requiring repeated credential entry. TLS encryption protects all authentication exchanges in transit, so even the masked credential data transmitted during initial login is encrypted on the wire.

At the workload consumption layer, VMware Kubernetes Service (VKS) and vSphere Supervisor extend these protections into the Kubernetes platform. The Kubernetes API server uses JWT and OIDC-based authentication flows in which the actual credential exchange occurs at the identity provider, such as VCF SSO or an external IdP, and the API server receives and validates signed tokens rather than handling plaintext passwords directly. JWTAuthenticator configuration specifies a unique issuer URL per authenticator and applies claim validation rules to incoming tokens; at most one JWT authenticator cryptographically validates a token per request, so authentication decisions are made on signed assertions without requiring credentials to traverse the API layer. Audience-aware token authenticators validate that a token was intended for the specific server it was presented to by verifying it against the server's audience identifier, further scoping token validity without additional password transmission.

Kubernetes Secrets provide the primary mechanism for storing authentication credentials within VKS clusters, including registry passwords, service account tokens, and other sensitive values. Secret data fields are stored in base64-encoded form and are not returned as human-readable text by default in API responses; when etcd encryption at rest is configured, Secret values are encrypted in the datastore. The Kubernetes platform requires that applications protect confidential values after

reading them from environment variables or volumes by not logging secret data in cleartext and not transmitting it to untrusted parties. The Harbor registry Supervisor Service stores its authentication credentials, including admin passwords, secret keys, and job service secrets, as Kubernetes Secrets rather than in plaintext configuration files, keeping sensitive material out of environment variables visible to other processes. Registry secrets in Kubernetes store authentication credentials for private container image registries within the Secrets API rather than in plaintext manifests.

The Supervisor Secret Store service enforces role-based access control for administrators, DevOps engineers, and application tenants to manage and distribute sensitive authentication credentials through a controlled interface. For CI/CD pipelines on VKS, Argo CD's OIDC integration supports Proof Key for Code Exchange (PKCE) authentication through the `enablePKCEAuthentication` field, reducing the risk of authorization code interception in OIDC flows by requiring a verifier that cannot be replayed. HashiCorp Vault can generate dynamic secrets with limited lifespans for services, reducing the risk of long-lived credentials being exposed through logs or process inspection. The Kubernetes hardening guidance recommends configuring short token lifespans via the `TokenRequest` API to limit the exposure window if tokens are captured.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to authenticator feedback protection through several mechanisms that operate at different layers of the authentication stack.

The DSM administrative and user interface presents a web-based login screen where users supply an email address and password. Standard web browser behavior renders password input fields with character masking, so entered characters are not displayed in plaintext. DSM authenticates local users by matching the email address and validating the submitted password before any directory service processing occurs. For environments using LDAPS, DSM matches the email domain against the registered LDAP server and validates credentials over an encrypted channel, so the password is not transmitted or displayed in cleartext during the authentication exchange. DSM can be configured to use an LDAP server for both authentication and authorization and falls back to local user authentication when directory service credentials are non-functional.

At the database layer, DSM supports host-based authentication (HBA) configuration for database instances. Custom HBA entries support the `scram-sha-256`, `reject`, and `cert` authentication methods. The `scram-sha-256` method is a challenge-response protocol that does not transmit the password itself over the connection, limiting exposure of credential material during the authentication handshake. DSM also supports enabling or disabling directory service authentication per database instance through the `Enable Directory Service Authentication` toggle, allowing administrators to enforce LDAPS-backed authentication for database access rather than relying on simpler mechanisms.

In 9.1, DSM extends LDAPS-encrypted authentication to MySQL databases. MySQL database users can be configured with LDAPS authentication, including Active Directory Secure/SSL Global Catalog configurations for multi-domain environments, carrying credentials over an encrypted channel. SQL Server databases support Windows Principal authentication through Kerberos-based Active Directory domain resources, which is a challenge-response mechanism that does not transmit passwords in plaintext. SQL Server data service policies also support SQL User authentication for standard SQL Server logins.

DSM's LDAPS integration uses certificate-based validation of directory service server connections, supporting protection of the credential exchange channel. What DSM does not provide is explicit product-level configuration for UI feedback behavior, such as a setting that controls whether password fields mask characters. That behavior is inherited from the client browser and web framework conventions rather than being a DSM-configurable control. Organizations should also account for any programmatic or API-based access patterns where credential handling falls outside the DSM UI and must be governed by application-level controls.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides authenticator feedback protection through log-level credential masking for application proxy authentication flows and through its administrative authentication interface.

For application-layer authentication, the `sensitive_log_profile` can be configured to mask sensitive fields, including Basic Authorization credentials and OAuth tokens, from virtual service application logs. This setting is available in the OAuth and

OIDC client and resource server configuration. Organizations deploying Avi as a proxy for OAuth-authenticated applications should enable this profile to restrict credential material from appearing in operational log output. The masking applies to credentials that Avi processes at the proxy boundary, not to credentials transmitted between clients and backend servers outside Avi's inspection scope.

Avi's log protection capabilities extend masking to additional credential-bearing HTTP content. HTTP headers containing sensitive user-related information, including cookies and authorization headers, can be masked or removed from application logs. A sensitive log policy can be applied to mask cookies in both WAF logs and application log headers, which keeps session and credential tokens out of operational log storage.

For LDAP-based basic authentication exposed through a virtual service, Avi supports configurable realm indication to clients during authentication requests. This identifies the authentication realm to the client without exposing credential content in the response.

For administrative access, the Avi Controller web administration interface is the credential entry point for all administrator logins, including local accounts and accounts authenticated through federated sources such as LDAP, TACACS+, or SAML identity providers. When Avi acts as a proxy for federated authentication flows in which end users authenticate interactively against an external identity provider, such as a SAML identity provider, an LDAP directory, or an OAuth/OIDC authorization server, the credential entry experience and feedback masking for those user-facing flows are rendered and governed by the identity provider. Avi validates the resulting token or session assertion at the virtual service boundary but does not control what the end user sees during the interactive login step with the external provider.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IA.L3-3.5.1e

> Bidirectional Authentication

SCF Controls: IAC-02.2, IAC-04

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several authentication mechanisms that are inherently resistant to replay attacks across its management interfaces, APIs, and service-to-service communication paths.

VCF SSO supports SAML 2.0 as its primary authentication protocol for identity provider integration and user access to management interfaces. SAML assertions are digitally signed, time-bounded, and scoped to a specific audience, which makes captured assertions unsuitable for reuse by an attacker. Administrators can configure VCF SSO to use Generic SAML 2.0 or specific SAML context options depending on the identity provider in use. The PasswordProtectedTransport authentication context method requires credentials to be transmitted over HTTPS, providing transport-layer replay protection. Identity federation with external identity providers through SAML or OIDC inherits whatever replay-resistant mechanisms the enterprise identity provider implements, including nonce-based challenges and time-bound assertions.

VMware Kubernetes Service (VKS) clusters, running on the vSphere Supervisor, inherit the platform's replay-resistant authentication framework at the Kubernetes workload layer. VKS clusters support VCF SSO and OIDC-compliant external identity providers for cluster access. For external OIDC providers, VKS clusters use the Pinniped authentication service to broker connections between the Kubernetes API server and the identity provider, inheriting the provider's replay-resistant properties such as time-bounded tokens and nonce binding. The VKS API server includes an authentication webhook pod that validates user authentication tokens on every API request, rejecting any token whose expiry has passed regardless of its cryptographic validity. The VCF Consumption CLI automatically renews access token credentials using a refresh token, keeping the active access token window short-lived without requiring manual reauthentication.

The VMware vCenter API infrastructure supports holder-of-key security tokens through the LoginByToken method. Holder-of-key tokens embed security artifacts that tie the token to the presenting party, requiring proof of possession of a private key associated with the token. Intercepting the token alone is insufficient for authentication because the presenting party must demonstrate it holds the corresponding key material. This mechanism is used for programmatic and service-to-service authentication within the VCF platform.

VCF also supports Kerberos authentication in environments integrated with Active Directory. Kerberos uses time-stamped tickets and session keys that are bound to specific client-server pairs, making replayed tickets detectable. VCF documentation recommends synchronizing system clocks across the environment to avoid Kerberos authentication failures caused by clock skew, with a default tolerance of 5 minutes. This confirms that Kerberos ticket validation, including its time-based replay protections, is actively enforced. VCF Operations orchestrator plug-ins can be configured with Kerberos authentication through the krb5.conf file.

The VCF SSO client API provides challenge-response authentication through the Security Support Provider Interface (SSPI). In SSPI authentication, the client sends an issue request containing credentials, the server uses its security provider to authenticate the client, and if additional negotiation is required, the server embeds a challenge in its response. The client then sends a challenge request back to complete the exchange. Challenge-response protocols generate unique values for each authentication exchange, so a captured response from one session cannot be replayed in another.

NSX Manager supports session-based authentication using JSESSIONID cookies, which reduces repeated credential transmission while maintaining authenticated state. NSX Manager authentication mechanisms are designed to resist replay attacks.

VMware ESX (ESX) supports bidirectional CHAP authentication for iSCSI and iSER storage adapters, where both the storage initiator and the target authenticate each other using challenge-response exchanges. This extends replay-resistant

authentication to storage fabric access paths, which auditors should verify are using mutual CHAP rather than one-way authentication or no authentication.

For webhook and API security, VCF Automation secures webhook behavior requests using hash-based message authentication codes (HMAC), a mechanism that validates the authenticity and integrity of HTTP requests. HMAC-authenticated requests include a computed signature that is tied to the request content, so replaying or tampering with requests is detectable.

For service account and API access, VCF uses access tokens that rotate after each use. Access tokens normally last one hour and are derived from a refresh token that normally lasts 90 days but can be revoked earlier. If rotation is activated, making a refresh token grant call returns both a new access token and a new refresh token, and the original refresh token is invalidated. This rotation pattern limits the window during which a captured token remains valid and, when single-use rotation is enabled, renders captured tokens useless after their first use. The VCF Automation API uses authentication tokens (csp-auth-token) for API requests, and users can revoke API tokens through the User preferences page.

VCF Operations supports single sign-on authentication, allowing token reuse within a session without re-entering credentials while relying on the underlying replay-resistant token exchange. VCF Operations for Networks supports token-based authentication for its management interfaces, providing replay-resistant access control for network management operations.

For CI/CD workloads running through the Argo CD Supervisor Service, OIDC authentication supports PKCE (Proof Key for Code Exchange) through the enablePKCEAuthentication field in the Argo CD spec.oidc configuration. PKCE binds each authorization code exchange to the specific client session that initiated the flow, blocking authorization code interception and replay in OAuth 2.0 authorization code flows. Service-to-service authentication within Kubernetes workloads on VKS clusters can use the Kubernetes TokenRequest API to generate short-lived credentials scoped to a specific audience and time window; Kubernetes hardening guidance recommends implementing short token lifespans to reduce the replay window if a credential is captured. Where workloads integrate with HashiCorp Vault through the Harness CI/CD Supervisor Service, Vault can generate dynamic short-lived credentials rather than long-lived static tokens, limiting exposure to credential replay.

Across management interfaces, APIs, service-to-service communication paths, Kubernetes workloads, and storage fabric access, VCF provides native replay-resistant mechanisms that include digitally signed and time-bounded SAML assertions, holder-of-key security tokens, Kerberos time-stamped tickets, SSPI challenge-response exchanges, HMAC-signed webhook requests, rotating API access tokens, bidirectional CHAP, Pinniped-brokered OIDC flows with per-request token validation, PKCE-bound authorization code exchanges for CI/CD, TokenRequest API short-lived credentials, and Vault-generated dynamic secrets. VCF documentation recommends migrating API, SDK, and CLI access from Simple Authentication to token-based authentication where possible. The VCF SSO configuration pages in VCF Operations and VMware vCenter provide the settings for selecting the authentication protocol in use.

VMware vDefend (Contributes)

VMware vDefend contributes to device authentication through its NDR Sensor onboarding process and ongoing sensor-to-platform communication. NDR Sensors connect to Security Services Platform using Mutual TLS (mTLS), providing bidirectional, cryptographically-based authentication before establishing the management connection. During initial registration, Security Services Platform generates a unique registration token that is valid for 30 minutes; the sensor presents this time-limited token as part of the mTLS-secured registration sequence, providing replay resistance for the onboarding step. Security Services Platform and NDR Sensor components implement FIPS 140-2 and FIPS 140-3 validated cryptographic modules for the underlying cryptographic operations, including the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861).

Beyond this sensor authentication, vDefend does not provide centralized AAA for general network devices. vDefend enforces policy on traffic flows based on identity, application, and network context, but it does not issue device certificates or manage a device identity registry for arbitrary network endpoints. That capability falls outside vDefend's scope and would be addressed by network infrastructure and PKI controls at the platform level.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) operates at the application delivery layer and provides multiple mechanisms that support replay-resistant authentication for both management plane access and application workloads traversing the load balancer.

For management plane access, the Avi Controller supports remote authentication via LDAP, TACACS+, and SAML, with the ability to deactivate local user login when remote authentication is enabled. SAML authentication delegates to a centralized identity provider (IdP), verifying user identity without storing credentials on client devices. SAML assertions carry timestamps and unique assertion IDs that the IdP and Avi use to detect and reject replayed assertions. The Avi Controller also supports token-based and session-based authentication for REST API access through the Avi Python SDK. In the Avi for VCF deployment, the Avi Controller provides a `POST /api/authtoken` endpoint for generating authentication tokens with configurable validity duration in hours, bounding the window during which a captured token could be reused.

For secure channel communication between the Avi Controller and Service Engines, Avi enforces configurable token timeouts via the `secure_channel_controller_token_timeout` setting, limiting the lifetime of authentication tokens used in the control plane. When the Avi Controller cluster enters a manual recovery state, secure channel credentials for all Avi Service Engines are revoked, requiring fresh authentication before those engines can resume normal operation.

For web applications and API traffic, SAML authentication can be enforced at the virtual service boundary. Authentication rules support Default Authentication (enforce SAML on rule match) and Skip Authentication (bypass for specified paths), allowing operators to apply path-specific policies. WAF authentication rules also support configurable custom actions when rule conditions are matched.

The Auth Credentials Cache Expiration setting controls the maximum allowed lifetime of cached client authentication state, limiting the window during which stale cached credentials could be reused. Avi Controller also provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, supporting detection of replay attempts.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IA.L3-3.5.3e

> Block Untrusted Assets

SCF Controls: AST-02.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF does not include a dedicated Network Access Control (NAC) solution, but NSX, VCF Operations, and VCF Automation provide several capabilities that contribute to detecting and restricting unauthorized devices on the virtual network.

NSX SpoofGuard is the primary mechanism for enforcing device identity at the network layer. SpoofGuard maintains a reference table of VM names, MAC addresses, and IP addresses, and blocks traffic from devices whose source addresses do not match the expected bindings on the corresponding logical port or segment. It can operate in MAC-only mode (authenticating MAC addresses) or IP mode (authenticating both MAC and IP addresses). SpoofGuard can be configured at the port or segment level through segment profiles. If a virtual machine's IP address does not match the IP address on the corresponding logical port and segment address binding, the virtual machine's vNIC is prevented from accessing the network entirely. This behavior flags unauthorized address changes instead of letting them pass silently. NSX also drops forged MAC packets by default when the source MAC of a packet differs from the MAC of the virtual machine adapter, and host transport node statistics track the count of these forged transmit drops for visibility. The MAC Discovery segment profile controls MAC learning behavior, and the recommended practice is to enable SpoofGuard alongside MAC learning for stronger address validation.

VCF Operations provides a Network Auto Discovery feature that scans defined IP address ranges to discover devices on the network. The discovery process supports SSH, SNMP v2/v3, and API credential types for accessing discovered devices. Discovered devices are categorized by status: devices that cannot be added as data sources are placed in an Excluded status, and devices with problems that need remediation are flagged with a Needs Attention status. Excluded devices can later be removed from the excluded list and added as data sources if they are determined to be authorized. VCF Operations also supports intent-based detection of default manufacturer passwords on discovered network devices, flagging devices that still have factory credentials.

The Management Pack for Network Devices extends this visibility by collecting Connected IP Addresses and IP Address information from network devices. It also tracks incoming unknown protocols on interfaces, counting packets or transmission units discarded due to unknown or unsupported protocols, which can help identify unauthorized or misconfigured devices attempting to communicate. The Management Pack retrieves system description information including hardware type, software operating system, and networking software for managed entities, and reports manufacturer name information for physical components.

For network segmentation and isolation, NSX supports VLAN-based segmentation, private VLANs (PVLAN) on distributed virtual switches, and overlay-based segments. VPC subnets can be configured with Private, Public, or Isolated access modes to control traffic flow between segments. NSX Manager enforces approved authorizations for controlling the flow of management information within the network based on information flow control policies. Network profiles in VCF Automation support isolation by subnet, external subnet, security groups, or VLAN transport zone, giving administrators control over which networks workloads can reach. These segmentation controls limit the reach of any unauthorized device that gains network access, even in the absence of a traditional NAC enforcement point.

VCF Automation provides a denylist of internal hosts through the `/cloudapi/1.0.0/testConnection/restrictions` API endpoint. This restricts connection testing API access to specified hosts, blocking access to sensitive internal resources. vDefend, a separately licensed product, adds a Malicious IP Feed that downloads known malicious IP addresses from the NTICS cloud service; administrators can create groups that include those addresses and configure Distributed Firewall rules to block traffic to or from them.

A full NAC implementation that performs 802.1X port-based authentication, posture assessment, and automated quarantine of non-compliant endpoints requires a dedicated NAC product integrated with the network infrastructure. Organizations

deploying VCF should pair these platform capabilities with such a solution to achieve automated detection and disabling of unauthorized devices at the network access layer. VCF's contributions are at the virtual network layer through address validation, device discovery and status tracking, traffic filtering, and network segmentation.

VMware vDefend (Contributes)

VMware vDefend provides several network-level access control capabilities that contribute to detecting and restricting unauthorized devices on the virtual network, though it is not a dedicated Network Access Control (NAC) solution that performs 802.1X authentication or endpoint posture assessment.

VMware vDefend (DFW) enforces security policy at the vNIC level, meaning every virtual machine's network interface is subject to firewall rules before traffic reaches the virtual switch. Administrators can define rules based on IP sets, MAC sets, security groups, and tags, restricting network access to only those workloads that match authorized criteria. DFW supports both an Allow List strategy, which denies all traffic by default with a Drop action, and a Deny List strategy, which allows all traffic by default, giving administrators control over the default application posture. Role-based access control governs who can create or modify firewall rules, preventing unauthorized changes to security policy. This per-vNIC enforcement acts as a form of network access control: only traffic matching approved policies is permitted, and workloads not covered by an allow rule are blocked.

vDefend Identity Firewall extends this by enabling identity-based access control for both virtual and physical devices. Identity Firewall integrates with Active Directory, allowing administrators to write firewall rules that reference user identities rather than IP addresses alone. For physical devices and Windows virtual machines, Identity Firewall uses event log scraping to associate devices with authenticated user identities. Identity Firewall rules can be applied to both DFW and Gateway Firewall, and on Gateway Firewall they can be applied to tier-0 or tier-1 gateways using Active Directory group membership as a source criterion for access control decisions. Devices that lack proper identity bindings can be denied network access at the firewall layer.

VMware vDefend (GFW) provides North-South traffic control at the perimeter of NSX segments and VPCs. The VPC Security Profile activates GFW policies for VPCs within a project, configurable through the NSX UI or NSX API. For multi-tenant environments, the Transit Gateway Firewall provides centralized policy management, and Enterprise Administrators can deny all inter-project communication except for essential infrastructure protocols such as DHCP, DNS, NTP, and ICMP. This allows administrators to control which devices communicate across network boundaries, contributing to isolation of unauthorized traffic flows.

Network Detection and Response (NDR), part of the vDefend Security Services Platform, collects and presents detection events representing security-relevant activity in the network. NDR supports filtering affected workloads by IP address, CIDR notation, or IP range, enabling operators to identify compromised or suspicious hosts. Network Traffic Analytics (NTA) detectors in the Security Services Platform perform suspicious traffic analysis, and Security Intelligence can be scoped to specific hosts or clusters for targeted traffic data collection. These capabilities support identifying unauthorized or anomalous devices by revealing unexpected traffic patterns.

A dedicated NAC solution that performs 802.1X port-based authentication, device posture assessment, and automated quarantine of non-compliant physical endpoints remains outside vDefend's scope. vDefend's contributions operate at the virtual network layer through identity-aware firewall policy, per-vNIC enforcement, and traffic anomaly detection.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer access control mechanisms that address the NAC requirement within the scope of traffic reaching Avi virtual services.

Avi's Network Security Policies and HTTP Security Policies can discard connections from client IP addresses by referencing a named IP Group called Blocklist. Network Security Policies pointing to IP Groups are the recommended method for implementing network-layer access control lists across Avi virtual services, and they are configurable through the virtual service Rules tab under Network Security in the Controller UI, through the Avi Controller CLI using the `networksecuritypolicy` command, or via the REST API. IP Groups define collections of IP addresses, IP ranges, and IP network prefixes that can be

shared across multiple virtual services. The Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited, including blocking traffic by dropping TCP SYN packets from identified bad actors.

Avi adds explicit IP Reputation integration with Network Security Policy. The policy can be configured to deny connection attempts from IP addresses with known bad reputations, and IP Group membership can be updated dynamically via the REST API, enabling integration with external threat intelligence sources to keep blocklists current without manual intervention.

Alert actions in Avi can invoke ControlScripts that automatically add offending client IP addresses to a Blocklist IP Group attached to a network security policy. When Avi detects a SYN flood attack, a triggered ControlScript adds the attacker's IP to the blocklist by configuring network security policy DOS rules with the `NETWORK_SECURITY_POLICY_ACTION_TYPE_DENY` action. Logging can be enabled on these rules by setting the log parameter to True, recording denied traffic for audit purposes.

The Avi WAF supports blocking IP addresses based on Autonomous System Number (ASN) using the `IpToASNumber` transformation in ModSecurity language, allowing broad blocking of traffic from known malicious network ranges at the application layer.

Device-level network admission control for the underlying infrastructure, including detection of unauthorized devices attempting access to compute or storage networks, relies on VCF networking and vDefend. Organizations should configure all available Avi mechanisms in conjunction with the platform-level controls available in VCF and vDefend to address the full scope of this control.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IR.L2-3.6.1

> Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities.

SCF Controls: IRO-02, IRO-05

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IR.L2-3.6.2

> Track, document, and report incidents to designated officials and/or authorities both internal and external to the organization. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

CHAPTER THREE PAGE 27 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control IR.L2-3.6.3

> Test the organizational incident response capability.

SCF Controls: IRO-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IR.L3-3.6.1e

> Security Operations Center

SCF Controls: OPS-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control IR.L3-3.6.2e

> Cyber Incident Response Team

SCF Controls: IRO-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MA.L2-3.7.1

> Perform maintenance on organizational systems.26

SCF Controls: MNT-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management capabilities for conducting controlled maintenance activities across the full infrastructure stack, spanning host servicing, component updates, and operational monitoring.

VCF Operations includes a maintenance mode capability that allows administrators to place managed objects into maintenance mode either manually or on a defined schedule. Manual maintenance mode can be applied indefinitely or for a specified duration in minutes, and it can be started or stopped independently of any assigned recurring schedule. For recurring maintenance windows, administrators can create maintenance schedules that place objects in maintenance mode at fixed intervals, such as from midnight until 3:00 a.m. on a specific night each week. These schedules are configured per policy through the Policy Definition interface in VCF Operations. When objects are in maintenance mode on schedule, VCF Operations suppresses alerts and status indicators for those objects, preventing misleading data that would otherwise result from objects being offline or in an unusual state during planned maintenance.

VCF Operations also supports automation of maintenance tasks through Automation Central, which allows administrators to create jobs that schedule actions to run automatically. Jobs can be configured with daily, weekly, or monthly recurrence and set to end after a specific date or number of occurrences. The VCF Operations orchestrator further supports scheduling of workflow runs at specified dates, times, and intervals. These capabilities allow maintenance tasks to run during defined windows without manual supervision.

Lifecycle management in VCF provides tools for planning and executing updates across the software stack. Starting with VCF 9, component lifecycle management is performed through the VCF Operations UI, which centralizes update and patch deployment for all VCF components. Administrators can schedule maintenance windows and coordinate changes to reduce disruption to services. Configuration updates are required to be performed during a maintenance window. VCF lifecycle management automates the process of applying updates and patches to software components within the stack, and it manages version compatibility across VCF components to maintain stability during and after updates.

VCF delivers maintenance releases as scheduled, cumulative updates focused on platform stability and support. These releases are synchronized among VCF components through a new Bill of Materials, which coordinates versioning across the stack so that components remain compatible after each update cycle. Patch releases, by contrast, are not synchronized among all components and do not require a new Bill of Materials.

For workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor, the platform provides structured lifecycle management procedures at both the cluster and workload levels. Cluster-level lifecycle operations are performed through the Cluster API resource, which manages provisioning, scaling, and upgrades of VKS clusters. Node maintenance follows a defined sequence: operators cordon a node to prevent new workload scheduling, then drain it using `kubectl drain` to safely evict running pods before performing maintenance. Maintenance should not begin until the drain command completes, and operators should select worker nodes rather than control plane nodes when performing tasks such as checking for updates, preserving control-plane stability during the maintenance window. On shared clusters, operators should verify that cordoning and draining a node will not adversely affect other tenants before executing the operation.

For application updates within VKS clusters, Kubernetes rolling update strategies on Deployments, DaemonSets, and StatefulSets allow workloads to be updated with maintained availability. The `kubectl rollout` command manages the rollout lifecycle, supporting pausing, resuming, and rolling back changes. StatefulSet controllers use `ControllerRevision` objects to track historical configuration changes and maintain a revision history that enables rollback when updates need to be reversed. StatefulSet pods retain their identity and persistent storage when rescheduled to available nodes during maintenance, allowing stateful applications to survive node maintenance events without losing state. The `DaemonSetUpdateSurge` feature gate enables DaemonSet workloads to maintain per-node availability during updates. Declarative object management using

kubectl apply with version-controlled configuration files provides a controlled change mechanism that supports tracking what changed and restoring prior state if needed.

Kubernetes Operators running on Supervisor extend these capabilities by automating lifecycle procedures for stateful applications, including snapshot creation, StatefulSet and volume management, backup scheduling, and version upgrade orchestration. Operators allow complex, application-specific lifecycle procedures to be codified and applied consistently across environments. The Kubernetes TTL controller automatically removes finished Jobs based on configurable time-to-live settings, supporting lifecycle hygiene for batch workloads without manual intervention. Finalizers provide an additional mechanism for controlling the lifecycle and cleanup of resources owned by deleted objects.

The VCF Automation self-service catalog allows consumers to deploy IT resources and independently manage workloads through day-2 actions including updates and patches. Catalog items are scoped to projects, and lifecycle and day-2 actions for custom resources in a deployment must be shared with all relevant projects to support continued management after a deployment moves between projects. VCF building-block services have independent lifecycles, enabling individual components to be updated or maintained without requiring a complete platform maintenance window.

For backup data lifecycle maintenance, Velero on VKS clusters includes a configurable maintenance job system through the backupRepository.maintenanceJobConfig setting, which supports both global configuration and per-backup-repository maintenance job configuration. The fullMaintenanceInterval defaults to normalGC, and resource limits for maintenance job pods are tunable.

Supervisor system components, including the vmware-system-tkg controller manager, state metrics, and webhook components, are deployed across multiple replicas for high availability. This design allows component-level updates to proceed without requiring a complete platform maintenance window. Cluster health visibility is available through Kubernetes cluster conditions, including a Remediating condition that surfaces details about ongoing remediation of controlled machines. Readiness probes run throughout a container's lifecycle and allow the platform to detect and respond to recovery from temporary faults during or after maintenance events.

For host-level maintenance, VMware ESX hosts support a formal maintenance mode with dedicated API methods (EnterMaintenanceMode_Task and ExitMaintenanceMode_Task) that allow hosts to be taken offline for servicing in a controlled manner. Maintenance mode can also be managed through the ESXCLI interface. Administrators can verify whether a host is in maintenance mode using `esxcli --server=<server_name> system maintenanceMode get`, and access to maintenance mode operations is governed by the `Host.Config.Maintenance` privilege, which controls the ability to place a host in and out of maintenance mode and to shut down and restart the host. When remediating hosts through Update Manager, administrators can configure maintenance mode settings to control how hosts enter and exit maintenance mode during patching operations. For vSAN clusters, placing a host in maintenance mode requires selecting a data evacuation mode, such as Ensure accessibility, Full data migration, or No data migration.

At the network layer, routine maintenance tasks for NSX Manager appliances include running backups, adding licenses and certificates, and changing passwords, providing a defined set of maintenance activities for the networking infrastructure.

VMware vDefend (Contributes)

VMware vDefend provides lifecycle management and operational visibility capabilities through its Security Services Platform (SSP) that support controlled maintenance activities for the vDefend security infrastructure.

SSP's Platform Inventory Monitor gives administrators status visibility across environments, regions, zones, and virtual machines, identifying assets in success, timeout, or out-of-sync states. Filtering by name and status allows administrators to assess operational health before and after maintenance activities. The View details of external rollouts option in SSP displays progress details for Refresh operations covering Bare Metal servers, NDR Sensors, and Service VMs at both the individual and overall feature status levels, providing granular visibility into rollout state.

SSP enforces sequencing constraints on maintenance operations: Bare Metal Service operations such as onboarding, offboarding, and upgrading Bare Metal servers should not be performed while a backup or restore is in progress. After restoring a backup in either a disaster recovery or in-place scenario, agent health status must be confirmed as Up on Bare

Metal servers before proceeding. The vDefend CLI provides a command to display the health of all services and agents running on a Bare Metal server, giving administrators a mechanism to verify service state before and after servicing. SSP also includes Depot and Registry services that run as systemd-managed services and can be restarted and monitored via systemctl commands.

SSP proactively manages its Platform CA certificate lifecycle. The certificate manager and security intelligence services within SSP can be queried for operational status to diagnose service availability issues during and after maintenance events.

NDR Sensor management operations, including activating or deactivating features and offboarding sensors, are restricted to the Enterprise Admin or Security Engineer role, limiting who can execute maintenance actions on detection infrastructure. Tokens, Bare Metal servers, and Bare Metal server interfaces are included in the full inventory backup, supporting recovery after maintenance activities.

When using vDefend Intelligent Assist or Network Detection and Response remediation workflows, objects that encounter errors during remediation require manual cleanup, which is a constraint administrators should account for in maintenance planning.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports controlled maintenance through two configurable policy mechanisms: a maintenance policy for the DSM plug-in software itself, and per-database maintenance windows for database engine upgrades.

For plug-in software updates, administrators configure a maintenance policy that specifies a start date, start time (in hours and minutes), and a permitted duration for applying updates. The policy is accessible from the Version & Upgrade section under the DSM System tab in the DSM UI, as well as from the vSphere Client. This policy governs automatic upgrades of the DSM Provider Appliance plug-in, allowing organizations to schedule maintenance during off-peak hours and bound the duration of any resulting downtime. The policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the revised settings. If an automatic upgrade fails, administrators can reconfigure the maintenance policy to reschedule or perform a manual update.

For database engines, each database supports an individually configurable maintenance window that controls when minor version upgrades are applied. The default schedule is Saturday at 23:59 UTC with a six-hour duration, adjustable through the Edit Maintenance Window dialog. MySQL databases include an Enable Maintenance Window toggle with the same default schedule. SQL Server databases support configurable maintenance windows for both software version upgrades and operating system patching. In 9.1, DSM adds a Monthly Occurrences setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more specific occurrences of that day. If no specific occurrence is selected, the maintenance window runs every week. Maintenance window settings, including Monthly Occurrences, are also configurable when provisioning databases through VCF Automation. Administrators are prompted to define maintenance window schedules during database creation alongside backup policies.

The DSM controller manages component dependencies through status monitoring and automated remediation. DSM also provides operational visibility into maintenance activity through the database Status indicator and the Operations tab, which display in-progress operations, configuration changes, disk extension tasks, and restore operations. This allows administrators to confirm that maintenance actions have been applied and to identify those that have failed.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support controlled maintenance activities across its application delivery infrastructure.

For back-end server pools, Avi's health monitoring framework includes maintenance mode detection. Health monitors can be configured so that when a back-end server enters maintenance mode (signaled by returning a designated response code or response string), Avi automatically changes the server's health status to "down for maintenance" and stops routing traffic to it. This behavior is supported across TCP, UDP, HTTP, HTTPS, HTTP/2, and POP3/POP3S health monitor types. TCP and UDP monitors use the tcp-udp-maintenance-mode-filters setting; HTTP monitors use the maintenance_response and

`maintenance_code` CLI parameters; HTTP/2 monitors use the `maintenance-server-response-data` setting; POP3/POP3S monitors match a configured string such as `MAINTENANCE_ACTIVE` against the health-check response body. The maintenance mode detection monitor must be associated with the pool the server belongs to. Administrators and application developers can inspect health-check responses directly to validate server maintenance state. When the maintenance string or code is no longer returned, subsequent health checks restore the server to active rotation.

For Global Server Load Balancing (GSLB) operations, Avi enforces a controlled pre-maintenance step before a manual leader change. The CLI command `gslb maintenancemode enabled` must be run in GSLB configuration mode to place the leader Controller into maintenance mode before the leader change proceeds; the corresponding `gslb no maintenancemode` command exits maintenance mode. Avi GSLB can also direct traffic to alternative endpoints during planned maintenance, supporting service continuity while primary endpoints are offline.

For cloud-level maintenance, the Avi Controller provides a CLI workflow to place an entire cloud into maintenance mode using `configure cloud <name>` followed by the `maintenance_mode` directive. This is used during Controller upgrades and patch operations. The cloud exits maintenance mode via the `no maintenance_mode` directive.

For Kubernetes deployments using the Avi Kubernetes Operator (AKO), maintenance mode detection is available through the HealthMonitor custom resource definition (CRD). AKO HealthMonitor TCP monitors support a `maintenance_response` value, enabling Kubernetes-native maintenance workflows where health-check responses trigger traffic drain before maintenance begins.

For bare-metal Linux Server Cloud deployments hosting both Controller and Service Engine components, Avi defines a sequential maintenance procedure: Service Engines must be deactivated before hardware maintenance, host OS upgrades, security patching, or kernel updates on the host. Controller cluster nodes must be serviced one at a time to preserve cluster quorum and availability throughout the maintenance window.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control MA.L2-3.7.2

> Provide controls on the tools, techniques, mechanisms, and personnel used to conduct system maintenance.

SCF Controls: MNT-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in mechanisms that contribute to controlling and monitoring the use of system maintenance tools across the infrastructure stack.

VCF enforces granular permissions through role-based access control (RBAC) across its component layers. NSX Manager implements RBAC to restrict system access to authorized users by assigning roles with specific permissions, and supports custom role creation to suit operational requirements. VMware vCenter provides privilege-based authorization levels, including an administrator role required for users who alter the vCenter configuration or exercise control functions. VCF Operations sends its roles as privileges to vCenter as part of the vCenter Global privilege group, and a vCenter administrator must assign VCF Operations roles to users in vCenter. These layered RBAC controls allow organizations to restrict which administrators can perform maintenance operations on specific components. Authentication occurs centrally through VCF SSO, which can be configured as a single sign-on source for VCF Operations and other components, providing a single point of identity verification for all maintenance activities.

VCF Operations provides lifecycle management capabilities that allow administrators to plan updates, schedule maintenance windows, and coordinate changes across VCF components with minimal disruption to running services. Maintenance releases are synchronized among VCF components through a coordinated Bill of Materials, so patching and update activities follow a structured, controlled process rather than ad hoc tool usage. Maintenance operations are performed through defined interfaces: the VCF Operations UI for lifecycle and update operations, the vCenter UI and APIs for host and VM management, and the NSX Manager UI for networking component maintenance. These structured interfaces limit the tools and methods available for performing maintenance. The ESX Shell, which provides lower-level maintenance commands on individual VMware ESX hosts, is deactivated by default and must be explicitly enabled before use, limiting access to this powerful maintenance interface.

VCF Operations provides granular maintenance mode controls that govern how and when infrastructure objects are taken offline for servicing. Administrators can place objects into maintenance mode manually, either indefinitely or for a specified time window, and the system requires explicit user action to end the maintenance period. For recurring maintenance activities, VCF Operations supports maintenance schedules that can be assigned to objects at fixed intervals, such as scheduled weekly windows. These schedules serve a dual purpose: they control when maintenance occurs and they prevent the monitoring system from generating misleading alerts based on objects being offline during planned maintenance. Maintenance schedules can also be attached to policies, providing a structured framework for controlling when objects are taken offline.

At the host level, ESX exposes discrete API methods (`EnterMaintenanceMode_Task` and `ExitMaintenanceMode_Task`) on the `HostSystem` managed object for placing hosts into and out of maintenance mode programmatically. For NSX transport nodes, maintenance mode status can be verified through the `get maintenance-mode` command in the admin CLI, providing an additional checkpoint for network infrastructure maintenance activities. For individual ESX hosts, the `esxcli --server=<server_name> system maintenanceMode get` command provides a CLI-based method to verify whether a host is currently in maintenance mode before performing update or remediation operations.

VCF Operations provides monitoring and reporting capabilities that give visibility into maintenance activities and system state. The Supervisor Dashboard monitors critical lifecycle components, the System Management Dashboard displays the status of services running on the system, and service discovery dashboards allow administrators to monitor services across the environment. OS and Application Monitoring Properties are collected for operating systems, application services, and processes, which can be used to create reports, views, and dashboards that track system state before, during, and after

maintenance windows. Automation Central displays a calendar of all scheduled jobs and provides History and Jobs tabs to view detailed information about job execution, including job frequency, type, and activation status.

Audit logging across VCF components captures administrative actions to provide accountability for maintenance activities. VCF Operations audit logs record administrative actions including CRUD operations and login/logout events, capturing actions from the API, the user interface, and the CLI. User activity audit logs can be accessed from the Administration Control Panel and downloaded in PDF or XLS format. NSX Manager logs security policy modification operations with audit trail details including username, module name, operation type, operation status, and old and new values. Event auditing in VCF Operations increases user accountability as each action is registered in audit events.

These capabilities allow an organization to define approved maintenance windows, restrict maintenance mode transitions to authorized administrators, monitor infrastructure status during maintenance activities, and verify that systems return to normal operation after servicing. However, VCF does not maintain an inventory of approved maintenance tools or enforce policies about which external tools may be used during maintenance. Organizational processes are needed to define approved tool lists, restrict physical and logical access to maintenance utilities, and maintain records of maintenance tool usage.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MA.L2-3.7.3

> Ensure equipment removed for off-site maintenance is sanitized of any CUI.

SCF Controls: DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support media sanitization workflows for virtualized infrastructure, though the full control requires organizational procedures for physical media handling, verification, and documentation.

Encryption-based cryptographic erasure

VCF supports encryption of virtual machine disk (VMDK) files, where data in an encrypted VMDK is never written in cleartext to storage or transmitted in cleartext over the network. For storage environments using vSAN data-at-rest encryption or VM Encryption, cryptographic erasure is available as a sanitization method: destroying the encryption keys associated with the storage renders the encrypted data unrecoverable without requiring block-level overwriting. This approach is recognized by industry-standard best practices as an acceptable sanitization technique for encrypted media. Administrators configure VM encryption through VMware vCenter and the key management infrastructure, which supports both KMIP-compatible external Key Management Servers and vSphere Native Key Provider.

The vSphere Web Services API provides `removeKey` and `removeKeys` methods for programmatic removal of cryptographic keys by ID, each with an optional `force` parameter. The `force` option is intended for cases where a key has been compromised or expired, removing it from use across the environment. These API methods support automated key destruction workflows as part of a cryptographic erasure process. On VMware ESX hosts, calling `removeKey` without the `force` option deletes the key from the host's key cache and renders any encrypted virtual machine using that key unusable, because ESX hosts do not track which keys are in use.

The No Cryptography Administrator role separates cryptographic privileges from routine administrative operations. This role includes all Administrator privileges except Cryptographic Operations, and it can be cloned to create custom roles with only specific cryptographic privileges. This separation helps restrict who can modify encryption settings or remove keys during media lifecycle activities.

vSAN disk sanitization features

vSAN includes a disk wipe capability for securely wiping storage devices. Before wiping ineligible disks, administrators must check the partition table and verify the data stored on those disks. When encryption is enabled on an existing vSAN cluster, the "Erase disks before use" option wipes existing data from storage devices as they are brought into encrypted disk groups. Devices added to a vSAN disk group that contain residual data or partition information must be cleaned before they can be claimed, providing a built-in sanitization step during device onboarding. vSAN also supports re-encrypting all data using new keys through a rolling disk reformat, which generates a new Key Encryption Key and new Data Encryption Keys.

ESX host configuration protection

ESX stores its configuration data in encrypted form on boot devices. When a Trusted Platform Module (TPM) 2.0 is available, encryption keys can be persisted in the TPM across reboots using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter. This means host decommissioning can include clearing the TPM to render the stored configuration unrecoverable.

Orphaned disk identification and reclamation

VCF Operations provides capabilities for identifying orphaned virtual disks, defined as VMDKs on datastores that are not connected to any registered virtual machines and have not been modified during a defined period. Administrators can configure a reporting threshold that sets the minimum number of days before unattached VMDKs are flagged as orphaned. The Reclaim Resources feature allows execution of resource reclamation processes, and administrators should verify the accuracy of reported orphaned disks before performing reclamation. A Reclaimable Orphaned Disks metric displays potential

savings from removing orphaned VMDKs across all datastores. Identifying and removing orphaned disks that may contain residual sensitive data is a relevant step in the media sanitization lifecycle.

Datastore removal and virtual disk controls

When a VMFS datastore is destroyed via the RemoveDatastore API, the partitions that compose the VMFS volume are removed and the datastore becomes unavailable to all ESX systems after a rescan. Datastore resignaturing is irreversible because it overwrites the original VMFS UUID. These operations provide mechanisms for decommissioning storage volumes as part of a media reuse or disposal workflow. The delete operation for a VMFS datastore permanently deletes all files associated with virtual machines on the datastore. Before initiating deletion, Storage DRS and Storage I/O Control should be disabled for the datastore to prevent automated storage management processes from interfering with the deletion workflow.

VCF also provides the `isolation.tools.diskWiper.disable` setting, which controls whether guest operating systems can issue virtual disk wiper operations. In hardened environments, this setting is typically configured to restrict disk wiper access, giving administrators centralized control over disk sanitization activities rather than allowing individual virtual machines to initiate wipe operations.

Protecting sensitive data in operational files

Backup files for VCF Operations, VMware vCenter, and NSX are encrypted using AES-256-CBC encryption with SHA256 message digest. After file-based restore operations, administrators are directed to securely delete decrypted backup files and control access to them during the restore process.

Core dumps on vCenter systems are not encrypted and can contain memory contents that include credentials, encryption keys, or other sensitive data. Administrators should consider disabling core dumps on vCenter systems to restrict sensitive information from persisting in diagnostic files. Managing the lifecycle of these operational files is part of a complete media sanitization program.

VCF does not include dedicated media sanitization workflow tools, inventory tracking for media disposal, or chain-of-custody documentation capabilities. These organizational processes, along with physical media destruction procedures and verification of sanitization effectiveness, must be addressed through enterprise asset management and data governance programs outside of VCF.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MA.L2-3.7.4

> Check media containing diagnostic and test programs for malicious code before the media are used in organizational systems.

SCF Controls: MNT-04.2

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend (vDefend) Malware Prevention can inspect files transferred over the network, including diagnostic and test programs, for malicious code. Inspection uses three detection methods: hash-based detection of known malicious files, local analysis of unknown files, and cloud analysis for files requiring deeper examination. Supported file categories include Executable, Document, Script, Archive, Data, and Media. Within the Script category, vDefend supports detection of PowerShell scripts, Python scripts, JavaScript, Visual Basic scripts, batch scripts, Perl scripts, shell scripts, Windows scripts, and HTML applications, covering the scripted diagnostic tools common in enterprise environments.

Malware Prevention also monitors in-memory script buffers and process activity to detect fileless malware, collecting evidence of the processes leading to execution of malicious in-memory script buffers before they execute.

File Analysis Reports include severity scores on a scale of 0 to 100 indicating the maliciousness of detected activities, activity type classifications (Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, and Stealth), MITRE ATT&CK technique mappings, file hash values (MD5, SHA1, SHA256), and an Additional Artifacts section listing files and URLs observed during analysis. Reports can be exported in XML, JSON, and PDF formats and include downloadable screenshots and packet capture files. Process Analysis Reports provide verdict information for each inspected process, filtering by verdict type, and similar export capabilities. File events with a maliciousness score of 30 or higher are forwarded to Network Detection and Response for correlation with broader campaign activity.

The Security Services Platform dashboard and the Malware Prevention Dashboard provide a breakdown of file inspections by analysis type and display detailed inspection history and event records for ongoing monitoring and review. Malware Prevention Service event logs record file metadata including file name, file type, and file size for each inspection.

vDefend's inspection capability applies to network-transferred files and files downloaded on workload VMs protected by a Malware Prevention security policy. It does not address physical removable media or files introduced through out-of-band channels, so complementary endpoint or media scanning controls are needed to fully satisfy this control.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MA.L2-3.7.5

> Require multifactor authentication to establish nonlocal maintenance sessions via external network connections and terminate such connections when nonlocal maintenance is complete.

SCF Controls: IAC-06, MNT-05, MNT-05.4

Aggregate Coverage: Meets

VCF (Meets)

VCF provides mechanisms for authorizing, monitoring, and controlling remote maintenance and diagnostic activities across the managed infrastructure, including the Consumption layer delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor.

All remote administrative access is authorized through VCF SSO, which provides centralized authentication for VMware vCenter, ESX, NSX, VCF Operations, and VCF Automation. At the ESX host layer, lockdown mode restricts direct host access so that maintenance and diagnostic operations are routed through VMware vCenter rather than the host directly. Normal lockdown mode permits local console and vCenter access, while strict lockdown mode stops the Direct Console User Interface and allows access only through vCenter. VCF Operations integrates with VCF SSO for centralized user and group authentication and management. VCF Operations for Networks also supports VCF SSO as a login method. Role-based access control within each component determines which maintenance and diagnostic operations a given user can perform. NSX Manager implements RBAC to restrict system access to authorized users by assigning roles with specific permissions. This authorization model applies to both graphical management interfaces and programmatic access through REST APIs, SDK, and PowerCLI.

For VKS workload clusters managed through vSphere Supervisor, the Kubernetes API server is the central control point through which all remote management and diagnostic operations pass. Access to the API server requires authentication before any action can be taken; supported methods include OIDC, X.509 client certificates, service account tokens, and webhook token authentication. Once authenticated, requests are evaluated against RBAC policies: Roles and ClusterRoles define permitted operations on specific Kubernetes resource types, and RoleBindings and ClusterRoleBindings associate those permissions with users, groups, or service accounts, scoped either to individual namespaces or cluster-wide. The built-in system:monitoring group provides read access to control-plane monitoring endpoints, including liveness, readiness, and health check endpoints (/healthz, /livez, /readyz) and /metrics, enabling authorized operators to query cluster health remotely without broader administrative access. On production clusters, Kubelet authentication and authorization should be enabled to restrict who can access node-level diagnostic operations and log retrieval remotely.

VCF Operations supports maintenance mode to take objects offline for maintenance activities. Administrators can put objects into maintenance mode manually, either indefinitely or for a specified period, or configure recurring maintenance schedules that activate at fixed intervals. For example, a maintenance schedule can place an object in maintenance mode from midnight until 3 a.m. on recurring days. Manual and scheduled maintenance modes are not mutually exclusive, giving administrators flexibility to respond to both planned and unplanned maintenance needs. These scheduling capabilities allow organizations to define and enforce approved maintenance windows, providing structured control over when maintenance activities occur. When remediating ESX hosts through Update Manager, administrators can configure maintenance mode settings to control how hosts are transitioned during patching and update operations.

At the Kubernetes layer, node cordoning and draining provides structured control over workload placement during planned maintenance operations. Cordoning a node prevents new pod scheduling on it, and draining it safely relocates running workloads to other available nodes before maintenance begins. Stateful applications deployed as StatefulSets maintain pod identity and persistent storage across the cluster, allowing rescheduling to available nodes during node maintenance. PodDisruptionBudgets can be defined to set availability constraints that Kubernetes respects when draining nodes during planned maintenance, helping maintain service continuity for critical workloads.

Maintenance schedules are integrated with the monitoring system to prevent VCF Operations from generating misleading alerts when objects are intentionally offline for maintenance. This separation of planned maintenance from genuine

operational issues helps administrators focus monitoring attention on actual problems rather than expected outages. VCF Automation retrieves VCF Operations health status and associated alerts about deployments, creating a feedback loop that helps administrators track the impact of maintenance activities. Proactive monitoring capabilities help maintain environmental stability by identifying issues that may arise during or after maintenance operations.

For monitoring remote maintenance activities, VCF Operations captures platform interactions through its audit events framework, reporting on authentication and security-related events. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change, allowing administrators to determine the principal identifier of the user who initiated a change to an object at a given time. User Activity Audit reports show the scope of user activities, including logging in, actions on clusters and nodes, changes to system passwords, activating certificates, and logging out. Audit data can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. VCF Operations for Networks provides audit logs that capture administrative actions, with access controlled by user role. VCF Operations can forward user activity audit logs to an external syslog server to meet security auditing requirements. API audit logging captures REST API calls, SDK usage, and PowerCLI commands with user attribution, providing visibility into programmatic maintenance actions. In NSX, API calls from all sources and users are audited, and this logging is always enabled and cannot be disabled.

At the Kubernetes layer, the API server includes built-in audit logging that records every request, capturing the requesting user, action taken, target resource, and outcome. Organizations can define an audit policy to control which request types and resource types generate audit records; audit events can be written to log files or forwarded to webhook endpoints for integration with external log management systems. This logging provides visibility into all remote management and diagnostic activity directed at VKS clusters. Kubernetes system components also generate traces that can be collected and analyzed for observability during maintenance activity.

VCF Operations provides remote monitoring capabilities including HTTP remote checks that support GET, POST, and PUT methods for application service monitoring. These remote checks support SSL certificate and key file paths for secure communication with target machines. Administrators can configure discovered services and perform custom monitoring actions including custom scripts, remote checks, Windows service monitoring, and Linux process monitoring. Service discovery and monitoring is available through VCF Operations Advanced and Enterprise editions, enabling administrators to discover and monitor services across the environment. Administrators can deploy product-managed Telegraf agents to monitor physical servers remotely, with lifecycle management available through the VCF Operations suite API. vSphere Hardware Health monitoring displays host component sensors, storage sensors, hardware alerts and warnings, and system event logs, providing hardware-level diagnostic visibility for administrators managing physical infrastructure.

VKS clusters can be monitored and managed from the Supervisor Management > Services tab in vSphere Client, giving administrators a centralized view of cluster state and component health. The Kubernetes API server exposes individual health check endpoints that operators can use for debugging system status. VCF Automation for VM Apps maintains a history of deployments that can be reviewed to retrieve information about deleted machines and diagnose deployment failures, supporting post-maintenance verification.

VCF also provides diagnostic capabilities for remote troubleshooting. The DiagnosticManager is a managed object that works service-wide, rather than on a per-session basis, and is available on both ESX and vCenter systems. ESX also supports out-of-band remote management through hardware management interfaces, including HP Integrated Lights-Out (iLO), Dell Remote Access Card (DRAC), IBM management modules, and Fujitsu iRMC, enabling authorized remote access and control at the hardware layer independent of the host operating environment. VCF Operations supports centralized log collection for diagnostic and monitoring purposes. Log Assist extends log export functionality with diagnostic capabilities, enabling remote troubleshooting without requiring direct console access to managed components. VCF supports configuring alerts for operational monitoring, providing visibility into the state of managed infrastructure during and outside maintenance windows.

Before performing maintenance activities such as upgrades, administrators should take on-demand backups of components like VCF Automation. This practice provides a recovery point if maintenance activities produce unexpected results, supporting controlled and reversible maintenance operations.

VMware vDefend (Contributes)

VMware vDefend contributes to remote maintenance oversight by enabling its Distributed Firewall to restrict network paths used for remote maintenance and diagnostic sessions, limiting access to authorized hosts and protocols. Distributed Firewall rules support per-rule logging that can be enabled or disabled individually, creating a traffic record for connections to management interfaces.

Security Services Platform (SSP) can be configured to forward log messages to a remote syslog server with configurable protocol, log level, and message ID filtering covering SECURITY and MONITORING categories, providing an audit trail of platform events that supports detection of anomalous activity during maintenance windows. The License Hub component also supports remote syslog forwarding. SSP Inventory tracks environment synchronization status and identifies environments that are timed out or out of sync, supporting operational awareness during maintenance activities.

When the SSP platform UI is unresponsive, SSH access to the SSP Installer VM provides access to support logs for diagnostic purposes. SSH is also used for remote access to Service Virtual Machine management interfaces. Support bundle collection is available for Bare Metal servers, Service Virtual Machines, and NDR Sensors when their status is degraded or disconnected, gathering diagnostic information from all controller and worker nodes in the deployment.

Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, which can help identify anomalous connections during maintenance windows. Network Detection and Response provides role-based access control for triage and configuration operations, restricting who can view detections, view campaigns, and modify SIEM configuration.

vDefend does not natively authenticate or authorize remote maintenance sessions and does not provide session recording. Privileged access management, multi-factor authentication, and session recording for remote maintenance remain the responsibility of complementary identity and access management controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides remote maintenance capabilities through the Protection and Recovery Appliance management interface, which allows administrators to configure appliance settings, modify security and network configuration, and perform maintenance operations after deployment. SSH access to the appliance can be explicitly activated or deactivated and requires administrator credentials, giving administrators direct control over shell-based remote maintenance alongside the web management interface. Administrator authentication to the appliance and to the vSphere Client plug-in flows through VCF SSO, restricting remote maintenance access to identities approved by the platform identity provider.

Authorization decisions on remote site manager operations are recorded in PNR log files, which capture authorization failures with method name, fault type, object reference, and privilege ID, providing an audit trail of remote maintenance and diagnostic activity. The Protection and Recovery Appliance can forward log files to a remote syslog server for log analysis and centralized monitoring, supporting external correlation in VCF Log Management or a third-party SIEM. Support logs including HMS logs, boot messages, and DR client logs can be copied via SCP or WinSCP for offline diagnostics. PNR monitors connections between protected and recovery sites by sending periodic ping requests and emits RemoteSitePingFailedEvent, RemoteSiteDownEvent, and RemoteSiteUpEvent events to record inter-site management connectivity status, with timeout and ping-delay parameters such as remoteManager.defaultTimeout, remoteManager.taskDefaultTimeout, remoteSiteStatus.drPingFailedDelay, and remoteSiteStatus.drPanicDelay available to tune monitoring behavior. Protection and Recovery dashboards in VCF Operations display alerts about configurations and deployments that need administrator attention, and the Clean Room Orchestrator generates warning alerts for expired snapshot schedules, replication errors, and connectivity issues with protected and target sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to remote maintenance authorization, monitoring, and control through defined access channels, configurable maintenance scheduling across all supported database engines, alert-driven monitoring, and audit logging.

For remote diagnostic activities, DSM Provider requires SSH access to the appliance VM, allowing administrators to inspect the dsmsystem config Custom Resource and review current status and configuration details. This SSH-based access model defines the channel through which remote maintenance activities occur, giving organizations a specific mechanism to control who connects and when. DSM can also be monitored using VCF Operations for troubleshooting and status visibility.

DSM supports policy-controlled maintenance scheduling across all managed database engines. The maintenance-policy setting, configurable from both the vSphere Client and the DSM UI, controls the time and duration of automatic software updates to the DSM plug-in. For PostgreSQL and MySQL database instances, a configurable maintenance window controls when minor software updates are applied; the default window starts each Saturday at 23:59 and runs for six hours. MySQL administrators can enable or disable automatic minor updates through the Enable Maintenance Window toggle. SQL Server cluster administrators can define separate maintenance windows for operating system patching. In VCF Automation deployments, DSM provides additional scheduling granularity through day-of-week selection and a Monthly Occurrences setting that restricts maintenance to specific weeks within a month rather than running every week.

For monitoring, DSM provides continuous performance monitoring paired with real-time alerts for resource and connectivity issues. The Global Alerts page surfaces system-level and installation alerts, including vCenterBinding API status and LicensingNotUpdated conditions, for administrator review and remediation. Database engine health monitoring detects service disruptions that may result in data service outage, read-only mode, or reduced data availability. DSM webhooks transmit alert notifications for health events including CPU Health, Data Disk Health, and System Disk Health to external systems. The monitoring framework covers both metrics-based and status-condition-based alerts, including database engine degradation, non-operational status, and backup failures. In VCF Automation deployments, DSM Consumption Operator pod logs can be inspected directly from the running container to diagnose error conditions.

Gateway Audit Logs, accessible through the Administering section of the DSM UI, record gateway-level audit trail events and support review of administrative activity.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides SSH (Secure Shell) access to the Avi Controller for remote administration, giving administrators a secure channel for non-local maintenance and diagnostic work. The Controller also maintains configuration audit logs and event logs that record administrative actions taken via the web interface, API, and CLI, and can forward alert notifications to remote syslog servers for centralized monitoring and audit trail collection. Avi's role-based access control system allows organizations to define which user accounts may access the Controller and at what privilege level, enabling organizations to scope remote access to authorized personnel.

The majority of facts retrieved for this control relate to Avi's backend server maintenance mode detection capabilities, where health monitors identify when a pool member has entered maintenance state based on configured HTTP response codes or response string patterns (the maintenance_response and maintenance_code parameters, and the HTTP Health Monitor's Maintenance Server Response Data setting). This is an application delivery and traffic management function that Avi provides to gracefully drain connections from servers undergoing maintenance, not a remote administrative access control mechanism.

For the control's requirements, which concern authorizing, monitoring, and controlling remote maintenance sessions on the Avi system itself, organizations must combine Avi's SSH access controls and audit logging with organizational governance. This includes defining authorization procedures and change management approval for remote maintenance activities, restricting SSH access to specific source addresses or jump hosts, and integrating Avi audit log output with a centralized security monitoring platform so that remote maintenance sessions are reviewable after the fact. These governance and integration activities extend beyond Avi's own feature scope and require deliberate organizational policy decisions.

Control MA.L2-3.7.6

> Supervise the maintenance activities of maintenance personnel without required access authorization.

SCF Controls: MNT-06, MNT-06.1, MNT-06.2

Aggregate Coverage: Contributes

VCF (Contributes)

The VCF platform's Consumption layer, through VMware Kubernetes Service (VKS) and vSphere Supervisor, contributes to this control by providing technical enforcement of authorization and a queryable record of who holds maintenance-scoped roles at any point in time.

Kubernetes RBAC governs access to all operations within the Consumption layer. Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings define what each principal can do within a given scope. Administrative maintenance tasks, such as deploying and managing the lifecycle of Supervisor Services and modifying cluster configurations, are the exclusive domain of vSphere administrators. DevOps engineers and Platform Operators are assigned non-admin or custom roles scoped to specific namespaces rather than platform-level access, authenticated via VCF SSO. This separation is enforced through role assignments, not merely documented in policy.

VKS clusters integrate with VCF SSO for identity. Users or groups to whom permissions are assigned must exist in the identity source, which means access cannot be granted to principals that no longer exist in the directory. When a user's directory account is removed, VCF SSO integration removes the ability to authenticate, even if a residual role binding remains.

Administrators can enumerate current role assignments at any time using the Kubernetes RBAC API. The RoleList resource, accessible via GET /apis/rbac.authorization.k8s.io/v1/roles, returns all Role objects in scope. The kubectl auth can-i command with user impersonation allows administrators to determine what actions any given principal can currently perform, supporting periodic authorization reviews. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege and narrow the set of principals authorized to perform maintenance operations.

VCF Automation provides organization-level RBAC through Organization Administrator, Organization Auditor, Project Administrator, and Project Auditor roles, giving administrators visibility into who holds what permissions across the catalog and deployment layer. Policy assignment views are accessible to Organization Administrator and Auditor roles, supporting authorization review at the consumption layer. Harbor Registry, when deployed as a standard package on VKS clusters, enforces RBAC to govern access to artifacts managed through the platform.

Kubernetes audit logging records role grant and revocation events, providing a historical record of authorization changes. Where Argo CD is deployed as a Supervisor Service, it maintains a complete history of all configuration changes in Git, supplementing the audit trail for GitOps-managed workloads.

The control requires that an organization maintain a current list of authorized maintenance organizations or personnel. That list is an organizational artifact rather than a platform function. The Consumption layer's RBAC enforcement, identity integration, and enumerable role bindings support the underlying requirement by providing a queryable record of current authorizations, but organizations must establish the governance process for reviewing and updating that list on a defined schedule.

VMware vDefend (Contributes)

VMware vDefend (vDefend) 9.1 implements Role-Based Access Control (RBAC) across its components to limit what operations maintenance personnel can perform based on their assigned roles. The Security Services Platform (SSP) defines five roles with differentiated permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Enterprise Admin role has Full Access to all SSP operations, including deployment, management, upgrades, authentication and authorization configuration, server configuration, backup and restore, and Security Intelligence activation. The Security Engineer role has Full Access to export flows, monitoring operations, Security Intelligence data collection configuration, and traffic flow visualization, with Read access only to administrative management operations such as deployment and server configuration. The Security Operator role has Restricted access to segmentation policy and group

publishing, discovery and inventory operations, and monitoring functions, with Read access to administrative management operations. Modifying role assignments in SSP requires Admin privileges, so role management itself is access-controlled.

In multi-tenant environments managed through VCF Automation, the Organization Administrator (Tenant Admin) role has full access to manage, view, and change any vDefend security component, including Transit Gateway (TGW) firewalls, Distributed Firewalls (DFW), and VPC gateway firewalls. This role requires eight specific rights covering DFW Manage/View, TGW Firewall Manage/View, VPC Gateway Firewall Manage/View, VPC Security Profiles Manage/View, and Groups.

SSP also maintains two predefined local accounts: an admin account with full privileges to access and manage the platform, and an audit account scoped to APIs and services for auditing the system. These built-in accounts provide baseline access separation for administrative and audit functions.

Mitigating risks from personnel who lack organizational clearances or formal access approvals beyond vDefend's RBAC boundary remains an organizational IAM and HR control outside the product's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to this control through its role-based access control system, which restricts maintenance-related activities to defined, named accounts. DSM defines two primary roles: the DSM Administrator role and the DSM User role. The Administrator role manages database backups, high availability settings, VM updates, and infrastructure policies. The User role is scoped to provisioning and managing only the objects that the user owns. DSM also supports custom user roles that can be assigned to directory service groups, allowing fine-grained access to the DSM UI for monitoring and management purposes. A vSphere administrator plans, administers, and secures database resources by creating and managing infrastructure policies in DSM. These role boundaries mean that maintenance-capable access is not granted by default and must be explicitly assigned.

In environments using DSM with VCF Automation, a VCF Automation organization administrator manages the cloud resources allocated to the organization, manages projects and users, and enforces standardized configurations. This role is an additional maintenance-capable persona in integrated deployments, and access can be tracked through the organization's VCF Automation identity management.

The Permissions view in the DSM dashboard provides administrators with a centralized interface for creating, monitoring, and managing configured users. This view is the operational record of who holds access within the DSM environment. Administrators can use it to review current user assignments and make changes as personnel or responsibilities shift. DSM also supports directory service integration, allowing user accounts and group memberships to be sourced from a directory service. This means that the authoritative list of authorized users can be maintained in the organization's existing identity management infrastructure, with DSM reflecting those assignments through directory-based authentication.

Software updates to the DSM plug-in require a user with administrator credentials to authenticate to the UI before any update actions can be taken. This access control applies to both manual and automatic update workflows. The Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, allows administrators to configure when automatic updates are applied without bypassing the requirement for valid administrative credentials.

DSM adds SQL Server as a supported database type. For SQL Server instances, DSM automatically creates a database user for the cluster administrator login in every database with db_owner role membership, allowing administrators to run maintenance tasks through agent jobs. Administrators can also activate SQL Server Agent configuration to schedule administrative tasks such as integrity checks, index optimization, and statistics maintenance.

Maintaining the formal list of authorized maintenance organizations or personnel as an organizational record remains an administrative process outside DSM's scope. DSM's RBAC system, Permissions view, and directory service integration provide the technical controls that support that process by making it possible to enumerate and manage who holds maintenance-capable access at any given time. Organizations should reconcile the users visible in the Permissions view against their formal authorization records on a regular basis.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L1-b.1.vii

> Sanitize or destroy information system media containing Federal Contract Information before disposal or release for reuse

SCF Controls: AST-01, AST-09, DCH-01, DCH-08, DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control MP.L2-3.8.1

> Protect (i.e., physically control and securely store) system media containing CUI, both paper and digital.

SCF Controls: DCH-01, DCH-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression,

and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The etcdctl snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During kubeadm upgrades, backup folders for etcd state and cluster manifests are written automatically to /etc/kubernetes/tmp with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides VolumeSnapshotContent and VolumeSnapshot resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a PersistentVolumeClaim using a VolumeSnapshotClass that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new PersistentVolumeClaim with the target VolumeSnapshot as its dataSource, referenced via the snapshot.storage.k8s.io API group. Kubernetes PersistentVolumes have a configurable reclaim policy; setting the policy to Retain preserves volume data in a Released state after the associated PersistentVolumeClaim is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control MP.L2-3.8.2

> Limit access to CUI on system media to authorized users.

SCF Controls: DCH-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides role-based access control (RBAC) across all platform components, restricting access to digital resources, including virtual machine files, templates, ISO images, content libraries, and management interfaces, to authorized individuals. These controls operate at multiple levels within the platform.

VCF SSO provides centralized authentication so that users authenticate through a single identity service rather than directly to individual components. This reduces direct access to VMware ESX hosts and supports consistent enforcement of access policies across VMware vCenter, NSX, and VCF Operations. An identity provider must be configured for VCF SSO before configuring SSO for VCF Operations and VCF Automation.

VCF Operations implements RBAC where administrators assign roles to users and user groups, restricting each user to only the actions their permissions allow. Roles are configured under Administration in the Access Control section, where administrators assign roles to user groups and control which objects each group can access. Beyond role-based restrictions, VCF Operations provides scope-based access control that allows administrators to limit a user's or group's visibility to specific objects within the environment. This means that even users with a given role can be further restricted to seeing and acting on only the subset of objects relevant to their responsibilities. Privilege-based access control in VCF Operations prevents users without appropriate privileges from viewing collected data for managed objects. Access groups define granular actions such as the ability to view, configure, or manage dashboards and objects.

VCF Operations orchestrator separates access rights into user roles and group permissions, allowing administrators to set permissions that control access to features and content. This layered approach means that access to operational data, automation workflows, and management interfaces is governed by explicit role assignments rather than implicit trust.

VCF Automation extends these controls at the project and organization level. Projects support role-based access control with distinct roles, including administrators, members, viewers, and supervisors. Access to entity types can be granted only to specific users and organizations. Authorization restrictions in VCF Automation control who can design and run workflows and automation tasks, and organization users can use only those rights from their roles that are published to their organizations. Rights bundles organize granular permissions by category, including Access Control, Administration, Compute, Content Hubs, Extensions, and Infrastructure. System administrators use rights bundles and global roles to manage the rights and roles available to each organization.

VMware vCenter provides authorization management that allows and restricts access to specific server objects based on the permissions associated with each object. The No Access role explicitly denies access to the user or group assigned this role, preventing the user from seeing any objects. Privileges are fine-grained access controls that can be grouped into roles and mapped to users or groups.

For Kubernetes workloads running on the VCF platform through VMware Kubernetes Service (VKS) and vSphere Supervisor, access control extends across multiple resource types. vSphere Namespaces provide three permission roles (Owner, Edit, View) that map to Kubernetes ClusterRoles through RoleBindings, controlling who can provision, operate, or read workload resources. Namespace consumers with these roles can provision VKS clusters and vSphere Pods using kubectl, while vSphere Administrator and Supervisor Administrator roles have broader access to cluster and namespace inventory resources.

Container image access within the Kubernetes consumption layer is restricted through private registry authentication. Private registries require credentials before a client can discover or pull images, so only service accounts or users with valid pull secrets can retrieve container images. Harbor Registry, available as a standard package on VKS clusters, extends this with artifact-level RBAC policies that control which users and teams may read, write, or administer specific repositories. Harbor also scans images for vulnerabilities and signs images as trusted, providing provenance controls alongside access controls.

The ImagePolicyWebhook admission controller allows administrators to enforce additional image access controls through webhooks, restricting which images workloads may use at deployment time. The VCF CLI supports uploading plugins to private registries that require authentication, supporting access control for tools and extensions in internet-restricted environments.

Persistent storage access for Kubernetes workloads is managed through the PersistentVolume and PersistentVolumeClaim model. RBAC governs which users and service accounts may create, modify, or bind PersistentVolumeClaims within a given namespace, separating storage provisioning authority from storage consumption. PersistentVolumeClaim access modes, such as ReadWriteOnce, further restrict volume attachment to a single node. This structure restricts which workloads can access persistent data at the Kubernetes API layer.

Secrets and sensitive configuration data are controlled through Kubernetes RBAC applied to Secret objects. Fine-grained rules specify which service accounts and users may read or modify individual Secrets within a namespace. The Secret Store Service, deployable as a Supervisor Service, enforces RBAC for administrators, DevOps engineers, and application tenants managing and distributing sensitive data across namespaces. The etcd data store, which holds all cluster state including Secrets, should be configured to limit access and not be publicly exposed; communication between the API server and etcd uses mutual TLS so only the API server component can interact directly with the backing data store.

Argo CD, available as a VCF Services component, supports local account authentication with global RBAC policies that define role-based access control through policy rules and group mappings. This restricts who can access continuous delivery workflows and application deployment resources within the consumption layer. Dynamic Resource Allocation APIs in Kubernetes should be controlled using RBAC to restrict access based on user persona, and the Kubernetes Node authorizer uses fine-grained selector-based authorization to control which resources individual nodes are permitted to access.

Content libraries support security policies and password-based access controls to restrict who can access published library content. When a content library is published, administrators can configure a password for authentication. VCF Automation content libraries also support password protection for subscribed external content libraries. In the Supervisor environment, content library subscriptions enforce read-only access to subscribed libraries, where only the administrator of the published library can add, modify, and remove contents. Local content libraries support Security Policy application and can be used in internet-restricted environments. The vSphere privilege model provides named privileges for granular content library access control: ContentLibrary.DownloadSession governs whether a user can download files from a content library, and ContentLibrary.ReadStorage governs read access to library storage.

For audit and verification purposes, VCF Operations provides a User Permissions Audit capability that displays the permissions assigned to users along with their associated access groups and access privileges. This allows administrators and auditors to review who has access to what resources within the platform.

VCF addresses the digital media access portion of this control through these layered RBAC, scope-based, and privilege-based controls spanning the platform management layer, the Kubernetes workload layer, and the VCF Services consumption layer. Non-digital media handling, such as restricting access to removable storage devices, backup tapes, or printed materials, requires organizational policies, physical security measures, and complementary tools outside the platform's scope.

VMware Private AI Services (PAIS) controls access to its AI-specific digital media through several mechanisms that work together to restrict access to authorized users.

PAIS access is governed by OIDC group-based authorization. When activating PAIS in an organization namespace, administrators configure the OIDC integration (issuer URL, client ID, scopes including openid and groups) and specify allowed groups in the `authorizedGroups` field when using the `kubectl` command, or the `oidc-authorized-groups` setting when using the VCF Automation UI. Only user accounts that are members of the specified groups (for example, `group-for-pais-access-01` or `group-for-pais-access-02`) can access the service. Activation requires coordination with the OIDC provider administrator and HTTPS-based communication with the OIDC endpoint. The Extra Audiences setting extends OAuth 2.0 token validation to additional clients when the OIDC provider requires it.

The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data that is used to train and tune models. Harbor registries in another VI workload domain or VCF instance can be replicated to the Supervisor where AI workloads run, keeping NVIDIA NGC catalog images within the customer's own registry boundary. In disconnected (air-gapped) environments, the resource mirroring utility from Broadcom KB 388470 uploads required container images to a project in a local Harbor registry, with files staged from a bastion host to an administrator host where VI administrators interact with the environment. Tooling authenticates to the private Harbor registry using `oras login` with username and password credentials, and `oras push` uploads artifacts with a specified project namespace, resource name, version tag, and media type.

Model endpoints for completion and embedding workloads authenticate to private registries through the `harbor-pull-secret-readonly` pull secret, restricting model image retrieval to credentialed clients. PAIS supports CA trust bundle management so that connections to external registries and content management systems can be established using administrator-supplied certificate files.

Access to AI catalog items in VCF Automation, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, is granted by organization administrators to specific users. Custom forms in PAIS blueprints can be modified to control user inputs at request time. Deep Learning VMs accept SSH access through the `public-keys` OVF property, which populates the default user's `authorized\_keys` file with administrator-supplied SSH public key values.

Knowledge Base data sources require credentials scoped to the service's needs. Google Drive folders used as Knowledge Base data sources must be shared with the PAIS service account using view-only permissions. Microsoft SharePoint On-Premises data sources require username and password authentication. Personal access tokens are generated from PAIS user account settings for programmatic access to Knowledge Bases and data sources.

VMware vDefend (Contributes)

VMware vDefend operates at the network layer and does not directly control access to physical or non-digital media. However, vDefend's Distributed Firewall and microsegmentation capabilities restrict network-level access to systems and storage resources that host digital data, limiting which workloads and users can reach sensitive data stores.

The Identity Firewall (IDFW) feature extends this capability by enabling firewall rules tied to Active Directory user and group identity. Rather than enforcing policy solely on the basis of workload IP address, IDFW allows administrators to create rules that allow or deny network traffic based on who is logged in. Active Directory security groups can be used as source criteria in IDFW rules, and those rules can target specific services, destination resources, and context profiles. Administrators can enforce access control in Remote Desktop Session Host (RDSH) environments as well, where multiple users share a single IP address, by assigning users to security groups and using those groups as rule sources. IDFW maps users to IP addresses at runtime to enable identity-based filtering without requiring changes to client applications.

The Gateway Firewall provides supplementary north-south and inter-project isolation. Administrators can deny all inter-project communication except for specified infrastructure protocols, further restricting which workloads can reach storage resources across project boundaries.

Controls over removable media, physical media, and non-digital storage remain outside vDefend's scope and must be addressed through endpoint security and physical security controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) restricts access to replicated data and disaster recovery operations through role-based access controls built on the VMware vCenter permissions model. The Protection and Recovery Administrator role governs who can create, modify, and execute recovery plans, and administrators can add new roles to restrict or grant access to specific users. vSphere Replication provides dedicated roles including the VRM Administrator, VRM Replication, and VRM Datastore Mapper roles, each scoped to specific DR functions. The VRM Administrator role can be cloned and modified to create custom roles that limit what replication infrastructure changes a user can make, such as allowing replication management while preventing registration of additional replication servers. Additional predefined roles include the VRM Replication Viewer role, which allows users to view replication configurations and sites without the ability to make

modifications, and the VRM Virtual Machine Replication User role, which scopes access to configuring replication between specific sites.

Access to shared recovery sites requires explicit permissions, and protection configuration requires privileges on both the primary and secondary vCenter instances. These controls restrict who can view, configure, and manage replicated copies of virtual machine data at recovery sites. Site Recovery Manager (SRM) applies role-based permissions at an object level, governing access to protection groups, recovery plans, virtual machines, and datastores independently. The SRM Protection Groups Administrator role can be assigned to specific users or groups to allow management of protection groups and protection configuration on virtual machines without broader administrative access.

Live Cyber Recovery (LCR) implements its own role-based access model at the organization level, where organization owners invite users and assign roles that define what operations each user can perform. Access to the LCR service requires an invitation with the appropriate role assignment. Guest file recovery operations are subject to additional access controls: when Management access lists are configured, file downloads are restricted to IP addresses listed in that access list. Specific roles including Recovery Admin and Recovery Tester govern access to security analysis features such as ransomware recovery tooling.

Non-digital media handling, including physical storage media management, printed materials, and device disposal, is outside PNR's scope and requires organizational policies and procedures.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L2-3.8.3

> Sanitize or destroy system media containing CUI before disposal or release for reuse.

SCF Controls: AST-01, AST-09, DCH-01, DCH-08, DCH-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to IT Asset Management programs through built-in inventory, discovery, and integration capabilities that provide the technical foundation for asset tracking and governance.

VCF Operations groups discovered objects logically and provides detailed inventory lists across the environment, covering compute, storage, and networking resources. The inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group.

The Service Discovery adapter automatically discovers applications, services, and their associated metrics (CPU, memory) running on managed infrastructure. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be exported in CSV format for use in external asset tracking systems.

For organizations using ServiceNow, VCF provides two integration paths. The Management Pack for ServiceNow in VCF Operations populates the ServiceNow CMDB with discovered resources through the ServiceNow Table API and CMDB Meta API, providing CMDB visibility within VCF Operations. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation provides a structured data source that captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

VCF Automation adds governance through its project model, which controls who can deploy what resources and where those resources are deployed. Projects link users, catalog items, and IaaS resources together. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources.

Tags within VCF Automation express capabilities and constraints that define deployments. Cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

The broader ITAM program responsibilities of establishing asset governance policies, defining ownership lifecycles, and maintaining organizational accountability remain outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security

zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports

additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control MP.L2-3.8.4

> Mark media with necessary CUI markings and distribution limitations.27

SCF Controls: DCH-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L2-3.8.5

> Control access to media containing CUI and maintain accountability for media during transport outside of controlled areas.

SCF Controls: DCH-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to media transportation security through encryption capabilities that protect data on storage media, data in transit across the network, and data during workload migration. Organizational policies for physical media handling, chain-of-custody tracking, and transport logging remain outside the platform's scope.

VCF provides multiple layers of encryption that protect data if storage media is physically removed, transported, or returned to a vendor. vSAN data-at-rest encryption protects data on storage devices so that if a disk is removed from the cluster, the data on it remains unreadable without the encryption keys. All vSAN traffic transmitted across hosts is also encrypted when data-at-rest encryption is enabled. VM Encryption provides equivalent protection across all datastore types by encrypting virtual machine files, virtual disk files, and core dump files before data reaches the storage layer. Storage profiles can specify encryption requirements so that encryption is applied consistently through policy. These capabilities help protect physical storage media from exposing readable data when devices leave organizational control.

When virtual machines are migrated between hosts or sites, encrypted vSphere vMotion protects the confidentiality, integrity, and authenticity of the transferred data. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (the default, which uses encrypted vMotion if supported), or Required. Each migration session uses one-time keys, which limits the usefulness of captured traffic for replay or later decryption. Cross-vCenter vMotion is supported when using shared key providers. For HCX migration operations, the vMotion encryption mode is changed to Opportunistic during migration initialization and set back to Required after completion.

vSAN data-in-transit (DIT) encryption protects storage replication traffic across the network. When enabled, vSAN encrypts all data and metadata traffic between ESX hosts in the cluster. DIT encryption can be configured through cluster parameters with a selectable rekey interval. For fault tolerance traffic, vSAN also supports data-in-transit encryption.

VCF's networking layer adds transport-level protections through distributed switch security controls. For environments with stringent transport security requirements, VCF supports multiple distributed switch models that provide physical air-gapped separation of network traffic. The Storage Separation Distributed Switch Model and the Workload Separation Distributed Switch Model each allow administrators to isolate traffic flows so that sensitive data in transit remains on dedicated network segments.

For data exchanged between VCF components and management services, Transport Layer Security (TLS) protects communications. The VCF Streaming Databus supports HTTPS as a transport protocol for on-premises environments, providing encrypted channels for operational data flows.

VCF Operations applies digital rights management to packages, controlling how the receiving server can use the contents of a package. This restricts what can be done with transported digital content after delivery, adding a layer of control beyond transport encryption alone.

For workloads that must be migrated or extended across sites, VCF Operations HCX builds a secure, optimized transport fabric between paired sites. Network extension and migration operations use underlay networks for transporting data from source to destination. Encrypted bulk migration requires that the Key Management Server (KMS) or vSphere Native Key Provider (NKP) used to encrypt the source VM is present on the target site.

vSAN includes disk wipe capabilities that support media sanitization before devices leave organizational control. When enabling vSAN encryption, administrators can choose to wipe existing data from storage devices as they are encrypted.

Administrators should combine these platform capabilities with organizational media handling policies that address physical media (tapes, portable drives, printed materials), chain-of-custody procedures, approved transport methods, and transport logging requirements. VCF secures digital data at rest and in transit within its managed infrastructure, but the broader media

transportation control requires governance processes that extend beyond what the infrastructure platform provides on its own.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L2-3.8.6

> Implement cryptographic mechanisms to protect the confidentiality of CUI stored on digital media during transport unless otherwise protected by alternative physical safeguards.

SCF Controls: CRY-01.1, CRY-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple cryptographic mechanisms for protecting data at rest across its infrastructure stack, primarily through vSAN data-at-rest encryption and vSphere Virtual Machine Encryption.

vSAN data-at-rest encryption is the primary mechanism for protecting stored data within VCF. When enabled on a vSAN cluster, vSAN encrypts everything in the vSAN datastore, including all files, virtual machines, and their corresponding data. This protection extends to scenarios where a physical storage device is removed from the cluster, as the encrypted data remains unreadable without the proper keys. vSAN supports both Original Storage Architecture (OSA) and Express Storage Architecture (ESA) deployments, with encryption behavior varying by architecture. For OSA, data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, and each disk has a different randomly generated Data Encryption Key. For ESA in hyperconverged infrastructure mode, data is encrypted at the VM host before network transmission, and all disks in the cluster use the same DEK to encrypt object data. In OSA, encryption occurs after other data processing operations such as deduplication and compression, preserving storage efficiency. vSAN encryption is the recommended approach for securing data on vSAN datastores because it is designed to be compatible with vSAN deduplication and compression, whereas virtual machine encryption causes these storage efficiency features to become less effective.

vSphere Virtual Machine Encryption provides an alternative or complementary data-at-rest encryption layer that works across all datastore types, including vSAN, iSCSI, NFS, and Fibre Channel. VM Encryption occurs before data reaches the storage layer, protecting virtual machine files and disks regardless of the underlying storage technology. This can be applied on a per-VM basis and operates independently of the underlying storage layer, making it applicable to environments where granular, VM-level encryption control is required. Most virtual machine files, in particular guest data not stored in the VMDK file, are encrypted. When combined with storage-level encryption, administrators should evaluate the performance impact of multiple encryption layers on latency and throughput, as well as the potential loss of storage efficiency features like deduplication and compression.

For organizations consuming VCF through the VCF Automation layer, VCF Encryption Management extends these VM and disk encryption capabilities to the namespace level. This service allows organization administrators to use encryption keys from their own third-party key providers to encrypt VMs and disks within a VCF Automation namespace, and also supports encrypting VMs with a Virtual Trusted Platform Module (vTPM). Provider administrators must register a default standard key provider in VMware vCenter before organization administrators can configure namespace-level encryption; the vSphere Native Key Provider cannot be used in this role, and key providers must be listed in the VMware Compatibility Guide for Key Management Servers. Organization administrators configure encryption by setting up a key provider and creating a namespace encryption class. Configuration of key providers requires either the Encryption Management Admin role or a custom role that grants the right to configure key providers.

Both encryption mechanisms require a key management infrastructure. VCF supports integration with KMIP 1.1-compatible external Key Management Servers (KMS) or the built-in vSphere Native Key Provider (NKP). VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts. When using a Standard Key Provider, the KMS sends keys to vCenter upon request, which are used as the Key Encryption Key (KEK) and are AES-256 keys. Standard Key Providers support key wrapping, creating a three-tier key hierarchy: Data Encryption Keys (DEK) encrypt object data, Key Encryption Keys (KEK) protect the DEK, and a wrapping key stored in the KMS protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. When using an external KMS, the recommendation is to deploy highly available KMS clusters to distribute the keys that encrypt the vSAN datastore, avoiding a single point of failure in the encryption key chain. The vSphere Native Key Provider offers a simpler deployment model for

environments that do not require an external KMS. Native Key Provider equips each participating host with decryption keys so hosts can operate independently of network-accessible key servers.

vSAN supports key rotation for both Key Encryption Keys (KEK) and Data Encryption Keys (DEK), with the capability to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. Key wrapping supports automatic key rotation with configurable intervals. This allows organizations to meet key lifecycle management requirements without disrupting operations. Encryption can also be enforced through vSAN storage policies, where the data-at-rest encryption option can be specified as a policy attribute, allowing administrators to define which datastores require encryption when provisioning virtual machines.

VCF supports virtual Trusted Platform Module (vTPM) 2.0 for virtual machines, enabling in-guest encryption capabilities such as Windows BitLocker and Linux disk encryption. Virtual machines can include various forms of encryption: VMs using a vTPM device, VMs with disks encrypted, and VMs with encryption enabled without disks encrypted. These guest-level encryption features work independently of or in combination with VMware's infrastructure-level encryption, supporting defense-in-depth strategies.

ESX hosts store their configuration data in encrypted form. When the host has a physical TPM 2.0 enabled, the configuration encryption key is stored in the TPM. Core dumps on an ESX host that has encryption mode enabled are always encrypted. ESX also supports key persistence as a cache for encryption keys in environments where a KMS may be unavailable. With key persistence enabled, ESX hosts can persist the encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence requires that the ESX host has a TPM, and can be enabled using the `esxcli system security keypersistence enable` command.

Memory Tiering encryption protects tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance. During vMotion, tiered memory pages are decrypted and transmitted over the encrypted vMotion channel, with new keys generated at the destination.

For access control over cryptographic operations, VCF provides the No Cryptography Administrator role, which supports all Administrator privileges except for the Cryptographic Operations privileges. This allows standard VM and infrastructure management while restricting unauthorized encryption changes. The No Cryptography Administrator role can be cloned to create custom roles with only specific Cryptographic Operations privileges, providing fine-grained control over encryption-related tasks.

The cryptographic modules used across VCF components are validated against industry-standard best practices. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program (CMVP). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 as a validated cryptographic module. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic algorithms including AES, ECDSA, HMAC, RSA, and SHA2 variants, as well as VMware OpenSSL FIPS Object Module versions 3.0 and 2.0.20-vmw, which collectively support AES, CKG, DRBG, DSA, ECDSA, HMAC, KAS-SSC, RSA, SHS, Triple-DES, SHA-3, and additional key derivation functions. ESX hosts use FIPS 140-2 validated cryptographic modules that implement security functions as a combination of hardware, software, and firmware. vSAN encryption uses AES-NI CPU offloading for efficient processing.

For workloads deployed through VMware Kubernetes Service (VKS) on vSphere Supervisor, the Kubernetes control plane supports encryption at rest for API objects stored in etcd. The kube-apiserver implements this through the EncryptionConfiguration API, specified via the `--encryption-provider-config` argument. When configured, Secrets, ConfigMaps, and other designated resource types are encrypted on write to etcd. The kube-apiserver supports an external KMS provider as well as local encryption keys; when using local keys, the aescbc provider encrypts data using Base64-encoded secret keys specified in the EncryptionConfiguration resource. Using an external KMS is the recommended approach for production environments, as it allows keys to be managed and rotated independently of the cluster configuration.

Encryption at rest for the Kubernetes control plane is not enabled by default; the default identity provider stores data in plaintext, and administrators must explicitly configure EncryptionConfiguration to activate it. After enabling EncryptionConfiguration, existing objects remain unencrypted until they are read and re-written. The Kubernetes etcd encryption mechanism does not extend to data stored in filesystems mounted into containers; for container workload data on persistent volumes, encryption depends on the underlying storage layer. vSAN File Service volumes used with vSphere Supervisor are mounted without encryption by default, so workloads relying on shared file volumes must address encryption at the storage layer or within the application. Kubernetes Secrets encrypted at rest are also protected from disclosure if an attacker gains access to etcd backup data.

Classifying which data requires encryption, selecting between vSAN encryption, VM encryption, or both for specific workload categories, choosing the Key Provider model, and operating the key lifecycle (rotation, revocation, archive, destruction) are organizational data-policy decisions.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) preserves and integrates with the data-at-rest encryption capabilities of the underlying VCF platform, so that encrypted virtual machines remain protected through replication and recovery operations. The encryption mechanisms themselves, including VM Encryption, vSphere Native Key Provider, external key management servers, and storage policies, are VCF platform capabilities; PNR's role is to maintain encryption continuity through the disaster recovery lifecycle.

vSphere Replication within PNR supports replication of encrypted virtual machines when vSphere Native Key Provider (NKP) or a common external Key Management Server (KMS) is configured at both sites. When NKP is used, it must be configured manually on both the local and remote sites, and the NKP ID assigned to the encrypted VM on the local site must match the NKP ID on the remote site. NKP enables encryption without requiring a separately deployed external KMS; vSphere Enterprise+ licensing is required for NKP. Replica disks must be located on datastores accessible through at least one host in a VMware vCenter cluster. A VM Storage Policy with VM Encryption enabled must be applied to target disks to enforce encryption continuity during replication configuration. Replication configuration using seed disks together with a vSAN target datastore and a VM Encryption Policy storage policy is not a supported combination.

Not all PNR replication methods support encrypted virtual machines. vSAN Snapshots and Replication, an alternative replication method within PNR, does not support replication of encrypted VMs. Organizations that require encrypted VM replication should configure protection groups using vSphere Replication rather than vSAN Snapshots and Replication.

vSphere Replication also supports optional network encryption of replication traffic, which can be enabled during replication configuration to protect data in transit between source and target sites.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides cryptographic mechanisms across data-in-transit and configuration-data-at-rest dimensions that address the intent of this control within the application delivery layer.

For data in transit, Avi performs TLS termination and re-encryption on application traffic. SSL/TLS profiles, configured under Templates > Security > SSL/TLS Profile, define the accepted protocol versions and cipher suites applied to each virtual service. Administrators can restrict accepted protocol versions and prioritize ciphers in a specific order, enabling consistent enforcement of strong cryptographic standards across all application endpoints managed by Avi. EC cryptography with Perfect Forward Secrecy is available. Avi's PKI Profile contains the list of trusted certificate authorities permitted to sign client certificates and can support Zero Trust security models between servers and clients. In VCF deployments, PKI Profiles are configurable as custom resources through the IaaS Service Console. The `kex_algorithm_exclude` field in Controller Settings allows administrators to exclude specific key exchange algorithms to restrict weaker cryptographic methods from SSH management connections to the Controller.

For sensitive configuration data at rest, the Avi Controller encrypts all sensitive fields, including passwords and private keys, before storing them in its internal database using AES-256-CBC encryption with a 16-byte random initialization vector and a

32-byte random key, so credentials in the Controller's configuration store are protected if the underlying database files are accessed directly. Controller backups also encrypt keys when a passphrase is included in the backup process.

Avi supports a FIPS 140-3 mode, which restricts all cryptographic operations on the Controller and Service Engines to algorithms validated under that standard. Starting with Avi Load Balancer version 31.2.1, this mode uses the OpenSSL FIPS Provider version 3.1.2, validated at FIPS 140-3 Security Level 1 and awarded CMVP Certificate #4985. When FIPS mode is activated, non-compliant algorithms are rejected. Avi also supports integration with Thales Luna hardware security modules, providing externalized key management aligned with FIPS 140-3 requirements.

For disk-level and VM-level data-at-rest encryption of the Avi Controller and Service Engine VMs themselves, organizations rely on VCF platform capabilities, including VM Encryption and vSAN Encryption with a configured key provider. The Avi-native cryptographic capabilities described above apply to application-layer traffic and internal configuration storage rather than the underlying infrastructure storage layer.

Not applicable for this control: VMware vDefend, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L2-3.8.7

> Control the use of removable media on system components.

SCF Controls: DCH-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several mechanisms that contribute to restricting the use of digital media on systems and system components within the virtualized environment, spanning virtual machine device controls, centralized media management, and policy-based enforcement.

At the virtual machine level, vSphere provides granular control over which physical devices can be attached. USB controllers, optical drives, PCI passthrough devices, and other hardware can be added to or removed from a VM's configuration, and physical device access can be revoked by removing the associated virtual device. Virtual devices use a backing field that specifies access to a particular physical device, and for USB connectivity the VM must have a compatible virtual controller configured. The `VirtualDeviceConnectInfo` data object controls connection behavior for virtual devices, supporting `allowGuestControl`, `connected`, and `startConnected` properties to manage guest access to device connectivity, current connection state, and connection at virtual machine startup. Administrators can restrict whether a guest operating system can control device connection state, whether devices auto-connect at startup, and whether connection is enforced as a requirement. VCF Operations monitors these settings through VM properties including `isolation.device.connectable.disable` (which restricts unauthorized removal and connection of devices) and `isolation.device.edit.disable` (which restricts unauthorized modification of device configurations). These isolation settings can be checked for compliance across the environment through both VMware vCenter and VCF Operations property definitions.

VCF's Content Library is the primary mechanism for managing digital media such as ISO images, OVA packages, VM templates, and other files used across the software-defined data center. Content libraries can be created, shared, and subscribed to on the same VMware vCenter instance or on remote instances, enabling centralized control over what media is available for deployment. By channeling media distribution through content libraries, administrators maintain consistency and standardization in the types of media deployed across the environment. Content Library storage is configured on Virtual Machine File System (VMFS) or Network File System (NFS) datastores, giving administrators control over where media is stored and who has access to the underlying storage. The `ContentLibrary.DownloadSession` privilege controls who can download files from content libraries, providing granular access control over which users can extract ISO images and other media items from the library.

VCF Automation extends media restriction capabilities through several controls. The platform supports enabling blocking of content library items upload, which restricts users from introducing unauthorized media into the environment. Provider content libraries in VCF Automation are read-only to the users of organizations, limiting the ability to modify or add media at the provider level. VCF Automation policies can prohibit virtual machines from being provisioned in specific namespaces, limiting where and how media-based deployments occur. Deployment limit policies with hard enforcement can strictly restrict resource allocation, providing another layer of control over media consumption.

VCF Operations contributes additional controls through its Digital Rights Management (DRM) capability, which controls how exported content can be viewed, edited, and redistributed. Role-based access control across vCenter, VMware ESX, and VCF Operations restricts which administrators can modify virtual machine configurations, including device assignments and media management operations. Only users with the appropriate privileges can add, remove, or reconfigure virtual devices on a VM. The `VirtualMachine.Interact.SetCDMedia` privilege specifically governs configuration of virtual DVD and CD-ROM devices, allowing administrators to assign this capability selectively and restrict optical media attachment to authorized users only.

The vSphere Automation REST API includes a File service that manages requests for changing library items by uploading files, providing programmatic control over media ingestion that can be integrated with automated approval workflows.

These capabilities provide the technical foundation for restricting digital media use. Restricting physical media at the host hardware level (BIOS-level USB disablement, physical port controls) falls outside VCF's scope and requires complementary

physical security measures. Organizational policies defining which media types are permitted, approval workflows for introducing new media, and periodic reviews of media libraries must also be established separately.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) restricts the use of removable media types in protection and recovery operations. The `replication.autoExcludeMediaDevices` parameter, enabled by default, automatically excludes CD/DVD and floppy media devices from protection when virtual machines are added to protection groups. This keeps removable media content out of replicated payloads, reducing the risk of transporting uncontrolled media across site boundaries during recovery.

Access to protection configuration is restricted through role-based access controls, requiring specific permissions to modify which virtual machines and their associated devices are included in protection groups. Recovery of replicated virtual machines is restricted to the PNR user interface, narrowing the surface where protected workloads can be brought online.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L2-3.8.8

> Prohibit the use of portable storage devices when such devices have no identifiable owner.

SCF Controls: DCH-10.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides hypervisor-level and virtual machine-level controls that restrict the use of removable and portable storage devices within the virtualized environment. While VCF does not maintain a registry of device ownership or enforce owner-identification policies on its own, it offers layered technical mechanisms that administrators can use to prohibit or limit portable storage device access across managed infrastructure.

In a VCF environment, physical USB and storage devices are not directly accessible to workloads unless an administrator explicitly configures passthrough. USB connectivity requires a compatible virtual controller to be configured on the VM, and host-attached USB devices must be specifically enumerated and assigned using the `esxcli hardware usb passthrough device list` command or the vSphere API before a VM can access them. This command prints available devices including Vendor ID and Product ID, which programs use to configure backing object types. Administrators can revoke physical device access by removing the associated virtual device from a VM's configuration, or by removing USB controllers from VM hardware configurations entirely. This default-deny posture means no USB or removable storage device is presented to a workload without deliberate administrative action.

VCF includes two VM-level isolation settings that restrict unauthorized device interaction. The `isolation.device.connectable.disable` setting restricts unauthorized removal and connection of devices to virtual machines. The `isolation.device.edit.disable` setting restricts the ability to connect or disconnect devices from a running VM, preventing users operating within the guest from attaching unauthorized USB or removable storage devices. Administrators can enforce these settings through VM advanced configuration options and through the Security Configuration Guide hardening recommendations. VCF Operations can monitor these settings across the environment through its property definitions for both settings.

The `VirtualDeviceConnectInfo` API provides granular control over device connection state. It supports `allowGuestControl`, `connected`, and `startConnected` properties that govern whether guest operating systems can control device connections, the current connection state, and whether devices connect automatically at VM startup. These properties let administrators enforce policies where guest-level users cannot independently attach or enable storage devices.

Access to device configuration settings is governed by VCF's role-based access control model. VCF Operations implements role-based access control where users can only perform the actions that their permissions allow, and vCenter's `AuthorizationManager` controls access to server objects based on associated permissions. Administrators can restrict the ability to modify VM device settings, add hardware, or change USB passthrough configurations to a limited set of authorized personnel. This layered permission model helps restrict who can enable or disable portable storage device access on virtual infrastructure.

These controls address the technical enforcement aspect of portable storage device restrictions within the VCF-managed environment. However, identifying device ownership, maintaining an inventory of authorized portable storage devices, and establishing organizational policies that prohibit the use of unowned devices require processes and tools outside VCF's scope. Asset management systems, endpoint device management solutions, and organizational policies governing removable media usage are needed to complement VCF's technical restrictions.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control MP.L2-3.8.9

> Protect the confidentiality of backup CUI at storage locations.

SCF Controls: BCD-11, BCD-11.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds.

VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a

separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VMware Live Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages,

including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30

minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage

target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control PE.L1-b.1.ix

> Escort visitors and monitor visitor activity; maintain audit logs of physical access; and control and manage physical access devices

SCF Controls: PES-03, PES-06, PES-06.1, PES-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L1-b.1.viii

> Limit physical access to organizational information systems, equipment, and the respective operating environments to authorized individuals

SCF Controls: PES-02, PES-02.1, PES-03.4, PES-04, PES-12, PES-12.1, PES-12.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L2-3.10.1

> Limit physical access to organizational systems, equipment, and the respective operating environments to authorized individuals.

SCF Controls: PES-02, PES-02.1, PES-03.4, PES-12, PES-12.1, PES-12.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L2-3.10.2

> Protect and monitor the physical facility and support infrastructure for organizational systems.

SCF Controls: PES-01, PES-05, PES-05.1, PES-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L2-3.10.3

> Escort visitors and monitor visitor activity.

SCF Controls: PES-03, PES-06, PES-06.1, PES-06.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L2-3.10.4

> Maintain audit logs of physical access. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

----- CHAPTER THREE PAGE 33 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: PES-03.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L2-3.10.5

> Control and manage physical access devices.

SCF Controls: PES-03, PES-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PE.L2-3.10.6

> Enforce safeguarding measures for CUI at alternate work sites.

SCF Controls: DCH-01.2, NET-14.5, PES-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PS.L2-3.9.1

> Screen individuals prior to authorizing access to organizational systems containing CUI.

SCF Controls: HRS-04, HRS-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PS.L2-3.9.2

> Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers.

SCF Controls: HRS-01.1, HRS-08, HRS-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides role-based access control (RBAC) capabilities across its component products that allow administrators to adjust logical access authorizations when personnel are reassigned or transferred. These capabilities support timely access modifications but require integration with organizational HR and identity lifecycle processes to fully satisfy the control.

VCF's authorization model is built around verifying what objects principals have access to, with a three-level authorization structure in VMware vCenter that maps to local roles and VCF SSO groups depending on how the user authenticated. For example, the vCenter operator authorization level maps to the SystemConfiguration.Administrators VCF SSO group and operator local role, while administrator authorization maps to its corresponding VCF SSO group and admin local role. On vCenter systems, privileges can only be assigned to authenticated users or groups of authenticated users, and users and groups must be defined in the identity source that VCF SSO uses to authenticate. In vCenter, when a user belongs to a group with a role that grants access to resources, an administrator can assign a more restrictive role directly to the user to override the group-level access for that individual, allowing immediate access restriction for a transferred user without waiting for directory group changes to propagate.

When VCF is integrated with an external identity provider (LDAP or SAML), changes to a user's group membership or status in the directory are reflected in VCF permissions at the next authentication event. VCF SSO supports configuration of identity providers using Generic SAML 2.0 and AD/LDAP. For SAML-based identity providers, users are assigned roles named in the SAML attribute defined in the organization's federation settings. For LDAP-based authentication in NSX, once a user is successfully authenticated, they are assigned roles corresponding to the groups they belong to. This means that when HR or IT updates a transferred employee's directory group memberships, the corresponding VCF access changes follow without requiring manual updates in each VCF component individually.

Within VCF Automation, organization administrators can import users from configured identity providers and assign one or more organization-level and project-level roles to control their permissions. Roles assigned to users that have been imported into VCF Automation can be edited at any time through the Access Control page, which provides a centralized interface for managing role assignments for both individual users and groups. When personnel transfer between teams or assume new responsibilities, administrators can modify their role assignments to reflect new access requirements without needing to remove and re-create accounts. Organization administrators can also distribute infrastructure and configure access management to groups, allowing group-level access changes during transfers.

VCF Operations provides similar RBAC capabilities through its Roles tab, where permissions can be selected or deselected when adding or editing a role. VCF Operations supports importing user accounts and groups from VCF SSO and other authorization sources, and assigning role-based access control permissions to those imported identities. The ability to manage group membership centrally through VCF SSO means that access changes during personnel transfers can be handled at the group level, adjusting what resources a user can reach by moving them between groups rather than reconfiguring individual permissions.

For service accounts, VCF Automation allows system administrators to manage service account attributes, revoke previously granted access, and delete service accounts. This is relevant to personnel transfers because service accounts associated with a departing team member's responsibilities may need to be reassigned or revoked. System administrators can also directly change account attributes for standard user accounts.

Ownership transfer capabilities help prevent orphaned resources when personnel change roles. VCF Operations allows administrators to assign a new owner for dashboards, report schedules, and credentials by selecting a target user from the Transfer dialog box. Administrators in VCF Operations become the new owner of dashboards, report schedules, and

credentials that are orphaned or unassigned, and can transfer ownership to new users or retain ownership themselves. In VCF Automation, users can share or transfer ownership of defined entities to other users within the same organization. The owner of a defined entity or a user with the Administrator Full Control right can transfer ownership by updating the entity model and changing the owner field with the ID of the new owner. If a deployment is moved to a project where the owner is not a member and loses access, administrators can add the owner to the target project, move the deployment, or use the Change Owner action.

Users with the Enterprise Administrator role in NSX can modify or delete objects owned by principal identities, providing an administrative override for access adjustments when standard role reassignment is insufficient. Users without the Enterprise Administrator role cannot modify or delete protected objects owned by principal identities, but can modify or delete unprotected objects. This tiered access model is useful during personnel transitions where objects created by the departing user need to be reassigned to their successor.

VCF also provides programmatic interfaces for access management. The vSphere Web Services API includes AuthorizationManager with methods such as RemoveAuthorizationRole for managing roles programmatically, enabling automation of access adjustments during personnel transfers.

VCF does not include built-in workflow automation for triggering access changes based on HR events such as reassignment or transfer notifications. The organizational processes for detecting personnel changes, initiating the corresponding access modifications within VCF's management interfaces, and verifying that access has been adjusted in a timely manner all fall outside VCF's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PS.L3-3.9.2e

> Adverse Information

SCF Controls: HRS-02.1, HRS-07, HRS-07.1, HRS-07.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides the technical access control mechanisms that an organization can use to proactively restrict logical access when an individual is under investigation for personnel sanctions. These capabilities do not replace the organizational processes required to identify individuals under investigation and initiate access restrictions, but they supply the platform-level controls needed to execute those restrictions quickly and precisely across all VCF components.

VCF SSO provides centralized authentication across all platform components. When an identity source is integrated, such as Active Directory via AD/LDAP or another supported directory service, disabling or suspending a user account in the directory is reflected across VCF. This centralized approach means a single administrative action at the identity source can revoke access to VMware vCenter, VCF Operations, NSX Manager, and other services simultaneously. Supported external identity providers include PingFederate, which supports the use of scopes to define and constrain access privileges for federated users.

vCenter's AuthorizationManager governs access to server objects based on permissions associated with each object. When an administrator needs to restrict an individual's access, the No Access role can be applied to explicitly deny that user access, which hides all objects from the user entirely. This role assignment can be applied at any level of the vCenter inventory hierarchy, allowing administrators to revoke access to specific resources or to the entire environment in a single operation. Administrators can also remove or modify role assignments on specific inventory objects, enabling targeted restriction of access to sensitive resources without fully disabling the account. When a user belongs to a group with broader access, assigning a more restrictive role directly to the user takes precedence over the group role assignment, enabling individual access restriction without changing group memberships that might affect other users. vCenter role-based access control supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects.

Within VCF Automation, organization administrators can disable users and user groups to deactivate their access to the organization and prevent login. Disabling a user does not remove them from the organization, so access can be reactivated later if the investigation concludes favorably. Administrators can also view and revoke individual user access tokens through the Administration access control settings, providing immediate session termination beyond simply preventing new logins. An access token can be revoked at any time. VCF Automation enforces access restrictions at the entity-type level, granting access only to specific users and organizations. Organization users can use only those rights from their roles that are published to their organizations, and different access restrictions can be set on different versions of an entity type. System administrators with the Manage General ACL right can create, modify, and remove specific ACLs by using the accessControls API, providing fine-grained programmatic control over access to defined entities.

VCF Operations implements role-based access control where users can only perform the actions their assigned permissions allow. Scope-based access control further allows administrators to limit a user or set of users to specific objects within VCF Operations. The administrators role should be assigned only to specific users who require access to objects and actions across the entire environment, supporting the principle of limiting privileged access to a small, auditable set of individuals. When an individual comes under investigation, administrators can modify or remove role assignments to restrict that person's access to monitoring and operational data.

NSX Manager supports deactivating local user accounts through the Local Users tab. Users with the Enterprise Admin role or the admin user can activate or deactivate any local user accounts, except for the admin user, whose account cannot be deactivated and whose role assignments cannot be changed. This allows administrators to immediately block access to network management functions for individuals under investigation.

For certificate-based authentication scenarios, VCF supports certificate revocation lists (CRLs). NSX Manager validates CRLs as part of certificate validation, and VCF Operations provides CRL management when standard certificate validation is activated. Adding a certificate associated with a user under investigation to the CRL blocks access at the authentication layer.

To use these capabilities for preventative access restriction during an investigation, the organization must have defined procedures that connect its HR and security investigation processes to IT administration actions. This includes establishing who has authority to initiate access restrictions, how quickly restrictions must be applied after an investigation begins, and how restrictions are documented and reviewed. VCF provides the technical enforcement layer that allows those organizational decisions to be carried out quickly and consistently across the platform, but the triggering process, coordination with HR and legal, and decision-making authority are organizational responsibilities.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L2-3.11.1

> Periodically assess the risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals, resulting from the operation of organizational systems and the associated processing, storage, or transmission of CUI.

SCF Controls: RSK-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L2-3.11.2

> Scan for vulnerabilities in organizational systems and applications periodically and when new vulnerabilities affecting those systems and applications are identified.

SCF Controls: VPM-06, VPM-06.3

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L2-3.11.3

> Remediate vulnerabilities in accordance with risk assessments.

SCF Controls: RSK-06, VPM-04, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides centralized software and firmware patching across the entire infrastructure stack through VCF Operations and vSphere Lifecycle Manager, which together form a unified lifecycle management plane. VCF Operations is the central orchestration point for patching and update operations, coordinating patch releases (such as 9.0.1.0100) that deliver time-sensitive fixes to security and operational issues between major, minor, and maintenance releases.

VCF uses a desired-state model for host remediation through vSphere Lifecycle Manager (vLCM). Administrators define a software specification for each cluster, and vLCM brings all hosts into compliance with that specification during remediation. This approach applies uniformly to VMware-supplied components and third-party solutions alike. To make a third-party solution available on a cluster, administrators create a software specification containing the solution and remediate all hosts with that image. vLCM manages software updates for VMware ESX hosts, including patches of the ESX base image, OEM additions, components from different software vendors, and VMware Tools updates. Dynamic patch baselines automatically adjust their contents based on specified criteria each time Update Manager downloads new patches, keeping remediation current without manual baseline maintenance. Fixed baselines are also available for environments that require explicit control over which patches are applied. Hardware Support Manager (HSM) plugins extend vLCM to manage vendor-specific firmware and driver updates alongside software patches, providing unified lifecycle management for both software and firmware from within the same interface. Firmware updates through Hardware Support Manager are only available for clusters and hosts managed with vSphere Lifecycle Manager images; hosts managed with baselines do not support firmware updates through this mechanism.

The remediation workflow is coordinated through multiple layers. Coordinator Manager runs pre-checks before remediation begins to evaluate how each host in the cluster is affected and whether additional steps are needed. Pre-checks verify component connectivity, version compatibility, and component status. The ESX Updater Manager then handles the actual remediation on each host. Coordinator Manager also allows administrators to query the status of the remediation operation for the cluster and for each individual host, providing centralized visibility into remediation progress. The VCF Operations cluster transition specification includes a remediationOptionsSpec with a configurable remediationFailureAction that supports automatic retry with adjustable retryCount and retryDelay parameters, allowing administrators to define consistent remediation behavior.

VCF Operations extends lifecycle management with patch planner functionality for VCF core components, including the ability to download and manage upgrade, patch, and install binaries. Pre-update validation performs health checks and compatibility verification before patches are applied, and component interdependency management helps maintain compatibility and stability across the infrastructure during updates. All dependent elements related to package objects are added to packages automatically to help maintain compatibility between versions. VCF Operations also provides compliance management capabilities that detect violations, highlight risk areas, and provide actionable remediation recommendations, with out-of-the-box workflows mapped to recommendations and associated with specific alerts for automated remediation.

VCF supports programmatic management of the patching process through multiple interfaces. The VMware vCenter patching API supports discovery of all available and applicable updates for vCenter instances in the environment, including minor in-place updates and major migration-based updates. REST API endpoints provide operations for checking pending updates, requirements checking, staging, and installation. The life cycle management API provides operations for listing all available updates and upgrades and generating a pre-check compatibility report before applying updates. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, and the Update-Entity operation remediates hosts by applying baselines with configurable failure handling and retry behavior. PowerCLI provides the Update Manager module with cmdlets for downloading software patches, creating and modifying baselines, and scanning and remediating hosts, including a Test-Compliance command to verify entities against

downloaded patches. The vCenter Appliance itself can be patched via the vCenter Appliance Management Interface (VAMI) or the appliance shell; VMware distributes vCenter patches in two forms, ISO-based and URL-based, and the `software-packages` utility in the appliance shell supports both methods, including staging patches from a repository URL, installing directly from a URL without staging, or installing from an attached ISO image. These interfaces enable integration with external change management and orchestration systems for automated remediation workflows.

VCF includes several capabilities to reduce patching risk and support continuity during updates. Live Patching updates and restarts discrete components without requiring host evacuation or reboot, as vSphere Lifecycle Manager does not place hosts into maintenance mode when a Live Patch is enforced. Snapshots should be created before patching VCF Operations fleet management to provide a rollback path. VCF supports Ensure Accessibility maintenance mode for vSAN storage clusters, which evacuates data to maintain object accessibility during updates through durability components. The VCF Download Tool supports a patches-only option and offline depot configuration for managing patch binaries in air-gapped environments.

VCF Operations complements patch application with patch-gap detection for server firmware. It monitors hardware properties across the fleet, including BIOS version and BIOS release date, and provides dashboards that flag hosts running outdated server BIOS. This detection capability helps administrators identify hosts that require firmware patching before they become a compliance or security gap.

The VCF Consumption layer, implemented through vSphere Supervisor and VMware Kubernetes Service (VKS), extends this patching coverage to Kubernetes control plane components and cluster add-ons. VKS clusters use a rolling update model where updates are initiated by changing the cluster specification; the Supervisor reconciler applies changes node by node to maintain cluster availability during the process. This model covers control plane components including kube-apiserver, kube-controller-manager, kube-scheduler, etcd, kubelet configuration, and CoreDNS, all updated through the kubectl upgrade mechanism. Kubectl supports targeted patching of individual components through a patches directory; files named with the pattern `target[suffix][+patchtype].extension` (for example, `kube-apiserver0+merge.yaml` or `etcd.json`) apply strategic merge patches, merge patches, or JSON patches to the specified component. The patches mechanism is available through the InitConfiguration, JoinConfiguration, and UpgradeConfiguration APIs, providing consistent patching behavior across cluster initialization, node join, and upgrade operations. Instance-specific patches can also be applied over the base KubeletConfiguration through kubectl customization.

VKS clusters support add-on management that enables installation and updates of standard packages through versioned add-on repositories. Administrators can track and update packages such as istio, harbor, sriov-network-device-plugin, windows-gmsa-webhook, and vsphere-pv-csi-webhook as new versions become available. For container image currency, Harbor is available as a Supervisor service and provides vulnerability scanning and content trust capabilities to help identify images that require patching. Admission controllers, including validating webhooks and image pull policies, can be configured to restrict deployment of images that have not passed vulnerability scanning or that contain known vulnerabilities, integrating image patch compliance into the workload deployment workflow. Content library VM images deployed in the vSphere Supervisor environment should be created with the latest patches and required security settings aligned with organizational security policies. Security Technical Implementation Guides (STIGs) are available for Supervisor and VKS node releases (VKRs), providing prescriptive hardening guidance that defines what patches and configurations constitute a compliant deployment for the Kubernetes consumption layer.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend) contributes to continuous vulnerability remediation by providing network-level threat detection and automated remediation capabilities that address known and emerging threats across protected workloads.

vDefend Distributed IDS/IPS detects known attack signatures across east-west traffic within the data center. The IDS/IPS engine supports CVE-based signature searches, allowing administrators to identify and enable signatures that address specific newly disclosed vulnerabilities. Knowledge-based signatures cover attacks that are already known and documented; for custom applications and zero-day scenarios, administrators can author custom IDS/IPS signatures that extend detection beyond the standard signature set. This combination of vendor-maintained and custom signatures allows organizations to

respond to new vulnerability disclosures by deploying detection rules that identify exploitation attempts before patches can be applied.

Security Services Platform's Security Assessment generates Security Segmentation Reports and Blast Radius Reports that identify at-risk workloads, communication chains, and network flows, providing the visibility needed to plan and prioritize remediation activities. Security Services Platform identifies vulnerable workloads that could be exploited for lateral movement and evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test. Security Services Platform provides remediation workflows that translate detected threats into actionable security policy changes. When IDS/IPS or Gateway Firewall events identify malicious activity, administrators can apply remediation actions that create or modify Distributed Firewall rules and IDS/IPS policies to block the identified attack vectors. Two remediation strategies are available: Targeted remediations create narrow, precise policies that address the specific threat with minimal impact to existing workloads, while Comprehensive remediations create broader policies that defend against similar attack patterns. Intelligent Assist automates the selection between these strategies and handles the creation of groups, security profiles, rules, and policies needed to implement the remediation. The Response and Remediation feature performs automated policy creation based on user role and permissions.

Security Services Platform supports ongoing security posture management through asset inventory classification and traffic monitoring. Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workload communication patterns change. Security Intelligence generates microsegmentation recommendations by analyzing inventory assets to create or update vDefend sections. The Security Segmentation Score Breakdown report details protection coverage across environment pairs and highlights pairs that lack inter-environment policies, making coverage gaps easier to identify and address.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a structured update management workflow for the DSM plug-in and the database services it manages. Software updates must be obtained from the Broadcom Support Portal and uploaded into the DSM environment before deployment, establishing a controlled software intake process. Plug-in and database template software updates can be initiated by a vSphere administrator or a DSM user in the DSM Admin role.

The update process includes a staged review step before administrators initiate installation. Updates can be checked and initiated directly from the DSM UI or managed from the vSphere Client. The upgrade process is designed to attempt at least one complete chain of software updates regardless of the configured maintenance window duration, reducing the risk of a partially applied update chain. When automatic updates are enabled, DSM retries the update a maximum of three times, with a 10-minute interval between each attempt during the configured maintenance duration. If automatic plug-in updates fail, DSM supports manual updates as a fallback.

For automated patching, DSM provides a configurable Maintenance Policy that allows administrators to schedule automatic software updates for DSM Provider Appliances. The policy specifies a start date, a start time, and a duration window, and is accessible from both the DSM UI and the vSphere Client. The maintenance policy can be edited during the 10-minute interval between automatic update attempts, which cancels the next scheduled attempt and applies the updated configuration.

For database engine patching, DSM supports database version upgrades, including major version upgrades of PostgreSQL. Minor version database upgrades can be configured to run automatically during maintenance windows and may include CVE fixes, bug fixes, and performance improvements. For SQL Server databases managed by DSM, administrators can define maintenance windows for operating system patching.

When deploying DSM through the Consumption Operator, the deployment process includes Signature Verification to validate package integrity before installation.

DSM provides the tooling to manage patching of the DSM platform and its managed database services. Patching of the underlying VCF infrastructure (VMware ESX hosts, VMware vCenter, NSX, storage systems, firmware) is handled through VCF's lifecycle management capabilities and falls outside DSM's scope. An organizational patch management program is needed to track patch applicability, establish patch windows across all technology assets, test patches before production deployment, and verify successful application across the full environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides dedicated patch management mechanisms for its two primary components: the Avi Controller (the management and control plane) and Service Engines (the data plane VMs that handle application traffic). The Controller is the central point through which patches are delivered and applied to both component types.

Patch images are uploaded to the Controller via the REST API or through the CLI. Once a patch image is available, operators select from four patching modes: Controller Patch, SE Group Patch, System Patch, and Disruptive Patch. The patch segroup command accepts an `se_group_refs` parameter to target a specific Service Engine group for patching; when `se_group_refs` is not specified, all Service Engine groups are patched. If more than one Service Engine group requires patching, each group requires a separate patch command.

A best practice in 9.1 is to apply patches only to the Service Engine groups that require them, using Service Engine group segmentation to scope patching operations rather than applying patches system-wide when not necessary. Patch packages are selected based on the current Controller and Service Engine versions.

Before applying Controller patches, the system runs pre-checks that validate patch compatibility. These checks use the `SYSERR_CHECK_CONTROLLER_PATCH_COMPATIBILITY` mechanism to confirm the patch is appropriate for the installed version. Pre-check status and progress are accessible via Administration > Update > System, and a dry run option is available for upgrade operations to verify object operational state before the patch is applied.

Patches within a given patch family are cumulative. Patch 1p2 contains all fixes from 1p1 plus its own new fixes, and 1p3 includes all fixes from both 1p1 and 1p2. This design means an operator applying the latest patch in a family receives all prior fixes without needing to apply them sequentially. Applying a patch from a different patch family once one family is already in place is not advisable, and once a patch from a specific series is applied, all entities in the system can only be upgraded to patches within that series or higher.

For REST API-driven workflows, the Controller supports asynchronous patch operations that queue and consolidate patch requests at fixed intervals. This approach reduces latency during high-rate configuration updates and is recommended for large Avi deployments.

Avi also supports virtual patching for application-layer vulnerabilities through its Web Application Firewall (WAF). Operators can import Dynamic Application Security Testing (DAST) scanner results into the WAF to identify and help block exploitation of known application vulnerabilities while formal software patches are being developed and tested.

Patching of the underlying VCF platform infrastructure on which Avi's Controller and Service Engine VMs run, including compute hosts, storage, and networking components, is handled by VCF lifecycle management and is reflected in VCF Coverage.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RA.L3-3.11.1e

> Threat-Informed Risk Assessment

SCF Controls: RSK-04, RSK-04.2, THR-03, THR-07

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters. Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L3-3.11.2e

> Threat Hunting

SCF Controls: MON-11.3, THR-07

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides automated mechanisms for identifying and alerting on indicators of compromise through VCF Operations, VCF Operations for Networks, VCF Log Management, and VMware vCenter alarm capabilities. These tools allow administrators to define custom detection logic, monitor for anomalous conditions, and receive automated notifications when suspicious activity is detected.

VCF Operations supports the creation and configuration of alert definitions that monitor infrastructure events and conditions. Administrators can define metric event symptoms based on reported violations of metric thresholds from monitored systems, creating symptoms that feed into alert definitions. Each alert carries a Criticality attribute with possible values of Info, Warning, Immediate, or Critical, based on the level assigned when the alert definition was created or on the highest symptom criticality. Alert definitions also carry an Impact setting, which can be configured to Risk to flag problems requiring near-term investigation. When defined thresholds are violated, whether dynamic or static, VCF Operations triggers alerts and displays results in dashboards, views, and reports. The system highlights anomalous metric behavior for identification during incident investigation.

Log-based alerting in VCF Operations provides another detection layer. Log-based alerts are available through Symptom Definitions in Infrastructure Operations, enabling administrators to create detection rules that match patterns in log data. This capability supports identification of indicators of compromise that manifest as specific log entries, such as authentication failures, unauthorized configuration changes, or other suspicious events recorded in system logs. Administrators can compare changes to an object with symptoms and other data in VCF Operations to identify a possible cause for a generated alert, supporting root cause analysis during incident investigation.

VCF Operations event auditing provides visibility into platform interactions and generates audit events across the following categories: Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. The audit framework surfaces suspicious access events and policy violations, with each event providing a detailed view to help analyze suspicious user actions or system issues. Authentication and security-related events are specifically tracked, increasing user accountability by registering each action as an audit event. Audit events are accessible from the left menu under Security and are displayed in a tabular format.

Configuration drift detection in VCF Operations monitors for unauthorized changes by comparing current configurations against assigned template values. VCF Operations continuously evaluates collected data against defined policies and assigns a compliance score to each object or group based on how well they adhere to those policies. When a setting deviates from its desired value, the system generates a drift notification. Configuration drift from established baselines can indicate compromise, and VCF Operations generates alerts when compliance standards are violated. The platform also generates alerts for specific security-relevant changes, such as when any property of a Security Group is changed in NSX. vSphere Configuration Profiles extend this to the VMware ESX host layer, where administrators can configure alarms triggered by host configuration out-of-compliance events (for example, the `com.vmware.vclntegrity.ClusterConfigurationOutOfCompliance` event), with notifications delivered via email or SNMP trap.

VCF Operations for Networks extends monitoring with search-based alerts that can be configured with severity levels and tuned to detect anomalous network patterns. The Guided Network Troubleshooting feature creates a dependency graph of related entities, shows all relevant and correlated metrics and alerts, and highlights entities with anomalies for visual identification and root cause investigation. The Troubleshooting Workbench Anomalous Metrics card displays metrics that have shown drastic changes within a selected scope and time period, ranking results by degree of change with the most recent anomalous metric given the highest weighting. The Troubleshooting Insights widget displays the top three troubleshooting insights containing hints and metric details related to potential anomalies.

For automated notification delivery, VCF supports multiple outbound channels. VCF Operations can send alert notifications via SNMP trap to up to four SNMP trap destinations, with support for filtering when defining notifications. vCenter can send SNMP traps when alarms are triggered and also supports email notifications with configurable recipient addresses. vCenter SNMP trap notifications support SNMPv1, v2c, and v3, with v3 supporting all security levels to allow authenticated and encrypted trap delivery when integrating with external security monitoring infrastructure. These notification mechanisms allow integration with external security information and event management systems and security operations center workflows, so that indicator-of-compromise alerts reach the appropriate response teams without manual intervention.

VCF supports integration with external logging and monitoring solutions through syslog forwarding. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS protocol and requires port 6514 to be open for TLS-encrypted log transmission. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

Administrators can build a library of recommendations in VCF Operations that include instructions or automated actions to resolve alerts, connecting indicator-of-compromise detection directly to response procedures. Alert definitions can be created from Infrastructure Operations under Alerts or Troubleshoot, allowing flexible construction of detection rules for particular object types or metrics. VMware vDefend, available as a separate product, extends these capabilities with network-layer threat detection including IDS/IPS and traffic analysis.

VMware vDefend (Meets)

VMware vDefend provides automated IoC identification and alerting through IDS/IPS signature matching, Network Detection and Response (NDR) event correlation, and Malware Prevention file analysis with threat scoring, all accessible through the Security Services Platform (SSP) interface.

The NDR Campaign Blueprint presents an interactive graph visualizing correlated security events that maps the different stages of an attack. Graph nodes represent Threats, Custom IDS Signatures, and Indicators of Compromise. The IoC Summary for each File IOC and Malware IOC presents file score, verdict, SHA hashes, and a View Reports link; directional arrows indicate when a workload is affected by an IoC, and node colors reflect severity based on the highest impact score from associated detections. The Campaign Blueprint's Triage and Investigate feature allows filtering detections by threat, affected workload, or MITRE tactics, enabling security teams to scope the impact of detected IoCs.

The IDS/IPS Monitoring page provides a timeline graph visualization of intrusion events, with colored dots indicating unique event types and dot size indicating event frequency over a selectable time span. Events can be filtered by severity rating: Critical, High, Medium, Low, or Suspicious. Security Intelligence within the SSP provides a visualization canvas displaying granular IDS/IPS event data, including a blast radius view that highlights affected connections and can be filtered by specific signature ID. The SSP also collects and provides IDS/IPS metrics to monitor the readiness and performance of vDefend IDS/IPS across the environment. vDefend IDS/IPS maintains a detailed event log on ESX hosts capturing all alerts, drops, and rejects with metadata including source port, destination IP, IP protocol, and timestamps.

The Threat Monitoring dashboard in the Security Services Platform displays file event statistics and recently detected threats, providing summary-level visibility into Malware Prevention activity. An alarm is triggered on the Security Overview dashboard when dropped events are detected, alerting administrators via both the alarm page and a notification banner, and the alarm remains active until no dropped events are detected.

NDR integrates with external SIEM platforms, including VCF Log Management and Splunk, sending campaign and event logs as they occur. Events forwarded to the SIEM include new detections, detection updates, and new campaign creation, supporting automated alerting to organizational monitoring infrastructure. Security Intelligence also continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic.

To configure IoC monitoring in a vDefend deployment: enable IDS/IPS profiles on Distributed Firewall rules, configure NDR in the Security Services Platform, enable the Malware Prevention service, and configure SIEM integration under NDR settings to receive real-time event forwarding.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer detection of Indicators of Compromise (IoC) through its Web Application Firewall (WAF) and event-driven alert framework. When WAF Application Rules match incoming requests, App Log Analytics captures attack events and records information about the type of attack, such as SQL injection or cross-site scripting. The Application Security Report surfaces these findings as ranked lists of top attack types and top attacking IP addresses, with trend summaries showing total and flagged requests over time. In Evaluation Policy Mode, Avi WAF can generate a WAF Evaluation Report with WAF Statistics that provides a high-level overview of the application's security posture without blocking traffic. Avi's scan detection system also dynamically tunes client group membership in response to changes in traffic patterns to reduce false positives.

Avi's Alert framework processes system events and performance metrics against user-defined rules to generate alerts that trigger configured notification actions. Administrators can deliver alerts to multiple destinations configurable in the Operations > Notifications page of the Avi Controller UI: email, syslog, SNMP traps (SNMPv2c and SNMPv3), and custom APIs. SNMP notifications can be configured with TLS encryption and strict certificate verification. The Controller also monitors for denial-of-service attacks, with the Avi Service Engine generating DOS_ATTACK alert events that include attack type, attack count, source IP addresses, affected virtual service name, and report timestamp at configurable severity levels. Avi's alerting and reporting tools monitor over 500 real-time metrics for DDoS and attack mitigation activity.

For automated response, ControlScript alert actions allow Avi to react programmatically to detected security events without manual intervention. A ControlScript can add an offending client IP address to a blocklist IP group attached to a network security policy, blocking or rate-shaping traffic from attackers identified in DoS or other attack events. DataScripts provide additional capability for custom identification of suspicious traffic and execution of appropriate mitigation actions.

Avi's ICAP integration extends threat detection to content-level indicators by forwarding content to the vDefend sandbox analyzer. The response includes X-Infection-Found and X-Virus-ID headers containing threat scores, file hashes, and task UUIDs for analysis tracking. IP reputation events can be logged for monitoring and investigation.

Organizations seeking IoC detection across the full VCF environment should forward Avi alerts and application logs to a SIEM or external threat intelligence platform. Full infrastructure-wide IoC detection requires correlating Avi's application-layer signals with telemetry from other VCF platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L3-3.11.3e

> Advanced Risk Identification

SCF Controls: OPS-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L3-3.11.4e

> Security Solution Rationale

SCF Controls: IAO-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L3-3.11.5e

> Security Solution Effectiveness

SCF Controls: CPL-01.2, CPL-03, RSK-03.1, RSK-04, THR-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L3-3.11.6e

> Supply Chain Risk Response

SCF Controls: RSK-06.1, RSK-09, RSK-09.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RA.L3-3.11.7e

> Supply Chain Risk Plan

SCF Controls: RSK-06, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L1-b.1.x

> Monitor, control, and protect organizational communications (i.e., information transmitted or received by organizational information systems) at the external boundaries and key internal boundaries of the information systems

SCF Controls: NET-01, NET-02.2, NET-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SC.L1-b.1.xi

> Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks

SCF Controls: NET-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides network segmentation as a foundational design principle, using multiple layers of isolation to separate technology assets, applications, and services from one another.

At the physical and logical network layer, VCF uses VLANs and vSphere Distributed Switches (VDS) to segment traffic by function. Management traffic is isolated on dedicated networks accessible only to administrators. vMotion traffic is separated on distinct networks using dedicated VMkernel interfaces. IP-based storage traffic, including vSAN and NFS, runs on dedicated VLANs and can use dedicated physical network adapters for additional isolation. vSAN storage clusters can separate external VM traffic from internal storage traffic by using dedicated VMkernel ports for each traffic type. Network I/O Control (NIOC) on distributed switches divides traffic into predefined resource pools, including fault tolerance, iSCSI, vMotion, management, vSphere replication, NFS, and virtual machine traffic. NIOC can reserve bandwidth for each traffic type and allocate shares so that one class of traffic cannot starve another during contention. Active/standby NIC teaming configurations are available for vSAN traffic to provide resiliency without mixing storage and compute traffic paths. Distributed switch port groups also support Private VLANs (PVLANs), which further subdivide a VLAN segment into promiscuous, community, and isolated port types, restricting intra-VLAN communication to only explicitly permitted paths.

NSX extends segmentation with software-defined networking that decouples the virtual network from the physical infrastructure. NSX supports two primary segment models. The VLAN Segment Model provides isolation from other networks and can maintain separate security domains, such as isolating the fleet-level management network using VLAN-backed distributed port groups. VLAN segments can be provisioned by specifying one or more VLAN IDs on a private NSX network type. The Overlay Segment Model similarly provides isolation but decouples the virtual network infrastructure from the physical network, allowing segments to be created dynamically without reconfiguring the underlying physical network. This dual-model approach gives administrators flexibility to implement macrosegmentation using either traditional VLAN boundaries or software-defined overlay networks depending on architectural requirements.

NSX allows administrators to create logical network topologies using the NSX UI or API, building multi-tier architectures with Tier-0 and Tier-1 gateways and segments. Segments are realized as NSX Distributed Virtual Port Groups on vSphere Distributed Switches, providing consistent policy enforcement at the hypervisor level. In topologies running multiple standard overlay VDS switches, NSX provides traffic isolation such that traffic traversing one VDS is isolated from traffic on another VDS. NSX also supports applying switch security profiles to distributed port groups, and segment security features can filter malicious traffic from VMs on the network, helping protect segment integrity. NSX Distributed Port Groups and Uplink Port Groups also support Traffic Filtering and Marking policies that can be enabled and configured at the port level, allowing administrators to qualify, filter, or remark specific traffic flows at the point of ingress or egress on each port.

For multi-tenant and multi-department environments, NSX provides two isolation mechanisms. NSX Projects enable isolation of networking and security configurations across organizational units. NSX Virtual Private Clouds (VPCs) represent an additional layer of multi-tenancy within a project, providing self-contained virtual network environments with their own permission models, topology, and IP address management. VPCs support role-based access control through user and user group role assignments for Local User, LDAP User, or vIDM User account types. These can be allocated to discrete projects or tenants, enabling each to consume networking and security services in a self-service model.

VCF Automation extends segmentation into provisioned workloads by providing security groups for network isolation of deployed resources. This allows segmentation policies to be applied consistently through automated deployment workflows, so that new workloads are placed into the correct network segments from the point of provisioning.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) and vSphere Supervisor, extends network segmentation to containerized workloads using the same NSX networking infrastructure. vSphere Namespaces serve as logical isolation units within VCF Kubernetes environments, providing resource and network boundaries between workloads deployed across different namespaces. A dedicated virtual network is provisioned for each namespace where a cluster is deployed and for each VKS cluster itself. Each VKS cluster is backed by a set of NSX networking objects: a Tier-1 gateway (router), a segment (switch) linked to that gateway, a load balancer server, and virtual servers for the cluster's control plane endpoints. VKS cluster nodes attach to these NSX-backed segments through VirtualNetworkInterface objects as logical ports, assigning each node an IP address and scoping cluster traffic to a dedicated segment isolated from other clusters and from the management plane. The management plane, which hosts VMware vCenter and NSX Managers, is architecturally separated from the compute plane, which hosts NSX Edge Nodes and Supervisor nodes, so management traffic does not mix with workload traffic at the network layer.

Within VKS clusters, Antrea serves as the CNI plugin and supports the standard Kubernetes NetworkPolicy API, allowing administrators to declare and enforce pod-level ingress and egress rules. By default, a pod is non-isolated for egress, meaning all outbound connections are permitted; a pod becomes isolated for egress only when a NetworkPolicy selects it and includes Egress in its policyTypes, at which point only connections explicitly allowed by applicable policies are permitted. A pod becomes isolated for ingress when any NetworkPolicy selects it with an Ingress rule, restricting inbound connections to those from the pod's own node and those explicitly permitted by applicable policies. Administrators can apply a namespace-scoped NetworkPolicy that denies all ingress and egress traffic, establishing a deny-all baseline from which only necessary flows are selectively opened; for environments requiring strict multi-tenant namespace isolation, the recommended approach is a default deny-all policy paired with an explicit allow for DNS resolution. Antrea distributed firewall policies can additionally restrict traffic between Kubernetes namespaces by applying filtering rules at specific pod groups, providing an enforcement layer that complements standard Kubernetes NetworkPolicies. The Antrea-NSX Adapter integrates each VKS cluster's networking with NSX Manager, enabling NSX to manage the networking behavior of the cluster and apply consistent segmentation policies across both the Kubernetes data plane and the underlying NSX infrastructure. Antrea's NetworkPolicyStats feature gate enables collection of network policy statistics, providing visibility into enforcement activity per workload. VKS cluster administrators control pod network attachment capabilities through NetworkAttachmentDefinition resources, which define the allowed network configurations that application users may request, preventing unauthorized network connections. For multi-network configurations, VKS uses SubnetConnectionBindingMap custom resources to bind overlay subnets to node vNIC subnets, with the vlanTrafficTag field specifying a unique VLAN ID for traffic isolation between parent and child subnets at the NSX data path level. The Antrea EgressSeparateSubnet feature allows egress IP allocation from a subnet distinct from the default node subnet, supporting stricter egress traffic segmentation. For SR-IOV deployments, VKS SR-IOV network configurations block cross-namespace selection of network resources, enforcing namespace-level boundaries for high-performance network access. For multi-tenant data plane separation, pod node selectors can restrict workload placement to specific nodes, preventing tenant workloads from sharing compute resources across tenant boundaries. Service meshes deployable on VKS clusters can extend segmentation to OSI Layer 7 by enforcing policies based on workload identity and providing mutual TLS encryption between workloads, adding isolation even within a shared network segment. The Argo CD Supervisor Service implements its own internal network segmentation and firewall rules to secure communication between its components.

For ongoing management and visibility, the NSX Segment Inventory Dashboard tracks and manages network segmentation while offering insights into the dependencies between logical switches and other NSX components. The NSX Switch Dashboard displays detailed information on logical switches for efficient tracking and management. VCF Operations for Networks supports segmentation planning by analyzing traffic flows and grouping them by entities such as VLAN, security group, application tier, subnet, cluster, or individual virtual machine. The micro-segmentation planning topology shows all flows present in an environment by dividing them into segments, helping administrators understand current traffic patterns and refine segmentation boundaries over time. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU configuration, and VCF Operations provides host metrics that detect unsupported MTU configurations across the infrastructure.

The VCF documentation states that network endpoints should be segmented. Administrators should configure VLAN or overlay segments appropriate to their environment, assign workloads to the correct segments, apply switch security profiles, and use the NSX dashboards and VCF Operations tools to verify and maintain segmentation boundaries. For microsegmentation below the network segment level, VMware vDefend provides fine-grained traffic control between individual virtual machines and containers, independent of their network placement.

For operational technology (OT) and industrial workloads, NSX Industrial vSwitch (IvS) extends segmentation to PROFINET traffic between virtual Programmable Logic Controllers (vPLCs) running on VMware ESX hosts and I/O devices located outside the vSphere cluster. The associated NSX Industrial vSwitch Segment Profile supports the Discovery and Configuration Protocol (DCP) as part of the PROFINET protocol suite, allowing discovery of IO devices, retrieval of device identity information, and configuration of device settings such as device name and IP address. This capability brings OT traffic under the same segmentation model as standard IT workloads, enabling administrators to isolate industrial traffic on dedicated segments alongside the rest of the network architecture.

VMware vDefend (Meets)

VMware vDefend (vDefend) provides network segmentation capabilities at multiple layers, from macrosegmentation at the network perimeter down to microsegmentation between individual workloads. This is a core function of the product and addresses the control directly.

VMware vDefend enforces segmentation at the workload level by applying security policies at the vNIC of every virtual machine and container. Policies follow the workload regardless of its network placement or physical location, so segmentation is not dependent on VLAN boundaries or physical network topology. Administrators can define rules based on security groups, application tiers, tags, and other logical constructs to isolate technology assets, applications, and services from one another. Layer 2 through Layer 7 inspection allows rules to be written against specific applications, protocols, and user behaviors rather than just IP addresses and ports. When using NSX Projects, firewall rules are automatically scoped to VMs connected to the segments within that Project and do not affect workloads outside the Project, providing a built-in boundary for multi-tenant or departmental segmentation.

Starting with VCF, vDefend supports enforcement on both Distributed Virtual Port Groups (DVPGs) created in vSphere Distributed Switch and segments created in NSX within the same cluster. This extends DFW coverage to VMs connected to traditional vSphere DVPG networks in addition to NSX overlay segments, allowing organizations to apply consistent security policy across mixed-network environments. DFW policy members can include DVPGs, NSX Segments, or both, and grouping constructs support dynamic or static membership criteria based on VM name, tags, segment, or IP addresses.

VMware vDefend provides stateful North-South traffic inspection at the network edge, controlling traffic entering and leaving each segment. Together, the Distributed Firewall and Gateway Firewall create a layered segmentation model where both East-West and North-South traffic are subject to policy enforcement.

Security Intelligence, delivered through the vDefend Security Services Platform, provides segmentation planning and monitoring tools. The Security Segmentation Report assigns a quantitative Security Segmentation Score that measures an organization's progress toward a fully segmented network. Segmentation planning workflows help administrators discover traffic flows, identify infrastructure services, group assets by environment (such as VLAN, security group, application tier, subnet, or cluster), and apply hierarchy tags to verify that segments have appropriate controls. Infrastructure services are categorized into their own groups separate from the asset hierarchy, with dedicated groups that users can create and apply policies to. Environment segmentation divides the data center into broader security zones such as production, development, testing, or regulated environments, and Security Intelligence workflows support planning and enforcement of policies at each zone boundary. Security Intelligence generates macrosegmentation policy recommendations for environment pairs based on observed traffic flow patterns; these recommendations can be reviewed, modified, and published to enforce segmentation policies through the Distributed Firewall.

Segmentation Monitoring continuously watches traffic for supported infrastructure services and detects new servers or services that appear on the network. The feature monitors supported infrastructure service types, including DHCP, DNS, NTP, and LDAP, and identifies both newly discovered servers and servers missing recommended security rules. Administrators can

configure protection policies for environment pairs to Drop or Reject unauthorized traffic, and create lockdown rules to disallow traffic to servers outside defined infrastructure asset groups. Segmentation Monitoring provides detailed investigation capabilities to identify potential security risks in application traffic and enable corrective action. This provides ongoing assurance that the segmentation scheme remains intact as the environment evolves.

Application-level microsegmentation implements granular isolation for individual applications. Segmentation planning supports import of application context using a flat file containing key workload attributes such as IP addresses, subnets, virtual machines, logical segments, and organizational roles. The Security Segmentation Report also identifies workloads running obsolete operating systems, workloads using risky application protocols, and workloads communicating with external IP addresses, helping administrators prioritize segmentation policy work.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.1

> Monitor, control, and protect communications (i.e., information transmitted or received by organizational systems) at the external boundaries and key internal boundaries of organizational systems.

SCF Controls: NET-01, NET-02.2, NET-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to

originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SC.L2-3.13.2

> Employ architectural designs, software development techniques, and systems engineering principles that promote effective information security within organizational systems.

SCF Controls: CLD-03, SEA-01, SEA-03

Aggregate Coverage: Meets

VCF (Meets)

VCF implements security as a layered architecture where each layer operates independently and does not depend on the correctness of layers above it. These layers span hardware-rooted trust at the physical host, network isolation, hypervisor-level encryption and access controls, identity and certificate management, encrypted communications, distributed security enforcement, workload-level policy propagation, and compliance assessment.

At the physical and network layer, VCF supports traffic separation through distributed switch models that isolate management, vMotion, vSAN, and workload traffic onto separate physical or logical networks. These models can be selected based on design qualities including availability, performance, and security. Dedicated distributed switches for vSAN traffic, for example, separate storage traffic from all other traffic types, while the Single Distributed Switch Model does not provide network traffic separation to another physical network fabric, making the choice of switch model a meaningful security design decision. This physical separation provides a foundational security boundary that operates independently of any software-defined overlay. NSX extends this with software-defined routing, switching, and segmentation using overlay-backed segments that do not require segment-specific physical infrastructure configuration. Network profiles support further isolation through subnets, security groups, and VLAN transport zones.

At the hypervisor layer, VMware ESX hosts support hardware-rooted security capabilities. TPM-based measured boot produces event logs that can be retrieved and validated by an attestation service, verifying the integrity of the boot process. UEFI Secure Boot verifies firmware and hypervisor integrity before the operating system loads. The Security Configuration Guide provides recommendations for enabling Secure Boot and TPM on ESX hosts as part of host hardening. ESX enforces local access controls, firewall rules (with per-service rulesets and allowed-host specifications), and resource isolation. The ESX host client enables management of the host even when VMware vCenter is not available, so these host-level protections continue to function independently of centralized management.

At the storage and encryption layer, vSAN provides data-at-rest encryption using a key management server, encrypting all data written to the vSAN datastore. VM encryption operates at the hypervisor level, protecting virtual machine disk files, NVRAM, swap files, snapshot files, and core dump files regardless of the guest operating system. These encryption controls function at the infrastructure layer without depending on application-level security. vSphere also supports Virtualization Based Security (VBS), which uses hardware virtualization capabilities to isolate key guest OS security services so they are protected against manipulation from within the guest environment. For workloads with data-in-use protection requirements, vSphere supports Intel Trust Domain Extension (TDX), a hardware-based mechanism that allows virtual machines to perform computations within a hardware-isolated trusted execution environment.

At the network security layer, VMware vDefend (a separate product that extends NSX and requires additional licensing) provides distributed security functions including Distributed Firewall (DFW) policies with Layer 2 through Layer 7 firewalling, Distributed IDS/IPS, Identity Firewall, Layer 7 Application Identification, Fully Qualified Domain Name filtering, and Guest Introspection. These security functions are enforced in the hypervisor kernel at the virtual NIC level, operating below the guest operating system and outside the reach of workloads running within virtual machines. NSX Projects enable isolation of networking and security configurations across departments within a single deployment, allowing delegation of configuration management to specific sets of users while restricting visibility to only project-scoped objects.

At the identity and access layer, VCF SSO provides centralized authentication as a single point of user verification for vCenter clients. Role-based access control (RBAC) restricts access across all VCF components. NSX provides granular RBAC with distinct roles including Enterprise Admin, Network Admin, Security Admin, Cloud Admin, and Cloud Project Admin, among others, separating administrative privileges so that network administrators, security administrators, and workload operators

have distinct permission sets. VCF implements security roles and management of security functions aligned with global compliance frameworks. The VMware Certificate Authority (VMCA), a purpose-built internal certificate authority integral to vSphere, issues certificates for service-to-service authentication between platform components. A dedicated No Cryptography Administrator role supports all Administrator privileges except for Cryptographic Operations, enabling separation of duties between infrastructure management and encryption key management.

At the communications layer, all management interfaces and API endpoints use TLS encryption. NSX Manager supports configurable TLS protocol versions and cipher suites, with older TLS versions deactivated by default.

At the Kubernetes and consumption layer, VMware Kubernetes Service (VKS), the native Kubernetes platform within VCF, implements multiple independent security enforcement points at distinct positions in the Kubernetes stack. All access to the Kubernetes API server requires TLS-encrypted transport, followed by authentication via OIDC, X.509 client certificates, or service account tokens, and then authorization via Kubernetes RBAC. Admission controllers, including validating and mutating webhooks, operate as a third independent check before any object is persisted, so a principal that passes authentication can still be rejected by RBAC or by an admission webhook. The Kubernetes cluster infrastructure is designed to provide the security supports that higher application layers expect, consistent with the principle that lower layers do not depend on higher-layer correctness.

VKS Cluster Management Security Policies can be applied at the cluster, project, or organization level and propagate downward through the resource hierarchy so that all clusters within a project inherit the project's security policy. These policies are implemented using the Gatekeeper project from Open Policy Agent (OPA), maintaining a consistent security posture across workload layers without requiring each layer to independently define its own controls. A Baseline pod security template is available that mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads; custom security policy templates allow fine-tuning of individual security context parameters to support organizational requirements. Individual pods can be further constrained through security contexts that configure fields such as `runAsUser`, `allowPrivilegeEscalation`, Linux capabilities, `readOnlyRootFilesystem`, and `seccomp` or AppArmor profiles. Seccomp profiles reduce the Linux kernel syscall attack surface available within containers using BPF-based allow or deny lists, and Linux kernel security features including AppArmor and SELinux can be applied to pods and containers through SecurityContext configuration, providing a security boundary below the container runtime that operates regardless of the container's contents. The Supervisor secret injection agent itself drops all Linux capabilities and enforces a RuntimeDefault seccomp profile to restrict the system calls available to it, minimizing its own attack surface.

At the namespace and network layer within VKS, Kubernetes network policies restrict ingress and egress traffic per namespace. VKS supports Antrea and NSX-based network policy enforcement as well as Cilium, which enforces policies at OSI layers 3 through 7 using an identity-based model decoupled from IP addressing. Service meshes available on VKS clusters provide OSI Layer 7 policies based on workload identity and mutual TLS encryption, protecting data in transit even in the presence of a compromised node. These controls operate independently of what applications within the namespace do.

At the secrets and credential layer within VKS, the Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants separately from the application workloads that consume secrets, so that access to a running application does not by itself yield access to stored credentials.

At the supply chain and pipeline layer, Harbor Registry secures container images with artifact security policies and RBAC before images reach the runtime environment. Harness CI/CD, available on VKS, incorporates integrated security scanning and secrets management, including pre-deployment vulnerability scanning and post-deployment performance verification, applied before artifacts are promoted. Argo CD deployments use network segmentation to secure inter-component communication. Security Technical Implementation Guides (STIGs) for system components, including Supervisor and VKR components, are available through Tanzu STIG Hardening to guide layer-by-layer hardening of the Kubernetes environment.

At the compliance and assessment layer, the VCF Security Baseline provides a consolidated, out-of-the-box benchmark that evaluates both default and non-default configurations. This baseline is designed and validated to tailor security settings without impacting VCF's ability to meet its design objectives. VCF Operations surfaces a security dashboard that complements the compliance capability, and each component has its own Security Configuration Guide with hardening recommendations

aligned with DISA STIG guidance. These assessment and monitoring functions operate as an independent verification layer above the controls they measure.

VMware vDefend (Contributes)

VMware vDefend (vDefend) implements multiple independent security layers within its own architecture, contributing to a defense-in-depth strategy at the network security tier of VCF. The vDefend security model is structured as a Security Journey, a staged approach that allows organizations to progressively adopt a Zero Trust posture, moving from initial assessment through increasing levels of microsegmentation and policy enforcement. Each stage can be deployed and validated independently, with lower-level enforcement mechanisms remaining operational regardless of higher-level policy states.

At the network enforcement layer, the vDefend distributed firewall provides Layer 2 through Layer 7 traffic inspection and policy enforcement at the hypervisor level. The Applied-To field defines precisely where security rules are enforced, enabling scoped enforcement boundaries within the environment. Security profiles are organized per Project, and Security Strategies are collections of policies and rules applied at the project level, allowing discrete enforcement boundaries to be maintained across the environment. Bare Metal Security extends this enforcement model to physical servers, applying Layer 3/4 Distributed Firewall policies outside the virtualization stack through a workflow that onboards physical servers to the Bare Metal Orchestrator for policy propagation and enforcement.

At the threat detection layer, vDefend IDS/IPS provides signature-based intrusion detection and prevention. Gateway Firewall TLS Inspection allows encrypted traffic flows to be analyzed before reaching their destination. Advanced Threat Prevention (ATP) adds malware analysis as a distinct layer operating on file content extracted from network flows.

At the segmentation planning layer, Security Intelligence and the Security Services Platform (SSP) provide traffic flow analysis, security posture assessment, and policy lifecycle management. The Security Segmentation hierarchy is structured as Region, Zone, Environment, Application, and Tier, enabling granular segmentation planning across the environment. Security Intelligence provides targeted policy recommendations organized within Distributed Firewall categories, supporting administrators in planning and verifying segmentation coverage.

The Security Segmentation Score assessment calculates security posture by evaluating Distributed Firewall configuration and traffic rules, and generates a Blast Radius Report that provides a qualitative view of segmentation posture. The Security Segmentation Report identifies vulnerable workloads that could be exploited for lateral movement and presents recommendations for strengthening defenses. The score breakdown details total environments and pairs, protection rule actions, and highlights environment pairs lacking inter-environment policies, giving operators visibility into coverage gaps between enforcement layers.

Administrative access to the Security Services Platform itself is governed by role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. This role structure means that policy authorship, audit review, and operational support functions are distinct within the platform's control plane, adding an administrative separation layer on top of the enforcement architecture.

Taken together, these layers, including packet filtering, threat detection, malware analysis, encrypted traffic inspection, and segmentation assessment, are designed so that each layer makes enforcement decisions based on its own analysis without relying on the correctness of adjacent layers. A misconfiguration or gap in one layer does not disable enforcement in others.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements its security controls as distinct, layered mechanisms that map to different tiers of the database-as-a-service architecture. This layered structure means that a failure or bypass at one level does not automatically compromise the controls operating at other levels.

At the network layer, DSM requires VDS and N-VDS port groups to be available for host component isolation. Infrastructure policies define the compute, storage, and networking resources for each database deployment, including IP pool configuration with subnet-scoped addressing. This creates a defined, bounded network environment for database workloads that is configured by administrators independently of the database consumers who use those workloads. DSM also detects

and blocks network overlap between infrastructure policy IP ranges and system configuration networks, a check that stops subnet conflicts before they affect database network isolation.

At the authentication and identity layer, DSM requires Lightweight Directory Access Protocol over TLS (LDAPS) for all directory service communication. There is no option to connect a directory service without transport encryption. MySQL deployments support Active Directory Secure/SSL Global Catalog on port 3269 for multi-domain controller environments. For local accounts, DSM supports automatic authentication secret generation with rootCA certificate configuration in the Supervisor Service, providing a credential layer for endpoint-to-endpoint communication that is generated rather than administrator-managed.

At the access control layer, DSM applies role-based access control at two scopes. DSM Admin roles govern platform-wide configuration. DSM User role assignments can be scoped to one or more specific namespaces, so that a given user can access only the databases and resources within their assigned namespace and no others. Namespaces themselves enforce this access boundary, and role assignments are visible and manageable through the DSM administrator UI.

At the database engine layer, DSM isolates management operations from user-accessible database operations through engine-specific mechanisms. For SQL Server, the `dsm_mgmt` internal management login confines administrative operations to a secure, isolated context; users cannot access or modify system-level objects through this channel. User-defined DDL triggers that execute during DSM management operations run within a restricted database-level security context, which blocks those triggers from accessing the server-level permissions held by the internal management account. PostgreSQL deployments support the `pgcrypto` extension, which provides cryptographic functions as an additional data security layer within the database engine.

At the resource governance layer, infrastructure policies act as guardrails that restrict the type and quantity of compute, memory, storage, and networking resources that DSM users can request when provisioning databases. These policies are configured by administrators and presented to users as a curated set of options. Storage policies within an infrastructure policy are filtered to show only those compatible with the specified compute resources, reducing the chance that a user provisions a database in a configuration that violates organizational standards. Data service policies can be applied uniformly across tenants, maintaining a consistent security posture at scale.

Network perimeter controls, workload traffic inspection, host-level security, and the organizational design decisions that govern how layers interact across the broader platform are addressed by other components of VCF or by organizational policy. DSM operates as one layer within a broader security architecture rather than defining or enforcing that architecture on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to a Defense-in-Depth (DiD) architecture by acting as the application delivery and inspection layer within VCF. Avi's security enforcement mechanisms are organized as distinct, ordered tiers within the application delivery path, each operating independently without relying on the correctness of the network layers beneath them.

The Virtual Service Policy framework is the primary structural mechanism for applying layered controls. Policies are applied in ordered stages covering network-layer security, HTTP security, HTTP request handling, and HTTP response handling, allowing administrators to apply different security controls at the appropriate point in the traffic-processing pipeline. Network Security Policies provide L4 access control across UDP, TCP, and Layer 7 virtual services, with IP Group references enabling IP-based filtering rules that scale across multiple virtual services without per-rule manual maintenance. NSX security groups can be defined once in NSX and reused across Avi Virtual Service security policies, eliminating the need to maintain duplicate IP address lists. These network-layer policies function independently of the HTTP-layer controls, preserving the separation between tiers. The System-Secure-HTTP application profile provides a pre-configured baseline that enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior. Front-end security for each Virtual IP can be enforced using network security policies on the virtual service. Virtual Service Policies are configured under the Virtual Service settings in the Avi Controller UI or via the Avi API.

At the application layer, Avi's Web Application Firewall (WAF) provides two independent security models that can be combined. The negative security model uses Application Rules to detect known attack patterns through signature matching. The Positive Security model, configured under Virtual Service > Positive Security Policy, works differently: it uses a decoupled Learning function to gather application behavior data and then promotes verified patterns to rules that restrict traffic to known-good requests. WAF Policies attach a Positive Security group to apply learned data for security and to define hit and miss actions. Together, these models represent distinct enforcement mechanisms within the application inspection tier, each addressing a different class of attack pattern without depending on the other. In VMware Kubernetes Service (VKS) environments, the Avi Kubernetes Operator (AKO) provides WAF integration for application-layer security in VKS clusters. The AKO also supports a SecurityPolicy custom resource definition that enables virtual services to reference a security policy for Distributed Denial of Service (DDoS) attack mitigation, bringing Kubernetes-native policy control to application delivery security.

TLS termination is handled by configurable SSL/TLS profiles applied at the Virtual Service level. Profiles control cipher suite selection, protocol version, and certificate assignment, with trade-offs between security, compatibility, and computational cost. The Avi Controller integrates with external Hardware Security Modules, specifically Thales Luna HSMs, to separate key management and cryptographic operations from application processing. This separation provides an additional boundary within the cryptographic control plane that is independent of the application and network policy tiers.

The Avi Service Engine's data-plane architecture isolates attacks on the data plane to the data plane alone, avoiding impact to management interfaces. The Avi control plane provides visibility into data-plane attacks through management interfaces and can help secure the data plane from certain attack types. This control-plane and data-plane separation is itself a layering boundary that preserves the integrity of management operations even under active attack conditions. The Service Engine detects and mitigates a wide range of Layer 4 through Layer 7 network attacks.

Avi's denial-of-service protection spans both Layer 4 and Layer 7 as distinct monitoring and enforcement tiers. The DDoS Policy, accessible via the Network Security policy on the virtual service, detects and mitigates a wide range of Layer 4 through Layer 7 network attacks. The Avi Service Engine tracks and breaks down attack data separately for Layer 4 and Layer 7 through DDoS Insights, displayed on the default security page in the Avi Controller. The application profile includes a DDoS tab for configuring custom Layer 7 attack limits.

Auditors should verify that Virtual Service Policies are configured with appropriate Network Security Policies for each service, that WAF policies include both Application Rules and Positive Security policies calibrated to the application's known-good traffic profile, that SSL/TLS profiles enforce the organization's required protocol and cipher standards, and that DDoS thresholds are set according to the organization's risk profile. The DiD architecture as a whole requires design and integration across VCF, which provides infrastructure-level security controls, and VMware vDefend, which provides network-level enforcement through its distributed firewall and inspection capabilities.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SC.L2-3.13.3

> Separate user functionality from system management functionality.

SCF Controls: SEA-03.2

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces separation of user functionality from system management functionality through a layered architecture that partitions management-plane operations from workload-plane activities, combined with role-based access controls within each component.

At the infrastructure level, VCF separates the management domain from workload domains. The management domain is created during initial deployment and hosts all platform administrative components, including VCF Operations, VMware vCenter, NSX Manager, and VMware ESX hosts dedicated to management functions. Workload domains are deployed separately to run customer workloads, and each workload domain adds its own isolated pool of compute, network, and storage resources. Workload domains cannot share the management domain's NSX cluster, enforcing a structural boundary between management infrastructure and user workloads. Management components for the management domain must be started first in a specific order before any workload domain components, reflecting the dependency separation between the two tiers. The workload domain model also supports a dedicated identity provider, enabling separate authentication for management and user-facing environments. Within workload domains, resource pools provide hierarchical partitioning of available CPU and memory resources, enabling administrators to isolate resource consumption between management-related services and user workloads in the same compute environment.

Within vCenter, dedicated managed objects enforce this separation at the API level. The SessionManager managed object controls user access to the server through methods for logging in, obtaining a session, and logging out. The AuthorizationManager managed object grants permissions to user accounts and associates those permissions with specific managed entities in the inventory, restricting which operations each user can perform. On ESX hosts, the HostLocalAccountManager managed object handles user administration tasks separately from other host operations, providing dedicated CreateUser, RemoveUser, and UpdateUser methods for local account management. ESX also supports integration with Active Directory as a directory service for host user management, allowing organizations to extend centralized identity management to the hypervisor layer.

For Kubernetes-based workloads, the VCF Consumption layer, which includes VMware Kubernetes Service (VKS), the vSphere Supervisor, and vSphere Namespaces, provides multiple tiers of separation between management and user functionality. At the infrastructure level, vSphere Zones can be reserved exclusively for the Supervisor control plane, with separate zones assigned to vSphere Namespaces for workloads. Management and workload networks must reside on different subnets, and communication between them passes through a Supervisor management proxy. Namespace permissions on vSphere Namespaces enforce three distinct roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These map to Kubernetes ClusterRoles through RoleBindings, restricting the scope of each identity's operations within the namespace.

Within VKS clusters, Kubernetes namespaces are the primary partitioning primitive, dividing cluster resources and applying distinct access control policies per namespace. Kubernetes Roles and ClusterRoles, bound through namespace-scoped RoleBindings or cluster-wide ClusterRoleBindings, define the boundary between user access and administrative access. Namespace-scoped resource quotas can enforce differentiated limits across namespaces, for example allowing production workloads up to 8 GiB of memory while constraining development workloads to 512 MiB, keeping workload environments from affecting one another or the management plane. Shared clusters with multiple users require namespace-level RBAC rather than blanket administrative privileges, and the system:masters group, which bypasses all RBAC checks, should be restricted to break-glass emergency access only.

ServiceAccount separation keeps workload identities distinct from human user credentials. Creating ServiceAccounts independently from human user onboarding allows workload processes to operate under minimal-privilege identities,

preventing confusion between user and system actor contexts. The kube-controller-manager can be configured with the `--use-service-account-credentials` flag so that each built-in controller runs under a separate, narrowly scoped service account with roles prefixed with `system:controller:`. IAM role trust policies should be scoped to specific service accounts and namespaces to enforce least privilege at the service level. Kubernetes guidance recommends creating least-privileged access even for administrators, reserving full administrative credentials for break-glass scenarios only.

At the pod level, security contexts separate process identities within the same node. The `runAsUser` field specifies the operating system user identity under which container processes run, preventing containers from executing as root. For Windows containers, the `windowsrunasusername` feature gate enables running processes as a non-default user. Kubernetes guidance recommends placing workloads with different trust contexts on separate nodes to keep system management pods off the same nodes as user workload pods. Partitioning sensitive operations across containers limits the potential scope of any individual compromise by requiring an attacker to subvert multiple isolated container contexts.

Administrative tooling supports ongoing verification of the separation model. The `kubectl auth can-i` command, used with user impersonation, allows administrators to determine what actions other users can perform, confirming that RBAC bindings produce the intended boundaries between user and management access. Lifecycle management operations for Supervisor Services are gated behind explicit privileges: activating or deleting a Supervisor Service requires the `Manage Supervisor Services` privilege on the VMware vCenter system where the service is registered. The Argo CD Supervisor Service extends access control to service catalog management, using policy rules and group mappings to define fine-grained RBAC permissions for both local accounts and OIDC-federated identities.

RBAC enforces management and user separation across all VCF components. NSX Manager supports creation and management of custom roles with granular permission assignment across system administration functions, including user management, role assignment, local user configuration, authentication provider setup, license management, and system administration. NSX RBAC provides granular permissions across system, fabric, transport zone, certificate management, and other administrative domains. Roles like `Network Admin`, `Network Operator`, `Security Admin`, and `Security Operator` are scoped to individual projects rather than the entire NSX system, restricting users from accessing system-level management functions.

VCF Automation extends the separation between system management and user functionality through its multi-tenant organization model. The Provider Management Portal provides a dedicated interface for managing users in the System organization. System Administrators operate within the provider organization and can create custom provider roles, create other system administrator accounts, and create user accounts. Organization owners within tenant organizations have a separate, more limited set of permissions for managing users within their scope. This organizational hierarchy keeps system-level management functions isolated from tenant-level user functionality. The `Assembler Administrator` is the only role with full access to infrastructure-level resources like cloud accounts and projects, further restricting who can modify system management configurations.

VCF Operations supports role-based access control for user management, providing another layer of separation between administrative and user-facing functions within the monitoring and operations tooling.

VMware vDefend (Contributes)

VMware vDefend contributes to application partitioning through its Security Services Platform segmentation planning capabilities and Distributed Firewall microsegmentation enforcement. The Security Services Platform allows operators to import workload attributes via flat file and organize inventory assets into a defined hierarchy of region, zone, environment, application, and application tier, categorizing workloads into functional types such as web servers, database servers, and application servers. When segmentation plans are published, the platform creates an inventory group for each application with member tiers as nested group members, producing discrete security policy objects that correspond to the logical application boundaries. These boundaries are enforced at the network layer through Distributed Firewall policy, logically separating application tiers from one another.

Two segmentation strategies are available for application microsegmentation: application ring-fencing and application microsegmentation, each supporting predefined and default rules. Segmentation Monitoring within the Security Services

Platform investigates detailed information about applications, identifies potential security risks, and enables corrective action, supporting ongoing validation of the separation posture.

Within the Security Services Platform itself, vDefend separates administrative and operational functions through role-based access control. Three defined roles are available: Enterprise Admin (full platform management, including deployment, upgrade, and authentication configuration), Auditor (API and service access for auditing the system), and Support Bundle Collector. The two predefined local accounts in the SSP Installer map to the Enterprise Admin and Auditor roles respectively. Instance management operations including deletion and offboarding of NSX Manager require Admin privileges via HTTPS, restricting those functions to authorized administrators. User Management and role assignment modification similarly require Admin privileges, separating management functions from read-only and auditing access.

Separation of user functionality from system management functionality at the identity and access management layer for the broader platform is handled by VMware vCenter and VCF SSO rather than vDefend directly.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) separates user functionality from system management functionality through a structured role-based access control model with two distinct roles reflected in separate user interface views.

The DSM Admin role is a super-user level role with watch and maintenance capabilities across all data services in the environment, including those created by other users. Administrators access DSM through the Data Services Manager Administrator UI, which exposes platform management functions including system configuration, user management, identity source configuration, and platform-wide visibility into all data services. Administrators can manage both local users and LDAPS users, configure which identity sources are active, and assign role assignments scoped to specific namespaces. Administrator authority over user configuration is bounded: an administrator can modify only a user's role and the namespaces to which the user has access.

The DSM User role is restricted to database lifecycle operations for databases the user owns or has been authorized to access. Users access DSM through the standard Data Services Manager UI and can provision and manage their own databases and perform database lifecycle operations, but cannot access system management functions, view or modify other users' data services, or change platform configuration. DSM User role assignments can be restricted to one or more specific namespaces, limiting each user's access to only the namespaces they have been explicitly granted.

DSM manages local users and LDAPS users independently, allowing organizations to use one or both identity sources within the same installation. Within a namespace, DSM's RBAC model allows multiple users to jointly work on data services while remaining isolated from data services in other namespaces.

DSM extends this partitioning to SQL Server clusters. DSM uses a dedicated `dsm_mgmt` internal management login within SQL Server clusters, which restricts users from accessing or modifying system-level objects and keeps administrative operations within an isolated management context. The provisioning model for SQL Server also enforces the separation of server management from database management: administrators provision SQL Server instances through DSM, and application teams create and manage databases on those instances.

Database clusters can also be deployed with infrastructure policies and storage policies that enforce workload isolation and resource constraints at the provisioning level.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that separate user-facing application delivery functions from system management functions, addressing this control at the network architecture, access control, and multi-tenancy layers.

At the network architecture level, management and control processes running on Avi Service Engines are bound to a dedicated management vNIC interface, keeping control-plane traffic segregated from application data traffic. This creates distinct communication paths: the management channel between the Service Engine and the Avi Controller uses only the management vNIC, while application data plane traffic flows through separate data-plane interfaces. Deploying Service Engines with a dedicated management network further extends this isolation by creating distinct network segments for

management traffic, front-end application data, and back-end server communication. These deployment choices are configured through the Service Engine group settings in the Avi Controller.

Avi's role-based access control provides granular access to system areas and resources independently. The Avi Controller supports predefined and custom roles that can be assigned to user accounts. Custom roles grant write, read, or no-access permissions per resource type, so that users managing application workloads receive only the access needed for application delivery tasks without access to system administration functions. Extended granular role-based access controls go further, supporting sub-resource access that enables users to execute specific functions within objects, allowing fine-grained partitioning of capabilities within a single resource type. User profile administration is managed through Administration > Accounts > User Profiles on the Avi Controller; accounts with write access to the Accounts section can perform management actions on other accounts, so user-profile administration is itself an access-controlled function.

Auth Mapping Profiles extend this by allowing user groups from external identity sources to be mapped to specific roles with tenant isolation, so that organizational boundaries in the identity provider are reflected directly in the Avi access model.

The tenant model provides a further layer of logical separation. When a user is associated with multiple tenants, each tenant isolates its own resources from those in other tenants; to access another tenant's resources, the user must explicitly switch the management session to that tenant. Service Engines can be organized into separate groups per tenant, cloud, or VRF context, scoping application delivery resources to the owning organizational boundary. The Avi GSLB component also supports non-admin users with assigned roles for granular access control over global server load balancing operations, extending the partitioning model to the GSLB tier.

In VCF deployments, the Avi Load Balancer integration with VCF supports multi-tenancy and regional quotas through VCF Automation, with tenant-scoped activation of Avi Load Balancer services per organization.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SC.L2-3.13.4

> Prevent unauthorized and unintended information transfer via shared system resources.

SCF Controls: SEA-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of mechanisms to prevent unauthorized and unintended information transfer through shared system resources, spanning memory isolation, storage data remanence controls, VM isolation settings, network segmentation, access controls on shared management objects, and authorization enforcement across the management plane.

At the memory layer, VMware ESX supports memory eager zeroing (Mem.MemEagerZero), which clears memory contents on the host to prevent one workload from reading residual data left by a previous workload. When VMs are deallocated, their memory pages are scrubbed before being made available to other workloads. For workloads requiring stronger isolation, confidential vSphere Pods use AMD Secure Encrypted Virtualization-Encrypted State (SEV-ES) to keep guest OS memory encrypted, protecting it against access from the hypervisor itself and preventing CPU registers from leaking information between execution domains. Transparent page sharing between VMs is governed by the `sched.mem.pshare.salt` parameter; each VM receives a unique salt value by default, preventing cross-VM page sharing unless administrators explicitly assign a common salt value to indicate that a group of VMs are mutually trusted.

At the storage layer, VCF supports multiple virtual disk provisioning formats that address data remanence. Thick Provisioned Eager Zeroed disks zero out any remaining data on the physical device when the virtual disk is created, preventing a new virtual disk from containing residual data from a previous tenant. Thin Provisioned disks zero data on demand at first write. vSphere virtual machine encryption encrypts virtual machine files, virtual disk files, core dump files, NVRAM, swap, and snapshot files, rendering residual data unreadable even if the underlying storage is shared. vSAN data-at-rest encryption encrypts everything in the vSAN datastore, protecting all files and virtual machines stored there from unauthorized access at the storage layer. Core dumps generated on ESX hosts are encrypted when vSAN encryption is enabled.

At the VM isolation layer, VCF provides several settings that restrict information channels between VMs and the hypervisor. The `isolation.tools.diskWiper.disable` setting helps prevent unauthorized disk wiping operations. The `isolation.device.edit.disable` and `isolation.device.connectable.disable` settings prevent unauthorized device modification and connection. The `isolation.tools.vixMessage.disable` setting blocks VIX messaging between VMs and the host, closing a potential inter-VM communication channel. The `isolation.monitor.control.disable` setting restricts VM Monitor Control interactions. The `isolation.tools.copy.disable` parameter disables copy and paste operations between the guest operating system and the remote console, and `isolation.tools.setinfo.disable` restricts the guest from setting host-visible informational data, both preventing information from being extracted through VMware Tools channels.

At the network layer, VLAN segmentation separates traffic types so that management, vMotion, storage, and workload traffic traverse isolated network paths. The Workload Separation Distributed Switch Model places workload traffic on dedicated physical NICs, preventing shared network resources from becoming an information transfer path. The NSX switch_security datapath module performs stateless L2 and L3 security checks on traffic to network segments, dropping unauthorized packets sent from virtual machines. This operates at the virtual switch level and restricts VMs from sending traffic that violates the segment's security posture. NSX Manager enforces approved authorizations for controlling the flow of management information within network devices based on information flow control policies. Together, these controls restrict both data plane and management plane information transfer to authorized paths.

When resources are explicitly shared across organizational boundaries such as NSX projects or VPCs, VCF enforces strict access controls on those shared objects. Shared resources are available in a read-only mode to the projects or VPCs with which they are shared, and project users cannot modify shared resources. This design restricts information transfer to a one-directional, read-only model where an Enterprise Admin controls what is shared and consumers can only reference the shared objects without altering them. The system also creates a default share for each project containing system-defined resources

such as Services, BFD Profiles, and App IDs, keeping these standard resources available while maintaining the read-only constraint.

For principal identity users and automation integrations, NSX restricts other users from overwriting inventory resources owned by the principal identity user. This helps prevent unintended modification of resources managed by automated systems or external integrations, maintaining clear ownership boundaries around shared management objects.

At the VMware vCenter layer, the AuthorizationManager controls access to specific server objects based on the permissions associated with each object. This role-based access model restricts users to only those resources they are authorized to interact with, preventing unauthorized information transfer through the management interface.

VCF Automation supports content sharing policies with a hard enforcement mode that controls which users or groups can access catalog items within a project, restricting unauthorized access to shared content. Content library security policies can be applied to local or subscribed content libraries, protecting the environment when synchronizing or downloading library content from third-party providers and restricting the introduction of unauthorized content through shared library resources. If a content library is protected by a security policy, all library items must be compliant with that policy.

At the VMware Kubernetes Service (VKS) and vSphere Supervisor layer, VCF provides additional information isolation controls for containerized workloads consuming the platform. Each vSphere namespace acts as a distinct partitioning boundary: Kubernetes Secrets, ConfigMaps, and service accounts are namespace-scoped, and each workload should be isolated in its own namespace so that it can access only its own resources while allowing tailored security policies to be applied per workload. Kubernetes RBAC Roles and RoleBindings restrict access to namespace-scoped resources to explicitly authorized subjects; RBAC also governs impersonation headers, enabling fine-grained control over which identities a subject may assume through configurable impersonation resourceName restrictions. Where a policy grants a user more permissions than required, the affected resources should be refactored into finer-grained namespaces to enforce least privilege.

Pod Security Admission (PSA) profiles control which host resources containerized workloads can access on a shared Kubernetes cluster. The Baseline profile restricts host namespace sharing, privileged containers, and host path mounts. The Restricted profile additionally requires non-root execution, read-only root filesystems, and dropped capabilities. Process namespace sharing is a specific information transfer vector that should be carefully controlled, as it permits cross-container process signaling and filesystem access; the Restricted profile helps prevent this by default. Namespaces that allow privileged workloads should establish access controls to maintain least privilege. Platform administrators should not bind the vmware-system-privileged Pod Security Policy cluster-wide via ClusterRoleBinding, as doing so disables native security controls across the entire cluster.

On Linux nodes, seccomp improves workload isolation by reducing the Linux kernel syscall attack surface available inside containers, using BPF-based allow or deny profiles. AppArmor can be applied to restrict filesystem paths and system calls available to individual containers. Platform administrators should enable RuntimeDefault as the default seccomp profile for all workloads to enforce a restrictive syscall baseline, and should apply more specific profiles for workloads handling sensitive data. The Supervisor secret injection agent, which handles injecting Secrets into pods on VKS clusters, itself enforces a RuntimeDefault seccomp profile, applying syscall restrictions to a privileged platform component. Network-level isolation should be established as a foundational layer before configuring kernel-level security capabilities.

Kubernetes NetworkPolicy objects, implemented through Antrea or NSX-based backends in Supervisor environments, restrict ingress and egress traffic at the namespace level, limiting which pods and services can communicate across shared network infrastructure. For service mesh deployments, Istio can be deployed with strict mutual TLS enabled (enableStrictMTLS), enforcing mutual authentication for all service-to-service communication within the mesh and reducing the risk that workloads can observe or intercept traffic destined for other services.

Kubernetes Secrets are namespace-scoped and access is governed by RBAC. The Secret Store service, available as a Supervisor service, enforces role-based access control for administrators, DevOps engineers, and application tenants managing and distributing sensitive data. Applications must protect secret values after reading them, including avoiding logging secret data in clear text or transmitting it to untrusted parties. Using short-lived Secrets limits the impact of any unintended exposure. Access to workload creation, service account usage, ConfigMap mounting, and volume mounting

should be governed by RBAC, as misconfigurations in these areas can enable privilege escalation that bypasses namespace boundaries.

ValidatingAdmissionPolicy provides a mechanism to protect platform namespaces from unauthorized mutations. Harbor Registry, available as a standard VKS service, secures container artifacts with policies and RBAC, restricting which users and service accounts can pull or push images from shared repositories. Kubernetes taints can be applied to nodes to dedicate them for exclusive use by a particular set of users, combined with corresponding tolerations on pods to enforce workload-to-node access control. Administrators can also taint nodes where swap memory is available to protect against workload spillover, preventing workloads from spilling onto nodes without swap under load conditions. Software supporting access control functions should be isolated from general workloads, as it runs with elevated privileges.

Security Technical Implementation Guides (STIGs) are available for Supervisor and Kubernetes Releases (VKrs), documenting the configuration baseline required to meet security requirements for each component.

A known limitation applies to vSAN File Service file shares in VKS environments: Access Control Lists used for ReadWriteMany volumes have a potential IP spoofing risk. Organizations relying on file-share access controls for sensitive workloads should account for this risk in their deployment design.

VMware vDefend (Contributes)

VMware vDefend (vDefend) restricts information transfer across shared network resources through microsegmentation, traffic flow control, and policy enforcement at the virtual network interface.

The Distributed Firewall enforces security policies at the vNIC level, preventing workloads sharing the same physical host, network segment, or cluster from communicating unless explicitly authorized by policy. Because enforcement is at the virtual network interface rather than a perimeter device, isolation persists even when workloads share the same physical switch, host, or VLAN. The Distributed Firewall supports stateful Layer 2 through Layer 7 inspection, allowing administrators to define rules based on IP addresses, port ranges, protocols, application identity, and user identity context. Policy enforcement extends to Bare Metal servers through Security Services Platform, providing consistent isolation controls across both virtualized and non-virtualized workloads sharing the same environment.

The Gateway Firewall provides an enforcement point at the perimeter of network segments, controlling north-south traffic entering and leaving tenant or workload zones. In 9.1, Enterprise Administrators can enforce isolation between projects by denying all inter-project communication except for infrastructure protocols such as DHCP, DNS, NTP, and ICMP using centralized transit Gateway Firewall rules, restricting information movement across shared routing infrastructure at the project boundary.

Security Services Platform supports environment-based segmentation. Administrators can configure block policies to prevent traffic between environment pairs that should never communicate, such as development and production workloads sharing the same physical infrastructure. Initial security segmentation policies, once published, cannot be modified through the user interface, reducing the risk of inadvertent policy weakening. Security Intelligence generates granular application-level rules that allow only authorized traffic between environments, and administrators can monitor traffic leakage between environments, establish exception policies for required communication paths, and implement lockdown protection rules.

The Security Segmentation Report provides a structured view of at-risk workloads, identifying those with public-facing traffic, obsolete operating systems, risky application protocols, and inter-VDI server connections, giving administrators targeted visibility into shared-resource exposure. Security Intelligence maps all discovered assets including workloads, groups, IP addresses, DVPGs, segments, and infrastructure services during segmentation analysis, making unintended communication paths visible so they can be addressed.

Malware Prevention adds a file-level control by inspecting files transferred to Windows workload VMs for malicious content. Distributed Malware Prevention with Guest Introspection provides interfaces for taking remediation actions on endpoints, including denying access to suspicious files or deleting files identified as malicious. The Security Services Platform Campaign Correlation capability correlates file transfer and endpoint-based detections with command-and-control events, persistence

events, and privilege escalation events on the same compute resource, providing detection coverage for multi-stage information transfer patterns across shared infrastructure.

These capabilities address the network and file-transfer dimensions of shared resource isolation. Memory isolation and storage isolation, which involve ESX memory zeroing and vSphere storage encryption respectively, are handled by VCF components outside vDefend's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer implements a multi-tenant isolation model in the Avi Controller that scopes configuration objects, virtual services, and resource access to individual tenants. When a user belongs to multiple tenants, each tenant isolates its resources from those in other tenants. To access resources in a different tenant, the user must explicitly switch the management session context to that tenant. This session-based boundary applies to both the Avi UI and the API, and is configured under Tenant Settings.

Avi Load Balancer's role-based access control supports granular object-level permissions. Write access can be granted to specific object types including Virtual Service, Application Profile, SSL/TLS Certificates, and Certificate Management Profile objects, allowing operators to scope modification rights precisely. A No Access privilege level prevents users from reading or listing resources entirely. Privilege-based access control with defined WRITE_ACCESS levels further restricts exposure of one tenant's configuration to another.

In Provider Context (Shared) mode, Service Engines are managed within the provider context and shared across tenants. The Avi Controller manages the tenant boundary for application traffic and configuration data. Service Engine Group extra shared memory is configured as a Service Engine group-level property and is a shared resource across all virtual services hosted on a given Service Engine. At this layer, the compute-level isolation of hardware resources such as memory pages and CPU cache state is handled by the underlying VCF platform rather than by Avi itself. The VCF Coverage reflects this platform responsibility.

In the 9.1 VCF integration, namespaces linked to Service Engine Groups define resource boundaries that restrict a single user from exhausting the organization's total capacity. Service Engine Groups can be shared across multiple namespaces within this model, with the namespace-to-group association defining the scope of resource access. This provides an additional layer of tenant isolation at the infrastructure boundary within VCF-integrated Avi deployments.

For incoming application traffic, network security policies can be applied to Avi virtual service VIPs to restrict which traffic reaches backend pools. Network Security Policies that discard traffic take precedence over HTTP request policies, scoping the processing pipeline from the earliest stage and reducing the risk of unintended data exposure across shared infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.5

> Implement subnetworks for publicly accessible system components that are physically or logically separated from internal networks.

SCF Controls: NET-06

Aggregate Coverage: Meets

VCF (Meets)

VCF provides network segmentation as a foundational design principle, using multiple layers of isolation to separate technology assets, applications, and services from one another.

At the physical and logical network layer, VCF uses VLANs and vSphere Distributed Switches (VDS) to segment traffic by function. Management traffic is isolated on dedicated networks accessible only to administrators. vMotion traffic is separated on distinct networks using dedicated VMkernel interfaces. IP-based storage traffic, including vSAN and NFS, runs on dedicated VLANs and can use dedicated physical network adapters for additional isolation. vSAN storage clusters can separate external VM traffic from internal storage traffic by using dedicated VMkernel ports for each traffic type. Network I/O Control (NIOC) on distributed switches divides traffic into predefined resource pools, including fault tolerance, iSCSI, vMotion, management, vSphere replication, NFS, and virtual machine traffic. NIOC can reserve bandwidth for each traffic type and allocate shares so that one class of traffic cannot starve another during contention. Active/standby NIC teaming configurations are available for vSAN traffic to provide resiliency without mixing storage and compute traffic paths. Distributed switch port groups also support Private VLANs (PVLANs), which further subdivide a VLAN segment into promiscuous, community, and isolated port types, restricting intra-VLAN communication to only explicitly permitted paths.

NSX extends segmentation with software-defined networking that decouples the virtual network from the physical infrastructure. NSX supports two primary segment models. The VLAN Segment Model provides isolation from other networks and can maintain separate security domains, such as isolating the fleet-level management network using VLAN-backed distributed port groups. VLAN segments can be provisioned by specifying one or more VLAN IDs on a private NSX network type. The Overlay Segment Model similarly provides isolation but decouples the virtual network infrastructure from the physical network, allowing segments to be created dynamically without reconfiguring the underlying physical network. This dual-model approach gives administrators flexibility to implement macrosegmentation using either traditional VLAN boundaries or software-defined overlay networks depending on architectural requirements.

NSX allows administrators to create logical network topologies using the NSX UI or API, building multi-tier architectures with Tier-0 and Tier-1 gateways and segments. Segments are realized as NSX Distributed Virtual Port Groups on vSphere Distributed Switches, providing consistent policy enforcement at the hypervisor level. In topologies running multiple standard overlay VDS switches, NSX provides traffic isolation such that traffic traversing one VDS is isolated from traffic on another VDS. NSX also supports applying switch security profiles to distributed port groups, and segment security features can filter malicious traffic from VMs on the network, helping protect segment integrity. NSX Distributed Port Groups and Uplink Port Groups also support Traffic Filtering and Marking policies that can be enabled and configured at the port level, allowing administrators to qualify, filter, or remark specific traffic flows at the point of ingress or egress on each port.

For multi-tenant and multi-department environments, NSX provides two isolation mechanisms. NSX Projects enable isolation of networking and security configurations across organizational units. NSX Virtual Private Clouds (VPCs) represent an additional layer of multi-tenancy within a project, providing self-contained virtual network environments with their own permission models, topology, and IP address management. VPCs support role-based access control through user and user group role assignments for Local User, LDAP User, or vIDM User account types. These can be allocated to discrete projects or tenants, enabling each to consume networking and security services in a self-service model.

VCF Automation extends segmentation into provisioned workloads by providing security groups for network isolation of deployed resources. This allows segmentation policies to be applied consistently through automated deployment workflows, so that new workloads are placed into the correct network segments from the point of provisioning.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) and vSphere Supervisor, extends network segmentation to containerized workloads using the same NSX networking infrastructure. vSphere Namespaces serve as logical isolation units within VCF Kubernetes environments, providing resource and network boundaries between workloads deployed across different namespaces. A dedicated virtual network is provisioned for each namespace where a cluster is deployed and for each VKS cluster itself. Each VKS cluster is backed by a set of NSX networking objects: a Tier-1 gateway (router), a segment (switch) linked to that gateway, a load balancer server, and virtual servers for the cluster's control plane endpoints. VKS cluster nodes attach to these NSX-backed segments through VirtualNetworkInterface objects as logical ports, assigning each node an IP address and scoping cluster traffic to a dedicated segment isolated from other clusters and from the management plane. The management plane, which hosts VMware vCenter and NSX Managers, is architecturally separated from the compute plane, which hosts NSX Edge Nodes and Supervisor nodes, so management traffic does not mix with workload traffic at the network layer.

Within VKS clusters, Antrea serves as the CNI plugin and supports the standard Kubernetes NetworkPolicy API, allowing administrators to declare and enforce pod-level ingress and egress rules. By default, a pod is non-isolated for egress, meaning all outbound connections are permitted; a pod becomes isolated for egress only when a NetworkPolicy selects it and includes Egress in its policyTypes, at which point only connections explicitly allowed by applicable policies are permitted. A pod becomes isolated for ingress when any NetworkPolicy selects it with an Ingress rule, restricting inbound connections to those from the pod's own node and those explicitly permitted by applicable policies. Administrators can apply a namespace-scoped NetworkPolicy that denies all ingress and egress traffic, establishing a deny-all baseline from which only necessary flows are selectively opened; for environments requiring strict multi-tenant namespace isolation, the recommended approach is a default deny-all policy paired with an explicit allow for DNS resolution. Antrea distributed firewall policies can additionally restrict traffic between Kubernetes namespaces by applying filtering rules at specific pod groups, providing an enforcement layer that complements standard Kubernetes NetworkPolicies. The Antrea-NSX Adapter integrates each VKS cluster's networking with NSX Manager, enabling NSX to manage the networking behavior of the cluster and apply consistent segmentation policies across both the Kubernetes data plane and the underlying NSX infrastructure. Antrea's NetworkPolicyStats feature gate enables collection of network policy statistics, providing visibility into enforcement activity per workload. VKS cluster administrators control pod network attachment capabilities through NetworkAttachmentDefinition resources, which define the allowed network configurations that application users may request, preventing unauthorized network connections. For multi-network configurations, VKS uses SubnetConnectionBindingMap custom resources to bind overlay subnets to node vNIC subnets, with the vlanTrafficTag field specifying a unique VLAN ID for traffic isolation between parent and child subnets at the NSX data path level. The Antrea EgressSeparateSubnet feature allows egress IP allocation from a subnet distinct from the default node subnet, supporting stricter egress traffic segmentation. For SR-IOV deployments, VKS SR-IOV network configurations block cross-namespace selection of network resources, enforcing namespace-level boundaries for high-performance network access. For multi-tenant data plane separation, pod node selectors can restrict workload placement to specific nodes, preventing tenant workloads from sharing compute resources across tenant boundaries. Service meshes deployable on VKS clusters can extend segmentation to OSI Layer 7 by enforcing policies based on workload identity and providing mutual TLS encryption between workloads, adding isolation even within a shared network segment. The Argo CD Supervisor Service implements its own internal network segmentation and firewall rules to secure communication between its components.

For ongoing management and visibility, the NSX Segment Inventory Dashboard tracks and manages network segmentation while offering insights into the dependencies between logical switches and other NSX components. The NSX Switch Dashboard displays detailed information on logical switches for efficient tracking and management. VCF Operations for Networks supports segmentation planning by analyzing traffic flows and grouping them by entities such as VLAN, security group, application tier, subnet, cluster, or individual virtual machine. The micro-segmentation planning topology shows all flows present in an environment by dividing them into segments, helping administrators understand current traffic patterns and refine segmentation boundaries over time. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU configuration, and VCF Operations provides host metrics that detect unsupported MTU configurations across the infrastructure.

The VCF documentation states that network endpoints should be segmented. Administrators should configure VLAN or overlay segments appropriate to their environment, assign workloads to the correct segments, apply switch security profiles, and use the NSX dashboards and VCF Operations tools to verify and maintain segmentation boundaries. For microsegmentation below the network segment level, VMware vDefend provides fine-grained traffic control between individual virtual machines and containers, independent of their network placement.

For operational technology (OT) and industrial workloads, NSX Industrial vSwitch (IvS) extends segmentation to PROFINET traffic between virtual Programmable Logic Controllers (vPLCs) running on VMware ESX hosts and I/O devices located outside the vSphere cluster. The associated NSX Industrial vSwitch Segment Profile supports the Discovery and Configuration Protocol (DCP) as part of the PROFINET protocol suite, allowing discovery of IO devices, retrieval of device identity information, and configuration of device settings such as device name and IP address. This capability brings OT traffic under the same segmentation model as standard IT workloads, enabling administrators to isolate industrial traffic on dedicated segments alongside the rest of the network architecture.

VMware vDefend (Meets)

VMware vDefend (vDefend) provides network segmentation capabilities at multiple layers, from macrosegmentation at the network perimeter down to microsegmentation between individual workloads. This is a core function of the product and addresses the control directly.

VMware vDefend enforces segmentation at the workload level by applying security policies at the vNIC of every virtual machine and container. Policies follow the workload regardless of its network placement or physical location, so segmentation is not dependent on VLAN boundaries or physical network topology. Administrators can define rules based on security groups, application tiers, tags, and other logical constructs to isolate technology assets, applications, and services from one another. Layer 2 through Layer 7 inspection allows rules to be written against specific applications, protocols, and user behaviors rather than just IP addresses and ports. When using NSX Projects, firewall rules are automatically scoped to VMs connected to the segments within that Project and do not affect workloads outside the Project, providing a built-in boundary for multi-tenant or departmental segmentation.

Starting with VCF, vDefend supports enforcement on both Distributed Virtual Port Groups (DVPGs) created in vSphere Distributed Switch and segments created in NSX within the same cluster. This extends DFW coverage to VMs connected to traditional vSphere DVPG networks in addition to NSX overlay segments, allowing organizations to apply consistent security policy across mixed-network environments. DFW policy members can include DVPGs, NSX Segments, or both, and grouping constructs support dynamic or static membership criteria based on VM name, tags, segment, or IP addresses.

VMware vDefend provides stateful North-South traffic inspection at the network edge, controlling traffic entering and leaving each segment. Together, the Distributed Firewall and Gateway Firewall create a layered segmentation model where both East-West and North-South traffic are subject to policy enforcement.

Security Intelligence, delivered through the vDefend Security Services Platform, provides segmentation planning and monitoring tools. The Security Segmentation Report assigns a quantitative Security Segmentation Score that measures an organization's progress toward a fully segmented network. Segmentation planning workflows help administrators discover traffic flows, identify infrastructure services, group assets by environment (such as VLAN, security group, application tier, subnet, or cluster), and apply hierarchy tags to verify that segments have appropriate controls. Infrastructure services are categorized into their own groups separate from the asset hierarchy, with dedicated groups that users can create and apply policies to. Environment segmentation divides the data center into broader security zones such as production, development, testing, or regulated environments, and Security Intelligence workflows support planning and enforcement of policies at each zone boundary. Security Intelligence generates macrosegmentation policy recommendations for environment pairs based on observed traffic flow patterns; these recommendations can be reviewed, modified, and published to enforce segmentation policies through the Distributed Firewall.

Segmentation Monitoring continuously watches traffic for supported infrastructure services and detects new servers or services that appear on the network. The feature monitors supported infrastructure service types, including DHCP, DNS, NTP, and LDAP, and identifies both newly discovered servers and servers missing recommended security rules. Administrators can

configure protection policies for environment pairs to Drop or Reject unauthorized traffic, and create lockdown rules to disallow traffic to servers outside defined infrastructure asset groups. Segmentation Monitoring provides detailed investigation capabilities to identify potential security risks in application traffic and enable corrective action. This provides ongoing assurance that the segmentation scheme remains intact as the environment evolves.

Application-level microsegmentation implements granular isolation for individual applications. Segmentation planning supports import of application context using a flat file containing key workload attributes such as IP addresses, subnets, virtual machines, logical segments, and organizational roles. The Security Segmentation Report also identifies workloads running obsolete operating systems, workloads using risky application protocols, and workloads communicating with external IP addresses, helping administrators prioritize segmentation policy work.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.6

> Deny network communications traffic by default and allow network communications traffic by exception (i.e., deny all, permit by exception).

SCF Controls: NET-04.1

Aggregate Coverage: Meets

VCF (Contributes)

VCF supports deny-by-default and allow-by-exception network traffic patterns at multiple layers, including the ESX host firewall, vSphere Distributed Switch traffic filtering, and NSX routing layer. Full workload firewall deny-by-default enforcement at distributed and gateway firewall levels is provided by VMware vDefend, which is a separate product.

ESX hosts include a built-in firewall that controls incoming and outgoing connections for management services, with service groups including SSH and SNMP. Each firewall service allows access from all IP addresses by default; administrators can restrict access by specifying allowed IP addresses in CIDR notation (for example, 192.168.0.0/24) or as individual comma-separated addresses. The `esxcli network firewall ruleset set --allowed-all` command disables open access for a ruleset and enforces an explicit IP allowlist per service, implementing a deny-by-default posture at the management-service level on every ESX host.

vSphere Distributed Switches support Traffic Filtering and Marking policies at the distributed port and uplink port level. Network traffic rules can be configured with Allow or Drop actions to control traffic flowing through individual ports, and port-level override options allow policy exceptions to be applied at the individual port level without modifying the parent distributed port group policy. These rules operate at the virtual switch tier and provide a deny-by-default mechanism independent of firewall functionality.

At the routing layer, NSX Tier-0 Gateways support IP prefix lists that control route redistribution with permit and deny actions. The default action for a route in an IP prefix list is Deny, which implements a deny-by-default posture for route advertisement. Administrators must explicitly add a Permit entry for each desired route, with all others denied by default. This deny-by-default routing posture restricts which traffic flows can be advertised and reachable through the NSX infrastructure.

VCF Automation allows administrators to associate security groups with network profiles. When a network profile includes security groups, all machines provisioned with that profile inherit the associated network policies, providing a way to apply consistent deny/allow policies at provisioning time. The security group constructs integrate with vDefend firewall enforcement when vDefend is deployed, surfacing rule-based access controls through the automation layer.

VCF Operations for Networks provides a Security Planning capability through the Plan and Assess interface. This feature analyzes flows and displays traffic flow patterns and micro-segmentation data, giving administrators visibility into which traffic is currently permitted and helping identify gaps in deny-by-default coverage. Planning queries can analyze data center security by planning security policies for specified entities before they are applied.

At the workload consumption layer, VMware Kubernetes Service (VKS) clusters use Kubernetes NetworkPolicy resources as the primary mechanism for deny-by-default traffic control between pods. A NetworkPolicy selects pods by label selector and specifies which ingress and egress traffic is permitted; once at least one NetworkPolicy applies to a pod, all traffic not explicitly permitted is dropped for that pod. To establish a deny-by-default posture in a namespace, administrators create a NetworkPolicy that selects all pods but specifies empty ingress and egress rules, then layer explicit allow rules on top using pod label selectors, namespace selectors, destination ports, or IP block CIDR ranges with optional exclusions. VKS uses Antrea as its default Container Network Interface (CNI) plugin; Antrea implements NetworkPolicy enforcement using Open vSwitch, enabling per-flow filtering at the virtual switch layer. The AntreaPolicy feature gate enables Antrea-native policies, which support tiered policy ordering and cluster-scoped rules beyond what standard NetworkPolicy resources support.

Beginning with VKS 3.6, VKS clusters support configurable inbound firewall rules for cluster nodes through the `firewall` subvariable of the `ClusterClass` node variable. The `firewall.inboundRules` variable can be set on control plane nodes and as variable overrides on each worker node `machineDeployment`; each rule accepts an optional source IP address or CIDR block

and a target protocol specified as an IANA protocol number or alias string such as ``tcp`` or ``udp``. This provides a declarative API for controlling node-level inbound access, complementing the pod-level NetworkPolicy layer.

Each VKS cluster is provisioned with a built-in distributed firewall rule for kube-dns, applied to the CoreDNS pod logical port at cluster creation, restricting CoreDNS access to its designated port. Antrea NetworkPolicyStats is enabled by default on VKS clusters, providing statistics on which network policies are active and what connection volumes they have matched. VKS Cluster Management Security Policies include a Policy enforcement setting whose default action is Deny, which fully enforces the policy and denies admission requests that contain violations; a Dry run mode is available for validation before enforcement is activated. The ``DenyServiceExternalIPs`` admission controller restricts use of ``LoadBalancer`` and ``ExternalIPs`` service types, limiting which services can advertise external endpoints.

Kubernetes itself enforces deny-by-default access control at the API server level: all parts of an API request must be explicitly permitted by at least one authorization mechanism in order to proceed. One scope boundary applies at the pod networking layer: Kubernetes NetworkPolicy resources are specified to restrict TCP, UDP, and SCTP traffic; for other protocols such as ARP and ICMP, enforcement behavior depends on the CNI plugin in use, and administrators should verify handling for those protocols in their specific deployment. A namespace with no NetworkPolicy applied allows all pod traffic by default; achieving deny-by-default behavior requires deliberate creation and deployment of default-deny NetworkPolicy objects in every namespace, which organizations must establish as an operational practice.

VMware vDefend extends these capabilities with full stateful firewall enforcement at both the gateway and workload tiers. vDefend applies security policies at tier-1 gateway service interfaces, controlling traffic as it enters and exits network segments. vDefend firewall rules provide granular control through configurable source groups, destination groups, services, and direction settings (inbound, outbound, or both). Each rule supports three actions: Allow permits matching traffic, Deny actively rejects it with a notification to the client, and Drop silently discards the packet. This rule structure enables administrators to build policies that block all traffic by default and then define specific exceptions for permitted flows.

Rule ordering within vDefend firewall policies is significant for implementing deny-by-default patterns. Rules that permit specific exceptions should be placed before rules that drop traffic, so that the allowed exceptions are evaluated first and all remaining unmatched traffic falls through to the default deny rule. vDefend preserves the order in which policy rules are added, and precedence is determined at both the policy level and the individual rule level.

vDefend Layer 7 access profiles support URL category filtering with configurable Allow, Reject, or Reject with Response actions for matched traffic. Administrators can define FQDN-based firewall rules to allow or reject traffic going to specific domains, using both pre-defined and custom FQDN lists. URL categories support wildcard pattern matching for domain filtering, including single-level and multi-level wildcards and anchored patterns to match specific URL structures.

vDefend includes a Firewall Exclusion List that allows administrators to designate up to 100 groups that should bypass firewall rule evaluation. This should be used sparingly, as excluded objects are not subject to the deny-by-default policy.

vDefend extends deny-by-default enforcement to east-west traffic between virtual machines. vDefend DFW is a software-defined Layer 2-7 firewall that provides stateful firewalling with distributed firewall policies supporting Allow, Drop, and Reject actions, direction controls, and context-aware rule parameters including sources, destinations, services, and context profiles. vDefend functionality can be configured on virtual distributed switches in data centers and workloads where segmentation, visibility, or advanced security capabilities are desired.

Organizational governance of firewall rule policies, change management for rule updates, and periodic review processes to verify that deny-by-default posture remains intact across the environment must be established outside the platform.

VMware vDefend (Meets)

VMware vDefend (VMware vDefend) implements a deny-by-default, allow-by-exception traffic policy for both East-West and North-South traffic in a VCF environment.

The vDefend distributed firewall (DFW) enforces stateful Layer 2-7 security policies at the virtual network interface level of each workload. Each firewall rule is configured with one of three actions: Allow, Drop, or Reject. DFW automatically generates a Default Drop rule that denies all traffic from any source to any destination for any service. This catch-all rule sits at the

bottom of the rule table and enforces policy for packets not matching any other rule. VMware recommends changing the DFW default rule to a block action and enforcing access control through a positive control model where only traffic explicitly defined in firewall rules is permitted. Specific rules should be placed above more general rules in the rule table so that more targeted permits take precedence. DFW supports Context Profiles for Layer 7-aware rule matching, enabling allow-by-exception rules that specify application-layer context in addition to source, destination, and port.

The Application Connectivity Strategy in DFW provides structured, API-driven approaches to configuring the default traffic posture. The Allow Intra, Deny Other Traffic strategy uses the `ALLOW_INTRA` and `ALLOWLIST` APIs to generate an intra-group Allow rule paired with a default `ANY/ANY/DROP` rule, isolating the group from all other traffic. The Allow List connectivity preference configures a Drop action as the default, denying all traffic not explicitly permitted. For traffic not covered by named strategies, DFW supports custom policies that provide granular control of lateral East-West traffic.

FQDN filtering rules in DFW support Allow, Drop, or Reject actions, extending the deny-by-exception model to domain-name-based traffic control. The Identity Firewall enforces the allow-by-exception discipline for user-identity-based access: each Identity Firewall rule that permits traffic from a user group to a destination must be paired with a corresponding DFW or Gateway Firewall rule applied to the destination group. Identity Firewall rules also support a Reject action, allowing administrators to deny traffic matching specified user groups, services, and destinations.

The vDefend gateway firewall provides deny-by-default enforcement for North-South traffic at the NSX edge. Gateway Firewall rules support Allow, Drop, and Reject actions. In federated deployments, DFW and Gateway Firewall rules can be created from the Global Manager with global, regional, or local spans and are synchronized to Local Managers. The default gateway firewall rule is editable from the Global Manager and can be configured as allow-all or deny-all, giving administrators control over the baseline North-South posture. The L7 Access Profile extends allow-by-exception to application-layer traffic, with rule actions of Allow, Reject, and Reject with Response.

The Security Services Platform (SSP) and Security Intelligence support the transition to and maintenance of a deny-by-default posture. After establishing exception policies for an environment pair, administrators can change the protection rule action to Drop or Reject to block new, unknown traffic. Policy recommendations can be scoped with a Source Exclusions List, allowing fine-tuned control over which traffic sources are included in generated allowlists. The Security Overview Dashboard provides views of DFW policies, including policy actions (allow, drop, and reject) and total rule counts, giving administrators visibility into the active enforcement posture. Security Policies in vDefend DFW can be reviewed and modified through the Policies and Rules field.

The Firewall Rule Analysis Report identifies potential security misconfigurations in the distributed firewall configuration, helping administrators find shadowed or overly permissive rules that could undermine the deny-by-default posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides deny-by-default traffic controls at the application delivery layer through Network Security Policies, HTTP Policy Sets, and Web Application Firewall (WAF) policies in Enforcement mode.

Avi's Network Security Policy is evaluated for every client connection to a virtual service. The policy determines whether a connection is accepted, discarded, or rate-limited based on network-level parameters. Multiple ordered rules can be configured within each Network Security Policy, with explicit Allow and Deny actions available. When a rule with a Deny action matches a connection, further policy evaluation stops, so downstream HTTP Security, Request, or Response policies do not execute for that traffic. Deny rules support a log parameter that, when set to True, records all denied traffic. ControlScripts can dynamically create Network Security Policy rules that deny traffic from specific client IP addresses identified during DDoS events, using `IS_IN` match criteria against a configured list of source addresses. Network Security Policy can also be configured to deny connection attempts from addresses identified as malicious through IP Reputation data, dropping TCP SYN packets before connections are established. Both Network Security and HTTP Security policies support a Blocklist mechanism, where a policy rule references a configured IP group named Blocklist to discard clients matching that group.

The HTTP Policy Set provides an additional allow-or-deny mechanism at the application layer. Match conditions classify traffic and apply explicit allow or deny actions; denied traffic receives a TCP RST unless the system is under a volumetric denial-of-service attack, in which case the connection is silently discarded.

When configured in Enforcement mode, Avi's WAF applies a positive security model to application-layer traffic. WAF rule actions support pass (allow) and deny (block) options; requests that satisfy configured rules are permitted, and those that do not are blocked by default. Administrators can author custom WAF rules using SecRule syntax with chain operators, enabling multi-condition enforcement such as allowlisting specific source IP ranges for specific URI paths. WAF Exceptions allow specific traffic to be excluded from rule enforcement based on Client IP, Path, or Match Element filter combinations. WAF Allowlist rules support a BYPASS action for trusted IP address groups, including IP Group-based allowlisting, providing an allow-by-exception mechanism alongside the default-deny posture.

Avi's traffic controls apply only to application traffic passing through its virtual services and Service Engines. Deny-by-default policy enforcement for general east-west and north-south network traffic across the VCF platform is a function of VMware vDefend, which is a separate product. An organization implementing deny-by-default network traffic controls in a VCF environment will typically use both Avi and vDefend together, with Avi addressing application-layer traffic at the load balancer boundary.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.7

> Prevent remote devices from simultaneously establishing non-remote connections with organizational systems and communicating via some other connection to resources in external networks (i.e., split tunneling).

SCF Controls: CFG-03.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.8

> Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards.

SCF Controls: CRY-01.1, CRY-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations. Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager

provides an `importProvider` method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options `krb5`, `krb5i`, and `krb5p`, where `krb5p` provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the `kube-apiserver` `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the `kube-scheduler` exposes the same `tls-cipher-suites` parameter to keep its API endpoint aligned; and the `kubelet` exposes `tlsCipherSuites` and `tlsMinVersion` settings in `KubeletConfiguration` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `tlsCipherSuites` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the `ClusterClass` variable `fips.enabled`, which controls which encryption algorithms are permitted at the node level. Tanzu Kubernetes Release references carrying the `-fips.1` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `tls.minimum-protocol-version` and `tls.maximum-protocol-version` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is `v1.33.1--vmware.1-fips-vkr.2` with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the `PAISConfiguration` custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the `PAISConfiguration` YAML references CA trust bundles supplied as `ConfigMap` resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry, content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the

pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints.

and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the `ssl_min_protocol_version` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable `sslmode` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has `require_secure_transport` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the `ssl_fips_mode` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the `network.tlsProtocols` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form.

At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control SC.L2-3.13.9

> Terminate network connections associated with communications sessions at the end of the sessions or after a defined period of inactivity.

SCF Controls: NET-07

Aggregate Coverage: Meets

VCF (Meets)

VCF provides configurable session timeout and connection termination mechanisms across its management interfaces, hypervisor layer, and programmatic access points. Sessions terminate on explicit logout and after configurable inactivity periods, with the specific timeout values set by administrators to match organizational policy.

NSX Manager sessions expire after 1800 seconds (30 minutes) of inactivity by default. Administrators can adjust this value using the CLI command "set service http session-timeout" with a value in seconds, followed by a UI service restart. The connection_timeout API parameter is also configurable for API service connections. Idle sessions are terminated automatically, and NSX Manager immediately destroys the session identifier when any user logs out, preventing session identifier reuse. The system recognizes only system-generated session identifiers and invalidates them upon administrator logout or other session termination. Administrators can also explicitly delete active sessions through the /api/session/destroy API endpoint.

On the hypervisor layer, VMware ESX provides a Host Client Session Timeout setting that controls the duration before an inactive Host Client session is terminated, giving administrators direct control over idle session lifetimes on individual hosts. This setting maps to the UserVars.HostClientSessionTimeout advanced system setting, which specifies idle time in seconds. ESX also provides shell-layer timeout controls: the ESX-Shell-idle-timeout setting terminates idle interactive shell sessions after a configurable period, and the ESX-Shell-availability-timeout setting deactivates the ESX Shell service itself after a specified period of inactivity, preventing further logins until re-enabled.

VCF Operations for Networks enforces a User Session Timeout that defaults to 15 minutes and can be configured from 15 minutes to 24 hours, allowing organizations to align session duration with their security policies. The VCF Operations orchestrator also supports configuring timeout periods for user interactions through the timeout.date variable. VCF Operations for Networks exposes a Session Count metric that tracks the total number of allowed sessions at configurable intervals, providing visibility into active session counts for monitoring purposes.

For programmatic access, the vSphere Web Services API provides a logout() method that clients use to close authenticated session connections. The documentation states that API clients must always close server connections by calling the logout method. The vSphere Client enforces a separate inactivity timeout that defaults to 120 minutes and is configurable via the session.timeout parameter, specified in minutes. The VCF Operations PowerShell plug-in provides a closeSession method that can terminate sessions by session ID, enabling scripted or automated session cleanup.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer within VCF extends connection termination controls to containerized workloads. At the node level, the kubelet streamingConnectionIdleTimeout setting governs the maximum time that streaming connections (exec, attach, and port-forward operations) can remain idle before automatic closure; in VKS clusters using the built-in ClusterClass at version 3.5.0 and later, this defaults to 10 minutes and can be overridden through the kubeletConfiguration section of ClusterClass variables. kube-proxy controls idle TCP connection state through the tcpEstablishedTimeout parameter in KubeProxyConfiguration, allowing administrators to define how long idle TCP sessions persist before termination. The VKS API server enforces a configurable timeout for all non-long-running requests, defaulting to 1 minute, after which the server terminates the connection if the request has not completed. Kubernetes Service objects using ClientIP session affinity bound the sticky session duration through sessionAffinityConfig.clientIP.timeoutSeconds, which defaults to 10800 seconds (3 hours) and is configurable from 1 to 86400 seconds. The Contour ingress controller, available as a standard package for VKS clusters, provides granular HTTP timeout controls: timeouts.connection-idle-timeout terminates connections that have been idle, defaulting to 60 seconds; timeouts.stream-idle-timeout terminates streams or requests with no activity; and timeouts.max-connection-duration bounds absolute connection lifetime independent of activity. Contour

Envoy pods use a configurable termination grace period, defaulting to 300 seconds via `envoy.terminationGracePeriodSeconds`. When the Istio service mesh standard package is deployed on VKS clusters, `meshConfig.connectTimeout` controls the connection establishment timeout across the mesh, defaulting to 10 seconds. At the workload level, each Pod specification accepts a `terminationGracePeriodSeconds` field that defines the grace period for open connections to complete before the platform forcibly halts the process, defaulting to 30 seconds. Kubernetes surfaces an `endpoints.conditions.terminating` state in `EndpointSlice` resources so that load balancers and service proxies can implement connection draining during rolling updates and scale-down events.

These mechanisms cover end-of-session and inactivity-based termination across all VCF management, programmatic access, and containerized workload paths. Timeout values are configurable at every layer so administrators can align session and connection duration with organizational security policy.

VMware vDefend (Contributes)

VMware vDefend provides configurable session timers and connection state management that terminate network connections after inactivity, directly addressing the workload traffic dimension of this control.

The vDefend distributed firewall (DFW) maintains session state for all connections traversing the firewall and applies configurable session timers that determine how long a session remains active after inactivity. These timers run on every VMware ESX host at the vNIC level, covering workload-to-workload connections regardless of physical network topology. When a session timer expires, the firewall removes the connection entry from its state table, terminating the session. Non-TCP connections (UDP, ICMP, and other protocols) are terminated with a `TIMEOUT` reason, and TCP connections record the specific termination reason in the firewall logs.

For TCP connections, vDefend provides granular timer controls across the connection lifecycle. The Established timer governs active TCP sessions with a default of 43,200 seconds. The Closing timer applies after the first FIN has been sent, defaulting to 120 seconds. The TCP Closed timer takes effect after one endpoint sends a RST, defaulting to 20 seconds. The TCP Opening timer governs sessions where the handshake is in progress, defaulting to 30 seconds after the second packet has been transferred. When both endpoints have sent packets, the multiple-connection timer defaults to 60 seconds. These values are configurable through session timer profiles, which can be applied to user-defined workload groups or to Tier-0 and Tier-1 gateways, allowing administrators to align timeout behavior with organizational security policy. Shorter timeout values can be applied to specific groups, such as externally facing workloads, while longer timeouts accommodate batch processing or database connections.

The Gateway Firewall provides comparable controls for north-south traffic, with configurable session timers spanning TCP connection states. Where Gateway Firewall TLS Inspection is enabled, a separate idle connection timeout governs how long a server can remain idle after a TCP connection is established, defaulting to 5,400 seconds and configurable through the Decryption Action Profile.

vDefend's firewall logging captures connection termination events, including the reason for termination. Distributed Firewall packet logs indicate the actual reason a TCP connection was terminated and generate a termination log entry when a TCP session has ended. These logs record the protocol (TCP, UDP, ICMP, or protocol number) for each packet and include termination reasons for TCP connections. Gateway Firewall packet logs record termination events including source IP, destination IP, ports, protocol, and direction, extending this audit capability to north-south traffic paths.

While vDefend addresses connection termination for workload network traffic at the data plane, management session timeouts (such as NSX Manager session expiry and VMware vCenter session management) are handled by other VCF components. vDefend contributes the workload-level network connection termination capability that complements these management-plane controls.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) operates as a full-proxy application delivery controller, managing the complete connection lifecycle on both the client-facing and server-facing sides of every proxied session. This architecture gives Avi direct control over when connections are established and terminated, without relying on underlying infrastructure components.

For TCP connections, the TCP Proxy profile in Custom Mode offers two mechanisms for handling idle connections: TCP keepalive, which periodically sends a keepalive packet to the client and resets the idle timer on successful acknowledgment, and Age Out Idle Connections, which terminates idle connections that have not received a keepalive signal after a configurable period. The Idle Duration setting accepts values between 5 and 14,400 seconds, or 0 for an infinite timeout. Administrators configure this in the TCP/UDP Profile settings in the Avi Controller UI under Templates. The Service Engine enforces this setting on back-end connections as well, closing server-side connections once a server has been idle for the configured Idle Duration.

For UDP traffic, the System-UDP-Proxy network profile includes a `session_idle_timeout` parameter with a default value of 60 seconds. This parameter can be adjusted to match organizational requirements for session termination.

Pool-level connection termination is controlled through the Graceful Deactivate Timeout parameter. When set to a value between 1 and 432,000 seconds, Avi stops accepting new sessions to a deactivating server while allowing existing sessions to complete within the specified timeout, after which remaining connections are terminated. Setting the parameter to 0 causes immediate termination of all client sessions to deactivated servers; setting it to -1 allows existing sessions to remain open indefinitely. When a back-end server is deactivated, it continues to process persistent and active connections; new connections are accepted only if they belong to an existing persistent session until persistence times out. Deactivating a virtual service terminates all existing connections immediately.

During Service Engine scale-in operations, the `vs_scalein_timeout` CLI parameter controls the timeout period for secondary Service Engines to gracefully close active connections before scale-in completes.

For HTTP multiplexing, the connection pool Life Timeout parameter specifies the maximum duration a connection can exist in the pool from creation, after which the connection is removed and closed following completion of outstanding requests.

Connection termination events are recorded in Avi's application logs. Significant events logged include connections closed due to the TCP profile idle timeout, connections closed abnormally due to TCP RST from clients or servers, and connections prematurely closed by the client. These records are accessible through the Virtual Service Application Logs in the Avi Controller interface.

Timeout values are configured through the network profile and pool settings in the Avi Controller UI or API. No external platform dependency is required; all mechanisms operate within Avi's own data plane on the Service Engines.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.10

> Establish and manage cryptographic keys for cryptography employed in organizational systems.

SCF Controls: CRY-08, CRY-09

Aggregate Coverage: Meets

VCF (Meets)

VCF provides cryptographic key management controls that protect the confidentiality, integrity, and availability of keys through multiple integrated mechanisms spanning key storage, access control, lifecycle management, and availability safeguards.

At the core of VCF's key management architecture is the CryptoManager managed object hierarchy in the vSphere API. The CryptoManager and its child object CryptoManagerKmp provide programmatic interfaces for managing cryptographic keys, integrating with external key management servers, and performing cryptographic operations. The API exposes methods for adding, listing, and removing keys, giving administrators and automation tools full control over key lifecycle operations.

VCF supports two models for key storage. Organizations can integrate with external Key Management Servers that support the Key Management Interoperability Protocol (KMIP) 1.1 standard, allowing interoperability with a wide range of third-party KMS products. Alternatively, the vSphere Native Key Provider (NKP) is included in all vSphere editions and does not require an external key server. NKP can be added, updated, and removed through the Providers interface in the vSphere API, and its configuration must be exported at least once before it can be used. For organizations that choose an external KMS, administrators establish a trust relationship by uploading a certificate and key file to the KMS vendor, and then select a KMS cluster during encryption configuration. The KMS must appear in the VMware Compatibility Guide for Key Management Servers and be KMIP 1.1 compliant; that guide provides the authoritative list of tested and supported third-party KMS products. Some KMS vendors allow further isolation of encryption keys by specifying dedicated credentials during configuration. Administrators can also configure separate key providers for different users or departments, providing more granular access control over encryption keys by organizational unit. VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts so that keys are accessible only to authorized components.

For organizations consuming VCF services through the multi-tenant consumption layer, VCF Encryption Management extends key management to organization administrators. This feature allows organization administrators to use encryption keys from their own key providers for encryption of virtual machines and disks within their VCF environment, enabling tenant-controlled key custody independent of the platform provider's key management infrastructure.

VCF uses a layered key hierarchy for encryption. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK), with optional wrapping keys protecting KEKs. Disk encryption keys use XTS-AES-256. This layered approach means that rotating or revoking a higher-level key protects all keys beneath it without requiring re-encryption of the underlying data. ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

For virtual machines, the vSphere API supports two recrypt operations: shallow recrypt replaces only the KEK and can be performed while the virtual machine is powered on, while deep recrypt replaces both KEKs and DEKs but requires the virtual machine to be powered off. For vSAN data-at-rest encryption, administrators can generate new KEKs or new DEKs with the option to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. vSAN data-in-transit encryption also supports a configurable rekey interval, defaulting to 1,440 minutes (24 hours) with a range from 30 minutes to 7 days. An Allow Reduced Redundancy option is available for clusters with limited resources during key rotation operations.

Workloads running in VMware Kubernetes Service (VKS) clusters on Supervisor benefit from an additional layer of key management integrated with the same external KMS infrastructure. VKS uses the Kubernetes KMS provider plugin interface to protect data at rest in etcd. The EncryptionConfiguration resource configures a provider of type kms in the providers array on the API server; the plugin communicates with an external Key Management Service via a Unix domain socket endpoint, keeping all key material outside the cluster. The current stable implementation is KMS v2 (available from Kubernetes v1.29), which uses an envelope encryption scheme where each resource is encrypted under a Data Encryption Key (DEK) that is itself

wrapped by a Key Encryption Key (KEK) held in the remote KMS. KMS v2 employs a key derivation function to generate single-use DEKs from a secret seed combined with random data, reducing the frequency of external KMS calls while maintaining per-encryption key uniqueness. KMS plugins are required to verify that a `key_id` presented for decryption was encrypted by them, providing a chain-of-custody check that restricts decryption to the originating plugin. The KMS provider must be listed first in the `EncryptionConfiguration` file to take precedence over any local encryption providers. VKS administrators manage sensitive material such as passwords, tokens, and SSH keys through Kubernetes Secret objects, which are protected at rest by the cluster's encryption-at-rest configuration. For environments requiring centralized secrets management beyond what Kubernetes natively provides, Supervisor and VKS clusters support integration with external vault systems. In CI/CD architectures built on Supervisor through integrations such as Harness or Argo CD, HashiCorp Vault provides dynamic secret generation, access policies, and a centralized store for API keys, certificates, and credentials; dynamic secrets reduce exposure from long-lived credentials by generating short-lived, automatically expiring credentials per service. Secrets are managed outside of source control, with access controls enforced across all components.

VKS node pools can be provisioned using Kubernetes releases that include FIPS cryptographic module support. The `tkr.reference.name` field in the `TanzuKubernetesCluster` specification selects a FIPS-enabled release so that cryptographic operations within the cluster use validated modules. For Windows node pools using Group Managed Service Accounts, a KDS Root Encryption Key must be provisioned on each domain controller by an Enterprise Administrator before Group Managed Service Account credentials can be derived; this key is managed in Active Directory and forms the cryptographic foundation for credential derivation. Certificate lifecycle management for VKS clusters is provided by Cert Manager, which handles issuance and renewal of certificates across cluster workloads. VKS clusters include automatic certificate rotation enabled by default, with renewal initiated 90 days before certificate expiry; this interval is configurable per cluster using the `renewalDaysBeforeExpiry` parameter in the ClusterClass `certificateRotation` variable. Administrators can also rotate certificates manually using the `kubeadm certs renew` command, and the `kubeadm certs check-expiration` command reports expiration dates and residual time for all control plane certificates, including the API server, etcd client, and controller-manager certificates. The Supervisor Kubernetes control plane supports replacing its default certificate with one signed by an external certificate authority, and `CertificateSigningRequest` resources from both the native `certificates.k8s.io` API group and the `cert-manager.io` API group are supported for certificate provisioning and rotation.

Access to key management functions is controlled through vCenter's privilege system. The Cryptographic Operations privilege set provides fine-grained control over encryption tasks, including separate privileges for individual operations. The `Cryptographer.ManageKeyServers` permission is specifically required to manage key servers. A dedicated No Cryptography Administrator system role includes all Administrator privileges except Cryptographic Operations privileges, enforcing separation of duties between key managers and system administrators. Administrators can clone the No Cryptography Administrator role to create custom roles with only selected Cryptographic Operations privileges, such as allowing encryption but not decryption of virtual machines.

For key availability, VCF supports several protective measures. Administrators should deploy highly available KMS clusters when configuring a standard key provider. KMS servers should not be deployed on the same vSAN datastore or cluster that is being encrypted, to avoid circular dependencies that could make keys inaccessible. VCF validates that the KMS is healthy before encryption can be enabled. On ESX hosts, the `esxcli system security keypersistence enable` command allows encryption key persistence, so that hosts can access encrypted workloads after a reboot without requiring immediate KMS connectivity.

Key lifecycle management extends to individual virtual machines and their disks, where different keys may be in use simultaneously. Administrators should take care when managing the lifecycle of these keys to avoid accidental data loss. VCF Operations also provides Keystore Workflows through the orchestrator that help manage certificates and keys within keystores. The vSAN Security Configuration Guide provides additional guidance on selecting appropriate encryption algorithms and managing KMS integration.

When an external key management system is used, responsibility for the lifecycle of keys held in that system, including generation, rotation, escrow, and destruction, rests with the organization operating the KMS; the platform integrates with the KMS through the standard key provider interface but does not manage the external key lifecycle on the organization's behalf.

VMware vDefend (Contributes)

VMware vDefend contributes to cryptographic key management through certificate lifecycle management within the Security Services Platform (SSP) and key pair controls for the Malware Prevention service.

The Security Services Platform manages certificates that identify client and host machines, establish trust between components, secure inter-component communication channels, and control access levels. SSP provides certificate management capabilities including export, certificate signing request (CSR) generation with configurable cryptographic algorithm selection and key size, and replacement with CA-signed certificates. Certificate initialization is handled by CertWatcher, which loads and validates root CA certificates and keys during SSP startup. Administrators should confirm certificate consistency between backup and restored SSP environments to avoid service disruptions during recovery scenarios.

SSP's cryptographic operations use FIPS 140-2 and FIPS 140-3 validated modules: the VMware BouncyCastle Module (Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (Certificate #4861). These validated modules underpin certificate operations and inter-component communications for SSP and its embedded services, including the NDR Sensor for vDefend. Administrators should be aware that TLS protocol version and cipher suite configuration on SSP Installer and SSP cannot be modified; these are fixed by the platform at deployment time. When deploying SSP on vSAN, administrators should activate the data-at-rest encryption option in the vSAN storage policy to provide encryption for SSP data at rest.

For Distributed Malware Prevention, vDefend manages public-private key pairs that secure communication between the malware analysis infrastructure and the hosts it protects. Administrators can configure whether a new key pair is generated per cluster or shared across all service deployments. Private keys must be stored securely, and the deployment strategy gives organizations control over the scope of any single key exposure.

vDefend TLS Inspection includes certificate management as part of its traffic inspection infrastructure. Administrators can manage certificate revocation within the TLS inspection path, and TLS Inspection policies include a Crypto Enforcement option that allows administrators to define the acceptable range of cryptographic strength for inspected connections.

These capabilities address certificate and key material that vDefend generates, consumes, and rotates as part of its security service infrastructure. Broader enterprise key management functions, including external key management server integration, key hierarchy management, and configurable rotation intervals, are provided by VCF rather than by vDefend.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces cryptographic key management requirements across both replication and recovery operations, making key availability a technical prerequisite for protecting and recovering encrypted virtual machines.

For encrypted virtual machine protection, PNR requires that the recovery and protected sites share a common Key Management Server (KMS) or that the KMS clusters at both sites use common encryption keys. The KMS cluster must be registered with the same name on both the protected and recovery sites. PNR maintains a trusted connection between VMware vCenter and the KMS, through which vCenter retrieves encryption keys as needed for encrypted virtual machine disks and other files. If the KMS is not available at the recovery site, encrypted virtual machine recovery fails at the power-on step, making key availability a hard technical requirement for successful failover.

vSphere Replication imposes the same requirements when replicating encrypted virtual machines: the KMS server must be registered with the same name at both source and target sites, and common encryption keys must be present at both locations. Encrypted virtual machines can also be protected using array-based replication protection groups within PNR.

PNR supports the vSphere Native Key Provider as an alternative to external KMS infrastructure. The Native Key Provider enables encryption-related functionality for virtual machines and virtual disks without requiring an external key server, and must be manually configured on both the local and remote sites. The vSphere Native Key Provider requires vSphere Enterprise+ edition.

For its own communications, PNR enforces certificate-based controls. Server SSL/TLS certificates must be x509v3 server certificates with Extended Key Usage attributes specifying both TLS Web Server Authentication (serverAuth) and client

authentication (clientAuth). PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. PNR defaults to a strong TLS protocol version for all connections, with the minimum acceptable version configurable through the `envoy-proxy-config.json` file using the `tls_minimum_protocol_version` parameter.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support cryptographic key management for database infrastructure. These center on certificate and private key handling for the DSM Provider VM and managed database clusters.

Certificate storage in DSM follows the Kubernetes TLS Secret model. Custom certificates for both the DSM Provider VM and individual database clusters are stored as Kubernetes TLS Secrets in the appropriate namespaces. For database clusters, the TLS Secret must reside in the same namespace as the cluster and include a Base64-encoded PEM signed certificate chain, a Base64-encoded PEM private key, and a Base64-encoded PEM CA certificate. DSM stores CA certificates as PEM-encoded data in Kubernetes Secrets within the cluster's namespace, making them available for client trust store configuration.

DSM supports configurable key algorithms for certificate generation. Administrators can specify RSA or ECDSA as the private key algorithm, with supported key sizes of 256 and 384 bits. Starting with version 9.1, DSM enforces FIPS 140-3 compliant cryptographic standards for all certificate handling. Only RSA and ECDSA public key algorithms are accepted; Ed25519 is rejected because it is not FIPS 140-3 compliant. Custom trusted certificates and certificates used during database upgrades must comply with FIPS requirements. DSM validates certificates during upload to reject unsupported algorithms or parameters.

Version 9.1 also introduces explicit KeyUsage enforcement at certificate upload. DSM validates KeyUsage requirements during upload and rejects server certificates that lack proper KeyUsage configuration. Server certificates must carry the `digitalSignature` bit in the KeyUsage extension. DSM accepts certificates that omit the KeyUsage extension entirely, treating the absence as permitting all usages per RFC 5280.

Certificate lifecycle management is supported through integration with Kubernetes `cert-manager`. Organizations can use `cert-manager` to automate certificate issuance, renewal, and rotation; `cert-manager` outputs the result as a Kubernetes TLS Secret in the required format, which DSM then references. Administrators are responsible for renewing Provider VM certificates before expiration and updating the corresponding Kubernetes TLS Secret.

Trust store management is an explicit operational step in DSM deployments. To establish secure connections to database clusters or the DSM Provider VM, clients must add the CA to the operating system trust store. DSM exposes the CA certificate through its API, allowing clients to retrieve it for both the provider VM and individual database clusters.

Password and credential protection in DSM operates at multiple layers. DSM stores local user passwords using PGCrypto symmetric encryption with a dedicated encryption key. PostgreSQL databases on DSM support the `pgcrypto` extension, which provides cryptographic functions for securing data at the database level. PostgreSQL instances enforce a minimum TLS protocol version for client connections via the `ssl_min_protocol_version` setting. MySQL databases on DSM have FIPS mode active on the client side via the `ssl_fips_mode` setting. SQL Server clusters in DSM require TLS for the DSM operator to manage them and support configurable TLS protocol lists via the `network.tlsProtocols` engine setting.

DSM contributes to this control's requirements by providing structured certificate and key storage, FIPS 140-3 aligned cryptographic enforcement, KeyUsage validation at upload, integration with `cert-manager` for lifecycle automation, and API-driven CA certificate retrieval. Full satisfaction of the control requires organizational processes to govern the external certificate authority, define certificate rotation schedules, establish key escrow procedures, and address key availability through backup and recovery planning. The underlying Kubernetes platform's configuration for Kubernetes Secret encryption at rest also affects the overall key management posture.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that support cryptographic key management. The primary mechanism is Hardware Security Module (HSM) integration: the Avi Controller integrates with Thales Luna (formerly SafeNet Luna) HSM for cryptographic key storage and management. Both the Controller and Service Engines support dedicated HSM

interfaces for certificate and key operations through HSM Groups configured at Templates > Security > HSM Groups, enabling organizations to store and manage private keys in tamper-resistant hardware rather than in software on the host. The Controller supports both RSA and EC key and certificate creation directly on the HSM.

For cryptographic algorithm governance, Avi's SSL/TLS Profile Templates define the accepted protocol versions and cipher suites applied to virtual services, configured under Templates > Security > SSL/TLS Profile in the Avi Controller UI. Cipher suites can be restricted or prioritized to match organizational key management policies. Key exchange algorithms for SSH management channels can be restricted on both the Controller and Service Engine Groups through the `kex_algorithm_exclude` field in the CLI, allowing exclusion of weak cryptographic key exchange methods such as `diffie-hellman-group14-sha1`.

When FIPS mode is enabled on the Avi Controller cluster, the Controller restricts all cryptographic operations to FIPS-compliant algorithms. The Controller uses the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP, enabled at the Controller cluster level under Administration settings. This mode provides an enforcement boundary for organizations that require alignment with government-recognized cryptographic module standards.

For cloud deployments, Avi integrates with platform-native key management services. In AWS environments, the Controller can list and use AWS KMS keys, including customer-managed keys (CMKs) with configurable key policies and IAM-governed access, supporting SNS/SQS, S3, and EBS encryption. KMS key access permissions can be scoped to a specific key ID or defined directly in the KMS key policy for tighter access control. In Google Cloud Platform deployments, the Controller supports separate KMS keys for Service Engine disk encryption, GCS bucket encryption, Service Engine image encryption, and GCS object encryption through Cloud KMS keys managed with appropriately scoped IAM roles.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports configuring both RSA and ECC signed certificates simultaneously on a single virtual service through the `alt.crt` and `alt.key` fields in ingress configurations and TLS default secrets. AKO also supports PKIProfile custom resources for certificate-based authentication and encryption with backend services. These capabilities extend Avi's key and certificate management to containerized workloads.

Data-at-rest encryption key management for the Avi Controller and Service Engine virtual machine disks is provided by VCF through VM Encryption and vSAN Encryption with Native Key Provider or external Key Management Server integration.

Control SC.L2-3.13.11

> Employ FIPS-validated cryptography when used to protect the confidentiality of CUI.

SCF Controls: CRY-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF implements cryptographic protections across its component stack using publicly standardized, validated cryptographic modules and algorithms.

Multiple VCF components rely on cryptographic modules validated through the NIST Cryptographic Module Validation Program (CMVP) to FIPS 140-2 and FIPS 140-3 standards. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, and NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. Specific NSX validated modules include IKE with Rambus Safezone 2.0 (Certificate #4898), VMware OpenSSL 3.0.9 (Certificate #4861), VMware BouncyCastle 2.0.0 (Certificate #4986), and VMware BoringCrypto 6.0 (Certificate #4694). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which holds FIPS 140-3 Certificate #4743. VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009 as its validated cryptographic module. This consistent use of FIPS-validated modules across the platform means that organizations deploying VCF in regulated environments can rely on cryptographic implementations that have undergone independent validation against well-known public standards. The VMware Kubernetes Service (VKS) consumption layer also supports FIPS mode: VKS ClusterClass configurations include a `fips.enabled` variable that, when set, restricts cryptographic operations on cluster nodes to approved algorithm implementations. FIPS-enabled Kubernetes release images, identified by a `-fips` suffix in the release reference name, are available for organizations that require FIPS-validated cryptography across their containerized workloads.

At the protocol and algorithm level, VCF enforces modern cryptographic standards throughout. Starting in vSphere 9.0, all TLS profiles are FIPS compliant; the COMPATIBLE profile supports modern TLS cipher suites with standardized elliptic curves. Monitoring infrastructure such as Telegraf enforces a modern TLS minimum version for secure communication. The NSX L2 VPN FIPS compliance suite uses AES-GCM encryption with Perfect Forward Secrecy and Diffie-Hellman Group 20. NSX also supports ECDSA (Elliptic Curve Digital Signature Algorithm) encryption for environments with high-assurance cryptographic requirements. VCF Operations for Networks supports several encryption algorithms and ciphers for its data sources. VCF Operations provides a FIPS Security Mode that, when enabled, applies additional algorithm and cipher prerequisites across the management domain. All system management network communications are encrypted by default using standardized cipher suites. At the VKS layer, Kubernetes control plane components expose parameters for restricting permitted TLS configurations: the `kube-apiserver --tls-cipher-suites` parameter, the `kubelet tlsCipherSuites` configuration field, and the equivalent parameter on the `kube-scheduler` each restrict the set of permitted cipher suites, allowing administrators to exclude deprecated or weak algorithms. The `kubelet tlsMinVersion` field and the `--tls-min-version` parameter on the `kube-apiserver` enforce a minimum TLS protocol version floor for inbound connections. The Antrea networking component and vSphere Cloud Provider Interface on VKS clusters also support configurable TLS cipher suites for component-to-component communication. Kubernetes hardening guidance identifies specific preferred cipher suites and calls out cipher suite configuration on the `kube-scheduler` as a required hardening step. VKS clusters support the Istio service mesh package, which provides mutual TLS between workloads within the mesh; the `meshMTLS.minProtocolVersion` setting controls the minimum protocol version for inter-service communication, defaulting to TLS 1.2 with support for configuring TLS 1.3.

Data-in-transit protections using TLS have customizable PKI keypair and certificate options. These range from fully automated within VCF to semi-automated using certificates from enterprise PKI infrastructure or fully custom certificates installed manually. Automated certificate issuance is supported with Microsoft Active Directory Certificate Services. Trust establishment uses standard PKI management with multiple certificate options including Root CA certificates, CSR-based certificates, and direct certificate uploads. VCF Operations provides centralized certificate lifecycle management for all VCF components, enabling automated certificate renewal, monitoring, and replacement across the infrastructure. Organizations should be aware that if self-signed certificates and private keys are generated using OpenSSL, those certificates and private keys are not FIPS-

compatible. Environments operating under FIPS requirements should use certificate authorities and key generation methods that produce FIPS-compliant artifacts. For FIPS environments, certificates should use key sizes of 2048 or 3072 bits; key sizes greater than 3072 bits have not been tested with FIPS. At the VKS layer, the cert-manager package manages the lifecycle of certificates issued to workloads and ingress endpoints. VKS clusters maintain TLS certificates for component-to-component communication across their control and data planes. The Contour ingress package supports minimum TLS version configuration through the `tls.minimum-protocol-version` parameter. Harbor, when deployed as a Supervisor Service, accepts custom TLS certificate configuration through the `tlsCertificate.tls.crt` and `tlsCertificate.tls.key` fields, allowing organizations to supply certificates from their enterprise certificate authority rather than relying on self-signed certificates. The Supervisor secret injection agent automatically configures mutual TLS for communication with the vault-agent-injector service using auto-generated certificates.

Data-at-rest encryption uses vSAN cluster-based encryption or VM Encryption on non-vSAN storage. vSAN encryption uses AES-NI CPU offloading for efficient processing, and VMware ESX hosts encrypt vSAN disk data using the industry standard AES-256 XTS mode. Encryption keys are managed through KMIP 1.1-compatible external Key Management Servers (KMS) or vSphere Native Key Provider (NKP), which is included in all vSphere editions and does not require an external key server. VCF implements a three-element domain of trust comprising the key provider, VMware vCenter, and vSAN hosts. Key Encryption Keys (KEK) wrap Disk Encryption Keys (DEK) for secure key management; ESX hosts use the KEK to encrypt their internal keys and store only the encrypted internal keys on disk, not the KEK itself.

VCF Standard Key Providers have key wrapping capabilities that let organizations store a single wrapping key in their KMS, protecting multiple Key Encryption Keys within the VCF environment. This creates a three-tier key hierarchy: the Data Encryption Key encrypts object data, the Key Encryption Key protects the DEK, and the wrapping key protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. Key wrapping includes automatic key rotation with configurable intervals from 30 days to 10 years.

With key persistence enabled, ESX hosts can persist encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence can be enabled using the `esxcli system security keypersistence enable` command.

VCF supports guest-level security features including virtual Trusted Platform Module (vTPM) 2.0 for VMs. This enables in-guest encryption capabilities such as Windows BitLocker, Linux disk encryption, and other operating system-native security features. Secure Boot provides UEFI verification to help ensure only signed and trusted code runs during the VM boot process. These features work independently of or in combination with infrastructure-level encryption, allowing organizations to implement defense-in-depth strategies.

vSAN offers Data-in-Transit (DIT) encryption as a cluster-wide setting that encrypts all data and metadata traffic as it transits across hosts. For vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, making DIT encryption strongly recommended to restrict network-level interception. For vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements and risk tolerance. DIT encryption operates without requiring external key management servers and provides independent key rotation from data-at-rest encryption.

Encrypted vSphere vMotion secures confidentiality, integrity, and authenticity of data transferred during VM migrations. For encrypted VMs, vMotion always uses encryption. For unencrypted VMs, encrypted vMotion can be set to Disabled, Opportunistic (default), or Required. Cross-vCenter vMotion is supported when using shared key providers or backup/import of Native Key Provider. VCF uses one-time keys (nonces) for each migration session so that captured traffic cannot be replayed or decrypted after migration completes.

Memory Tiering encryption provides protection for tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance or per host depending on configuration.

VM Encryption provides protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. Disk encryption uses XTS-AES-256 keys as the disk encryption key. This encryption occurs before data reaches the storage layer, providing both data-at-rest and data-in-transit protection.

Kubernetes on VKS supports encryption at rest for data stored within the control plane. Operators configure the encryption provider and manage key access for control plane secrets; when relying on a managed key provider, administrators retain responsibility for access controls over the managed key material. The VCF Automation consumption layer includes VCF Encryption Management, which grants organization administrators the ability to use encryption keys from their own key providers for encryption of virtual machines and disks in their VCF environment, extending the platform's cryptographic key management to tenant-level operations.

For storage protocols, VCF provides varying levels of native encryption support. iSCSI includes CHAP for session authentication. Fibre Channel Gen 7 supports end-to-end encryption with secure HBAs. For NFS datastores, version 4.1 supports Kerberos authentication with three security levels: krb5 (authentication only), krb5i (authentication plus integrity checking), and krb5p (authentication plus privacy with full encryption).

ESX stores configuration data in encrypted form on boot devices. When the host has a TPM 2.0 enabled and configured, the configuration encryption key is stored in the TPM. The encryption mode can be configured using the `esxcli system settings encryption set` command with the `--mode=TPM` parameter.

Cryptographic operations are controlled through fine-grained privileges in vCenter. Only users assigned the Cryptographic Operations privileges can perform cryptographic operations. A dedicated No Cryptography Administrator role enables standard VM and infrastructure management while restricting unauthorized encryption changes. This role can be cloned and customized to grant only specific Cryptographic Operations privileges, such as allowing encryption but not decryption, supporting the principle of least privilege for encryption tasks. The `CryptoManager` and `CryptoManagerKmp` managed objects provide programmatic interfaces for handling cryptographic keys and integrating with key management server infrastructure. vSAN encryption key management requires specific permissions including `Cryptographer.ManageEncryptionPolicy`, `Cryptographer.ManageKeyServers`, and `Cryptographer.ManageKeys`.

vSAN includes secure disk wipe capabilities for proper media sanitization when decommissioning storage, supporting the Erase disks before use option during encryption configuration and disk management operations.

Defining the organization's cryptographic policy (algorithm selection, key strength, rotation schedules, KMS architecture, FIPS-mode activation decisions) and the key lifecycle management standards that govern key creation, distribution, storage, archive, and destruction sit with the organization above the platform. VCF supplies the validated cryptographic modules and protocol enforcement; the organizational cryptographic governance program determines how those mechanisms apply across the environment. Security Technical Implementation Guides (STIGs) for Supervisor and VKS releases are available to guide cryptographic hardening of the consumption layer.

VMware Private AI Services (PAIS) provides cryptographic controls across its AI infrastructure components, building on the cryptographic foundation of VCF.

GPU-accelerated VMware Kubernetes Service (VKS) clusters deployed for PAIS workloads use a FIPS-enabled Kubernetes runtime. The VKS cluster topology version applied to both control plane and worker deployments uses a FIPS-enabled VKR build running on Ubuntu 24.04, so AI workloads on PAIS VKS clusters operate within a FIPS-compliant Kubernetes runtime.

PAIS endpoints use TLS for service communication. The `PAISConfiguration` custom resource supports configurable CA bundle references through `spec.clientTls.caBundleRefs` for OIDC provider and Harbor registry authentication. The Supervisor endpoint communication for PAIS uses HTTPS on port 6443 with certificate-based authentication. The PAIS Prometheus metrics endpoint uses self-signed certificate authentication with TLS, where the CA certificate is retrieved from the `pais-ingress-default Secret` in the PAIS namespace and configured in base64-decoded form. Prometheus TLS client authentication and certificate validation are off by default; auditors should verify that client authentication is enabled in production deployments where mutual certificate validation is required.

PAIS requires CA trust bundles to be configured for all external HTTPS connections, including OIDC providers, Harbor registries, content management systems used as data sources in the Data Indexing and Retrieval service (such as Confluence or SharePoint), MCP servers that provide tools to agents, and the pgvector database server used for vector storage. Trust bundle material is obtained from each external system's administrator either as a certificate file or as a ConfigMap stored in the namespace where PAIS is deployed, and PAIS recommends maintaining separate trust bundles per application with periodic updates before certificate expiration. Administrators add trusted certificates through the VCF Automation Provider Management UI under Certificate Management and Trusted Certificates. The issuer certificate of the Harbor registry must also be added to the certificate trust store on Deep Learning VMs that pull models from the registry. When connecting to an MCP server over HTTPS, the MCP server issuer certificate must be added as a CA trust bundle.

The underlying cryptographic algorithms, cipher suites, and platform-level key management are provided by VCF and VKS. Organizations are responsible for selecting and enforcing approved cryptographic standards at the VCF and infrastructure level, while PAIS provides the certificate management and trust chain configuration mechanisms specific to AI service endpoints.

VMware vDefend (Contributes)

VMware vDefend contributes to the implementation of cryptographic protection controls by using known public standards and trusted cryptographic technologies across its component stack for securing inter-component communications and providing cryptographic inspection capabilities for network traffic.

Security Services Platform (SSP), the control-plane component of vDefend, secures communications between vDefend product components using certificates and current TLS protocol versions with approved cipher suites. SSP and the SSP Installer deploy with the most current TLS version by default and also support the prior major TLS version. The TLS versions and cipher suites allowed on SSP Installer and SSP are fixed and cannot be modified, which enforces a consistent cryptographic baseline across deployments.

SSP components, including the SSP Installer and the NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 cryptographic module standards. SSP uses the VMware BouncyCastle Module (NIST CMVP Certificate #4943) and the VMware OpenSSL FIPS provider Object Module (NIST CMVP Certificate #4861) for its cryptographic operations. SSP actively enforces cryptographic hygiene by rejecting any certificate or TLS configuration that uses deprecated algorithms, short keys, or legacy protocol versions, returning a validation error rather than permitting degraded connections.

Certificate management within SSP provides lifecycle controls including certificate export, certificate signing request (CSR) generation, and CA-signed certificate replacement. SSP monitors and manages several certificate types used to identify client and host machines, establish trust between components, secure communications, and control access levels. Administrators can retrieve and validate LDAP certificates using standard tools to establish secure LDAPS connections for platform authentication. These capabilities allow organizations to integrate vDefend into their broader PKI infrastructure and follow standard certificate lifecycle practices.

vDefend provides TLS Inspection capabilities that allow the firewall to decrypt, inspect, and re-encrypt TLS-protected traffic. Without TLS Inspection, encrypted traffic cannot be examined or enforced against security policies even when other advanced security features are enabled. With TLS Inspection enabled, vDefend gains visibility into encrypted traffic flows, supporting more effective access control and threat detection. TLS Inspection also supports importing or generating trusted and untrusted proxy certificate authorities for external decryption profiles, giving administrators control over the CA chain used in inspection.

TLS Inspection includes a Crypto Enforcement option within decryption action profiles that allows administrators to set minimum and maximum protocol version and cipher suite constraints for both client and server connections. Profiles can be configured in Transparent or Enforce modes; the Enforce mode requires compliance with the configured cryptographic constraints.

vDefend IDS/IPS signature rules extend cryptographic visibility by supporting protocol version matching and certificate Subject field matching, enabling enforcement decisions based on certificate metadata in encrypted traffic. IDS/IPS rules also support storing TLS/SSL certificates to disk for forensic analysis and threat investigation. SSP guidance recommends that

organizations restrict or block protocols that carry data in cleartext and enforce minimum secure protocol versions as part of their network security practices.

vDefend does not itself provide the underlying key management infrastructure (KMS), platform-wide PKI lifecycle management, or the broader VCF platform's cryptographic controls; those responsibilities belong to VCF. However, vDefend's consistent use of approved cryptographic standards for its own operations and its ability to perform cryptographic inspection of network traffic contribute to an organization's overall implementation of cryptographic protection controls.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements cryptographic protections for disaster recovery workflows using known public standards and trusted cryptographic technologies.

PNR uses modern TLS by default for all connections to the PNR server. The minimum TLS protocol version is configurable through the `envoy-proxy-config.json` file by editing the `tls_minimum_protocol_version` parameter. When the minimum protocol version is modified, PNR requires that the change be applied consistently across all relevant configuration occurrences in the system. Administrators can verify the TLS version in use on the Site Recovery Manager component using standard OpenSSL tooling.

The PNR Appliance requires an SSL/TLS certificate as the endpoint certificate for all TLS connections to the PNR server. PNR supports custom certificates signed by a certificate authority as an alternative to self-signed certificates. Custom SSL/TLS server endpoint certificates must meet specific requirements, including x509v3 Extended Key Usage indicating TLS Web Server Authentication. The Appliance Management Interface allows administrators to import CA-signed server certificates and custom root CA certificates, and to replace the appliance certificate. PNR uses TLS certificates and private keys to protect network communication and establish authentication with other servers. Certificate verification error messages are logged in security-related log files, and operational log files do not contain sensitive information such as private keys or passwords.

For encrypted virtual machine replication, PNR requires that the recovery and protected sites use a common Key Management Server (KMS) or that the KMS clusters at both sites share common encryption keys. Replication of encrypted virtual machines also requires Secure LWD support to be available on the virtual machine. This supports data-at-rest encryption continuity for virtual machines through the recovery lifecycle.

Defining the organization's cryptographic policy, including KMS architecture decisions, minimum TLS version selection, certificate management standards, and key lifecycle practices, sits with the organization above the DR layer. PNR supplies the cryptographic mechanisms needed for DR-specific traffic and operations; the organizational cryptographic governance program determines how those mechanisms apply across the environment.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) implements cryptographic protections across multiple layers of its architecture, applying standard cryptographic technologies for data in transit, certificate trust management, and credential storage.

Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms or parameters. Only RSA and ECDSA public key algorithms are accepted for certificates. The Ed25519 elliptic curve signature algorithm is rejected because it does not comply with FIPS 140-3. Custom trusted certificates should use ECDSA P-256 or P-384 algorithms; RSA certificates must meet a minimum key size of 2048 bits per FIPS requirements. DSM's latest certificate validation mode enforces strict cryptographic and KeyUsage validations across all DSM endpoints, including the Provider VM and data service clusters.

For connections to database clusters, DSM requires TLS for all client traffic. PostgreSQL database instances enforce a minimum TLS protocol version through the `ssl_min_protocol_version` setting. MySQL enforces minimum TLS versions on both the main connection interface and the administrative interface; these settings are fixed and cannot be modified by users, which helps maintain a consistent cryptographic baseline across deployments. MySQL also exposes the `group_replication_recovery_tls_version` setting to specify the TLS protocol used during distributed recovery connections. DSM supports SQL Server clusters, which use TLS to encrypt communication between clients and the cluster; the `network.tlsProtocols` custom engine setting defines the allowed TLS versions for client connections, and a minimum TLS

version must be included for the DSM operator to manage the cluster. DSM supports TLS verification during PostgreSQL database migration, covering replication traffic between source and target clusters.

DSM's certificate management capabilities support standard PKI practices. Administrators configure custom TLS certificates for database clusters through the DSM UI or API, providing certificates in PEM format with associated private keys and CA certificates. Supported private key algorithms are RSA and ECDSA with key sizes of 256 and 384 bits. When present, the X509v3 KeyUsage extension on a custom certificate must include the DigitalSignature capability; DSM also accepts certificates that omit the KeyUsage extension entirely, treating absent KeyUsage as permitting all usages in accordance with RFC 5280. To establish secure connections to database clusters and to the DSM Provider VM, clients add the CA to the operating system trust store or the trusted CA list. DSM's API provides a mechanism to retrieve the CA certificate from a custom certificate secret. The Consumption Operator, which enables self-service database provisioning, requires a TLS certificate for its communication with the DSM provider. Certificate management can also be handled through Kubernetes cert-manager, which manages various issuer types and outputs Kubernetes TLS Secrets in the format DSM requires.

DSM supports TLS for connections to external systems. When configuring log forwarding to an SMTP server, DSM supports Auto TLS to establish a secure connection. For private container registries, DSM supports CA certificate validation for untrusted registries.

For local user credential storage, DSM encrypts passwords using PGP symmetric encryption through the PGCrypto library, with dedicated encryption keys stored using the PGCRYPTO_PASSWORD and PGCRYPTO_ALGORITHM keys. MySQL has FIPS mode available on the client side through the `ssl_fips_mode` setting. PostgreSQL databases include the `pgcrypto` extension, which provides cryptographic functions that applications can use directly within the database. The DSM Provider Appliance includes virtual machine encryption, which activates when a Key Management Server is configured in the environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides configurable SSL/TLS profiles that control which cipher suites, protocol versions, and key exchange algorithms are permitted for application traffic termination. The SSL/TLS Profile, configured under Templates > Security > SSL/TLS Profile, contains the accepted protocol version list and a prioritized cipher suite list applied to virtual services. Administrators can create custom profiles or select from built-in templates; the documentation notes that the choice of accepted ciphers and protocol versions involves trade-offs between security, client compatibility, and computational expense. SSL profiles in 9.1 include a Post Quantum Cryptography section with support for modern cipher suites. Controller SSL/TLS certificates support elliptic curve (EC) or RSA algorithms, with EC recommended for new deployments.

For environments subject to cryptographic module validation requirements, Avi supports a FIPS mode backed by the OpenSSL FIPS Provider, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by the Cryptographic Module Validation Program (CMVP). When FIPS mode is activated on the Controller cluster, Avi restricts cryptographic operations to FIPS-compliant algorithms only. FIPS 140-3 also requires stricter handling of sensitive security parameters including keys, authentication data, and random number generation. FIPS mode is enabled at the Controller cluster level through the Controller settings. Note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which may affect certain scripted traffic inspection use cases.

Avi Controller allows administrators to restrict specific key exchange algorithms and ciphers for management session access. The Allowed Ciphers field restricts management session ciphers to a specified subset, and the `kex_algorithm_exclude` field under Controller Settings excludes specific key exchange methods for SSH-based administrative access. Internal communications between the Avi Controller and Service Engines also use SSL/TLS, and custom certificates can be selected for this Secure Channel connection via the Access tab certificate field.

For certificate management, Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. The Controller is set up as an HSM client and can create keys and certificates directly on the HSM through client libraries, supporting high-availability HSM configurations. Automated certificate lifecycle management is available through Let's Encrypt integration using the ACME protocol. Avi's App Transport

Security feature supports integration with the Venafi Trust Protection Platform for certificate administration across tenants, with the Trust Protection Platform pushing signed certificates and required chain certificates to Avi Load Balancer.

For Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports PKIProfile-based certificate validation and trust management for backend services. The PKIProfile, configured through custom resources, enables secure communication with backend services through certificate-based authentication and encryption. In VCF environments, the Avi PKI Profile defines the list of trusted certificate authorities permitted to sign client certificates and can be used to implement Zero Trust security between servers and clients.

Data-at-rest encryption for Avi Controller and Service Engine VMs is provided by VCF at the platform layer, not by Avi itself. Organizations must configure Avi SSL/TLS profiles, select appropriate cipher suites, and enable FIPS mode where cryptographic module validation requirements apply to activate these controls.

Control SC.L2-3.13.12

> Prohibit remote activation of collaborative computing devices and provide indication of devices in use to users present at the device.²⁹

SCF Controls: END-14

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.13

> Control and monitor the use of mobile code.

SCF Controls: END-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.14

> Control and monitor the use of Voice over Internet Protocol (VoIP) technologies.

SCF Controls: NET-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L2-3.13.15

> Protect the authenticity of communications sessions.

SCF Controls: NET-09

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple mechanisms to protect the authenticity and integrity of communications sessions across its management interfaces, API endpoints, and infrastructure components.

Session identity and token management

VCF's VMware vCenter includes a SessionManager service that provides the interface to the authentication infrastructure on the target server system. Each session is associated with a specific user account for its full duration, and valid session identifiers are used to establish and verify the identity of principals and to establish trust with API endpoints. A session ID acquired from SessionManager is a temporary substitute for username and password, limiting risk to the principal's credentials. The Common Infrastructure Services (CIS) Session service provides additional token management capabilities, including creation, deletion, and retrieval of session information. The client API supports session maintenance through HTTP cookies via the SESSION_MAINTAIN_PROPERTY setting, and a session preservator capability saves user sessions and acquires persistent tokens to preserve identity across reconnections. Administrators should define Release Session Requests when using session authentication to properly log out sessions and reduce the risk of session leaks. Concurrent session monitoring is recommended to detect excessive session creation that could indicate unauthorized activity or resource exhaustion.

At the Consumption layer, the Kubernetes Secrets API provides a mechanism for storing and distributing session tokens and other short-lived credentials to workloads without exposing them in pod specifications. The operator pattern allows a controller to fetch short-lived session tokens from an external service and create Secrets that pods consume, keeping token issuance and refresh logic separate from pod implementations. Using short-lived Secrets limits the exposure window when credential data is inadvertently disclosed. For workloads running as VMs through VM Service, secrets can be injected via a disk-based sidecar mechanism, where a trusted pod retrieves secrets and makes them available to the VM without direct credential exposure in pod specifications.

Transport-layer encryption for session communications

All management plane communications across VCF are encrypted using TLS. NSX Manager session communications are encrypted to restrict session hijacking, and NSX authentication mechanisms are resistant to replay attacks. NSX uses mutual TLS authentication based on self-signed or CA certificates between transport nodes (hosts) and the Central Control Plane, providing bidirectional identity verification for infrastructure-level sessions. vCenter API authentication transports credentials over HTTPS with TLS encryption. VCF Operations supports enforcement of TLS for secure communications through the ServerCertificateValidationCallback configuration. VCF Operations for Networks also supports TLS for its communications.

NSX BGP neighbors can be configured with message authentication to apply integrity checks to routing protocol messages, protecting the integrity of routing sessions between network components. NSX remote logging can be configured to use TLS for secure log transport. VCF supports SSH fingerprint verification for remote server connections, allowing administrators to confirm they are connecting to the correct server and providing protection against interception attacks. Metadata exchanged between service providers and identity providers includes information required for establishing trust and facilitating secure communication, supporting session authenticity at the federation layer.

At the Consumption layer, the Kubernetes API server in VMware Kubernetes Service (VKS) clusters on vSphere Supervisor operates exclusively over TLS, establishing authenticated and encrypted sessions between clients and the API server. Secure communications between all Kubernetes control plane services are implemented using certificates. For service-to-service session integrity within a cluster, Istio is available as a standard package on VKS clusters and provides mutual TLS encryption between services with identity-based authentication and authorization, so that each service authenticates the other before

establishing a session. Organizations whose workload sensitivity warrants it should deploy a service mesh to encrypt all intra-cluster communications.

API session authentication

NSX Manager supports session-cookie-based API authentication over TLS. Cookie-based authentication is enabled by default, and subsequent API calls use the session cookie and XSRF token for request validation rather than transmitting credentials with each request. VCF Automation uses OAuth access tokens for session management. Device authorization tokens issued by VCF Automation expire in 3600 seconds by default, and API access tokens have their own configurable expiration periods. The access token returned upon successful authentication through VCF Automation's identity provider proxy is valid for 5 minutes, requiring periodic refresh.

At the Consumption layer, the Kubernetes API server in VKS supports client authentication via service account tokens, X.509 client certificates, OIDC tokens, and webhook tokens, depending on the deployment configuration. Audience-aware token authentication validates that a token was specifically issued for the target API server by verifying the token against the server's expected audience identifier, which restricts token reuse across different services. For container registry operations, Harbor Registry (available as a standard package on VKS clusters) uses shared secrets for inter-component communication among its core server, job service, and registry components.

Session lifetime controls

Session lifetimes are bounded by configurable timeouts to limit exposure from idle or abandoned sessions. NSX Manager session expiry defaults to 1800 seconds (30 minutes) and can be adjusted using the CLI or API. VCF Operations session inactivity timeout defaults to 30 minutes. VCF Operations for Networks supports user session timeout configuration with values ranging from 15 minutes to 24 hours, defaulting to 15 minutes. The VMware ESX Host Client session timeout controls the duration before an inactive host management session is terminated. The vCenter session timeout for unified VIM/vAPI sessions can be configured through the vpx.conf file or the vSphere Client UI.

At the Consumption layer, Kubernetes guidance recommends setting short lifetimes on certificates and automating their rotation to reduce the window of opportunity for credential exploitation. Using short-lived Kubernetes Secrets for session tokens further limits the impact of credential exposure.

PKI infrastructure and cryptographic foundation

The PKI infrastructure that underpins session security offers multiple certificate management options. VCF supports fully automated certificate issuance within the platform, replacement of default certificates with enterprise CA certificates, and integration with Microsoft Active Directory Certificate Services using a restricted service account for least-privilege access. NSX cryptographic modules are validated to FIPS 140-3 standards by the NIST Cryptographic Module Validation Program (CMVP), and NSX is configured to use FIPS 140-3 validated cryptographic modules by default. VCF Operations for Networks uses FIPS-validated cryptographic modules matching those specified by the FIPS 140-2 standard.

VKS clusters on vSphere Supervisor include a set of TLS certificates that support the cryptographic infrastructure for secure communications among cluster components; these certificates can be manually rotated through the VKS certificate management interface when needed. For ingress traffic, the Contour ingress controller is available as a standard package on VKS clusters and uses internally issued certificates with configurable validity periods to secure communications between the Contour controller and its Envoy proxies. Leaf certificates default to 720 hours and the CA certificate defaults to 8,760 hours; both durations are configurable.

Data plane session integrity

For data plane sessions, encrypted vSphere vMotion secures the confidentiality, integrity, and authenticity of VM migration traffic. Encrypted vMotion can be set to Opportunistic (use encryption if supported) or Required (do not migrate if unsupported), and vSphere always attempts encryption when migrating encrypted virtual machines. Fault Tolerance (FT) logging traffic between primary and secondary VMs, which replicates guest network and storage I/O data as well as memory contents, is unencrypted by default and should be isolated on a dedicated network segment; vSphere supports optional

encryption of FT log traffic to protect the integrity and confidentiality of this inter-host session channel. vSAN data-in-transit encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic as it transits across hosts and file service inter-host connections. NSX IPSec VPN supports certificate-based authentication for site-to-site VPN sessions, where the site certificate configured on the local endpoint is used for mutual authentication.

VMware vDefend (Contributes)

VMware vDefend (DFW) and Gateway Firewall provide stateful session tracking that monitors entire conversations between endpoints, enforcing session boundaries and detecting anomalous session behavior. DFW rules can be configured with TCP strict mode (tcp-strict-mode), which enforces connection state validation and drops packets that do not conform to expected TCP state transitions. Session Timers define how long a session is maintained on the firewall after inactivity, with configurable timeouts for TCP, UDP, and ICMP sessions that can be applied to user-defined groups or Tier-0 and Tier-1 gateways.

Security Intelligence analyzes flow data to identify unexpected communications between workloads, enabling exception policy creation to protect required inter-workload sessions. Security Intelligence also detects suspicious behavior associated with remote connection protocols such as telnet, SSH, and VNC.

vDefend TLS Inspection extends session integrity enforcement to encrypted traffic by detecting advanced threats transmitted over encrypted channels. TLS Inspection includes certificate revocation list validation to restrict sessions using revoked certificates. vDefend IDS/IPS detects sessions using obsolete transport protocols by combining port verification with application identification, covering clear-text protocols and outdated transport protocol versions.

Security Services Platform (SSP) establishes its own external communications using TLS handshake negotiation and rejects any certificate or TLS configuration that uses deprecated cryptographic algorithms or older protocol versions. Network Detection and Response (NDR) uses SSL verification for event logs sent over HTTPS.

vDefend does not provide cryptographic end-to-end session authentication or confidentiality between communicating endpoints; those protections require application-layer or infrastructure-layer controls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) protects the authenticity and integrity of management and replication sessions through several mechanisms. PNR uses TLS certificates and private keys to protect network communication and to authenticate with remote servers. Replication traffic between protected and recovery sites supports optional network encryption.

For service-to-service authentication, the PNR server acquires a holder-of-key SAML token from VCF SSO and sends the token in a cryptographically signed message to remote services. Remote services validate the signature to confirm the identity of the calling service before accepting requests, which helps protect against token reuse across paired sites.

The PNR REST API Gateway enforces explicit session lifecycle controls. Callers authenticate through the Authentication API POST endpoint, which returns a session identifier that must be included as the x-dr-session header on subsequent requests. A DELETE endpoint terminates an authenticated session, and a GET endpoint returns information about the current session if one exists. The Site Pairing REST API uses a POST endpoint to create an authenticated session to a remote PNR server, and a Validate Connection POST operation tests connectivity to a remote appliance before pairing.

PNR records session-related activity in security log files, including login events with timestamps, user identity, session keys, and locale information. Certificate verification errors and connection failures during authentication attempts are also recorded in the log files and in the user interface. The logManager.SessionManager setting controls the verbosity of session management logging, with a default value of verbose. PNR monitors active site-to-site connections by sending periodic ping requests and logs connection check events, so broken connections are detected operationally.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides session integrity mechanisms for database and management-plane communications through certificate-based encryption and strong authentication. Database cluster connections use TLS certificates for client connectivity and monitoring. DSM stores PEM-encoded certificate authorities in the ca.crt property of Kubernetes Secrets for database cluster authentication, and administrators can configure custom CA certificates per database

cluster through the DSM UI. The DSM Provider Appliance supports secure TLS connections validated against a trusted CA. DSM also establishes secure connections to VMware vCenter using certificate validation. This certificate validation chain supports session authenticity by confirming that connections reach the intended endpoint before data exchange begins. DSM requires that certificate expiration dates are verified to maintain secure operations, with the alerting system tracking certificate validity as part of its monitoring coverage.

For PostgreSQL databases, DSM uses host-based authentication (HBA) configured through `pg_hba.conf` rules. These rules apply ordered matching based on connection type, client address, requested database name, and username, and the first matching record determines the authentication outcome. DSM supports `scram-sha-256`, `reject`, and `cert` as configurable authentication methods for custom HBA entries, giving administrators control over which connection patterns are accepted or denied. The `scram-sha-256` method is the default for standard user accounts and internal accounts including `pgadmin` and `postgres_exporter`. Administrators can configure additional HBA entries to include LDAP-backed authentication where directory service integration is desired. DSM also supports enabling or disabling directory service authentication on a per-database-instance basis through the database settings interface.

PostgreSQL replication session integrity is maintained through a trust bundle and dedicated replication credentials that authenticate connections between primary and secondary instances. Replication connections support SSL/TLS encryption with a configurable `sslmode` parameter to scope encryption to approved connection modes. For remote replication, users with the DSM user role must manually establish trust between primary and secondary instances before replication begins. For MySQL, DSM verifies network access to the source database and validates SSL trust during replication operations, and controls TLS protocols permitted during group replication recovery connections through the `group_replication_recovery_tls_version` setting.

For SQL Server databases, DSM uses TLS to encrypt communication between clients and SQL Server clusters. An internal management login (`dsm_mgmt`) restricts access to system-level objects, scoping administrative operations within a secure context.

The DSM Consumption Operator requires a TLS certificate for secure communication between the operator and the DSM provider, obtained and saved by the Cloud Administrator as part of operator installation. Metrics forwarding from DSM to VCF Operations supports Mutual TLS (mTLS) authentication, enabled by configuring the Client Certificate Authentication toggle along with the client certificate and private key, extending mutual authentication to management-plane communications. Connection activity logging is available for PostgreSQL through the `log_connections` parameter, which records connection attempts and the successful completion of client authentication, supporting session visibility alongside the integrity controls.

DSM session integrity mechanisms apply to DSM-managed database connections and management-plane communications. Session integrity for non-database services, user interfaces outside DSM, and broader organizational network communications relies on platform-level and organizational controls. Operators are responsible for managing CA certificate trust stores, configuring HBA rules suited to their environment, and applying network-layer session protections beyond what DSM configures directly.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides multiple application-layer mechanisms that contribute to protecting the authenticity and integrity of communications sessions.

TLS termination is the primary session-integrity mechanism for application traffic. Avi Service Engines terminate SSL/TLS sessions on behalf of backend applications, with SSL profiles controlling the allowable cipher suites for each virtual service. The SSL Cipher Strength setting governs the cipher strength used to authenticate applications to clients. During SSL handshake processing, Avi negotiates protocol version and cipher suites to establish authenticated, encrypted sessions. Avi also supports TLS session persistence, which maintains session continuity using TLS session tickets with automated mirroring across Service Engines, without adding processing overhead.

The System-Secure-HTTP application profile secures HTTP traffic by enforcing HTTPS, protecting cookies, managing client IPs, and controlling protocol behavior for virtual services. This provides a consistent session-security baseline for HTTP application workloads and can be assigned to virtual services during advanced setup.

For HTTP application workloads, Avi provides Cross-Site Request Forgery (CSRF) protection through session token management. When a session ID is invalid or absent, Avi creates a new session for the request and restarts the CSRF protection flow from token creation, helping maintain the integrity of application sessions against forged requests.

For internal control-plane communications, Avi establishes a secure TLS session between an Envoy proxy on each Service Engine and the Avi Controller. Secure Channel Certificates for Controller-to-Service Engine communication are configured in the System Settings administration panel under Administration > System Settings.

At the management plane, Avi's User Profile includes a Maximum Concurrent Login Sessions feature that restricts simultaneous active sessions per administrator account to a configurable threshold. When the threshold is reached, existing sessions can be invalidated using the `--clear-sessions` shell command.

For BGP routing sessions, Avi supports MD5 authentication. When BGP authentication is enabled, each TCP segment exchanged between BGP peers is verified and accepted only when authentication succeeds, blocking unauthorized peer session establishment.

In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports session affinity through the HTTPRule Custom Resource Definition (CRD), which provides cookie-based session persistence for application workloads managed by Avi ingress controllers. Avi also supports MCP load balancing with session affinity based on unique MCP Session IDs, maintaining connection persistence between clients and servers for AI model serving workloads.

In distributed deployments, GSLB Site Persistence directs all requests in a long-lived transaction from a client to the same server, maintaining application session integrity across sites.

Avi requires that all external communication-related authentication failures be logged and persisted for auditing purposes, covering session establishment and authentication events across the platform.

Administrators should configure SSL profiles, cipher suites, CSRF policies, session limits, and the System-Secure-HTTP application profile for each virtual service and user profile based on the sensitivity of the applications and the organization's session security requirements.

Control SC.L2-3.13.16

> Protect the confidentiality of CUI at rest.

SCF Controls: CRY-05, END-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple cryptographic mechanisms for protecting data at rest across its infrastructure stack, primarily through vSAN data-at-rest encryption and vSphere Virtual Machine Encryption.

vSAN data-at-rest encryption is the primary mechanism for protecting stored data within VCF. When enabled on a vSAN cluster, vSAN encrypts everything in the vSAN datastore, including all files, virtual machines, and their corresponding data. This protection extends to scenarios where a physical storage device is removed from the cluster, as the encrypted data remains unreadable without the proper keys. vSAN supports both Original Storage Architecture (OSA) and Express Storage Architecture (ESA) deployments, with encryption behavior varying by architecture. For OSA, data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, and each disk has a different randomly generated Data Encryption Key. For ESA in hyperconverged infrastructure mode, data is encrypted at the VM host before network transmission, and all disks in the cluster use the same DEK to encrypt object data. In OSA, encryption occurs after other data processing operations such as deduplication and compression, preserving storage efficiency. vSAN encryption is the recommended approach for securing data on vSAN datastores because it is designed to be compatible with vSAN deduplication and compression, whereas virtual machine encryption causes these storage efficiency features to become less effective.

vSphere Virtual Machine Encryption provides an alternative or complementary data-at-rest encryption layer that works across all datastore types, including vSAN, iSCSI, NFS, and Fibre Channel. VM Encryption occurs before data reaches the storage layer, protecting virtual machine files and disks regardless of the underlying storage technology. This can be applied on a per-VM basis and operates independently of the underlying storage layer, making it applicable to environments where granular, VM-level encryption control is required. Most virtual machine files, in particular guest data not stored in the VMDK file, are encrypted. When combined with storage-level encryption, administrators should evaluate the performance impact of multiple encryption layers on latency and throughput, as well as the potential loss of storage efficiency features like deduplication and compression.

For organizations consuming VCF through the VCF Automation layer, VCF Encryption Management extends these VM and disk encryption capabilities to the namespace level. This service allows organization administrators to use encryption keys from their own third-party key providers to encrypt VMs and disks within a VCF Automation namespace, and also supports encrypting VMs with a Virtual Trusted Platform Module (vTPM). Provider administrators must register a default standard key provider in VMware vCenter before organization administrators can configure namespace-level encryption; the vSphere Native Key Provider cannot be used in this role, and key providers must be listed in the VMware Compatibility Guide for Key Management Servers. Organization administrators configure encryption by setting up a key provider and creating a namespace encryption class. Configuration of key providers requires either the Encryption Management Admin role or a custom role that grants the right to configure key providers.

Both encryption mechanisms require a key management infrastructure. VCF supports integration with KMIP 1.1-compatible external Key Management Servers (KMS) or the built-in vSphere Native Key Provider (NKP). VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts. When using a Standard Key Provider, the KMS sends keys to vCenter upon request, which are used as the Key Encryption Key (KEK) and are AES-256 keys. Standard Key Providers support key wrapping, creating a three-tier key hierarchy: Data Encryption Keys (DEK) encrypt object data, Key Encryption Keys (KEK) protect the DEK, and a wrapping key stored in the KMS protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. When using an external KMS, the recommendation is to deploy highly available KMS clusters to distribute the keys that encrypt the vSAN datastore, avoiding a single point of failure in the encryption key chain. The vSphere Native Key Provider offers a simpler deployment model for environments that do not require an external KMS. Native Key Provider equips each participating host with decryption keys so hosts can operate independently of network-accessible key servers.

vSAN supports key rotation for both Key Encryption Keys (KEK) and Data Encryption Keys (DEK), with the capability to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. Key wrapping supports automatic key rotation with configurable intervals. This allows organizations to meet key lifecycle management requirements without disrupting operations. Encryption can also be enforced through vSAN storage policies, where the data-at-rest encryption option can be specified as a policy attribute, allowing administrators to define which datastores require encryption when provisioning virtual machines.

VCF supports virtual Trusted Platform Module (vTPM) 2.0 for virtual machines, enabling in-guest encryption capabilities such as Windows BitLocker and Linux disk encryption. Virtual machines can include various forms of encryption: VMs using a vTPM device, VMs with disks encrypted, and VMs with encryption enabled without disks encrypted. These guest-level encryption features work independently of or in combination with VMware's infrastructure-level encryption, supporting defense-in-depth strategies.

ESX hosts store their configuration data in encrypted form. When the host has a physical TPM 2.0 enabled, the configuration encryption key is stored in the TPM. Core dumps on an ESX host that has encryption mode enabled are always encrypted. ESX also supports key persistence as a cache for encryption keys in environments where a KMS may be unavailable. With key persistence enabled, ESX hosts can persist the encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence requires that the ESX host has a TPM, and can be enabled using the `esxcli system security keypersistence enable` command.

Memory Tiering encryption protects tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance. During vMotion, tiered memory pages are decrypted and transmitted over the encrypted vMotion channel, with new keys generated at the destination.

For access control over cryptographic operations, VCF provides the No Cryptography Administrator role, which supports all Administrator privileges except for the Cryptographic Operations privileges. This allows standard VM and infrastructure management while restricting unauthorized encryption changes. The No Cryptography Administrator role can be cloned to create custom roles with only specific Cryptographic Operations privileges, providing fine-grained control over encryption-related tasks.

The cryptographic modules used across VCF components are validated against industry-standard best practices. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program (CMVP). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 as a validated cryptographic module. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic algorithms including AES, ECDSA, HMAC, RSA, and SHA2 variants, as well as VMware OpenSSL FIPS Object Module versions 3.0 and 2.0.20-vmw, which collectively support AES, CKG, DRBG, DSA, ECDSA, HMAC, KAS-SSC, RSA, SHS, Triple-DES, SHA-3, and additional key derivation functions. ESX hosts use FIPS 140-2 validated cryptographic modules that implement security functions as a combination of hardware, software, and firmware. vSAN encryption uses AES-NI CPU offloading for efficient processing.

For workloads deployed through VMware Kubernetes Service (VKS) on vSphere Supervisor, the Kubernetes control plane supports encryption at rest for API objects stored in etcd. The kube-apiserver implements this through the EncryptionConfiguration API, specified via the `--encryption-provider-config` argument. When configured, Secrets, ConfigMaps, and other designated resource types are encrypted on write to etcd. The kube-apiserver supports an external KMS provider as well as local encryption keys; when using local keys, the aescbc provider encrypts data using Base64-encoded secret keys specified in the EncryptionConfiguration resource. Using an external KMS is the recommended approach for production environments, as it allows keys to be managed and rotated independently of the cluster configuration. Encryption at rest for the Kubernetes control plane is not enabled by default; the default identity provider stores data in plaintext, and administrators must explicitly configure EncryptionConfiguration to activate it. After enabling EncryptionConfiguration, existing objects remain unencrypted until they are read and re-written. The Kubernetes etcd

encryption mechanism does not extend to data stored in filesystems mounted into containers; for container workload data on persistent volumes, encryption depends on the underlying storage layer. vSAN File Service volumes used with vSphere Supervisor are mounted without encryption by default, so workloads relying on shared file volumes must address encryption at the storage layer or within the application. Kubernetes Secrets encrypted at rest are also protected from disclosure if an attacker gains access to etcd backup data.

Classifying which data requires encryption, selecting between vSAN encryption, VM encryption, or both for specific workload categories, choosing the Key Provider model, and operating the key lifecycle (rotation, revocation, archive, destruction) are organizational data-policy decisions.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to endpoint device protection by providing the network security layer that shields workloads from threats traversing the virtual network. While the full scope of endpoint protection spans hardware trust, hypervisor integrity, storage resilience, and lifecycle management addressed by other VCF components, vDefend addresses the network-facing attack surface that endpoints are exposed to.

The Distributed Firewall (DFW) enforces security policies at the vNIC level, meaning every virtual machine's network interface is individually protected regardless of network topology. Administrators can define microsegmentation policies using object tagging, security tags, workload-centric grouping, IP-based groups, MAC-based groups, and tag-based groups. This allows organizations to establish both broad zone-based segmentation and granular per-workload rules that restrict lateral movement between endpoints. The Distributed Firewall supports layer 2 through layer 7 filtering, enabling policies based on application identity and context rather than just IP addresses and ports. Gateway Firewall extends this protection to north-south traffic at the edge, applying consistent security policies to traffic entering and leaving the environment. The Identity Firewall extends policy enforcement to physical devices through event log scraping, enabling consistent identity-based rules across virtual and physical endpoints.

vDefend IDS/IPS provides signature-based intrusion detection and prevention on both the Distributed Firewall and Gateway Firewall. The IDS/IPS engine evaluates network flows against intrusion detection rules and generates alert events based on protocol and application identification. Organizations can upload custom signature bundles to detect threats specific to their environment. This capability helps protect endpoint confidentiality and integrity by detecting and blocking exploit attempts, command-and-control communications, and other malicious network activity before it reaches the endpoint.

Malware Prevention Service adds file-based and fileless malware detection to the Distributed Firewall and Gateway Firewall. The distributed malware prevention architecture uses a Host Agent (MUX) component running on each ESX host together with Guest Introspection thin agents installed on guest VMs to collect file, network, process, registry, and system events from within the endpoint. Guest Introspection supports thin agents on both Linux and Windows virtual machines. When traffic passes through a firewall rule with a malware prevention profile, intercepted files are analyzed for malicious content. The service includes cloud sandboxing with artifact analysis for unknown files, running suspicious files in isolated environments to observe their behavior. When files are identified as malicious, the service can take active remediation actions on the endpoint, including denying access to suspicious files or deleting confirmed malware. Fileless malware detection identifies attacks that operate within system memory using existing binaries. This provides a network-inline layer of malware defense that complements any endpoint-resident security tools.

Network Detection and Response (NDR) correlates events from IDS/IPS, malware prevention, and suspicious traffic analysis to identify multi-stage attack campaigns targeting endpoints. NDR uses detectors to classify suspicious network traffic and associates detections with specific MITRE ATT&CK techniques and tactics. This correlation capability helps identify threats that individual detection mechanisms might miss when viewed in isolation.

Security Services Platform (SSP) provides security segmentation scoring that measures how well endpoints are protected. The scoring system evaluates environment protection, checking whether workloads are covered by environment-specific segmentation policies such as Dev, Prod, and Test, and infrastructure protection, assessing whether infrastructure workloads like DNS, NTP, and DHCP are explicitly protected. This gives administrators visibility into endpoint protection posture and

identifies gaps in segmentation coverage. SSP is deployed with high availability by default to maintain continuity of security services.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) preserves and integrates with the data-at-rest encryption capabilities of the underlying VCF platform, so that encrypted virtual machines remain protected through replication and recovery operations. The encryption mechanisms themselves, including VM Encryption, vSphere Native Key Provider, external key management servers, and storage policies, are VCF platform capabilities; PNR's role is to maintain encryption continuity through the disaster recovery lifecycle.

vSphere Replication within PNR supports replication of encrypted virtual machines when vSphere Native Key Provider (NKP) or a common external Key Management Server (KMS) is configured at both sites. When NKP is used, it must be configured manually on both the local and remote sites, and the NKP ID assigned to the encrypted VM on the local site must match the NKP ID on the remote site. NKP enables encryption without requiring a separately deployed external KMS; vSphere Enterprise+ licensing is required for NKP. Replica disks must be located on datastores accessible through at least one host in a VMware vCenter cluster. A VM Storage Policy with VM Encryption enabled must be applied to target disks to enforce encryption continuity during replication configuration. Replication configuration using seed disks together with a vSAN target datastore and a VM Encryption Policy storage policy is not a supported combination.

Not all PNR replication methods support encrypted virtual machines. vSAN Snapshots and Replication, an alternative replication method within PNR, does not support replication of encrypted VMs. Organizations that require encrypted VM replication should configure protection groups using vSphere Replication rather than vSAN Snapshots and Replication.

vSphere Replication also supports optional network encryption of replication traffic, which can be enabled during replication configuration to protect data in transit between source and target sites.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SC.L3-3.13.4e

> isolation 70

SCF Controls: NET-02, NET-03.7, PES-04.1, PES-12, PES-18

Aggregate Coverage: Meets

VCF (Meets)

VCF implements network security as a series of independent, layered functions that operate at distinct points in the network path. Each layer enforces its own policies without relying on the correctness or availability of other layers, satisfying the principle of layered defense with minimal inter-layer dependence.

At the hypervisor level, VMware ESX defines network security policies through HostNetworkSecurityPolicy, which governs traffic behavior on virtual switches independently of any overlay network configuration. This provides a baseline layer of network security enforcement at the physical host boundary. The vSphere networking security policy, implemented in Layer 2 of the network protocol stack, protects traffic against MAC address impersonation and unwanted port scanning on both standard and distributed switches. ESX also supports UEFI Secure Boot and Trusted Platform Module (TPM) for boot-time integrity verification, and TPM event logs can be retrieved for attestation and boot measurement validation. Each ESX host enforces its own boot chain integrity independently of the management plane above it.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. DVFilters provide a packet-level interception mechanism within the virtual switch layer, enabling security functions to inspect and act on VM traffic independently of overlay or gateway controls.

NSX provides a tiered gateway architecture that creates a well-defined routing hierarchy. Tier-0 gateways handle North-South connectivity between the NSX logical network and the physical infrastructure, with external interfaces to upstream networks and router links to Tier-1 gateways. Tier-1 gateways connect southbound to network segments and northbound to Tier-0 gateways. Each tier enforces its own policies without relying on the other.

NSX segment security provides stateless Layer 2 and Layer 3 filtering at the network segment boundary. This function checks ingress traffic to the segment and drops unauthorized packets by matching IP addresses, MAC addresses, and protocols against a set of allowed values. Because segment security operates statelessly at L2/L3, it functions independently of higher-layer stateful inspection or application-level controls.

At the identity layer, VCF centralizes authentication through VCF SSO, and all VCF components use role-based access control (RBAC) to restrict access to authorized users. NSX extends RBAC with project-scoped roles, so that network and security administrators have permissions only within their assigned project rather than the entire NSX deployment. NSX VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. Custom roles can be created for more granular delegation.

NSX multi-tenancy through Projects enables isolation of networking configurations across tenants in a single NSX deployment. Network profiles support isolation through subnets, external subnets, security groups, and VLAN transport zones. NSX overlay segments provide additional network isolation, enabling separate network paths for fleet-level networks.

At the management layer, all management interfaces and APIs use TLS encryption. NSX Manager supports configurable TLS protocol versions and cipher suites. VCF provides a security baseline that can be used to evaluate both default and non-

default configurations and can assist organizations in securing information systems in a compliance context. Built-in compliance scanning measures security posture against industry-standard benchmarks. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, with recommendations covering strong authentication, RBAC implementation, and administrative access controls.

VCF Automation extends this layered model into workload provisioning by supporting security groups that can be associated with machine resources in cloud template designs. Administrators can define both existing and on-demand security groups within network profiles, applying consistent security grouping as workloads are deployed without requiring manual per-VM configuration.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture.

Audit logging supports ongoing governance by recording administrative actions with full traceability, so that organizations can track who changed configuration, what was changed, and when. Programmatic management through PowerCLI supports infrastructure-as-code approaches, enabling version-controlled and repeatable policy deployment.

VMware vDefend is a separate product that builds on VCF's networking foundation to add further security layers at the VM vNIC, the overlay boundary, and the application layer. vDefend operates above VCF's native network isolation and segment security and is independent of them.

The Consumption layer of VCF extends these layered network defenses into the Kubernetes workload tier through VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes security model requires that cluster infrastructure provide the security guarantees that higher application layers depend on, and VCF grounds the Consumption tier in the platform's NSX networking and vSphere security controls described above, so each tier remains independent from the layers above it.

At the namespace layer, vSphere Supervisor namespaces support Pod Security Admission (PSA) enforcement, which evaluates pod specifications at admission time in the Kubernetes API server, independently of any network-layer or runtime-layer controls. Three standard PSA profiles are available: Privileged, Baseline, and Restricted. The Baseline profile mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. The Restricted profile additionally blocks host network access, privileged containers, and unrestricted capabilities. Because PSA operates at admission time, non-conforming pods are rejected before reaching the network or runtime layers, regardless of whether a NetworkPolicy exists for that namespace.

At the network policy layer within VKS clusters, Antrea serves as the default Container Network Interface (CNI) plugin and operates at Layer 3 and Layer 4 using Open vSwitch as the networking data plane. The AntreaPolicy feature gate enables network policy enforcement in Antrea. Kubernetes NetworkPolicy objects deployed within VKS clusters are enforced by Antrea, providing declarative control over packet filtering between pods and external endpoints. Service meshes can layer workload-identity-based OSI Layer 7 policies on top of namespace-level isolation and provide mutual TLS encryption for inter-pod traffic that would otherwise traverse the cluster network unencrypted. Cilium, available as a cluster addon, enforces network policies at L3 through L7 using an identity-based security model that is decoupled from network addressing, supporting environments where IP-based policy is insufficient.

At the container runtime layer, Kubernetes security contexts allow administrators to restrict container privileges at the Pod or individual container level. Controls include specifying the Linux user identity, dropping Linux capabilities to the minimum required set, setting a read-only root filesystem to block writes to the container filesystem, and applying seccomp profiles that use BPF to filter system calls through allow or deny lists, reducing the kernel syscall attack surface available inside containers. AppArmor and SELinux profiles applied through security context annotations provide mandatory access control at the kernel level, extending restrictions beyond the container boundary to help mitigate container runtime vulnerabilities. VKS Cluster Management Security Policy templates in the VCF services consumption interface enable fine-tuning of individual security context parameters and support governance controls tailored to organizational requirements.

VKS clusters use TLS encryption to secure communications among Kubernetes components, including the API server, etcd, and service clusters, independently of workload-level network policy configuration. Security Technical Implementation Guides (STIGs) for Supervisor and Kubernetes release (VKr) components are available through Tanzu STIG Hardening, providing documented hardening guidance across these layers.

VMware vDefend (Meets)

VMware vDefend (vDefend) provides layered network security enforcement spanning Layer 2 through Layer 7, with each layer operating on its own policy evaluation independently of the others. The Distributed Firewall (DFW) Ethernet category enforces Layer 2 traffic, and an Allow rule match triggers further evaluation through Layer 3-7 categories in the DFW policy hierarchy. At the network and transport layers, the DFW performs stateful packet inspection and offers protocol validation to protect against low-level IP attacks. Layer 7 enforcement uses a Deep Packet Inspection (DPI) engine that receives pending Layer 7 flows from the DFW via VSIP, enabling application-identity and user-identity-based access controls including FQDN filtering. The Gateway Firewall provides north-south enforcement at the NSX edge, analyzing application-layer content to permit or block traffic based on application-level information.

The vDefend Advanced Threat Prevention (ATP) edition layers IDS, Network Traffic Analysis (NTA), and Network Detection and Response (NDR) as concurrent and independent detection capabilities over the base DFW enforcement. NDR provides security analysts with capabilities to understand security events, triage, and remediate them by creating policies. NDR classifies detections by Detection Type, MITRE Tactic, MITRE Technique, Threat name, Affected Workload, Campaigns, and Signature Type. These ATP capabilities operate in air-gapped environments, where IDS, NTA, and NDR provide detection in isolated networks without cloud connectivity.

The Security Services Platform (SSP) supports security segmentation planning through a multi-level hierarchy spanning Region, Zone, Environment, Application, and Tier levels for granular segmentation design. DFW activation of malicious IP feeds and corresponding security rules provides foundational defenses within this segmentation model. Bare Metal Security extends Layer 3/4 DFW policy enforcement to physical servers, applying consistent policy across both virtual and physical workloads. The Security Segmentation Score and Report feature in SSP evaluates DFW deployment coverage, including network and transport layer protocol protections, to assess the layered defense posture.

The vDefend security model is structured as a Security Journey, a staged approach that allows organizations to progressively adopt a Zero Trust posture, moving from initial assessment and quick wins toward application-level microsegmentation.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports boundary protection and system component isolation through infrastructure policies, namespace isolation, network configuration, and data service policy enforcement. These mechanisms restrict the placement, resource consumption, and network access of database workloads managed through DSM.

Infrastructure policies are the primary isolation mechanism in DSM. A vSphere administrator creates infrastructure policies through the DSM plug-in, and these policies define the compute resources, IP pools, VM classes, storage policies, and networking configuration available to database deployments. Each policy establishes guardrails that restrict what DSM users can provision and where workloads are placed. When a database cluster is created, it is deployed with an assigned infrastructure policy and storage policy that enforce resource constraints and placement boundaries. The Infrastructure Policies view in the DSM administrator UI displays all defined policies alongside the databases associated with each policy, giving administrators visibility into how resources are allocated and partitioned across the environment.

DSM enforces namespace-level isolation by deploying database clusters in isolated Kubernetes namespaces and using InfrastructurePolicyBinding resources to bind infrastructure policies to specific namespaces. A DSM Cloud Administrator can enforce namespace-specific restrictions that allow or disallow the use of InfrastructurePolicies and BackupLocations in different namespaces, providing an additional boundary layer between workloads sharing the same cluster. Separate infrastructure policies and backup location bindings per namespace support the isolation of critical database assets at the Kubernetes resource level.

IP pools defined within infrastructure policies segment network addressing for database workloads. DSM also detects and prevents network overlap between infrastructure policy IP ranges and system configuration networks, reducing the risk of unintended cross-boundary connectivity. DSM supports deployment in network-isolated, air-gapped environments using images and manifests bundled in the DSM appliance, supporting deployments in higher-security network zones that restrict external connectivity.

In environments that integrate DSM with VCF Automation, administrators can assign data service policies and object stores to specific tenants or organizations to enforce tenant isolation across organizations sharing the same infrastructure.

Boundary protection at the network perimeter, including firewall policies, microsegmentation, and traffic inspection, is provided by other components of the VCF stack rather than by DSM itself. Organizations deploying DSM should define infrastructure policies for each workload tier or sensitivity level and configure IP pools to align with their network segmentation architecture. DSM contributes to isolation within its operational scope, but complete boundary protection for critical database assets requires coordination with the broader VCF network security configuration.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer implements security functions as a discrete application-delivery layer within the broader defense architecture of VCF. At the application delivery tier, Avi enforces independent security policies at Layer 4 and Layer 7, with each layer operating without dependence on the other for its enforcement decisions.

At Layer 4, the Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. Network Security Policy rules reference reusable IP Groups, which can be shared across multiple virtual services to apply network-layer access control at scale. NSX security groups defined in the network platform can be referenced directly as IP Group members in Avi virtual service security policies, allowing network-level groupings maintained in NSX to drive Avi's Layer 4 access control without manual IP address list duplication. The DDoS Policy detects and mitigates a range of Layer 4 through Layer 7 network attacks through the Network Security policy, with network-layer enforcement taking effect before Layer 7 HTTP processing.

At Layer 7, Virtual Service Policies provide independent controls over HTTP security, HTTP request handling, and HTTP response rewriting. The System-Secure-HTTP application profile secures HTTP traffic by enforcing HTTPS, protecting cookies, managing client IPs, and controlling protocol behavior. The Web Application Firewall (WAF) adds an application-inspection tier with both negative security (signature-based Application Rules that detect attack patterns) and a Positive Security model maintained as a distinct policy object. The Positive Security model reduces attack surface by only allowing known-good traffic, while the signature-based rules operate independently, keeping the two security models separate within the application layer.

In 9.1, the Avi Kubernetes Operator (AKO) provides WAF integration for VMware Kubernetes Service (VKS) clusters, extending application-layer security to Kubernetes ingress traffic within the VCF environment.

Avi's DDoS telemetry maintains this layered organization: Service Engine DDoS Insights reports Layer 4 attack data (including IP fragmentation attacks and TCP SYN flood) separately from Layer 7 attack data, so operators can assess and respond to threats at the appropriate layer without conflating the two.

Avi also supports integration into Firewall Sandwich topologies, where Avi Service Engines are positioned in conjunction with external firewall tiers. This architecture allows Avi to handle application-delivery and application-security functions while network-layer security appliances operate independently, each tier functioning without dependence on the other's correctness.

The full layered network defense architecture requires platform mechanisms outside Avi's scope. NSX provides the routed underlay and network segmentation, and VMware vDefend provides microsegmentation between workloads. Together with Avi's application-delivery security tier, these form the layered defense architecture this control addresses. Organizations must configure mechanisms across all relevant tiers to implement the layered structure the control requires.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SI.L1-b.1.xii

> Identify, report, and correct information and information system flaws in a timely manner

SCF Controls: VPM-01, VPM-02, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a `Remediating` condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the `kube-security-announce` mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as `Invalid` or `Warning`, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply

remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SI.L1-b.1.xiii

> Provide protection from malicious code at appropriate locations within organizational information systems

SCF Controls: END-01, END-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L1-b.1.xiv

> Update malicious code protection mechanisms when new releases are available

SCF Controls: END-04.1

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to automatic antimalware signature updates through two distinct mechanisms: IDS/IPS signature management and the Malware Prevention Service. Both operate with automated update capabilities that reduce the operational burden of keeping threat detection current.

The vDefend IDS/IPS component supports automatic signature bundle retrieval from the VMware vDefend Threat Intelligence Service (vTIS), the cloud-hosted signature service. Administrators can configure the Global Manager to manage signature updates across Local Manager sites using either an Auto Update mode, which pushes new signature bundles automatically to all mapped Local Manager sites, or a manual update mode for environments that require change-control oversight before deployment. The download interval for automatic updates is configurable. When the Auto Update toggle is turned off, administrators can manually download the IDS signature bundle (.zip) file and upload it to the system. vDefend IDS/IPS also supports custom signature bundles that administrators can manage through the NSX Manager interface under Security > IDS/IPS & Malware Prevention. Before uploading a new custom bundle, administrators should export the existing bundle, as uploading a new custom bundle replaces all previously uploaded custom signatures. The interface displays counts of new, deleted, and existing signatures when re-uploading bundles. Administrators can also bulk-edit system signatures to update actions or toggle signature state across the signature set.

The Malware Prevention Service provides a separate signature-based detection and prevention capability. The service deploys a service virtual machine (SVM) on each host in a vSphere cluster and uses Guest Introspection thin agents installed on guest virtual machines to perform file inspection at the hypervisor layer. Malware prevention signatures are retrieved automatically through internet connectivity to the NSX management plane; unlike IDS/IPS signatures, malware prevention signatures cannot be uploaded manually and require internet access from the NSX environment. When signatures identify a file as malicious, Malware Prevention can take remediation actions including denying access to the file or deleting it. Malware Prevention signature bundles also support file magic matching to identify files by their binary content signatures rather than relying on file extensions alone.

In vDefend, the Malware Prevention Service adds support for fileless malware detection on Windows endpoints. Rather than relying solely on file hash-based signature matching, the service monitors behavioral Indicators of Compromise (IoC) to identify process-based threats. Analysis reports generated by the service include signature activity detail that identifies malicious subjects, supporting post-incident review.

vDefend does not replace a general-purpose endpoint antimalware product. Its signature update capabilities are specific to network-level IDS/IPS and the Malware Prevention Service for file-based and fileless threat detection at the hypervisor layer. Organizations deploying guest-level antimalware agents remain responsible for those agents' signature update mechanisms independently of vDefend.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L1-b.1.xv

> Perform periodic scans of the information system and real-time scans of files from external sources as files are downloaded, opened, or executed

SCF Controls: END-04, END-04.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L2-3.14.1

> Identify, report, and correct system flaws in a timely manner.

SCF Controls: VPM-01, VPM-02, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply

remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control SI.L2-3.14.2

> Provide protection from malicious code at designated locations within organizational systems.

SCF Controls: END-01, END-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several platform capabilities that support malicious code protection, though organizations must deploy additional tools to achieve full antimalware coverage across endpoints.

At the hypervisor layer, VMware ESX supports Secure Boot and code signing to restrict unauthorized code from executing on hosts. Trusted Platform Module (TPM) support enables boot-time integrity measurement, and VMware vCenter provides APIs to retrieve TPM event logs for validating boot-time measurements or configuring firmware trust with an attestation service. Administrators can verify that hosts have booted in a known good configuration by checking TPM device status and event logs through the vCenter trusted infrastructure API. ESX host TPM modules must be verified as running the latest 2.0 firmware, and if not in use, disabled in the BIOS. Virtual machines can be configured with UEFI firmware for guest operating system boot integrity. Windows guest operating systems support Virtualization Based Security (VBS), which enables Device Guard to help prevent malware from running and Credential Guard to protect credential secrets; these features are configurable through Group Policy on VMs with ESX 6.7 or later compatibility. Virtual machines can also have the Guest Integrity (GI) security device enabled through the VMware Host Client, which is the platform foundation for VMware AppDefense.

The vSphere Security Configuration Guide provides hardening recommendations for ESX hosts, including configuring authentication and authorization settings, disabling unnecessary services, and enabling security features like Secure Boot and TPM. These configuration baselines are industry-standard best practices for host hardening.

vSphere Lifecycle Manager and VCF Operations Configuration Profiles maintain desired-state configuration for ESX hosts. Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes and identify when vCenter instances and vSphere clusters deviate from their approved baselines. Drift status is updated through a collection cycle that runs every 8 hours. This helps identify when host software or configuration has been modified from its approved state, which can indicate unauthorized changes or tampering.

VCF's networking layer, NSX, supports integration with third-party endpoint protection solutions for virtual machine security. The platform documentation references specific partner integrations including Symantec Endpoint Protection and ESET Antivirus/Security software, which provide anti-malware, intrusion prevention, and firewall capabilities for guest virtual machines. NSX App IDs can be used in conjunction with these third-party solutions for network management and security policy enforcement. Organizations can implement security groups, define security policies, and use NSX's integration with third-party security solutions for virtual machine protection.

NSX Guest Introspection provides an agent-based framework that supports endpoint security within virtual machines. The Guest Introspection Agent must be installed and running in each guest VM, and logged-in users should not have the privilege to remove or stop the agent. This architecture enables third-party security solutions to inspect guest operating system activity without requiring agents to be installed directly on the hypervisor. The security and integrity of the guest operating system must be maintained for these integrations to function correctly.

For container workloads, the VCF CLI supports cosign signature verification for container images through the `imgpkg` tool, which enables finding and copying cosign signatures. Image pull authentication through `imagePullSecrets` restricts container image pulls to authenticated private registries. Plugin discovery image signature verification is supported, with configurable public key paths for the cosign verifier. These capabilities help restrict deployment of images that have been tampered with.

VCF Operations supports the deployment and monitoring of agents on endpoint virtual machines, with guest operation privileges required to install agents. Automated software update capabilities in vCenter help keep systems current with security patches, reducing the window of exposure to known malware exploits.

For organizations that deploy VMware vDefend as an add-on to VCF, distributed malware prevention capabilities become available. The NSX Application Platform hosts the Malware Prevention for vDefend feature, which can be deployed from the Local Manager UI in NSX Federation environments. When host clusters are activated for Distributed Malware Prevention, a service virtual machine (SVM) is deployed on each host to perform malware scanning. vDefend also supports IDS/IPS capabilities alongside distributed malware prevention. The DistributedMps runbook is available to verify the health of the Malware Prevention Service pipeline and diagnose issues such as protection not working on a particular VM or certain files not being scanned.

Malware prevention activities generate log data for audit and forensic purposes. The Malware Prevention for vDefend feature writes log files that can be used for troubleshooting and security monitoring, and remote logging can be configured on the malware prevention SVMs for centralized log collection.

VMware Private AI Services (PAIS) includes model validation capabilities that scan machine learning model files for malicious content before they are accepted into a Model Gallery. The validation runs as a sandbox process on Deep Learning VMs and covers integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference behavior testing with NVIDIA Triton Inference Server. Both the malware and serialization checks run as part of the validation workflow required before a model can be uploaded to a Model Gallery and made available to downstream model endpoints, knowledge bases, or AI agents.

Machine learning model files are a category of artifact that traditional endpoint security tools may not inspect. Serialized models in formats such as Python pickle files can carry executable payloads that activate when an application or researcher loads the model. The PAIS Model Gallery intake workflow treats this upload boundary as a security checkpoint, requiring each artifact to pass hash, malware, serialization, and inference behavior tests before it is published for use. PAIS guidance also directs organizations to distribute only models that have been validated internally on a Deep Learning VM rather than pulling artifacts directly from the Internet, where models may contain malicious code or be tuned for malicious behavior. The validation is operated by MLOps engineers, who confirm that onboarded models meet the organization's security, privacy, and technical requirements.

For platform-level malware protection covering virtual machines, VMware ESX hosts, and general workloads running on the PAIS infrastructure, organizations rely on VCF platform controls and, where deployed, VMware vDefend. PAIS adds the specialized scanning layer applied to AI model artifacts at the point of intake, addressing a threat surface that general-purpose antimalware tools do not typically cover.

VMware vDefend (Contributes)

VMware vDefend provides multiple layers of malicious code detection and prevention through its Malware Prevention Service and IDS/IPS capabilities. Together these address the detection aspect of this control directly and contribute to the eradication aspect by restricting malicious code from executing and spreading across the network.

The Malware Prevention Service deploys as a service virtual machine (SVM) on each host in a cluster, with Guest Introspection thin agents installed on each protected guest VM. This architecture separates the detection engine from the protected workload, giving the service visibility into file activity, process execution, and network events from outside the guest. On Linux guests, a File and Network Agent handles file and network traffic introspection. A Host Agent (MUX) component running on ESX hosts supports the Guest Introspection functionality.

The service detects both known and unknown malicious files, including zero-day threats. Supported file categories include Windows executables (.exe, self-extracting), Linux executables (.elf), installer files (.msi), and shortcut files (.lnk), among others. When a file is analyzed, Malware Prevention assigns a verdict and classifies the threat by malware class (virus, trojan horse, worm, adware, ransomware, spyware) and malware family. A single detection event can be associated with multiple malware families and classes. Upon detection, the service can take direct remediation actions, including denying access to suspicious files or deleting files identified as malicious. An allowlist capability enables administrators to override verdicts for files known to be legitimate, suppressing false positives without disabling broader detection.

Beyond file-based detection, Malware Prevention Service includes fileless malware detection to identify attacks that operate entirely within system memory using existing binaries and in-memory operations such as PowerShell or VBScript, without

leaving executable artifacts on disk. The service monitors Indicators of Compromise including process command lines, process hashes, process execution trees, and in-memory executions. In-memory script buffer executions are scored for threat severity and assigned a verdict of malicious or suspicious, with the associated malware family and class displayed on the Malware Prevention Dashboard.

When malware is detected, the service extracts artifacts and in-memory script buffers that security teams can use to define incidents of compromise and create new detection rules for similar future threats. This extends malware coverage as new threat patterns are identified within the environment.

The Malware Prevention Dashboard in Security Services Platform aggregates detection events for malicious files, suspicious files, and uninspected files over configurable time periods. Each unique file is tracked by hash, and events can be filtered by verdict criteria. This centralized visibility allows security teams to identify malware incidents, track detection trends, and coordinate eradication efforts across the virtualized environment.

vDefend IDS/IPS provides signature-based and behavioral intrusion detection and prevention at the distributed firewall level, complementing Malware Prevention with network-layer detection of malware delivery attempts, command-and-control communications, and lateral movement patterns associated with malware infections. IDS/IPS operates at the virtual network interface level, providing visibility into east-west traffic between workloads that perimeter security tools cannot inspect.

While vDefend provides strong detection and file-level remediation capabilities, complete eradication of malicious code from infected guest operating systems typically requires endpoint security agents operating inside the guest. vDefend restricts malware from spreading across the network and blocks or removes detected malicious files, but cleaning an already-infected system requires host-level remediation tooling.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to malicious code protection at the application delivery layer through WAF-based payload inspection, IP Reputation threat intelligence, Application Rules, and Bot Management.

The Avi WAF inspects inbound HTTP/HTTPS request bodies and parameters against signature-based rules, including ModSecurity rules, to detect and block exploit payloads, injection attacks, and known malware delivery patterns. WAF rules are configurable per virtual service and can be tuned to reduce false positives while maintaining coverage of malicious traffic patterns. Configuration is managed through the Avi Controller UI under the WAF Policy section for each virtual service.

The Application Rules service, available through Avi Cloud Console Live Security Threat Intelligence, provides automatically updated WAF rules targeting known vulnerabilities with CVE mappings across more than 5,000 applications, including WordPress, Drupal, and Apache. These rules are pushed automatically to Avi Controllers, reducing the window between vulnerability disclosure and protection.

Avi's IP Reputation service provides a threat intelligence feed that classifies IP addresses known to be infected with malware or identified as contacting malware distribution points (threat category code 6). The service also identifies IP addresses known to distribute malware, shell code, rootkits, worms, or viruses, including Windows exploit IP addresses. An "All threats" classification (threat category code 32) can be applied to block any suspicious IP addresses at the application delivery layer. IP Reputation data is synchronized via Avi Cloud Services and can be referenced in virtual service policies to block malicious source traffic before it reaches protected workloads. This is configured under Administration > External Services > Cloud Services.

Avi Bot Management provides a default System-BotDetectionPolicy that can be bound to virtual services to detect and mitigate malicious bots used in online fraud, credential stuffing, and automated data scraping. Bot Management performs heuristic scanning of User-Agent strings to detect malicious patterns such as SQL injections, marking such requests as bad bot of type web attack. In Kubernetes deployments, the Avi Kubernetes Operator (AKO) supports assigning a BotDetectionPolicy to virtual services via the botPolicyRef parameter, extending bot detection to Kubernetes ingress workloads.

Avi WAF does not include built-in virus or file-content malware scanning. Avi documentation explicitly recommends deploying a dedicated virus and malware scanning tool on the upload directories of protected applications to detect and mitigate malicious uploads, including uploads that may bypass WAF inspection. Malware detection and eradication for workloads

running behind Avi is the responsibility of endpoint protection tools deployed on those workloads. Organizations should configure WAF policies, Application Rules, IP Reputation, and Bot Management on Avi virtual services while also deploying dedicated antimalware solutions on application workloads and their supporting infrastructure.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L2-3.14.3

> Monitor system security alerts and advisories and take action in response.

SCF Controls: MON-01.8, THR-01, THR-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpdx.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKR 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to execute while logging each to syslog or auditd; an `audit.json` seccomp profile can log all syscalls of a process for detailed syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with local buffering at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Contributes)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response (NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the

ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of

security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control SI.L2-3.14.4

> Update malicious code protection mechanisms when new releases are available. SP 800-171, REVISION 2 PROTECTING CONTROLLED UNCLASSIFIED INFORMATION

----- CHAPTER THREE PAGE 42 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-171r2>

SCF Controls: END-04.1

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to automatic antimalware signature updates through two distinct mechanisms: IDS/IPS signature management and the Malware Prevention Service. Both operate with automated update capabilities that reduce the operational burden of keeping threat detection current.

The vDefend IDS/IPS component supports automatic signature bundle retrieval from the VMware vDefend Threat Intelligence Service (vTIS), the cloud-hosted signature service. Administrators can configure the Global Manager to manage signature updates across Local Manager sites using either an Auto Update mode, which pushes new signature bundles automatically to all mapped Local Manager sites, or a manual update mode for environments that require change-control oversight before deployment. The download interval for automatic updates is configurable. When the Auto Update toggle is turned off, administrators can manually download the IDS signature bundle (.zip) file and upload it to the system. vDefend IDS/IPS also supports custom signature bundles that administrators can manage through the NSX Manager interface under Security > IDS/IPS & Malware Prevention. Before uploading a new custom bundle, administrators should export the existing bundle, as uploading a new custom bundle replaces all previously uploaded custom signatures. The interface displays counts of new, deleted, and existing signatures when re-uploading bundles. Administrators can also bulk-edit system signatures to update actions or toggle signature state across the signature set.

The Malware Prevention Service provides a separate signature-based detection and prevention capability. The service deploys a service virtual machine (SVM) on each host in a vSphere cluster and uses Guest Introspection thin agents installed on guest virtual machines to perform file inspection at the hypervisor layer. Malware prevention signatures are retrieved automatically through internet connectivity to the NSX management plane; unlike IDS/IPS signatures, malware prevention signatures cannot be uploaded manually and require internet access from the NSX environment. When signatures identify a file as malicious, Malware Prevention can take remediation actions including denying access to the file or deleting it. Malware Prevention signature bundles also support file magic matching to identify files by their binary content signatures rather than relying on file extensions alone.

In vDefend, the Malware Prevention Service adds support for fileless malware detection on Windows endpoints. Rather than relying solely on file hash-based signature matching, the service monitors behavioral Indicators of Compromise (IoC) to identify process-based threats. Analysis reports generated by the service include signature activity detail that identifies malicious subjects, supporting post-incident review.

vDefend does not replace a general-purpose endpoint antimalware product. Its signature update capabilities are specific to network-level IDS/IPS and the Malware Prevention Service for file-based and fileless threat detection at the hypervisor layer. Organizations deploying guest-level antimalware agents remain responsible for those agents' signature update mechanisms independently of vDefend.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L2-3.14.5

> Perform periodic scans of organizational systems and real-time scans of files from external sources as files are downloaded, opened, or executed.

SCF Controls: END-04.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF does not include a built-in anti-malware scanning engine, so it cannot directly satisfy the requirement for always-on antimalware protection. However, VCF provides several infrastructure-level capabilities that support continuous, tamper-resistant operation of anti-malware technologies and help keep those technologies running and shielded from unauthorized interference. The actual anti-malware scanning engines require additional products such as VMware vDefend or third-party endpoint protection solutions.

ESX Agent Manager (EAM) is a VMware vCenter component that manages the lifecycle of agent virtual machines deployed on ESX hosts. EAM can restrict operations on agent VMs so that non-privileged users cannot power off, delete, or otherwise interfere with running security agents. Operations on ESX agent virtual machines can be limited to users who hold the EAM.Modify privilege, blocking other users from disrupting agent VMs. vCenter can also be configured to warn users when they attempt to perform operations on virtual machines or vApps that a solution manages, providing an additional safeguard against accidental or unauthorized disruption of security agents.

For workloads that rely on NSX Guest Introspection, the Guest Introspection Agent must be installed and running in each guest VM. Platform guidance states that logged-in users should not have the privilege to remove or stop the agent, so the anti-malware scanning path that depends on it continues running independent of non-privileged user actions. The Guest Introspection Agent provides the communication channel between the guest operating system and the security service virtual machines running on each host, so keeping it operational is a prerequisite for agentless security scanning.

VCF's role-based access control model enforces consistent security controls regardless of operational context. Administrative actions such as modifying security configurations, disabling services, or altering host settings require appropriate privileges. VCF Automation allows organization administrators to disable user accounts to revoke access without removing users from the organization, and administrators can view and revoke individual user access tokens through the Administration access control settings. vCenter can disable unauthorized modification of devices through the `isolation.device.edit.disable` setting, and unauthorized removal and connection of devices to virtual machines can be disabled through the `isolation.device.connectable.disable` setting. These controls help restrict the ability of non-privileged users to alter the security posture of the virtualized environment.

VCF's NSX networking layer integrates with third-party security solutions such as Symantec Endpoint Protection, which provides anti-malware, intrusion prevention and firewall features for servers and desktops within the virtual environment. For organizations using VMware vDefend, Distributed Malware Prevention can be deployed across host clusters, with a service virtual machine (SVM) running on each host to provide malware scanning capabilities. The NSX Application Platform hosts Malware Prevention for vDefend, vDefend Network Detection and Response (NDR), and Security Intelligence. Malware Prevention can be deployed and managed centrally from the NSX Manager interface or from the Local Manager UI in NSX Federation environments, giving administrators a single point of control over the anti-malware deployment. vDefend also provides IDS/IPS capabilities alongside Distributed Malware Prevention. A dedicated DistributedMps runbook verifies the health of the Malware Prevention Service (MPS) pipeline and diagnoses issues such as protection not working on a particular VM or certain files not being scanned, allowing administrators to confirm that protection remains active across the deployment.

VCF Operations and vSphere Lifecycle Manager provide mechanisms to detect and remediate configuration drift that could degrade protection. VCF Operations monitors configuration drift for vCenter instances and vSphere clusters through the Configuration Drifts feature, updating drift status data through a collection cycle that runs every 8 hours. Through the Management Pack for VCF Operations Orchestrator, VCF Operations can enforce host security configuration hardening rules

automatically via the Apply Host Security Configuration Rules workflow. This auto-remediation capability helps maintain a consistent security baseline across the environment, reducing the window during which protection might be degraded due to configuration changes. VCF Operations also provides alert definitions and alert lists that enable investigation of issues affecting infrastructure, giving visibility into conditions that might indicate a lapse in protection.

Auditors should verify that ESX Agent Manager privileges are configured to restrict agent VM operations to authorized administrators, that Guest Introspection Agents are deployed with appropriate OS-level protections against user tampering, that device isolation settings are enabled on virtual machines, and that either vDefend Malware Prevention or a third-party anti-malware solution is deployed and configured for continuous real-time scanning.

VMware vDefend (Contributes)

VMware vDefend contributes to always-on anti-malware protection through its Malware Prevention Service (MPS), which operates as a distributed, hypervisor-integrated security layer that runs continuously across protected hosts and is resistant to tampering from within guest workloads.

The Malware Prevention Service deploys a Service Virtual Machine (SVM) on each protected VMware ESX host, using a Host Agent (MUX) component running on the hypervisor to support Guest Introspection functionality. This architecture means the malware detection engine runs outside the guest operating system, where guest workloads have no direct access to it. The service detects and prevents known malicious files, unknown malicious files, and zero-day threats. It also includes fileless malware detection to identify attacks that operate within system memory, leveraging existing binaries and in-memory operations. A dashboard and logs are available for security operations teams to extract relevant artifacts associated with in-memory malware execution. The service uses Guest Introspection thin agents deployed inside guest VMs, extending file-based malware detection to both Windows and Linux workloads. For Linux virtual machines, the Guest Introspection File and Network Agent provides file and network traffic introspection capabilities, and the running status of the thin agent can be confirmed using the `systemctl status vsep.service` command. When a threat is identified, the service takes automatic remediation actions, including denying access to suspicious files or deleting files confirmed as malicious.

Protected virtual machines retain security protection through shutdowns and restarts, and after a vMotion move to another ESX host with the security solution installed. This continuity supports always-on protection as workloads move within the environment.

Access controls restrict who can manage the Malware Prevention Service. Enterprise Administrator privileges are required to log in to the Security Services Platform and activate, modify, or delete the Malware Prevention Service. The Enterprise Administrator role has full access to activate the service, run prechecks, view generated events, view the Cloud Analysis Report, add or modify SHA256-based exclusions, and collect Security Services Platform and SVM support bundles. Non-privileged users do not have the privileges required to modify or disable the service through the management plane. The Security Services Platform must be in a good state with no active alarms before the Malware Prevention Service can be deleted, providing an additional safeguard against unauthorized removal of protection.

vDefend's IDS/IPS capabilities supplement the malware prevention layer with continuous, real-time network-level threat detection operating at the vNIC level, transparent to workloads and inaccessible from within the guest operating system.

One operational consideration: the Malware Prevention Service requires the NSX environment to be connected to the internet to function as designed. In environments with restricted internet access, this dependency may affect continuous protection coverage, and organizations should account for this in their architecture and compensating control design.

vDefend contributes to, but does not fully satisfy, this control because it provides network-level and hypervisor-level malware prevention rather than endpoint anti-malware within guest operating systems. Traditional endpoint protection platforms that run inside guest operating systems remain the responsibility of the organization to deploy and manage. vDefend provides an additional layer of malware detection that operates independently of guest-level security tools.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L2-3.14.6

> Monitor organizational systems, including inbound and outbound communications traffic, to detect attacks and indicators of potential attacks.

SCF Controls: MON-01, MON-01.3, NET-08

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter

Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Meets)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as `SUCCESS`, `NOT_ENOUGH_BASELINE`, and `FAILURE`.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control SI.L2-3.14.7

> Identify unauthorized use of organizational systems.

SCF Controls: IRO-03, MON-02.1, MON-11.3, MON-16

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides several capabilities that contribute to anomalous behavior detection and user activity monitoring, though it does not include a dedicated User & Entity Behavior Analytics (UEBA) or User Activity Monitoring (UAM) solution.

VCF Operations includes anomaly detection capabilities that use both dynamic and static thresholds to identify when metrics deviate from normal operating behavior. Dynamic thresholding is enabled by default and uses historical data analysis to establish baselines for each monitored object. The Smart Early Warning feature analyzes the number of applicable metrics that violate the dynamic threshold determining normal operating behavior, triggering alerts when the number of anomalies on an object exceeds a trending threshold. When an anomalous entity is detected, VCF Operations generates an outlier violation alert (vmwAnalyticsOutlierEvent, OID 37002), notifying administrators of unexpected behavior. A Critical threshold violation alert is also generated when anomalous entities are detected.

The Anomalies widget displays detected anomalies for a resource over the past six hours at configurable time intervals, with color-coded criticality indicators. The Anomaly Breakdown widget shows likely root causes for symptoms on a selected resource, helping operators triage issues. The Troubleshooting Workbench includes an Anomalous Metrics card that surfaces metrics exhibiting drastic changes within a selected scope and time window, ranked by degree of change with the most recent anomaly given the highest weighting. Administrators can also examine outlier VMs detected by VCF Operations to identify unexpected behavior and take corrective actions. VCF Operations supports outbound SNMP trap notifications, enabling alert delivery to external SNMP management systems with up to four configurable trap destinations.

For user activity monitoring, VCF Operations provides a User Activity Audit report that offers traceability of user actions including logging in, operations on clusters and nodes, changes to system passwords, certificate activation, and logging out. Each audit event has a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. Event auditing across the VCF platform provides visibility into platform interaction changes and surfaces suspicious access events and policy violations. Administrators should continuously monitor user security aspects to detect security risks early and respond to potential threats. VCF SSO maintains a dedicated audit log that captures user management events, including account creation, modification, deletion, and activation or deactivation, as well as changes to account credentials and profile information. The vSphere Client's Advanced Export feature allows administrators to export tasks performed by a specific user during a specified time range, providing targeted audit data for investigating suspicious activity.

Audit logging extends across VCF components. NSX Manager generates audit log messages that record user operations with fields for UserName, ModuleName, Operation, and Operation status, along with detailed resource change information and timestamps. NSX Manager audit logs also record failed login attempts with username and timestamp information, enabling tracking of access patterns across the environment. VCF Operations for Networks captures audit logs of administrative actions, including CRUD operations and login/logout events.

VCF Operations supports forwarding user activity audit logs to an external syslog server, enabling integration with dedicated SIEM or UEBA platforms for broader correlation and behavioral analysis. VCF Log Management includes content packs that offer pre-built dashboards, alerts, and queries for VCF components. These content packs support security monitoring use cases such as tracking failed login attempts and privilege escalations.

VCF's built-in anomaly detection is primarily oriented toward infrastructure metrics and operational health rather than user behavior profiling. A dedicated UEBA or UAM solution consuming VCF's audit data would be needed to establish user behavior baselines, detect credential compromise through behavioral deviation, and provide the full scope of analytics this control requires. For organizations requiring deeper behavioral analysis, VMware vDefend extends VCF's monitoring foundation with IDS/IPS, network traffic inspection, and threat intelligence integration.

VMware vDefend (Meets)

VMware vDefend Network Detection and Response (NDR) correlates detection events into campaigns, comparing new detection data against existing events to identify related activity. Campaigns provide a view of a threat by correlating detection events to identify the different stages of an attack, and security analysts can view and triage threat campaigns through a campaign timeline. NDR supports SIEM integration, sending campaign and event logs to a connected SIEM in real time, allowing network security event data to be exported for broader correlation with other enterprise data sources.

Security Intelligence detects and categorizes suspicious events using MITRE ATT&CK tactics and techniques, recording event occurrences during selected time periods, and provides a View Full Event History capability that displays all events associated with a given signature ID and intrusion severity. Security Intelligence also correlates IDS events from the same source and destination hosts to connect related events and build a broader picture of an attack. This structured, MITRE-tagged event data can support SIEM-based analysis and enterprise-wide threat correlation.

The Security Services Platform (SSP) can be configured to forward log messages to external syslog servers for centralized log collection. SSP syslog configuration supports TCP, TLS, and UDP protocols and allows administrators to specify server address and port, integrating with existing SIEM ingestion pipelines. NDR Sensors report metrics covering health, traffic trends, and data processing activity, available as point-in-time measurements or aggregated data over time.

vDefend correlates only technical network security data and has no capability to ingest or correlate non-technical information such as HR records, physical access logs, or operational data. Satisfying the full scope of this control, which requires correlation of both technical and non-technical information across the enterprise, requires an external SIEM or equivalent platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L3-3.14.1e

> Integrity Verification

SCF Controls: AST-18, CRY-13, TDA-01.2

Aggregate Coverage: Meets

VCF (Meets)

VCF uses cryptographic hash algorithms across multiple components to validate the integrity of data and software.

vSAN uses end-to-end checksums to confirm the integrity of stored data, verifying that each copy of a file matches the source file. When software checksum is enabled alongside deduplication and compression, vSAN performs additional integrity validation at the cost of approximately 6.2 percent capacity overhead per device. This provides a continuous, built-in mechanism for detecting data corruption or tampering at the storage layer.

NSX Manager uses the SHA-512 cryptographic hash algorithm to hash local user passwords, configurable through the `hash_algorithm` parameter in the authentication policy. For certificate management, NSX Manager supports SHA-1 and SHA-256 hashing algorithms for computing certificate thumbprints, with SHA-1 as the default. NSX supports multiple digest algorithms for IPsec negotiation, including SHA-1, SHA-256, SHA-384, and SHA-512, and the IPsec VPN Phase 1 authentication algorithm defaults to SHA-256. NSX Manager also authenticates SNMP messages using a FIPS-validated Keyed-Hash Message Authentication Code (HMAC), and uses FIPS 140 approved algorithms for authentication to its cryptographic module, generating unique session identifiers using a FIPS 140 approved random number generator.

VCF Automation secures webhook behavior requests using HMAC authentication, which verifies the authenticity and integrity of HTTP requests. Each webhook request includes two custom headers: a signature header (`x-vcloud-signature`) and a digest (`x-vcloud-digest`).

VCF Operations supports SHA-224, SHA-256, SHA-384, and SHA-512 algorithms for SNMP trap authentication protocols, providing multiple hash algorithm options for integrity verification in monitoring communications.

The platform's cryptographic infrastructure is built on FIPS-validated cryptographic modules that include the hash algorithm implementations used throughout the stack. NSX uses FIPS 140-3 validated cryptographic modules by default, validated through the NIST Cryptographic Module Validation Program (CMVP). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. The use of validated modules provides assurance that hash algorithm implementations conform to established standards. For the VMware vCenter appliance, the OpenSSL FIPS Object Module version 3.0 supports SHA-3, HMAC, KMAC, and SHS among its validated algorithms, and the VMware Boring Crypto Module version 6.0 implements SHA2 variants and HMAC.

VCF CLI repository configuration supports GPG signature verification of repository metadata. On RHEL, GPG checking is enabled through the `gpgcheck` parameter. On Debian and Ubuntu, VCF CLI installation uses GPG-signed package verification with a keyring stored at `/etc/apt/keyrings/vcf-archive-keyring.gpg`. This allows administrators to verify the integrity of software packages before installation. vSphere Lifecycle Manager verifies the SHA-256 checksum of each software download before applying updates to hosts, and VMware ESX VIB signature validation uses a cryptographic checksum to confirm that each VMware Installation Bundle was produced by its stated author. The VCF Consumption CLI binary can be verified using a `sha256sum.txt` checksum file available for download from the VCF Automation Tenant Portal, providing a hash-based integrity check for the CLI tool before deployment.

TLS connections across VCF components use cryptographic hashes within message authentication codes to protect data in transit. Basic authentication for the vSphere JSON Protocol, for example, transports credentials over HTTPS with TLS encryption.

The VMware Kubernetes Service (VKS) and vSphere Supervisor layer, which provides workload consumption capabilities within the VCF platform, applies cryptographic hash algorithms through several mechanisms. The `ClusterClass` API exposes a `fips.enabled` variable that activates FIPS-validated cryptographic modules across cluster nodes; when this is set, hash

functions and other cryptographic operations are restricted to approved algorithms. VKS cluster nodes can reference Kubernetes releases built with FIPS-validated cryptographic modules, identifiable by the `-fips.1` suffix in the release name, and the Istio service mesh package available for VKS clusters provides FIPS compliance through its carvel package configuration. The Kubernetes API server (kube-apiserver), kubelet, kube-scheduler, and vSphere Cloud Provider Interface each support configurable TLS cipher suites whose message authentication components incorporate SHA-256 and SHA-384; the `--tls-cipher-suites` parameter on kube-apiserver and kube-scheduler and the `tlsCipherSuites` setting on kubelet allow administrators to restrict the cipher suites accepted. Antrea, used as the container network interface within Supervisor, exposes a `tlsCipherSuites` setting for CNI-layer communications. Container images deployed on VKS clusters are identified by cryptographic digests using the SHA-256 algorithm, and the kubelet uses a SHA-256 hash of image pull credentials as the `CredentialHash` field to track secret state. Kubernetes bootstrapping uses a SHA-256 hash of the Subject Public Key Info object (in DER-encoded ASN.1) as the certificate authority pin during cluster join operations, providing integrity assurance for the node-to-control-plane trust chain. VKS clusters include a TLS certificate infrastructure that supports cryptographic hash-based integrity assurance for communications among cluster components.

The vSphere CryptoManager API provides programmatic access to cryptographic operations, including integration with key management servers. Access to cryptographic operations is restricted to users who hold the Cryptographic Operations privilege in vCenter, with fine-grained sub-privileges allowing precise control over which users can perform specific encryption and hashing tasks. By default, the user with the vCenter Administrator role holds all Cryptographic Operations privileges.

The vSphere Security Configuration Guide provides recommendations for enabling security features such as Secure Boot and Trusted Platform Module (TPM) on ESX hosts, which rely on cryptographic hashes to validate boot component integrity.

VMware vDefend (Contributes)

VMware vDefend uses cryptographic hash algorithms across multiple subsystems to validate the integrity of data and to identify known threats, contributing to the organization's broader use of hash-based integrity verification.

Malware Prevention uses hash-based detection as a primary mechanism for identifying known malicious files. When files traverse the network and are intercepted for inspection, the service computes MD5, SHA-1, and SHA-256 hashes of each file and compares them against databases of known malware signatures. Custom Malware Prevention signature bundles support file hash matching using MD5, SHA-1, and SHA-256 checksums, allowing organizations to define detection rules that trigger on specific file hashes. File Analysis Report Details display the MD5, SHA-1, and SHA-256 hashes of analyzed files alongside MIME type and submission timestamps, providing auditors with a clear record of hash-based integrity checks performed on inspected files. Process Analysis Report Details similarly capture MD5, SHA-1, and SHA-256 hash values for analyzed processes, enabling forensic correlation across detection events. Malware Prevention Service generates `FileInspectionEvent` log messages containing SHA-256, SHA-1, and MD5 hash values for inspected files, supporting audit trails of hash-based detection activity.

vDefend IDS/IPS custom signature rules support hash computation through buffer transformation modifiers. The `to_md5`, `to_sha1`, and `to_sha256` modifiers convert arbitrary buffers to hash values within signature logic, enabling detection patterns that hash observed content before matching. Custom signature rules also support `ja3.hash` and `ja3s.hash` sticky buffer content modifiers to match on JA3 and JA3S hash fingerprints of TLS client and server handshake parameters, classifying encrypted traffic without decryption.

The IDS/IPS signature bundle includes a SHA-256 checksum that organizations can use to verify the integrity of the downloaded signature file before applying it to detection profiles. This hash-based integrity check helps confirm that signature content has not been corrupted or modified during distribution.

The Security Services Platform components, including the Security Services Platform Installer and NDR Sensor for vDefend, implement FIPS 140-2 and FIPS 140-3 validated cryptographic modules. Security Services Platform uses VMware BouncyCastle Module `bc-fips-2.1.2` (NIST Certificate #4943) and VMware OpenSSL FIPS provider Object Module version 3.0.15 (NIST Certificate #4861). These validated modules underpin the cryptographic operations across Security Services Platform components.

vDefend's hash usage is focused on network security functions: malware identification, signature-based detection, TLS fingerprinting, and integrity verification of downloaded signature content. The broader control encompasses hash algorithms used across all organizational systems for data and software integrity validation, including storage checksums, password hashing, code signing, and boot integrity verification, which are addressed by other VCF components.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) applies cryptographic hash algorithms across certificate management, replication, and ransomware recovery functions to validate data and software integrity.

PNR rejects installation of certificates signed with the SHA-1 hashing function by default. SSL/TLS server endpoint certificates must use SHA-256 or stronger signature algorithms, and certificates with MD5 signature algorithms are not accepted. When legacy environments require SHA-1 compatibility, administrators can explicitly enable it by adding an `<allowSha1>true</allowSha1>` entry to the `vmware-dr.xml` and `va-configurator.xml` configuration files on the PNR appliance and restarting the PNR Server and va-configurator services. PNR also validates server certificates by SHA-1 thumbprint during connection establishment to the Lookup Service.

PNR uses TLS 1.3 by default for TLS connections between PNR, VMware vCenter (vCenter), and replication components. The minimum TLS protocol version is configurable through the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; the same value must be updated consistently across the system when modified. TLS sessions apply hash-based message authentication for integrity verification of data in transit. Network encryption of replication traffic is available as a configurable option for traffic between protected and recovery sites.

Cyber Recovery scans VM guest files for malware and viruses during ransomware recovery by calculating hashes of binaries, parsing binary components, and identifying attributes that match known malware signatures, supporting verification that recovered workloads do not contain known malware before being returned to production. Snapshot badging assigns security status indicators (Verified for clean snapshots, Compromised for malware-confirmed snapshots, Encrypted for data encryption) to create an audit trail of snapshot validation results, and historical snapshot validation includes analysis of change rate, entropy rate, and other advanced metrics across snapshots to identify suitable recovery candidates.

PNR exports configuration data in XML format that can be validated using an XSD schema to confirm data integrity and proper structure during import. Certificate verification error messages are recorded in security-related log files for audit trail purposes.

The VCF platform supplies the foundational hash infrastructure that PNR builds on, including SHA-256/384/512 for IPsec digest algorithms, vSAN end-to-end checksums for storage integrity, HMAC authentication for platform webhook operations, Secure Boot hash verification, code signing for software updates, and FIPS 140 validated cryptographic modules underpinning platform-wide hash operations.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports integrity mechanisms for software updates through certificate-based trust validation for update sources, a controlled staging workflow for applying updates, and signature verification for operator package deployments.

For the Consumption Operator, DSM includes Signature Verification validation as part of the deployment process to confirm package integrity before components are installed. This capability applies when deploying or uninstalling the Data Services Manager Supervisor Service in VCF Automation environments.

DSM supports configuration of private container registries with CA certificate validation for untrusted registries, restricting update package sources to those that can be authenticated against a trusted certificate authority. Administrators manage the trusted root certificates used for these validations through the DSM certificate store, where certificates can be added, updated, or removed. In version 9.1, DSM introduces a "latest" certificate validation mode as the default, which enforces strict cryptographic and KeyUsage validations for all endpoints including the Provider VM and data service clusters. DSM also supports validation of trust bundles for self-signed certificates in image registry connectivity. As part of upgrading to version

9.1, DSM requires that all existing certificates be reviewed and replaced to confirm compliance with updated cryptographic algorithm requirements before the upgrade proceeds.

For platform-level software updates, DSM implements a staged upgrade workflow. Update bundles uploaded to the system progress through a defined status sequence from "available" to "Ready to Install" before installation proceeds. This staged approach provides an explicit review point between update availability and installation. Administrators can check for available upgrades and review upgrade history through the Version and Upgrade interface in the vSphere Client, accessible under the VMware vCenter Configure tab. The DSM plug-in supports a configurable Maintenance Policy that controls when automatic updates are applied, with settings for start date, start time, and duration.

Satisfying this control fully requires organizational processes beyond what DSM provides directly. DSM supports signature verification for operator packages, certificate-based validation of update sources, and controlled staging for applying updates, but the control's Process categorization requires organizations to establish procedures for verifying that update bundles are obtained from authorized VMware sources, maintaining a managed set of trusted CA certificates, and documenting the integrity validation steps applied before updates are approved for installation.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides cryptographic hash capabilities within its application delivery functions. The DataScript runtime exposes three built-in hashing functions: `avi.utils.sha1_hash`, `avi.utils.md5_hash`, and `avi.utils.murmurhash`. These functions compute hash values of arbitrary data within virtual service policies, and operators can use them to inspect, hash, or validate content at the application delivery boundary. The DataScript hashing API is documented under DataScript Functions > Utilities Functions in the Avi documentation.

For TLS certificate operations, the Avi SSL/TLS Profile supports configurable signature algorithms including MD5, SHA-1, SHA-224, SHA-256, SHA-384, and SHA-512, governing hash algorithm negotiation during TLS handshakes. This configuration is accessible under Templates > Security > SSL/TLS Profile in the Avi Controller UI and can be tuned to restrict negotiation to approved algorithms only.

Avi also supports MLDSA, a hash-based quantum-resistant signature algorithm, for certificate signing requests. This is configured under Security > SSL Certificates > CSR Certificates and provides a post-quantum option for certificate integrity operations.

Service Engine NTP authentication supports MD5 and SHA1 algorithms with configurable authentication keys, providing hash-based integrity verification for time synchronization communications. This is configured under Controller Settings > DNS/NTP Settings.

When FIPS mode is enabled on the Avi Controller, all cryptographic operations are restricted to FIPS 140-3 compliant algorithms via OpenSSL FIPS Provider 3.1.2, including all hash operations throughout the system. FIPS mode is configured at the controller cluster level under FIPS Compliance > Enabling FIPS Mode for a Controller Cluster Deployment. Organizations that require FIPS-validated hash operations should enable FIPS mode; note that FIPS mode does not support SSL Client Hello events in Avi DataScript, which limits certain DataScript-based TLS inspection scenarios.

Avi's hash mechanisms are scoped to application delivery and TLS operations. Platform-level data and software integrity validation, including VM image integrity and software package verification, is provided by the underlying VCF platform (see VCF Coverage).

Control SI.L3-3.14.3e

> Specialized Asset Security

SCF Controls: AST-04.1, CPL-01.2, NET-06, NET-06.4

Aggregate Coverage: Meets

VCF (Meets)

VCF provides network segmentation as a foundational design principle, using multiple layers of isolation to separate technology assets, applications, and services from one another.

At the physical and logical network layer, VCF uses VLANs and vSphere Distributed Switches (VDS) to segment traffic by function. Management traffic is isolated on dedicated networks accessible only to administrators. vMotion traffic is separated on distinct networks using dedicated VMkernel interfaces. IP-based storage traffic, including vSAN and NFS, runs on dedicated VLANs and can use dedicated physical network adapters for additional isolation. vSAN storage clusters can separate external VM traffic from internal storage traffic by using dedicated VMkernel ports for each traffic type. Network I/O Control (NIOC) on distributed switches divides traffic into predefined resource pools, including fault tolerance, iSCSI, vMotion, management, vSphere replication, NFS, and virtual machine traffic. NIOC can reserve bandwidth for each traffic type and allocate shares so that one class of traffic cannot starve another during contention. Active/standby NIC teaming configurations are available for vSAN traffic to provide resiliency without mixing storage and compute traffic paths. Distributed switch port groups also support Private VLANs (PVLANs), which further subdivide a VLAN segment into promiscuous, community, and isolated port types, restricting intra-VLAN communication to only explicitly permitted paths.

NSX extends segmentation with software-defined networking that decouples the virtual network from the physical infrastructure. NSX supports two primary segment models. The VLAN Segment Model provides isolation from other networks and can maintain separate security domains, such as isolating the fleet-level management network using VLAN-backed distributed port groups. VLAN segments can be provisioned by specifying one or more VLAN IDs on a private NSX network type. The Overlay Segment Model similarly provides isolation but decouples the virtual network infrastructure from the physical network, allowing segments to be created dynamically without reconfiguring the underlying physical network. This dual-model approach gives administrators flexibility to implement macrosegmentation using either traditional VLAN boundaries or software-defined overlay networks depending on architectural requirements.

NSX allows administrators to create logical network topologies using the NSX UI or API, building multi-tier architectures with Tier-0 and Tier-1 gateways and segments. Segments are realized as NSX Distributed Virtual Port Groups on vSphere Distributed Switches, providing consistent policy enforcement at the hypervisor level. In topologies running multiple standard overlay VDS switches, NSX provides traffic isolation such that traffic traversing one VDS is isolated from traffic on another VDS. NSX also supports applying switch security profiles to distributed port groups, and segment security features can filter malicious traffic from VMs on the network, helping protect segment integrity. NSX Distributed Port Groups and Uplink Port Groups also support Traffic Filtering and Marking policies that can be enabled and configured at the port level, allowing administrators to qualify, filter, or remark specific traffic flows at the point of ingress or egress on each port.

For multi-tenant and multi-department environments, NSX provides two isolation mechanisms. NSX Projects enable isolation of networking and security configurations across organizational units. NSX Virtual Private Clouds (VPCs) represent an additional layer of multi-tenancy within a project, providing self-contained virtual network environments with their own permission models, topology, and IP address management. VPCs support role-based access control through user and user group role assignments for Local User, LDAP User, or vIDM User account types. These can be allocated to discrete projects or tenants, enabling each to consume networking and security services in a self-service model.

VCF Automation extends segmentation into provisioned workloads by providing security groups for network isolation of deployed resources. This allows segmentation policies to be applied consistently through automated deployment workflows, so that new workloads are placed into the correct network segments from the point of provisioning.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS) and vSphere Supervisor, extends network segmentation to containerized workloads using the same NSX networking infrastructure. vSphere Namespaces serve

as logical isolation units within VCF Kubernetes environments, providing resource and network boundaries between workloads deployed across different namespaces. A dedicated virtual network is provisioned for each namespace where a cluster is deployed and for each VKS cluster itself. Each VKS cluster is backed by a set of NSX networking objects: a Tier-1 gateway (router), a segment (switch) linked to that gateway, a load balancer server, and virtual servers for the cluster's control plane endpoints. VKS cluster nodes attach to these NSX-backed segments through VirtualNetworkInterface objects as logical ports, assigning each node an IP address and scoping cluster traffic to a dedicated segment isolated from other clusters and from the management plane. The management plane, which hosts VMware vCenter and NSX Managers, is architecturally separated from the compute plane, which hosts NSX Edge Nodes and Supervisor nodes, so management traffic does not mix with workload traffic at the network layer.

Within VKS clusters, Antrea serves as the CNI plugin and supports the standard Kubernetes NetworkPolicy API, allowing administrators to declare and enforce pod-level ingress and egress rules. By default, a pod is non-isolated for egress, meaning all outbound connections are permitted; a pod becomes isolated for egress only when a NetworkPolicy selects it and includes Egress in its policyTypes, at which point only connections explicitly allowed by applicable policies are permitted. A pod becomes isolated for ingress when any NetworkPolicy selects it with an Ingress rule, restricting inbound connections to those from the pod's own node and those explicitly permitted by applicable policies. Administrators can apply a namespace-scoped NetworkPolicy that denies all ingress and egress traffic, establishing a deny-all baseline from which only necessary flows are selectively opened; for environments requiring strict multi-tenant namespace isolation, the recommended approach is a default deny-all policy paired with an explicit allow for DNS resolution. Antrea distributed firewall policies can additionally restrict traffic between Kubernetes namespaces by applying filtering rules at specific pod groups, providing an enforcement layer that complements standard Kubernetes NetworkPolicies. The Antrea-NSX Adapter integrates each VKS cluster's networking with NSX Manager, enabling NSX to manage the networking behavior of the cluster and apply consistent segmentation policies across both the Kubernetes data plane and the underlying NSX infrastructure. Antrea's NetworkPolicyStats feature gate enables collection of network policy statistics, providing visibility into enforcement activity per workload. VKS cluster administrators control pod network attachment capabilities through NetworkAttachmentDefinition resources, which define the allowed network configurations that application users may request, preventing unauthorized network connections. For multi-network configurations, VKS uses SubnetConnectionBindingMap custom resources to bind overlay subnets to node vNIC subnets, with the vlanTrafficTag field specifying a unique VLAN ID for traffic isolation between parent and child subnets at the NSX data path level. The Antrea EgressSeparateSubnet feature allows egress IP allocation from a subnet distinct from the default node subnet, supporting stricter egress traffic segmentation. For SR-IOV deployments, VKS SR-IOV network configurations block cross-namespace selection of network resources, enforcing namespace-level boundaries for high-performance network access. For multi-tenant data plane separation, pod node selectors can restrict workload placement to specific nodes, preventing tenant workloads from sharing compute resources across tenant boundaries. Service meshes deployable on VKS clusters can extend segmentation to OSI Layer 7 by enforcing policies based on workload identity and providing mutual TLS encryption between workloads, adding isolation even within a shared network segment. The Argo CD Supervisor Service implements its own internal network segmentation and firewall rules to secure communication between its components.

For ongoing management and visibility, the NSX Segment Inventory Dashboard tracks and manages network segmentation while offering insights into the dependencies between logical switches and other NSX components. The NSX Switch Dashboard displays detailed information on logical switches for efficient tracking and management. VCF Operations for Networks supports segmentation planning by analyzing traffic flows and grouping them by entities such as VLAN, security group, application tier, subnet, cluster, or individual virtual machine. The micro-segmentation planning topology shows all flows present in an environment by dividing them into segments, helping administrators understand current traffic patterns and refine segmentation boundaries over time. Distributed virtual switches support health check operations for NIC teaming and VLAN/MTU configuration, and VCF Operations provides host metrics that detect unsupported MTU configurations across the infrastructure.

The VCF documentation states that network endpoints should be segmented. Administrators should configure VLAN or overlay segments appropriate to their environment, assign workloads to the correct segments, apply switch security profiles, and use the NSX dashboards and VCF Operations tools to verify and maintain segmentation boundaries. For

microsegmentation below the network segment level, VMware vDefend provides fine-grained traffic control between individual virtual machines and containers, independent of their network placement.

For operational technology (OT) and industrial workloads, NSX Industrial vSwitch (IvS) extends segmentation to PROFINET traffic between virtual Programmable Logic Controllers (vPLCs) running on VMware ESX hosts and I/O devices located outside the vSphere cluster. The associated NSX Industrial vSwitch Segment Profile supports the Discovery and Configuration Protocol (DCP) as part of the PROFINET protocol suite, allowing discovery of IO devices, retrieval of device identity information, and configuration of device settings such as device name and IP address. This capability brings OT traffic under the same segmentation model as standard IT workloads, enabling administrators to isolate industrial traffic on dedicated segments alongside the rest of the network architecture.

VMware vDefend (Meets)

VMware vDefend (vDefend) provides network segmentation capabilities at multiple layers, from macrosegmentation at the network perimeter down to microsegmentation between individual workloads. This is a core function of the product and addresses the control directly.

VMware vDefend enforces segmentation at the workload level by applying security policies at the vNIC of every virtual machine and container. Policies follow the workload regardless of its network placement or physical location, so segmentation is not dependent on VLAN boundaries or physical network topology. Administrators can define rules based on security groups, application tiers, tags, and other logical constructs to isolate technology assets, applications, and services from one another. Layer 2 through Layer 7 inspection allows rules to be written against specific applications, protocols, and user behaviors rather than just IP addresses and ports. When using NSX Projects, firewall rules are automatically scoped to VMs connected to the segments within that Project and do not affect workloads outside the Project, providing a built-in boundary for multi-tenant or departmental segmentation.

Starting with VCF, vDefend supports enforcement on both Distributed Virtual Port Groups (DVPGs) created in vSphere Distributed Switch and segments created in NSX within the same cluster. This extends DFW coverage to VMs connected to traditional vSphere DVPG networks in addition to NSX overlay segments, allowing organizations to apply consistent security policy across mixed-network environments. DFW policy members can include DVPGs, NSX Segments, or both, and grouping constructs support dynamic or static membership criteria based on VM name, tags, segment, or IP addresses.

VMware vDefend provides stateful North-South traffic inspection at the network edge, controlling traffic entering and leaving each segment. Together, the Distributed Firewall and Gateway Firewall create a layered segmentation model where both East-West and North-South traffic are subject to policy enforcement.

Security Intelligence, delivered through the vDefend Security Services Platform, provides segmentation planning and monitoring tools. The Security Segmentation Report assigns a quantitative Security Segmentation Score that measures an organization's progress toward a fully segmented network. Segmentation planning workflows help administrators discover traffic flows, identify infrastructure services, group assets by environment (such as VLAN, security group, application tier, subnet, or cluster), and apply hierarchy tags to verify that segments have appropriate controls. Infrastructure services are categorized into their own groups separate from the asset hierarchy, with dedicated groups that users can create and apply policies to. Environment segmentation divides the data center into broader security zones such as production, development, testing, or regulated environments, and Security Intelligence workflows support planning and enforcement of policies at each zone boundary. Security Intelligence generates macrosegmentation policy recommendations for environment pairs based on observed traffic flow patterns; these recommendations can be reviewed, modified, and published to enforce segmentation policies through the Distributed Firewall.

Segmentation Monitoring continuously watches traffic for supported infrastructure services and detects new servers or services that appear on the network. The feature monitors supported infrastructure service types, including DHCP, DNS, NTP, and LDAP, and identifies both newly discovered servers and servers missing recommended security rules. Administrators can configure protection policies for environment pairs to Drop or Reject unauthorized traffic, and create lockdown rules to disallow traffic to servers outside defined infrastructure asset groups. Segmentation Monitoring provides detailed investigation

capabilities to identify potential security risks in application traffic and enable corrective action. This provides ongoing assurance that the segmentation scheme remains intact as the environment evolves.

Application-level microsegmentation implements granular isolation for individual applications. Segmentation planning supports import of application context using a flat file containing key workload attributes such as IP addresses, subnets, virtual machines, logical segments, and organizational roles. The Security Segmentation Report also identifies workloads running obsolete operating systems, workloads using risky application protocols, and workloads communicating with external IP addresses, helping administrators prioritize segmentation policy work.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control SI.L3-3.14.6e

> Threat-Guided Intrusion Detection

SCF Controls: MON-01.1, THR-03, THR-07

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides networking infrastructure through NSX that supports the deployment of intrusion detection and prevention capabilities across virtualized environments. The VCF stack includes IDS/IPS and distributed malware prevention through vDefend, a separately licensed product that extends NSX with security functions, and these capabilities can be configured on discovered host clusters using the NSX UI or API. vDefend Distributed IDS/IPS is also available for consumption under NSX Projects, allowing IDS/IPS policies to be scoped to specific tenants or workload groups within the platform.

The IDS/IPS functionality in the VCF stack is delivered through VMware vDefend with Advanced Threat Prevention (ATP). ATP combines multiple detection technologies, including an Intrusion Detection/Prevention System, network sandboxing, and Network Traffic Analysis (NTA), with aggregation, correlation, and context engines from Network Detection and Response (NDR). vDefend with ATP is a software-defined Layer 2-7 firewall purpose-built to secure virtualized workloads in a private cloud, providing stateful firewalling with threat prevention capabilities. The NSX Application Platform hosts the features that support these advanced capabilities, including Security Intelligence, vDefend Network Detection and Response, and Malware Prevention for vDefend.

Administrators configure IDS/IPS rules through the Security > IDS/IPS & Anti-malware page in NSX Manager. vDefend distributed firewall rules can be created with an IDPS security profile applied in either Detect Only or Detect and Prevent mode, allowing organizations to start with visibility before moving to active blocking. vDefend signature-based identification and enforcement provides visibility into, or restriction of, protocols that have known vulnerabilities across all deployed applications and their east-west flows within the datacenter. The NSX Distributed Load Balancer can apply vDefend IDPS and Anti-malware Prevention features for traffic traversing load-balanced services.

To supplement signature-based detection, vDefend supports a Malicious IP Feed that downloads a list of known malicious IP addresses from the NTICS cloud service. Administrators can create groups that include these downloaded IPs and configure vDefend firewall rules to block access to them, providing a threat-intelligence-driven layer of protection. NSX App IDs further support traffic inspection by enabling network traffic classification and control based on application identity rather than port or protocol alone, helping reduce both north-south and east-west attack vectors.

The vDefend distributed firewall can be configured on vSphere Distributed Switches in data centers and workloads where segmentation, visibility, or advanced security capabilities are desired. This distributed architecture places IDS/IPS inspection at each host rather than relying solely on chokepoint-based appliances, providing coverage for east-west traffic that traditional perimeter IDS/IPS solutions do not inspect. The packet interception mechanism underlying this distributed inspection is DVFilters, which operate at the VMware ESX kernel level to intercept packets at each virtual machine's virtual NIC. When deploying IDS/IPS in environments where vSphere vMotion is in use, administrators should verify that IDS and firewall rules permit the ports used for vMotion on ESX hosts. VCF's networking layer, NSX, is the foundation on which vDefend positions its detection and prevention sensors across the environment, providing the traffic routing and distributed switch architecture that the vDefend sensors attach to.

Organizations deploying VCF should note that while the platform provides the technical IDS/IPS capabilities described above, effective intrusion detection and prevention also requires ongoing operational processes: signature and feed updates, alert triage and tuning, incident escalation workflows, and integration with a security operations center or SIEM for centralized monitoring. The vDefend components that deliver IDS/IPS are licensed separately from the base VCF platform.

VMware vDefend (Meets)

VMware vDefend provides native Intrusion Detection and Prevention System (IDS/IPS) capabilities that operate at both distributed and gateway enforcement points across the VCF environment.

Distributed IDS/IPS runs within the hypervisor on every VMware ESX host, inspecting east-west traffic at the vNIC level. This positions detection and prevention directly on the workload, covering internal network segments without requiring traffic to traverse a centralized appliance or choke point. Distributed IDS/IPS is available in the Advanced Threat Prevention edition and can be enabled across discovered clusters using the NSX management interface or API. An onboarding wizard guides administrators through the initial setup, including preparing the data center for IDS/IPS and Malware Prevention features.

Gateway IDS/IPS operates at the perimeter, inspecting north-south traffic at gateway choke points. Together, the distributed and gateway deployment models provide layered detection across both internal segments and network boundaries.

vDefend IDS/IPS uses knowledge-based, signature-based detection. Signature bundles incorporate custom detection logic that can be updated without recompiling or modifying the IDS engine. The latest signatures can be downloaded automatically from the cloud when Internet connectivity is available, or through a configured proxy server. Administrators can also create custom signatures to address threats related to custom applications and zero-day vulnerabilities. Custom signatures can be included in IDS/IPS profiles and applied to Distributed Firewall (DFW) and Gateway Firewall (GFW) rules. Signature thresholds can be configured to control how frequently a signature generates an event and to dynamically adjust the rule's action when specific conditions are met. Signatures can be filtered by CVSS score, products affected, service, and attack target in addition to severity and attack type, enabling prioritization based on exploitability.

Network Detection and Response (NDR) extends IDS/IPS by correlating IDS signature matches, including matches from custom signatures, against network traffic in the protected network. NDR classifies detections by detection technology type with IDS events as a supported detection type, combining intrusion detection events with network traffic analysis to identify campaigns and advanced threats that individual signature matches might not surface on their own.

The Distributed IDS/IPS Summary dashboard provides operational visibility into detected threats, displaying intrusion event trends organized by severity and a radar chart showing distribution of intrusion events by attack type, attack target, or severity over configurable periods from 24 hours to 14 days. IDS Packet Capture records raw network packets associated with detected intrusion events, supporting forensic investigation. Security Intelligence, available through the Security Explorer interface, detects intrusion events in real time and allows filtering of intrusion history by action, attacker IP, attacker port, PCAP UUID, profile, rule, target IP, target port, and detection location. Impact scoring and per-virtual-machine detection status visibility are available through the Security Explorer, and events can be filtered by Compute and IDS Signature ID. IDS/IPS Rule Performance Metrics identify resource-intensive rules across Distributed and Gateway enforcement points, supporting operational tuning without affecting detection coverage. The Intelligent Assist feature within the Security > IDS/IPS interface allows administrators to investigate intrusion attempts by selecting specific events and reviewing the latest or historical occurrences.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to IDS/IPS implementation through several application-layer threat detection and mitigation capabilities, with the core threat intelligence delivered through the Live Security Threat Intelligence service.

The Live Security Threat Intelligence service delivers real-time security threat feeds across globally distributed Avi Load Balancer Controller clusters. It includes two primary components. The IP Reputation Service classifies client IP addresses across multiple threat categories, including DoS/DDoS attack sources, malware-infected hosts and malware distribution points, phishing sites, botnet and spam sources, and proxy services. The service performs real-time automatic updates and can block or flag addresses associated with known threats. Network Security Policy rules on Virtual Services can match on IP Reputation categories to allow, log, or deny traffic from those sources. The IP Reputation Service is also used as a source for bot detection and classification, enabling Virtual Services to identify and act on automated attack traffic. The Application Rules Service, also part of Live Security Threat Intelligence, provides rules specifically designed to block attacks on known application vulnerabilities, including many with published CVEs. These rules are automatically updated, allowing Avi deployments to respond to newly disclosed vulnerabilities without manual signature management.

Avi Service Engines detect and mitigate a wide range of Layer 4 through Layer 7 network attacks through the DDoS Policy and Network Security policy. DDoS capabilities include detection of volume attacks, DNS reflection ingress attacks, NXDOMAIN attacks with identification of attacking clients, and Neighbor Discovery Protocol (NDP) attacks on IPv6 networks. DDoS

threshold values are applied per dispatcher core for virtual service level attack detection. The Avi Kubernetes Operator (AKO) exposes this capability in Kubernetes environments through the L4 Rule custom resource definition (CRD), which can express a custom Security Policy specifying DDoS attack detection and mitigation configuration for virtual service traffic.

When Avi Service Engines detect a DDoS attack, the Controller generates DOS_ATTACK alert events that include the attack type, source IP addresses, virtual service UUID and name, and a report timestamp for audit and forensic use. Alert actions can invoke ControlScripts that automatically add offending client IP addresses to a blocklist IP group attached to a Network Security Policy, enabling automated response to active attacks. The Controller also tracks denial-of-service attack events with attack count metrics and generates alerts at configurable severity levels.

Avi Load Balancer provides a traffic cloning capability that replicates application traffic flowing through Virtual Services to ancillary servers. This can be used to feed traffic to external IDS and IPS systems, extending inspection coverage beyond what Avi analyzes inline.

Avi's detection and response scope is limited to application traffic that flows through its Virtual Services at the load balancer boundary. IDS/IPS coverage for host-based intrusion detection, east-west workload traffic, and network segments that do not traverse Avi is outside this scope. That coverage is provided by VMware vDefend, a separate product that delivers network-layer IDS/IPS and distributed firewall capabilities across the VCF platform. Organizations deploying VCF should treat Avi and vDefend as complementary layers: Avi for application-layer threat detection at load balancer entry points, and vDefend for network-layer and host-level intrusion detection across the broader infrastructure.

To configure these capabilities, enable IP Reputation threat categories and Network Security Policy rules under Virtual Service Policies > Network Security in the Avi Controller, attach DDoS security policies to application-facing Virtual Services, and configure ControlScript alert actions to automate IP blocking responses. Live Security Threat Intelligence features, including the Application Rules Service and IP Reputation Service, are activated through the Avi Cloud Console.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

